

Architecture brief

2026-09-22

Contents

0. About this document

- What you will understand by the end
- What the brief is and is not
- Maturity on 2026-09-14
- How the brief is argued
- Reading paths
- Conventions
- Key decisions and what to read next

Part I — Intent

1. Executive summary

- What you will understand by the end
- Where things stand on 2026-09-17
- What was asked, and the readings the design declines or qualifies
- What is proposed: a platform, of which the three agents are the first tenants
- Why build it, and how the programme can stop
- The central fact: nothing narrows a super admin
- What makes it acceptable to try
- Eve's independence, stated honestly
- Mo in one line
- The residual risks a signature would accept
- Hundreds of agents, and a closed tier for agents of general capability
- Compliance: mechanisms and evidence, never outcomes
- What the platform will not do
- The organisation that exists, and what the platform costs
- What the sponsor is asked for, in order
- Key decisions
- Read next

2. The objective and what it demands

- What this chapter settles
- The objective, in the owner's words
- The sixteen requirements
- Where each requirement is met
- Where a literal reading is qualified or declined
- What the objective demands without saying
- Key decisions and what to read next

3. The problem and its risks

- What this chapter explains
- The design before the objective
- The Google facts that fix the problem
- What the Super Admin choice costs
- The other reversals the objective forces
- Why agents are a distinct risk
- The five hardest problems
- The risk themes the rest of the brief answers
- Key decisions and what to read next

4. The principles

What you will understand by the end

4.1 The thesis

4.2 Enforcement-grade and detection-grade

4.3 The six containment primitives

4.4 The standing constraints

4.5 Designing around a decided premise

4.6 Operability and the four cells

4.7 The platform charter

4.8 What the platform does not do

Key decisions and where to read next

Part II — The platform

5. Architecture overview

What this chapter explains

5.1 The platform in layers

5.2 Trust boundaries B1–B7

5.3 Placement

5.4 The one rule for crossing a project boundary

5.5 What is shared in platform-core and what stays per agent

Key decisions and what to read next

6. The Gemini Enterprise environment

What you will understand by the end

Why one app is the only front door

Bringing the app to a secure baseline

An agent's life in the tenant app

The tenant egress gateway gemini-egress (P57, P6)

Connectors and data sources (P58)

Audit logging of the app

The runbook to baseline

What is still unverified

Key decisions and what to read next

7. Landing zone and the tier model

What you will understand by the end

Why a folder, a factory and a tier model

The tiers

The folder tree

Why project-per-agent is forced

The factory

The organisation-policy baseline

Non-production and the sandbox tenant

Naming, labels, budgets, contacts and quotas

How the landing zone is verified as a whole

What remains open

Key decisions and where to read next

8. Identity, privileged access and the fleet kill switch

What you will understand by the end

The principles, stated once

Agent Identity for every reasoning layer

- The three principal populations
- Service-account policy
- Groups and workforce identity
- The identity drift job
- The folder deny policy
- The Principal Access Boundary
- Privileged Access Manager
- Human access to control surfaces
- Break-glass
- The robot accounts' shared rules
- The super-admin roster and key custodians
- Multi-party approval and the two-person rule
- The fleet kill switch K7
- K7 beside each agent's K0 to K6
- What is unverified, and what closes each
- Key decisions and what to read next

9. Registry, governance and the autonomy contract

- What this chapter explains
- Four things that are not each other
- Why the inventory of record is a git file
- The register
- Finding shadow agents
- Governance policies
- Admission and revocation
- The compliance registers are exports
- Autonomy as data: the ladder's fleet rules
- The autonomy contract
- What remains
- Key decisions and what to read next

10. Agent Gateway, Model Armor and the perimeter

- What you will understand by the end
- Why screening exists: the injection surface
- The screens on one request
- The gateway rule
- What the gateway does not screen
- Model Armor
- The perimeter
- What this layer does not do
- Key decisions and what to read next

11. Monitoring, detection and incident response

- What you will understand by the end
- The rule: detection is the primary control for the super-admin tier
- What the platform watches
- Registered implies feeding the SIEM
- The correlation contract
- The detection catalogue
- Silence becomes a halt
- The platform reporting path
- Incident response

The regulatory clocks

Tabletops and SOC metrics

Key decisions and what to read next

12. Data, logging, retention and sovereignty

What you will understand by the end

12.1 The rule: evidence leaves the reach of the judged thing before it is needed

12.2 Every store has a class (P109)

12.3 The central logging project (P104)

12.4 Data Access audit logging at the folder (P105)

12.5 Retention (P106, P13)

12.6 The daily export and the witness push (P107)

12.7 Sensitive Data Protection (P108)

12.8 Sovereignty

12.9 Asset owners per project

12.10 What could not be verified

Key decisions and what to read next

13. Supply chain, keys and recovery

What you will understand by the end

The supply chain

Secrets

Keys

Recovery

What remains unverified

Key decisions and where to read next

14. Scale and AGI readiness

What you will understand by the end

Two readings of "hundreds of agents"

Agents the organisation did not write

Code execution

Containing the top tier

Tier X: a closed tier with written opening conditions

What remains open

Key decisions and what to read next

Part III — The agents

15. Wall-E, the doer

What you will understand by the end

Why the doer holds Super Admin

Where Wall-E sits and what it is meant to be

Principals, credentials and the account

From prompt to action

Three bands decided by code

The two lists and what stays out of the catalogue

What replaces the Workspace role

The thirteen compensations as an argument

Five trust boundaries

A control plane that fails closed

Autonomy, step by step

Stopping Wall-E

What Wall-E does not do

Known structural weaknesses

Key decisions and what to read next

16. Eve, the independent controller

What you will understand by the end

The thesis

What Eve is not

Two paths

Eve's own project and its three carve-outs

Independence in two parts

Two authorities on opposite schedules

The pre-approval pass

Verdicts after the fact

Watching a super admin

Reporting

When Eve is absent: Wall-E's sweepers

Eve's Workspace robot

When each part arrives

When Eve is wrong, compromised or alone

What Eve's independence does not cover

Key decisions and what to read next

17. Mo, continuous improvement

What you will understand by the end

The thesis: numbers that have to be true

What Mo is not

Three tiers and the seam between them

The deterministic boundary

From proposal to production

One Mo per platform, and a remit that includes Eve

What Mo produces

What Mo measures

How the numbers are checked

Grading, the seed and attribution

Staging, the acceptance test and the baseline

The human grading cost

What Mo needs from Wall-E

Failure, threats and residuals

Key decisions and what to read next

18. How the three work together

What you will understand by the end

Three rules that stop the team collapsing into one

Who owns which half

Who may do what to whom

The interfaces between them

One set of facts, three readings

What each design forces on the others

Four journeys through the team

A detection becomes an improvement

When the team itself fails

What a fourth agent inherits
What remains open
Key decisions and what to read next

Part IV — Proof: threats, compliance and people

19. Threat model and residual risk

What you will understand by the end
The honest risk statement and the ceiling
What prompt-based defence cannot do
The adversaries, the controls that stop them and the detections that see them
What a compromise of each project reaches
Facts kept out of the safety case
How each risk theme of Chapter 3 ends
The platform risk register (P140)
Residual risks knowingly accepted in Wall-E's design
The residual risks a sponsor accepts by signing
Key decisions and what to read next

20. EU AI Act

What this chapter explains
The position in one paragraph
The regulatory state on 2026-09-13
Who is provider and who is deployer (P23)
Classification, system by system
The classification gate for every future agent
The AI compliance owner (P131)
The obligations, theme by theme
The evidence register
What "bulletproof" can and cannot mean
What is unverified, and what closes each item
What remains
Key decisions and what to read next

21. TISAX

What you will understand by the end
TISAX on 2026-09-13
The target: label, level, scope and catalogue (P133)
Module scope (P134)
Shared responsibility with Google (P135, P32)
The control mapping, as themes
Separation of duties: the item most likely to stop an assessment
The super-admin deviation (P136)
Assurance: penetration test, internal audit, management review (P139)
The legal and contractual register (P141)
Documentation versus controls that do not exist
What is unverified, and what closes it
Key decisions and what to read next

22. Personal data, employees and the works council

What you will understand by the end
22.1 The position: controller, and internal processing
22.2 What the platform owes the DPO, and where each input stands

- 22.3 Where a person is identifiable along one request
- 22.4 The actions that affect employees, and how they are bounded
- 22.5 The profiling boundary (P18, P126)
- 22.6 Operators as data subjects: the limits on monitoring
- 22.7 Workers: information, consultation and the explanation path (P129)
- 22.8 The DPO's decisions and engagement points
- 22.9 Still open
- Key decisions and what to read next

Part V — Delivery

23. Operating model

- What you will understand by the end
- Who exists on 2026-09-13
- The roles
- Lines of authority and report
- Duties one person may never combine
- The minimum number of distinct humans
- Who runs which control at each tier
- The hours
- The detection desk by tier
- What people must hold before the build
- Training
- The recurring calendar
- When "the four owner groups are one person" expires
- Key decisions and what to read next

24. Roadmap and cost

- What you will understand by the end
- Where the programme starts
- The tier gate
- The register's gate groups are the roadmap
- What can start with the people who exist
- Day-one lead-time items
- The builder's order
- The first spikes: what the design holds until each passes
- The opening sequence
- The super-admin grant sequence
- Stage floors across the three agents
- The propagation stage
- Which runbook creates what, and the effort shape
- Cost
- Key decisions and what to read next

25. Decisions awaiting the owner

- What you will understand by the end
- First actions
- How a decision is made and recorded
- The register in one screen
- Who must answer what
- The agent-set registers
- Where the pages still disagree

Every unresolved point the brief raises
What the register does not do
Every open row and unsigned signature
Key decisions and what to read next

A. Glossary

What this appendix gives you
Identifier families
Families that share letters
Platform terms
Google products and features
Regulatory terms
Abbreviations
Key decisions and what to read next

B. Document map

What this appendix gives you
Precedence
The platform set
The agent sets
Build procedures
Decision records
Pages kept as dated records
Chapter to canonical pages
Reading paths through the wiki
Key decisions and where to go next

0. About this document

What you will understand by the end

What this brief is for, which source wins when it and a design page differ, what exists of the platform on 2026-09-14 (nothing but the design), how the argument runs from Part I to Part V, which short path through it fits your role, and the conventions that make a word such as *proposed* mean the same thing on every page.

What the brief is and is not

The platform — a secure Gemini Enterprise environment for hundreds of agents, whose first tenants are Wall-E the doer, Eve the controller and Mo the improver — is specified in full on thirteen platform pages, the three agent sets and the project topology page. Those pages say *what*: every folder, role, control, retention period and decision row, with its owner, verification and failure mode.

The brief says *why*: the intent behind each choice, whom it serves, what it costs in people, bought services and signatures, which risks it answers, and what it deliberately does not do. It is written for readers who must judge the design: a sponsor accepting a residual risk, a data protection officer weighing a log's proportionality, an assessor weighing a deviation.

The brief is not a second specification. It summarises mechanisms and links to the section that defines them; it reproduces no design table and introduces no product fact, value or decision of its own.

Precedence

Every value — a name, a number, a date, a decision state — is authoritative on its design page ([design set status](#)). Where the brief and a design page disagree, the design page wins and the brief is corrected. Where two design pages disagree with each other, the brief says so in one sentence and cites both; it does not choose between them.

Maturity on 2026-09-14

The platform is a design; nothing is built ([maturity](#)). There is no platform folder, factory run, gateway, registry entry, log sink, SIEM, witness organisation or robot account holding Super Admin. The four projects of the topology are decided and not created. The Workspace tenant exists with Gemini Enterprise licences, and the tenant app's project, `GEMINI_PROJECT`, is to be imported rather than recreated; the design set's maturity table records it as existing, while the HLD and the topology page carry its existence as an *Assumption*: ([HLD §2.1](#), [topology §2](#)). No spike has been run.

When a chapter says a control "refuses" or "halts", it describes what the design requires of something that does not yet exist. Behind it today stands one administrator holding every role (Chapter 1, Executive summary; Chapter 23, Operating model); which tiers can open with the people who exist is Chapter 24, Roadmap and cost.

How the brief is argued

The brief is a case, not a catalogue; each part hands the next its premise.

- **Part I, Intent** (Chapters 1–4) says why: the objective and what it demands, the problem it creates and its risk themes, and the principles every later answer derives from. Chapter 1 stands alone.
- **Parts II and III, The platform and The agents** (Chapters 5–18) say what is built and how. Each chapter opens with the Chapter 3 risk themes it answers and closes with what Chapter 19 found remaining. The platform comes first because Wall-E, Eve and Mo are instances of its rules, not its definition.

- **Part IV, Proof** (Chapters 19–22) tests the design: the threat model, closing each risk theme with its residual, then the EU AI Act, TISAX, and personal data from the employees' side.
- **Part V, Delivery** (Chapters 23–25): who must exist, in what order the platform opens and at what cost, and which decisions wait for whom.

Reading paths

Stop when your question is answered. The paths adapt the design set's reading orders for a [security reviewer](#) and a [builder](#).

Reader	Path
Executive sponsor	Chapter 1 alone; or Part I, then the residual risks in Chapter 19, then Chapters 24 and 25
Security architect	Chapters 3 and 4, Part II, then Chapters 15, 16 and 19
Builder	Chapters 5, 7, 8, 9, 13 and 24
Data protection officer	Chapters 2 and 22, Chapter 12, then the regulatory clocks in Chapter 11
Works council	Chapter 22, the bands and ceilings in Chapter 15, the reporting contract in Chapter 16
TISAX assessor	Chapters 21, 19, 23, 8 and 12
AI compliance owner and legal	Chapters 20 and 22, then the post-market monitoring plan in Chapter 17
Programme lead	Part V, then the scaling argument in Chapter 14

Appendix B, Document map, gives the design pages behind every chapter.

Conventions

The brief carries the design's conventions unchanged ([design set status](#)).

- **Assumption:** marks a fact the design inferred rather than verified; the brief keeps every one, including all cost figures.
- *tbd* marks a value nobody has decided.
- Every Google product, launch stage, role, constraint, regulatory article and date was verified against its source on 2026-09-13, or is listed under "Unverified" on its design page and stays *tbd*; the brief never upgrades an unverified fact.
- Dates are absolute. Roles are named, never people.
- No company other than Google is named; no secret appears.

Decision identifiers and states

The platform register's identifiers form one sequence: P1–P34 are the HLD's decisions, P35–P141 those of the detailed pages in page order, then P142 and P143 ([how the register works](#)). Every other identifier family — tiers, primitives, detections, agent-set registers — is listed once, with the chapter that explains it, in Appendix A, Glossary.

Five state words are used exactly as the register defines them (in full in Chapter 25, Decisions awaiting the owner): *decided* (the named owner decided, on a date), *closed* (answered by a later row or a verified fact), *proposed* (stands until its owner overturns it in writing), *open* (nobody has decided; the gate it blocks stays red) and *spike* (settled by a test on a throwaway resource in nonprod). A proposed or open row is never presented as settled.

Chapter shape

Every chapter opens with a Status block and what you will understand by the end, and closes with the key decisions it rests on, with register id and state, and the canonical design pages to read next. An element is explained fully in one chapter only; elsewhere it gets at most a sentence and a pointer by number and title. Part dividers carry one paragraph.

Key decisions and what to read next

- **P33, decided** by the owner: Wall-E holds Super Admin, and the design is built around that choice rather than re-arguing it; the deviation signatures are pending ([decision record](#)). Chapter 15, Wall-E, the doer, explains what it costs and what compensates.
- The register's states and gate rule, P1–P143 — [12-open-decisions.md §1](#).
- Read next: the [design set README](#) for the page inventory and maturity, [what the platform deliberately is not](#), then the first chapter on your path.

Part I — Intent

Part I makes the case for the platform before describing it. Chapter 1 is a summary a sponsor can read alone, gain and exits included. Chapter 2 answers what the owner asked for, and where a literal reading must be qualified. Chapter 3 answers why meeting that request is hard and dangerous for an organisation that, on 2026-09-13, ran one administrator and no security operations centre. Chapter 4 answers which few principles every later design choice derives from, starting from the [platform thesis](#).

1. Executive summary

What you will understand by the end

This chapter is written to be read alone. By the end of it you will know what is proposed and why, what the organisation is meant to gain and how the programme can stop if the gain does not appear, what state it is in, what giving a robot the highest administrative role in the organisation's Google Workspace costs in safety and what makes that acceptable to try, which risks you would be accepting by signing, what the platform will not do, and what it needs from you in people, bought services and signatures, in the order the platform can open. Each paragraph ends with the chapter that explains its subject in full.

Where things stand on 2026-09-17

The platform is a design and nothing is built. The Google Cloud project behind the organisation's Gemini Enterprise app (Google's enterprise assistant, for which the tenant holds licences) exists and is to be imported (Assumption); the platform folder, factory, registry entries, security monitoring service, witness organisation and the robot's Super Admin grant are still to be made. (Chapter 24, Roadmap and cost; [maturity on 2026-09-13.](#))

Three human-executed build sets now exist, none executed, each growing into the next. The full build ([setup](#), written 2026-09-15, revised 2026-09-16) is 42 procedure files in the order platform, then Mo and Eve, then Wall-E, needing every role the third group of asks below names; it takes six to seven months to Stage 0, the super-admin grant not before 2027-03, and it alone owns that grant, the sandbox twin, the witness organisation and every Tier P-SA gate. The proof of value ([pov](#), written 2026-09-16) runs on the production tenant at Tiers C, R and W for the owner, an operator, the second person and one engineer, 20 to 26 person-days of procedure over 6 to 20 weeks (Assumption); its doer holds no Workspace admin role, no agent holds Super Admin, Eve reports on every human super admin, and nothing it produces is evidence for the grant; it hands over to the full build with nothing torn down. The three-day build ([3-day](#), written 2026-09-17) is two people and six person-days: a doer holding one organisational-unit-scoped admin privilege over four synthetic accounts, Eve polling the admin audit log through the Admin SDK Reports API before any doer exists, and Mo's scorecard; it is a demonstration of machinery under control, claims no saved minutes and is not compliance evidence, and hands over to the proof of value once unwound. The register of record runs to P204: P144–P191 are the full build's 48 decisions and P192–P204 the proof of value's thirteen, all proposed and pending the owner's signature. (Chapter 24, Roadmap and cost; [the register in one screen.](#))

What was asked, and the readings the design declines or qualifies

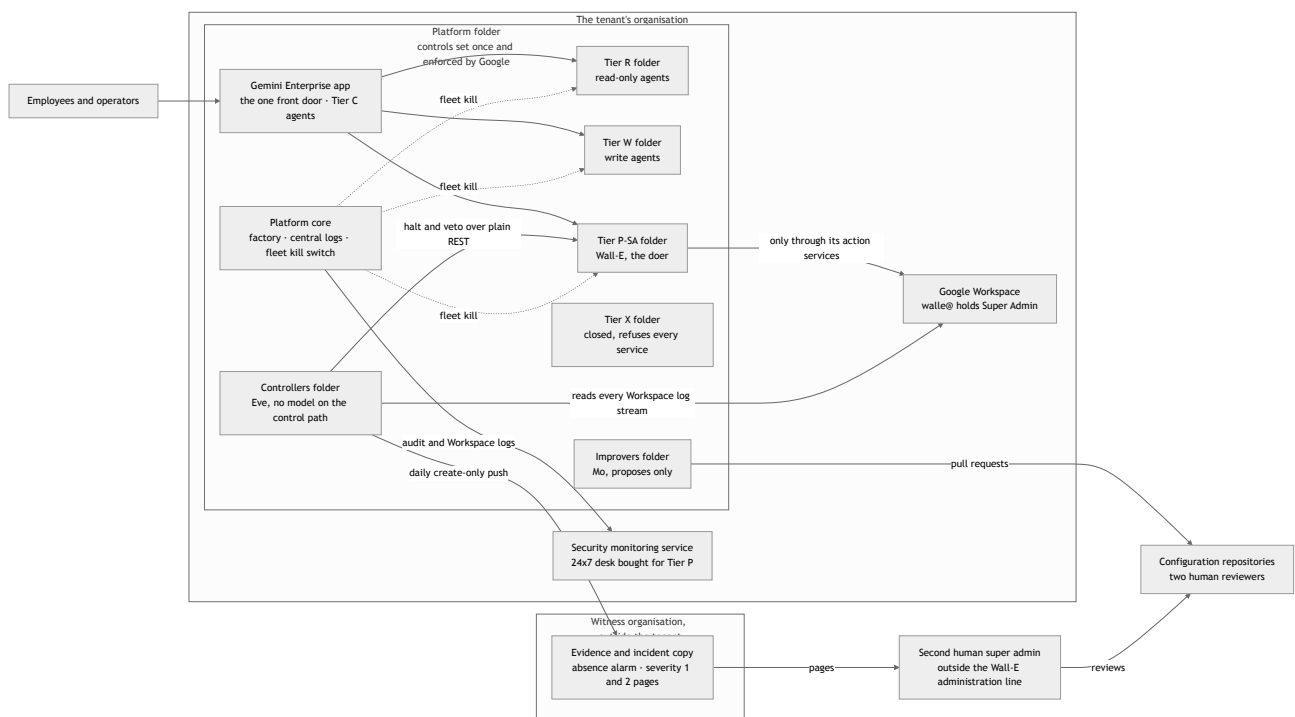
On 2026-09-13 the owner asked for a secure Gemini Enterprise environment through which every agent — a program that uses a language model to decide what to do — is secured, naming agent identity, an agent registry and Model Armor (Google's screen for prompts and responses), and inviting any other control an autonomous agent needs. On that environment they asked for three agents: Wall-E, the doer, acting on a human's prompt through a dedicated, licensed user account holding Super Admin, the Workspace role with every administrative power; Eve, who controls Wall-E, reports misbehaviour to a human, holds no super-admin access and works independently; and Mo, who improves both. The whole must sustain hundreds of classical and autonomous agents, host future AGI-class agents, meaning agents of general capability beyond what their designers foresaw, deliver enterprise-class security and monitoring, and be "EU AI Act bulletproof" and TISAX compatible (TISAX being the automotive industry's information-security assessment). (Chapter 2, The objective and what it demands; [the objective.](#))

Two readings are declined — "bulletproof" (R14) and hosting AGI-class agents in 2026 (R12) — and "any super-admin action" (R4) is qualified; other requirements are qualified for stated reasons. No design can guarantee a regulator's decision, so the design lists what it cannot promise; agents of general capability get a closed tier. "Any

super-admin action" keeps its breadth but not its letter: console-only work becomes instructions to a human, and a hard-denied list — changes to the tenant's security posture among them — is refused whatever the lane. One reading awaits the owner: catalogued work may run on scheduled, event and inbox triggers once earned, so Wall-E will act without a fresh prompt, and the design records no qualification of R3 for this; the brief reads the prompt as the origin of Wall-E's mandate, not its only trigger (Chapter 25, Decisions awaiting the owner). (Chapter 2, The objective and what it demands; [traceability](#).)

What is proposed: a platform, of which the three agents are the first tenants

The platform is five things. A folder in the organisation's Google Cloud hierarchy, where every control Google can enforce once is set where one person can own it. A factory, a pipeline that creates each agent's own project with identity, gateway, logging, budget and deny rules already in place. A register, one file in version control that every agent needs a row in before it may exist. A contract, the rules every writing agent adopts for autonomy, audit and measurement. And a gate, which lets a tier of agents open only when the people and services that tier needs exist. Tiers run from C (no-code assistants inside the Gemini Enterprise app) through R (agents with read-only tools), W (agents that write to a system of record) and P (agents holding a tenant-wide administrative credential, with P-SA the single super-admin agent), to X, reserved for agents of general capability and closed. Wall-E, Eve and Mo are the first tenants, proof the rules can be met, not the platform's definition. (Chapter 5, Architecture overview; [thesis](#).)



Why build it, and how the programme can stop

The gain is routine administration done faster and on the record, and further agents added without rebuilding their security. From its read-only stage Wall-E produces weekly digests the design assumes are made by hand today or not at all (Assumption): last week's administrative changes, accounts unused for 90 days, suspended accounts still licensed, groups with external members or no owner, administrators checked against a signed list. At its first writing stage it carries out leaver and joiner actions from chat and reclaims licences from suspended accounts, the first measurable saving; at S3, batch approval, one operator approves a whole planned run, where the toil goes away ([Wall-E stages](#)). For the platform, a hundredth agent costs a register row and a factory run and inherits controls reviewed once.

No benefit figure exists: the saving is *tbd* until four weeks of toil on the top three administrative tasks are measured before Wall-E's first phase, since no "before" can be measured afterwards. Two exits are deliberate. At the end of S1 a dated stop-or-continue review sets toil saved, plus the projected S3 saving, against operating cost including human hours, and stops the programme if the balance is negative (Wall-E decision 38; [Mo staging, S1](#)). And L3, a human approving each action, is a legitimate permanent end state: Eve's gate layer is not to be funded until a promotion can state how much approval work it removes ([Eve staging](#)). A signature is not a commitment to full autonomy. (Chapter 17, Mo, continuous improvement, and Chapter 24, Roadmap and cost.)

The central fact: nothing narrows a super admin

Two Google facts fix everything that follows: a service account, the identity programs normally use, cannot hold Super Admin, so Wall-E needs a user account; and Super Admin cannot be limited to part of the organisation or a subset of its powers. The earlier design had two enforcement points — Wall-E's action service, the code that holds the credential and decides, and Google refusing any call outside a narrow custom role. The objective removes the second, leaving as Google's only ceiling the permissions the robot's credentials were consented with. A leaked credential or an interactive login becomes a compromise of the whole tenant, with a path into the organisation's Google Cloud estate, because a super admin can grant itself the top role there. Detection becomes the primary control rather than a check on a role that already refused, and least privilege becomes a signed deviation from TISAX control 4.2.1. (Chapter 3, The problem and its risks; [what this reverses and what it costs](#).)

What makes it acceptable to try

The Super Admin choice is the owner's decision of 2026-09-13 (P33); the platform designs around it rather than re-arguing it. It is defensible because thirteen compensations are preconditions of the grant, none deferred. Among them: three lanes decided by code, of which only the catalogue of typed operations can ever run without a human, while uncatalogued super-admin requests need two different human super admins and console-only work is done by a human; the two signed lists; two credentials in two services, so the broad one is never used unattended; hardened account hygiene with Google's multi-party approval on; kill switches K0 to K7, of which K6, a human super admin removing the role, is the one that survives a token already issued; no super-admin-class operation ever autonomous; and a second human outside Wall-E's administration line. The grant is a gate with a checklist, not a runbook step: it happens the day the last row is green; a row turning red afterwards is a finding, and any of three named rows red, or two rows at once, makes the on-duty human super admin pull K6 until they are green again. (Chapter 15, Wall-E, the doer, and Chapter 21, TISAX; [Wall-E on the platform, the checklist the gate reads](#).)

Eve's independence, stated honestly

Eve has two paths. The control path, which approves, vetoes, halts and demotes, contains no language model by construction; a separate reporting path may reason about findings but writes only reports and pages, and nothing it writes is read by any gate. Because a super admin can reach anything inside the tenant's organisation, Eve's independence there is detective, not structural: a super admin could redeploy Eve, and only detection would see it. What leaves is structural: Eve pushes its evidence, incident record and heartbeat daily to a witness organisation outside the tenant, run by two people from IT security outside the Wall-E line, which holds the paging channels; an absence alarm on Eve's heartbeat and Google's own feed raises within fifteen minutes, so it sees Eve's deletion that fast; it does not see a forged approval. Moving Eve's control path into the witness is recorded as the end state (P15, proposed), not a condition of the first grant. (Chapter 16, Eve, the independent controller; [Eve's independence](#).)

Since 2026-09-15, at the owner's request, Eve's first half — the observe-and-report layer — watches every human super admin from its first run, before Wall-E exists: the committed roster and every live admin-role holder are the actors its detection catalogue watches, findings go to the second human outside the administration line with a copy in the witness, and Eve is not declared live over the human super admins until the second human has

independently proved it on a seeded super-admin action, reading Google's own admin log without any Eve component or platform-owner help. The full build makes this in its files 23 to 28 (P153–P155, proposed). ([Scope from the first run](#), [Eve's LLD §14.1.](#))

Mo in one line

Every number Mo publishes is re-derived by a validator Mo cannot reach, which refuses anything it cannot recompute, and Mo reaches production only through a pull request, a proposed change to configuration, that two humans review. (Chapter 17, Mo, continuous improvement; [Mo's thesis.](#))

The residual risks a signature would accept

A leaked robot credential is still a compromise of the tenant: custody, split credentials, detection within minutes and the kill switches meet it, but nothing prevents it; the risk register holds it as row one, accepted with compensation. Eve inside the organisation sees a super admin's actions but cannot structurally stop one, so a super admin who reaches the Google Cloud organisation could forge an approval or undo a kill until the end state is built. The robot's gate is one process its build pipeline can rewrite, so a compromised pipeline is a tenant compromise with only Google's audit log and detection beneath it. Manipulated content will reach the model and can put a false proposal before an operator or a reviewer; screening only detects; the ceilings in code stop it becoming an action. Several Google facts are unverified — whether an access boundary blocks invoking a service, whether the Admin console's access level applies to super admins, how the deny policy spells agent identities — and each is kept out of every safety argument until a test answers it. (Chapter 19, Threat model and residual risk; [the honest risk statement](#), [the risk register.](#))

Hundreds of agents, and a closed tier for agents of general capability

The factory makes projects repeatable, so people, not projects, limit scale: an autonomous agent's promotion rests on humans grading a blind sample of its work, so the number of writing agents is capped by named grading capacity, about an hour a week per Tier W agent, and the cap itself (P25) is still open. Tier X is a folder that refuses every Google service, with written opening conditions — a sandbox available in the EU, a provider's capability evaluation per model version, an AI-safety reviewer, six months of drills of the fleet kill switch that stops every agent at once, an advisory monitor on a different model family and every buildable containment control live. Only the first is met; the rest are out of reach in 2026. (Chapter 14, Scale and AGI readiness; [the honest line](#), [before any Tier W agent writes.](#))

Compliance: mechanisms and evidence, never outcomes

The platform lists what the regulator, the guidelines or the assessor still decide. Under the EU AI Act, classification follows the purpose the provider declares, not the privilege an account holds: Wall-E's declared purpose is its catalogue, close to the high-risk category for systems taking decisions that affect workers, with a documented claim that it falls outside it; the Super Admin grant is the fact most likely to be held against that claim, and high-risk obligations apply from 2027-12-02. For TISAX the target is the Confidential label (Assumption) at assessment level AL2; separation of duties becomes a staffing minimum the gate enforces, and an assessor may still refuse the expected maturity on least privilege however good the compensation. (Chapter 20, EU AI Act, and Chapter 21, TISAX; [what bulletproof can and cannot mean](#), [the TISAX position.](#))

What the platform will not do

The platform will not pretend to narrow a super-admin account; its perimeter is credential custody, split credentials, a split control plane, detection latency and the witness. It will not let any model produce an approval, a signature, a halt, a veto or a refusal. It will not automate the Admin console under the robot's session. It will not run a security operations centre: it buys round-the-clock acknowledgement for Tier P and

feeds the organisation's own centre if one exists. And it will not host a second super-admin agent, a third-party agent without a supplier record, or any agent without a register row. It also grants domain-wide delegation to nothing and claims no containment of agents of general capability. (Chapter 4, The principles; [what the platform does not do](#).)

The organisation that exists, and what the platform costs

On 2026-09-13 the organisation behind the platform is one administrator: no security operations centre, no second super admin outside their own line, no security reviewer, no Eve owner, no engaged data protection officer (DPO). Every role the platform needs is held by one person, the finding most likely to stop a TISAX assessment. The design opens tiers in order: Tier C and Tier R open with the people who exist, self-review recorded as such; Tier W, Tier P and the super-admin grant wait for people and bought services. The proposed minimum is one human at Tier R, three when the first agent writes, and four at the grant. The bought round-the-clock detection desk (P10, open) is contracted before the grant. A later staffing row, for Wall-E's first catalogued work without a human approving each action, adds only a quarter of evidence that the desk acknowledges in time; the TISAX page places it at "Stage 3 at L4" ([11 §7.2](#)), while Wall-E's ladder brings L4 with Eve at S4 ([stage overview](#)). (Chapter 23, Operating model, and Chapter 24, Roadmap and cost; [the tier gate](#).)

No price is quoted: pricing pages were not read and every amount is still to be set, so the design names each cost's driver and payer. Security Command Center Premium, Google's organisation-wide security findings service, is paid by IT security (Assumption: a platform budget line until then). Central log ingestion, driven by the volume of Workspace audit logs, is the largest line and falls to the platform budget. Model Armor is paid per request from each agent's budget, device-posture licences for operators arrive at Tier W, and Tier P adds a Workspace licence per privileged agent plus the monitoring service and the witness organisation, both paid by IT security. The agents' own estimates are all Assumption: Wall-E's first-stage infrastructure in the low tens of euros a month; Eve seven to nine engineer-weeks and under €50 a month plus one licence, a figure that predates the witness and Eve's reporting path; Mo 24 to 37 person-days and €25–60 a month. The cost that binds is human hours. (Chapter 24, Roadmap and cost; [cost classes](#).)

What the sponsor is asked for, in order

Each group opens one gate; a group left unprovided keeps that gate and every later one closed. Third-group items take longest to obtain and are best started now, though their gate opens last. The deciders behind each item are Chapter 25, Decisions awaiting the owner; what each gate contains is Chapter 24, Roadmap and cost.

- 1. To open Tier C and Tier R — the assistant baseline and read-only agents.** - Nobody new: the owner builds and operates both tiers. - Security Command Center Premium activated at organisation level, with its funding and ownership decided by IT security (P11, open). - If not provided: no platform folder, no factory run and no agent beyond what the Gemini Enterprise app offers today. - Alongside, the information security management system's written acceptance of self-review at Tier R; without it that risk stays unaccepted and a TISAX assessment cannot be ordered.
- 2. To open Tier W — the first agent that writes to a system of record.** - A second named operator who is not the agent's owner, about two hours a week. - A part-time security reviewer from IT security, about two hours a month, who reviews autonomy raises, policy changes and privileged access. - A blind grader who does not write the agent's playbooks, its scripted routines, about an hour a week per Tier W agent. - Information to the works council, the employees' elected representatives, before any agent acting on employee accounts takes its first write (P129, proposed), with the DPO's retention decision (P13, open) before the same step. - If not provided: the platform stays read-only, and no autonomy contract is exercised.
- 3. To open Tier P and the super-admin grant — Wall-E with Super Admin.** - A second human super admin outside the Wall-E administration line, from IT security, as Eve's owner and the sole recipient of reports about the administrator. - An incident commander from IT security. - An engaged DPO and an AI compliance owner, legal's designate, accountable for classifications and regulatory reports (P131,

proposed). - Google SecOps, Google's security monitoring service, in the EU or the organisation's existing equivalent (P10, open), with a managed detection and response retainer, an outside service contracted to watch the super-admin detections and respond round the clock, and a paging service. - Hardware security keys for the robot and the human super admins, with witnessed custody. - The witness organisation, set up and administered by IT security (P14, open). - A penetration test with no open critical or high finding. - The data protection impact assessment (DPIA), which the tier gate lists as a condition and the grant checklist records as started. - Signatures: the two lists by the owner (P29, open); Wall-E's declared intended purpose by the owner with legal (P28, content proposed, signature open — the register files it before Wall-E's first write, while the grant checklist asks for it before the grant); and the deviation record, decided by the owner, signed by the security reviewer and entered by the information security management system (P136, proposed). - If not provided: the robot account may exist, licensed and hardened, but holds no administrative role and reads nothing, and Tier P stays closed.

(Who exists on 2026-09-13, the tier gate, before the super-admin grant.)

Key decisions

- P33 — Wall-E holds Super Admin: decided by the owner on 2026-09-13; the deviation signatures are pending and the grant is blocked until every precondition is green ([decision record](#)).
- P1 — the tier model and the tier gate: proposed.
- P29 — the two lists: open, awaiting the owner's signature. P28 — Wall-E's intended purpose: content proposed, signature open.
- P10 (the monitoring service and its managed detection partner), P11 (Security Command Center Premium funding) and P14 (the witness organisation): open, with IT security.
- P25 — the Tier W cap by grading capacity: open.
- P34 — Eve's reporting path may reason: proposed. P15 — Eve's control path moved to the witness as the end state: proposed.
- P129 (works-council information before the first write), P131 (the AI compliance owner), P136 (the deviation record) and P137 (separation of duties as a counted minimum): proposed.

Read next

- In this brief: Chapter 2, The objective and what it demands; Chapter 3, The problem and its risks; Chapter 17, Mo, continuous improvement, for the value review; Chapter 19, Threat model and residual risk; Chapter 24, Roadmap and cost; Chapter 25, Decisions awaiting the owner.
- In the design: [the platform set's README](#); [the platform HLD, what this reverses and what it costs](#); [the register in one screen](#) (P1–P204) and [its gate before the super-admin grant](#).
- The three build sets, smallest first: [the three-day build](#), [the proof of value](#) and [the full build](#).

2. The objective and what it demands

What this chapter settles

By the end of this chapter you will have read the objective in the owner's words and will know the sixteen requirements drawn from it, the chapter that meets each, the eight literal readings the design qualifies or declines and why, and the demands the objective makes without stating them. This is the brief's only requirement-to-chapter map; later chapters point here.

The objective, in the owner's words

Stated by the platform owner on 2026-09-13 and quoted as written, spelling included (00 §1):

Create a secure Gemini Enterprise environment and secure all agents through it (including agent identity, agent registry, model armor). If you think about other security element to secure autonomous agent, please add the correct path. Then, have 3 different agents. The first agent "Wall-e" is the doer and execute action based on a prompt by a human. The action will have the ability to any super admin level action of Google Workspace. In order to do that, Wall-E will have a dedicated user account, with a google license and super admin roles. The second is "Eve" that needs to control & report any misbehaviour of Wall-E. She won't have super admin access to control and should work independantly & autonomous. She needs to report to the human anything wrong. The thrid is "Mo" that work on continuous improvements of both Wall-E & Eve agent.

The overall objective is to set up an agentic platform that can sustain hundreds of agents (classicial or autonomous) & host future AGI agent while ensuring a full proof security & monitoring for enterprise class. All of that must be EU AI Act bulletproof & TISAX compatible.

Please review the entire documentation first & focus on the HLD. Then work on the detailed.

The text names mechanisms, outcomes and a method. The design treats the mechanisms as binding, turns each outcome into mechanisms plus evidence, and says where an outcome cannot be delivered as worded, because a promise it cannot keep would mislead the sponsor who signs for it.

The sixteen requirements

The design restates the objective as sixteen requirements, R1 to R16 (00 §1); Appendix A, Glossary, separates them from other R-numbered families.

The platform

- **R1 — a secure Gemini Enterprise environment through which all agents are secured.** No agent reaches users, tools or data except through platform-owned controls, agent identity, the registry and Model Armor among them.
- **R2 — any other security element an autonomous agent needs, "with the correct path".** Missing controls arrive as enforced mechanisms, not recommendations.

Wall-E

- **R3 — Wall-E is the doer and acts on a human's prompt.** An identifiable person is the origin of what Wall-E does.
- **R4 — Wall-E can perform any super-admin-level action of Google Workspace.** Literally, breadth with no upper bound inside the tenant.
- **R5 — a dedicated user account with a Google licence and super admin roles.** A licensed robot user holds Super Admin; a service account cannot, so the account type is fixed too.

Eve

- **R6 — Eve controls and reports any misbehaviour of Wall-E.** Detection covers everything Wall-E can do, not only what it was designed to do.
- **R7 — Eve holds no super admin access.** The controller's power is observing and halting, never the controlled agent's privilege.
- **R8 — Eve works independently and autonomously.** Eve keeps working, and keeps its evidence, against the wishes of the agent it watches or its administrator.
- **R9 — Eve reports anything wrong to the human.** A named human reliably receives Eve's reports and can act on them.

Mo

- **R10 — Mo continuously improves both Wall-E and Eve.** The improvement loop covers both without becoming a way to weaken the controller or approve its own proposals.

Scale and assurance

- **R11 — hundreds of classical or autonomous agents.** Adding an agent is repeatable and cheap in people, not a re-run of hand-built controls.
- **R12 — future AGI agents.** A place, and conditions, for agents whose capabilities exceed their designers' foresight.
- **R13 — "full proof" security and monitoring at enterprise class.** Someone contracted to answer handles detection and response, at a stated latency.
- **R14 — EU AI Act "bulletproof".** Every system has a classification and the documentation and evidence that class requires.
- **R15 — TISAX compatible.** An assessor can rate the controls against the VDA ISA catalogue, with evidence.
- **R16 — the method: review all the documentation, focus on the HLD, then the detailed design.** The platform is decided before the agents' detail.

Where each requirement is met

The design section behind each row is in the HLD's traceability table ([01 §0.6](#)).

R	Met in	Reading
R1	Chapter 6, The Gemini Enterprise environment; agent identity in Chapter 8, Identity, privileged access and the fleet kill switch; the registry in Chapter 9, Registry, governance and the autonomy contract; Model Armor in Chapter 10, Agent Gateway, Model Armor and the perimeter	as stated
R2	Chapter 7, Landing zone and the tier model; Chapter 12, Data, logging, retention and sovereignty; Chapter 13, Supply chain, keys and recovery; deny policies and the fleet kill switch in Chapter 8; the perimeter in Chapter 10	as stated
R3	Chapter 15, Wall-E, the doer: band A on the chat trigger	as stated; see the note below
R4	Chapter 15: the three bands and the hard-denied list	qualified
R5	Chapter 15: the robot account, its hygiene set, P33; the roster in Chapter 8	as stated; the grant waits for its checklist
R6	Chapter 16, Eve, the independent controller: detection catalogue and reporting path	qualified
R7	Chapter 16; the robot accounts in Chapter 8	as stated
R8	Chapter 16: two-part independence and the witness organisation	qualified
R9	Chapter 16: the reporting contract and the second human outside the Wall-E line; the role in Chapter 23, Operating model	as stated
R10	Chapter 17, Mo, continuous improvement; separation in Chapter 18, How the three work together	as stated

R	Met in	Reading
R11	Chapter 14, Scale and AGI readiness; the factory in Chapter 7 and the register in Chapter 9	qualified
R12	Chapter 14: Tier X and its opening conditions	declined for 2026
R13	Chapter 11, Monitoring, detection and incident response; the tier gate in Chapter 24, Roadmap and cost	qualified
R14	Chapter 20, EU AI Act	"bulletproof" declined
R15	Chapter 21, TISAX	qualified
R16	Chapter 3, The problem and its risks (the earlier design and what stands); Chapter 24 (the propagation stage)	as stated

Chapter 19, Threat model and residual risk, tests every answer.

A note on R3. Band B is chat-only, but Wall-E's ladder lets catalogued band A families run on scheduled, event and inbox triggers once each has earned it, scheduled runs acting on behalf of the agent owner ([wall-e 05 §3](#)). The traceability table records no qualification of R3 for this, so the brief reads the human prompt as the origin of Wall-E's mandate rather than its only trigger. Wall-E will then act without a fresh human prompt, and that reading is the owner's to confirm (Chapter 25, Decisions awaiting the owner).

Where a literal reading is qualified or declined

Eight requirements are not delivered word for word. For each: what the design delivers instead, why the literal reading cannot be delivered or defeats another requirement, and the decision that carries the position, in its state on 2026-09-14.

R4 — "any super admin level action"

Read literally, R4 includes assigning admin roles, changing security posture, deleting administrators and removing Eve's access: a doer that can switch off its controller defeats R6 to R9. As a declared purpose, "any admin action on a prompt" also makes Wall-E an Annex III high-risk system (Chapter 3 states the regulatory problem; Chapter 20 the classification).

The design keeps the breadth but routes it through three bands ([01 §13.1](#)). Band A, the catalogue of typed operations, is the declared purpose and the only band that can become autonomous. Band B carries uncatalogued work as a generic request, permanently approved by two different human super admins. Band C turns console-only work into instructions for a human. In every band a hard-denied list — escalation, blinding Eve or the alerting, minting or deleting administrators, unlisted spend among its rows — is refused however many approve ([wall-e 03](#)).

"Any" becomes "any, except what lets Wall-E escalate, blind its controller or cause permanent loss, and nothing autonomous beyond the catalogue". Breadth is paid for in human approvals, enforced by the action service's code, not Google (Chapter 3). The two lists are P29, open until the owner signs; the register describes them as hard-denied operations and protected principals ([12](#)), the HLD as the hard-denied list and the operations reachable only through band B ([01 §13.1](#)). Wall-E's intended purpose is P28: content proposed through P125, signature, by the owner with legal, open. The bands are Chapter 15, Wall-E, the doer.

R6 — "any misbehaviour"

Eve detects with a deterministic catalogue over every stream it ingests, all six Workspace log streams included, and reconciles every robot event against Wall-E's audit rows; an unmatched event halts Wall-E. A catalogue cannot name what nobody foresaw, so a reporting path, `eve-advisor`, may use a model to describe the rest ([01 §13.2](#)).

That path is report-only by construction: nothing it writes is read by Eve's gate, Eve's reconciler or either Wall-E action service. Approving, halting, vetoing and demoting stay model-free (Chapter 4, The principles; the mechanism is Chapter 16). "Any" ends where enumeration ends: Eve halts on what is enumerated, reports beyond it, and declares as limits what Google never records and the settings Eve cannot read. The reporting path is P34, proposed; its AI Act class is P19, open with legal, and its paging rights wait on that answer.

R8 — "independantly & autonomous"

Autonomy is met: Eve's control path runs and halts without a human in the loop. Independence is split: because a super admin can reach Eve's project, structural independence inside the tenant's organisation is declined as unachievable and is detective there, while what leaves for the witness organisation — evidence, incident record, pagers, an absence alarm — is structural (Chapter 16, Eve, the independent controller; [eve 01 §1](#)). The witness sees the deletion of Eve's project within fifteen minutes, not a forged approval; only relocating Eve's control path into the witness would stop that. The relocation is the end state P15, proposed, built when IT security operates the witness and gated on Tier X, not the grant. The witness itself, P14, open with IT security, is a precondition.

R11 — "hundreds of agents"

The factory makes a project per agent, so projects are not the limit; people are. Tier W, agents that write to a system of record, is capped by named blind-grading capacity, and a Tier W register row without a named grader with declared hours is refused at admission ([02 §1.3](#)). Hundreds is realistic for classical and read-only agents; writing agents are as many as graders allow, privileged agents stay rare by policy, and at most one holds Super Admin. The cap is P25, open, its number *tbd* until the first Tier W agent's first quarter (Chapter 14).

R12 — "host future AGI agent"

Declined for 2026. Tier X is a closed folder that refuses every service until six written conditions hold — among them a capability-evaluation report per model pin, an AI-safety reviewer and the fleet kill switch drilled for six months — of which only the first, an EU sandbox at general availability, was met on 2026-09-13; the monitor condition is P26, open ([01 §11.5](#); Chapter 14, Scale and AGI readiness). Capability evaluation is the provider's work and deception-robust monitoring is research, so the platform claims no AGI containment.

R13 — "full proof security & monitoring for enterprise class"

Below Tier P, findings and absence alerts page the platform owner and are answered "next business morning", written down as such ([01 §7.1](#)). Tier P and the super-admin singleton get a bought 24x7 desk: Google SecOps in the EU or the organisation's own SIEM, with a managed detection and response retainer (P10, open with IT security), severity 1 acknowledged within 15 minutes in business hours and 60 outside (Assumption: until the contract fixes them). With no SOC, a round-the-clock promise nobody is contracted to answer would be a log line. Nor does the design claim "full proof": detection never stands alone in a safety argument (Chapter 4).

R14 — "EU AI Act bulletproof"

Declined as worded. No harmonised standard gives a presumption of conformity, an Art. 6(3) claim rests on draft guidelines, Annex III obligations are deferred to 2027-12-02, and the Super Admin grant is the fact most likely to be held against Wall-E's narrow-task reading. The platform promises mechanisms and evidence, and lists what the regulator or guidelines still decide: eleven residuals, each with its closing evidence ([10 §6](#)).

R15 — "TISAX compatible"

The target is the Confidential label (Assumption) at assessment level AL2 against ISA2027 (P20 proposed through P133; the ISMS confirms). The qualification is least privilege, 4.2.1: a machine Super Admin cannot show it, so it is a signed deviation whose compensations are preconditions of the grant (P136, proposed), and an

assessor may still refuse maturity 3 on 4.2.1 (11 §0). Separation of duties, 1.2.2, the item most likely to stop an assessment, is answered rather than qualified, by counting distinct humans per stage (P137, proposed; Chapter 23).

What the objective demands without saying

Controls the existing organisation can operate

The organisation asking for enterprise-class security is, on 2026-09-13, one administrator (Chapter 1, Executive summary; 01 Status). The unstated demand is that every control has someone able to run it, because a control nobody operates is a promise the first audit breaks. No tier opens until the people and services it needs exist: classical and read-only agents start now; writing agents and the super-admin grant wait. Hence R13's qualification by tier. The principle is Chapter 4, The principles; staffing, Chapter 23, Operating model; the gate, Chapter 24, Roadmap and cost.

Three agent designs brought into line with the platform

The three agents' existing designs assume a Wall-E that never holds Super Admin (Chapter 3), so they must change; the HLD lists the edits (01 §18) and P143, proposed, gives them owners and gates. The items that make the grant safe, Eve's observe-and-report layer and the witness among them, gate the grant; the rest, Mo's included, gate Wall-E's Stage 1. Until then agent and platform pages still differ, and rows 10 to 14 of the register's list of differing values stay open (12 §7). The propagation stage is Chapter 24.

The objective's silence does not lift the standing constraints that already governed every agent (Chapter 4, The principles).

Key decisions and what to read next

Decision	State on 2026-09-14	Bears on
P33 Wall-E holds Super Admin	decided by the owner; deviation signatures pending (P136 proposed)	R5, R15
P29 the two lists	open, owner signs	R4
P28 Wall-E's intended purpose	content proposed through P125; signature open	R4, R14
P34 Eve's reporting path may reason	proposed	R6
P19 eve -advisor's AI Act class	open, legal	R6, R14
P14 the witness organisation	open, IT security	R8
P15 Eve's control path relocated to the witness	proposed, end state	R8
P25 the Tier W grading cap	open	R11
P10 SIEM and managed detection partner	open, IT security	R13
P20 TISAX target through P133	proposed; ISMS confirms	R15
P137 distinct humans per stage	proposed	R15, implied demands
P143 the propagation stage	proposed	R16, implied demands

Read next:

- 00 §1, the requirement text of record; 01 §0.6, the design section behind each row; 01 §16, the refusals behind several readings; 12 §0, the register of record.
- Chapter 3, The problem and its risks, for what Super Admin breaks in the earlier design and the risk themes the brief answers.

3. The problem and its risks

What this chapter explains

By the end of this chapter the reader knows what the design looked like on 2026-09-12, before the objective of 2026-09-13, and which parts of it survive into the platform. They know the three Google facts that make a super-admin robot a different kind of problem from a narrowly scoped one, which safety properties the Super Admin choice removes, and the other reversals the objective forces on Eve, Mo and the project layout. They can name the five hardest problems in order of weight, including the two that are not technical: one person holds every role, and the robot's declared purpose decides its legal classification. The chapter closes with seven risk themes; every chapter in Parts II and III opens by naming the themes it answers, and Chapter 19, Threat model and residual risk, tests every answer and records what remains.

The objective and the readings the design declines are Chapter 2, The objective and what it demands; the principles derived from this problem are Chapter 4, The principles.

The design before the objective

What it was on 2026-09-12

On 2026-09-12 the design described one privileged Workspace agent and two companions bolted to it, not a platform.

Wall-E was a narrow operator. Its robot account held a customer-scoped read role and a custom write role scoped to a pilot organisational unit, which the design called "a second enforcement point outside our own code": if every control in Wall-E's action service failed, Workspace would still refuse any call outside the role or the pilot unit. The role grew with the autonomy ladder, and Wall-E could run a fixed catalogue of about twenty typed operations and nothing else. "Never Super Admin" was design intent on nineteen pages, enforced by the setup script. Changes to security posture and permanent data loss were excluded twice over: in neither the catalogue nor the role. The threat model bounded a leaked credential "by the role's privileges at the current stage". Decision 26 sought a keyless service account for the administrative half; decision 27 recorded that Wall-E was not a stand-in for a super admin.

Eve was a deterministic verifier of catalogued plans: its verdict a pure function of six plan inputs, and "no model anywhere in Eve v1 or v2" a settled row. Eve gated nothing in the pilot, received its own Workspace account at Stage 3 and began signing approvals at Stage 4.

Mo measured Wall-E and nothing else: every number re-derivable from Wall-E's audit table, its grants and validator reaching Wall-E's data only.

Above the three agents there was nothing: no landing zone, factory, tier model, SIEM, incident-response roles, retention schedule, supply-chain control, privileged access mechanism, register of agents or compliance classification. Compliance meant data protection: a DPIA and employee representatives "before Stage 3". The words "hundreds", "AGI", "TISAX" and "AI Act" appeared nowhere. Every control was configured by Wall-E's runbook, in Wall-E's project, and the runbooks still placed Eve's and Mo's identities, and Eve's signing key, inside that project ([project-topology §1.1](#)). A fourth agent would have re-implemented the security chapters by hand ([objective review §2](#)).

What of it stands

Much of the earlier design's shape generalises. Seven elements are lifted into the platform unchanged, and Chapter 4, The principles, states them as platform rules.

- **The credential split.** The model never holds a credential; one action service does, and it is the only place authorisation is decided.
- **A deterministic gate before every write.** Code the model cannot talk its way past stands between generated text and any Admin SDK call.
- **Autonomy as data with permanent ceilings.** Each (operation family, trigger class) pair carries a level in versioned configuration; humans raise it, machines lower it, and some ceilings are code that no promotion can move.
- **A model-free authority path for Eve.** Whatever approves, halts, demotes or vetoes contains no model — deterministic by absence, not by discipline.
- **Re-derivable numbers for Mo.** Every figure Mo publishes can be recomputed by a validator Mo cannot reach.
- **Resource-level cross-project grants.** A principal in one project reaches a resource in another only through a grant on that resource, never through a project-level role.
- **The three separation rules.** No agent both decides and acts; no agent grades its own work; only humans loosen anything ([wall-e 08](#)).

The pages on prompt security and Model Armor, agent identity, agent interconnection and project topology were already platform-grade in substance and are promoted rather than rewritten. Eve's own credential, project, key, halt authority and "not a super admin, ever" are exactly what the objective asks of Eve. The standing constraints hold unchanged (Chapter 4). The pages that need no change are listed in [objective review §7](#).

The Google facts that fix the problem

Three facts about Google's products, verified on 2026-09-13, turn the owner's choice into a structural problem rather than a configuration choice ([wall-e HLD](#), [the Google facts behind Super Admin](#)).

A service account cannot hold Super Admin, though it can hold any other Workspace administrator role. The robot must be a user account — licensed, with a password, able in principle to sign in interactively — and decision 26's keyless service account closes for Wall-E by fact, not preference.

Super Admin cannot be limited to an organisational unit or to a subset of privileges. There is no scoped Super Admin and no way to grow it with the autonomy ladder. Once granted, Workspace enforces nothing on the account except the OAuth scopes consented for the client holding its token. One consequence is severe: the call that makes a user an administrator sits under the ordinary directory-user scope the narrow client already needs, so only Wall-E's own hard-denied list stops the robot minting further super admins.

A super admin can grant itself Organization Administrator on the GCP organisation, so every project in it — Eve's and Mo's included — is within a super admin's reach. The console mechanism and the standing recovery right are carried as Assumptions to be verified before the grant, and neither Google nor the design calls the reach irrevocable; why it justifies the witness organisation is Chapter 16, Eve, the independent controller ([eve HLD](#), [choice 1](#)).

The objective is not re-argued: Super Admin for Wall-E is the owner's decision of 2026-09-13, register row P33, and the platform is designed around it ([decision record](#)).

What the Super Admin choice costs

The platform HLD states the loss "without softening" in seven rows ([HLD](#), [what this reverses and what it costs](#)); the rest of the brief responds to them.



The Workspace-side gate

Before, there were two enforcement points: the action service, and Google refusing any call outside the role or the pilot unit, so even a total failure of the action service would leave Workspace refusing the call. After, there is one. The pilot-unit allow-list, the never-list rows on posture and permanent loss, the role that grew with the ladder, the bound on a leaked credential and the split between safe and sensitive user fields are all enforced by code inside the component under audit. The only Google-enforced ceiling left is each OAuth client's consented scope set, which is why the design splits the robot's credential into a narrow client for everything unattended and a broad client for human-approved work. The sentence promising refusal at Google's end is deleted from the setup pages; keeping it would be a false statement in the safety case.

The blast radius

Before, a leaked token was bounded by the role's privileges at the current ladder stage. After, a leaked refresh token or an interactive login on the robot account is a compromise of the tenant and — through Organization Administrator, or a token carrying the cloud-platform scope — a path into the GCP organisation, including Eve's, Mo's and the platform's core projects. The perimeter becomes token custody, key custody, the scope split and detection latency. Only what has already left the organisation — evidence in the witness organisation, its alarms, its paging channels — is out of reach. How a leaked token travels is Chapter 19.

Eve's structural independence

Before, Eve's project, credential, key and halt authority were out of Wall-E's reach by construction. After, the robot's credential can suspend Eve's account, revoke its token, remove its role, switch off Workspace data sharing with Google Cloud and re-filter the log sinks. Inside the tenant's organisation Eve's independence is detective, not structural; what leaves the organisation can still be structurally independent, the reason for the witness organisation (Chapter 16, Eve, the independent controller).

The catalogue as a ceiling

Before, nothing executed that was not in the catalogue. After, "any super-admin action on a human's prompt" cannot be delivered by twenty operations, so the catalogue becomes the declared purpose: the only band that can ever become autonomous, beside a two-person generic lane and a console handoff to a human ([wall-e HLD](#), [the three action bands](#)). The ceiling is now a rule in code rather than a limit of what exists. Decision 27 moves from "whether" to "which lane". The qualification of R4 is Chapter 2; the bands are Chapter 15, Wall-E, the doer.

Least privilege as a property

Before, TISAX control 4.2.1 could be shown by an enumerated role. After, least privilege becomes a signed deviation — row one of the platform risk register, carried entirely by the bands, the two lists, the ladder, Eve and a split control plane. An assessor may still refuse maturity 3 on it. The deviation record and its signatures are Chapter 21, TISAX.

The narrow-task argument under the EU AI Act

Before, the argument that Wall-E performs narrow procedural tasks rested on the role and the catalogue. After, it rests on the declared intended purpose, on the hard-denied list enforced in code with its CI ownership outside the agent's repository, and on audit logs showing no out-of-catalogue operation outside band B under approval. The account's privilege is the fact most likely to be held against the argument. The classification is Chapter 20, EU AI Act.

Detection moves from a check to the primary control

Before, alerts confirmed what the role had already refused. After, for the super-admin tier, detection is the primary control, and the design says so. Since nothing detection-grade may stand alone in a safety argument (Chapter 4, The principles), detection must be paired with enforcement the design still owns — the action service, the scope split, the kill switches — and made fast, independent and staffed. Monitoring is Chapter 11; the thirteen compensations that must be green before the grant, as a design argument, are Chapter 15.

The other reversals the objective forces

Super Admin is the loudest reversal but not the only one. Eight more follow from the same objective, each changing a sentence the earlier design held as settled ([objective review §3.2](#)).

The catalogue is purpose, not ceiling, as described above.

Eve gains a reporting path that may reason. "Report anything wrong" cannot be enumerated, so the "no model anywhere in Eve" row is reopened, but only for a separate, report-only path; approval, halt, demotion and veto stay model-free (Chapter 2; the path is Chapter 16). The platform HLD records this reversal as decided on its own page, while the register carries P34 as proposed; this brief carries it as proposed ([HLD](#), [register](#)).

Eve detects misbehaviour instead of verifying plans. A verifier sees only the plans it is shown, so Eve's core becomes a versioned, deterministic detection catalogue over every ingested stream — privilege changes, out-of-family writes, deviations from baselines, divergence between what was prompted and what was done.

Mo improves both agents. Mo reads Eve's quality data through dataset-level grants made by Eve's own runbook and proposes changes to Eve's configuration through a closed set of change types. Eve reads nothing Mo writes, and Mo is never Eve's grader, so improvement cannot weaken the controller.

Four projects become a factory pattern. The earlier topology counted four projects for four things; for hundreds of agents, one project per agent is a pattern produced by a factory under tier folders.

Decision 26 closes by fact. The keyless service account for Wall-E's administrative half is impossible under Super Admin; the idea survives only as Eve's E-16, where a service account could still remove Eve's password, key and consent.

Compliance becomes two regimes. The EU AI Act and TISAX are named, classified and mapped beside data protection, and worker consultation moves from before Stage 3 to before Stage 1 under both the GDPR and the Act.

Eve arrives before the grant. Eve's observe-and-report layer must be live and drilled before the robot holds Super Admin, so the grant becomes a gate with its own checklist. Eve's gating and signing layers keep their later stages.

Why agents are a distinct risk

A conventional administration script does what its author wrote; an agent does what a model infers. Tool arguments are generated text: the process that summarises an email can compose a call that suspends a user, and under Super Admin that call could name an administrator-role assignment and Google would execute it. The steering content arrives not only from the operator but through the mailbox the agent reads, the results its tools return and the peer agents it talks to — any of which an attacker can write to. So no prompt instruction is a boundary (Chapter 19, Threat model and residual risk), and the action service stays a separate process with the only credential and the hard-denied list in the gate ([wall-e HLD](#)). The injection surface and its screens are Chapter 10, Agent Gateway, Model Armor and the perimeter.

The five hardest problems

The distance between the earlier design and the objective reduces to five problems, in order of weight ([objective review §2](#)).

1. Super Admin cannot be scoped, so Workspace stops enforcing anything

This is the loss described above. Three controls the earlier design had deferred to "before Stage 1" — a network perimeter around the credential holder, the control-plane split into two services, and privileged access on the deploy grant — become preconditions of the grant. The only gate left is code the platform itself writes and deploys, so the deploy path, the code's owners and the speed of detection all become part of the security boundary.

2. Eve's independence is no longer structural

Beyond that loss, Eve read only one of the many streams a super admin acts in, and reported through a page budget whose conditions were empty, addressed to the person who administers Wall-E. The design had to decide where Eve's trust root sits and what "report to the human" means before the grant. It answers with a witness organisation outside the tenant and a second human outside the Wall-E administration line; relocating Eve's control path to the witness, the only mechanism that would stop a super admin forging an approval, is the end state, proposed and not built (P15). Chapter 16 explains both.

3. There was no platform — the scale problem

One project per agent is forced by Google, for reasons Chapter 7, Landing zone and the tier model, sets out ([project-topology §1](#)), so hundreds of agents means hundreds of projects. Google's resource limits make that routine; the earlier design did not. It offered a hand-run runbook, 26 hand-made cross-project grants, log sinks built per agent and alert channels reading "paste yours", and no fleet kill switch outside any agent's own project, which matters most for the most capable agents. The tier model, landing zone, factory, shared services, SIEM, Security Command Center and monitoring baseline had to be designed from nothing; they are Part II, and the scaling argument is Chapter 14, Scale and AGI readiness.

4. "Any super-admin action" collides with the must-never list and with the Act — the regulatory problem

Read literally, "any super-admin action" includes what the never-list existed to exclude, and silencing Eve, which contradicts the objective's own Eve requirement (Chapter 2). The same words decide Wall-E's legal class: under the EU AI Act, classification follows the intended purpose the provider declares, not an account's privileges. If "any admin action on a prompt" is the declared purpose, the Art. 6(3) derogation for narrow procedural tasks collapses and Wall-E becomes high-risk under Annex III 4(b), with the full Chapter III programme — risk management, technical documentation, conformity assessment, registration, post-market monitoring — due by 2027-12-02 and no harmonised standard to lean on ([EU AI Act page §3.1](#)). The design recommends declaring the catalogue as the purpose, with band B as execution of requests two human super admins have specified and approved, and band C as instructions to a human. That line is the owner's to draw and sign: the purpose text is proposed (P28, content via P125, signature open) and the two lists are open (P29). Chapter 20 carries the classification.

5. One person holds every role — the organisational problem

On 2026-09-13 every role, from platform owner and approver to Eve's owner and the recipient of Eve's pages, is held by one person, who will also prompt a super-admin robot (Chapter 1, Executive summary; [HLD §0.3](#)). Three consequences follow. TISAX control 1.2.2 on separation of duties will not be rated at maturity 3, the item most likely to stop an assessment. Eve's reports about the administrator have nowhere independent to go. And every two-person rule is notional: a second approval by the same human is not a second approval. No amount of code answers an organisational problem. The design's response is the tier gate — Tier W, Tier P and the super-

admin grant do not open until the people and bought services they need exist (HLD §0.4) — and the recorded state "the four owner groups are one person" expires on the grant date. The roles, distinct humans per stage and hours are Chapter 23, Operating model.

The risk themes the rest of the brief answers

The problems condense into seven risk themes, stated at the level of intent, each naming the chapters that answer it.

Risk theme	What could go wrong	Answered in
Tenant compromise through the robot credential	A leaked refresh token, an interactive login or a compromised super-admin lane gives an attacker the tenant and a path into the GCP organisation, with nothing in Google to narrow it	Chapter 8, Identity, privileged access and the fleet kill switch; Chapter 11, Monitoring, detection and incident response; Chapter 15, Wall-E, the doer
Manufactured silence	The actor being watched switches off data sharing, re-filters sinks, deletes evidence or suspends the watcher, so that absence of alerts looks like calm	Chapter 11, Monitoring, detection and incident response; Chapter 12, Data, logging, retention and sovereignty
Autonomy outrunning evidence	A level is raised, or a fleet grows, faster than graded and independently re-derivable evidence supports	Chapter 9, Registry, governance and the autonomy contract; Chapter 17, Mo, continuous improvement
A controller reachable by what it controls	Eve's account, key, project, rules or pages are within reach of the super-admin credential or of the administrator Eve reports on	Chapter 16, Eve, the independent controller
Shadow and third-party agents	Agents reach the tenant or the Gemini Enterprise app without a register row, a gateway, a screen or a classification, including agents built or hosted by suppliers	Chapter 9, Registry, governance and the autonomy contract; Chapter 14, Scale and AGI readiness
Classification collapse	What an agent does, or how it is positioned, contradicts its declared purpose, and a system claimed as narrow is treated as high-risk — or an agent enters service with no classification at all	Chapter 20, EU AI Act
Staffing that makes two-person rules notional	Approvals, reviews, grading and pages that need a second person are given by the same person, so the control exists on paper only	Chapter 23, Operating model

Chapter 19, Threat model and residual risk, takes each theme, names the enforcement-grade control that stops it and the detection that sees it, and records whether the residual is accepted in writing, mitigated or blocks a gate. Some themes the design does not close: a leaked robot credential remains a tenant compromise met by detection and kill switches rather than prevented, and Eve inside the tenant's organisation sees a super admin but cannot structurally stop one.

These risks are accepted only for a gain not yet measured. Chapter 1, Executive summary, states the work Wall-E is meant to remove, why no benefit figure exists until four weeks of toil are measured before Wall-E's first phase, and the two exits: the stop-or-continue review at the end of S1, which ends the programme if the saving does not cover the cost including human hours, and human approval of each action (L3) as a legitimate permanent end state.

Key decisions and what to read next

Key decisions

- **P33 — decided** by the owner on 2026-09-13: Wall-E holds Super Admin on a dedicated licensed user account; deviation signatures pending ([decision record](#)).
- **Decision 26 — closed for Wall-E by fact**: a service account cannot hold Super Admin; the idea survives as Eve's E-16.
- **P28 — proposed content (via P125), signature open**: Wall-E's declared intended purpose, the catalogue plus bands B and C, against "any admin action" with the full Chapter III programme.

- **P29 — open**, owner signs: the two lists, decision 4 re-ratified (Chapter 2 notes how the register and the HLD describe them).
- **P34 — proposed**: Eve's reporting path may reason, report-only ([decision record](#)).
- **P15 — proposed**: relocation of Eve's control path to the witness organisation as the end state.
- **P25 — open**: the Tier W cap expressed as grading capacity rather than project count.
- **P10 — open**, IT security: the SIEM and managed detection partner that the super-admin tier's primary control depends on.

States are the register's on 2026-09-14; who decides each is Chapter 25, Decisions awaiting the owner.

Canonical pages to read next

- [Objective review §2, verdict, §3.1, Wall-E holds Super Admin, §3.2, other reversals and §7, what does not change](#)
- [Platform HLD, what this reverses and what it costs and §13.1, the super-admin singleton](#)
- [Wall-E HLD, the Google facts behind Super Admin and why the action service stays separate](#)
- [Eve HLD, choice 1: detective inside the organisation, structural through the witness](#)
- [Project topology §1, why one project per agent](#)
- [EU AI Act page §3.1, Wall-E and TISAX page §10, the risk register](#)
- Next in the brief: Chapter 4, The principles.

4. The principles

What you will understand by the end

This chapter states the few rules every later design choice follows from. By the end you will know where a control is placed and why placement follows the people who exist rather than the ambition; the one test that decides whether a control may carry a safety argument or only produce evidence; the six containment primitives every agent receives; the constraints no page may loosen; why a decided premise is designed around rather than re-argued; what the platform promises each agent and demands in return; and the full list of what the platform refuses to do, each with its reason. Chapter 3, The problem and its risks, explains why the rules are needed; Parts II and III apply them.

4.1 The thesis

The objective asks for enterprise-class security and monitoring across hundreds of agents, to be run by an organisation that is, on 2026-09-13, one administrator (Chapter 1, Executive summary). The design treats that as the central fact to design around, not an inconvenience to be staffed away later ([HLD §0.1](#)).

The two ways to fail

The first is a platform shaped like a security operations centre (round-the-clock triage, two-person approvals everywhere) that nobody can operate: its alerts go unread and its approvals are granted by the person who requested them. The second is to call the controls hand-built for the pilot agent "the platform" and let every later agent re-implement them; each copy drifts, and none can be reviewed as a class. The design refuses both.

Where a control sits

The answer is a placement rule. Every control Google enforces once set — organisation policy, deny policies, Principal Access Boundaries, Model Armor floors, Binary Authorization, Security Command Center, aggregated log sinks — is set at the platform folder, where one person can own it and every project beneath inherits it. Every control that needs a second person, or a desk that answers at any hour, sits in the tiers that need it, and those tiers do not open until the person or service exists. Staffing becomes a gate instead of a hope.

The rule also makes cost visible before anyone commits: a read-only assistant costs a register row and a factory run; a super-admin robot costs a witness organisation, a second super admin, a bought detection desk and a signed deviation (Chapter 24, Roadmap and cost).

The tier as the unit of everything

A tier is at once a folder, a factory module, a monitoring baseline variant, a metric pack, a staffing minimum and a compliance gate ([HLD §11](#)). Admission to a tier settles all six together, so nobody negotiates controls agent by agent. Tiers are lettered so they never collide with the ladder's trigger classes T0–T3: C classical, R read tools, W write agents, P privileged with the super-admin singleton P-SA, and X for AGI-class agents, not open. A future AGI-class agent is therefore a new tier with written opening conditions, not a new design. The tier model is register row P1, proposed; letters, admission test and mandatory controls are Chapter 7, Landing zone and the tier model.

4.2 Enforcement-grade and detection-grade

Every control carries one of two grades, and the grade decides whether it may carry a safety argument ([HLD §0.2](#)).

The three conditions

A control is enforcement-grade only when three conditions hold together: the action cannot proceed without a verdict from the control; the verdict is produced outside the agent's own process, by Google or by code in the action service or gateway that the agent cannot bypass; and a failure of the control stops the action. If any condition fails, the control is detection-grade: the action happens, and at best something independent sees it within a stated latency.

Each condition closes one escape. Without the first, an unscreened path exists and an attacker takes it. Without the second, a code change in the agent, or an injected instruction steering its generated arguments, removes the control. Without the third, the control vanishes when it matters: a screen that skips its check when its service is unreachable is one outage from absent.

What the grade does not measure

The grade describes placement and failure mode, not accuracy. Model Armor on the ingress gateway sits in the request path and fails closed, so it is enforcement-grade on the prompt channel it sees; floor settings applied inline to the model call fail open when the service is unreachable, so they are detection-grade in every mode, blocking mode included (06 §3.1). Neither makes the classifier right. A probabilistic content screen, Model Armor classifier or language-model judge, is never a trust boundary whatever its grade: an attacker can keep testing a screen that is usually right until it is wrong.

Nothing detection-grade stands alone

A safety case may rest on an enforcement-grade control; a detection-grade control produces evidence and never a boundary. Detection matters greatly (for the super-admin tier it is the primary control, Chapter 11, Monitoring, detection and incident response), but it is always paired with something that refuses. The rule applies to the design's own uncertain facts: a feature whose enforcement Google's documentation does not settle stays out of every safety case until a test answers (section 4.8, item 6). Charter demand D8 binds every tenant to it.

4.3 The six containment primitives

Containment for any agent reduces to six primitives, numbered CP1 to CP6 so they are never confused with register rows P1–P143, each with a named enforcer and a grade (HLD §0.2).

CP1: a trust boundary the agent cannot redraw. The factory creates the agent's principal, project, gateway, Model Armor floor and deny policy, governed at the folder; the agent's owner cannot loosen them. Folders, organisation policy, the factory's CI identity and Privileged Access Manager enforce it. Enforcement-grade, because a boundary its occupant can edit is only a preference.

CP2: autonomy as data; humans raise, machines lower. A promotion is a pull request whose evidence a validator recomputes, and the action service's ceiling module reads the result. Enforcement-grade in the action service. Autonomy held in prompts or scattered code cannot be audited, compared or lowered quickly. Chapter 9, Registry, governance and the autonomy contract.

CP3: a capability ceiling outside the agent's process. The model holds no credential; the action service is the only credential holder; ceilings are code in the action service and permissions the folder deny policy refuses, with the OAuth scope set as the outer limit Google enforces. Enforcement-grade, and for the super-admin robot the one enforcement point left on the Workspace side (Chapter 15, Wall-E, the doer).

CP4: a fleet kill switch outside any agent project. One organisation-policy change and one deny rule stop every agent principal in the selected tier folders, drilled monthly. Enforcement-grade, though two of its levers count only as far as unresolved decisions allow. K7 is Chapter 8, Identity, privileged access and the fleet kill switch.

CP5: a model-free monitor with halt authority. The path that approves, halts, demotes or vetoes contains no model. Enforcement by absence: a CI check forbids a model client in the image, and a service-usage denylist removes the Vertex AI API from Eve's project. The reporting path may reason but writes reports and pages only, and nothing it writes feeds a verdict (P34, proposed). Chapter 16, Eve, the independent controller.

CP6: evidence the judged thing cannot forge or silence. Organisation-level sinks copy Google-written audit streams into a locked bucket and the SIEM export and, for the super-admin case, to the witness organisation, beyond the agent, its owner and the tenant's super admins. Detection-grade with an absence alarm: evidence stops nothing, but an attacker who stops the logs causes a page. Chapters 11 and 12.

4.4 The standing constraints

Eight constraints sit above every page; no page loosens them ([HLD Status](#)).

- **No domain-wide delegation.** Delegation lets one credential act as any user; compromised, it impersonates everyone and the audit row names the victim, not the actor. Mechanism in Chapter 8.
- **The language model holds no credential and cannot approve.** The model reads text an attacker can reach (mail, tool results, peers). A credential in its reach is in the attacker's reach; an approval it can give is one the attacker can write.
- **The action service is the only holder of a Workspace credential.** One place where deterministic code decides and acts: one component to review, test, sign and halt.
- **Humans raise autonomy and machines lower it.** A raise widens what happens without a human, and a machine that can raise can be talked into raising. Lowering is safe to automate because its failure costs throughput, not harm.
- **No model produces an approval, a signature, a halt, a veto or a refusal.** Each is an authority act; made by a model it would be a probabilistic screen presented as a boundary. A model may narrate; it may not decide.
- **Mo holds no credential and reaches production only through a pull request a human merges.** The improver can change behaviour across agents at once; the human merge makes each change a reviewed, attributable act (Chapter 17, Mo, continuous improvement).
- **Safety interlocks are plain authenticated REST.** Reasoning under D12 in section 4.7.
- **No secrets in the wiki.** The design is written for assessors, a data protection officer and a works council; a design holding secrets could not be shared with them.

4.5 Designing around a decided premise

Wall-E holding Super Admin on a dedicated, licensed user account is the owner's decision of 2026-09-13, register row P33, the only row marked decided ([decision record](#)). No page reopens whether the account holds the role; pages ask only how it is contained ([HLD Status](#)). A premise re-argued on every page yields controls assuming a narrow role beside controls assuming Super Admin, and nothing buildable.

Designing around a premise is not accepting it uncritically. The design states the safety the choice removes (Chapter 3), turns least privilege into a signed deviation, makes thirteen compensations preconditions of a grant that is a gate with a checklist, enters the residual as row R-01 of the risk register, and records that a TISAX assessor may still refuse maturity 3 on least privilege. On 2026-09-14 the security reviewer's and the ISMS's signatures on the deviation are pending, and the grant stays blocked until every precondition is green. The argument for the choice is Chapter 15; the deviation record is Chapter 21, TISAX.

4.6 Operability and the four cells

A control the people cannot run is the wrong control

If a control cannot be operated by the people at the tier where it is required, the control is wrong, not the people ([HLD Status](#)). The tier gate enforces this, and it changes how targets are written. Below Tier P the detection desk is Security Command Center findings routed to a person, plus absence alerts paging the platform owner; the target is "next business morning", written down as the honest number ([HLD §7.1](#)). A fifteen-minute target nobody meets would give the sponsor false assurance and an assessor a finding. Likewise at Tiers C and R self-review is recorded as self-review. Faster targets come with the tier that buys the desk (Chapter 11; the desk per tier is Chapter 23, Operating model).

The four cells

Every control on every design page names its **owner** (a role from the platform RACI), the **resource** it sits on, its **verification** (a job, a drill or a CI check, with a cadence) and its **failure behaviour** (fail-closed, fail-open with a page, or a detection with a latency). A control that cannot fill the four cells is not on the page ([README Status](#)). Each cell removes one way to exist only on paper: without an owner nobody acts when it fires; without a resource it cannot be inspected and drifts; without verification there is no evidence it still works, the first thing an assessor asks for; without a failure behaviour it cannot be graded (section 4.2). The fleet kill switch's failure behaviour, for instance, is measured in the monthly drill rather than asserted, because one lever rests on an Assumption about how running Cloud Run instances respond.

4.7 The platform charter

The charter is the contract between the platform and each tenant: nine promises and twelve demands ([HLD §1](#)). The promises remove any reason for an agent team to build its own platform control; the demands let every agent be reviewed against one list.

What every agent is promised

On the day it is created an agent receives a project of its own, made by the factory in under an hour with APIs, identity, gateway, sinks, budget, labels and deny policy in place (PR1); a Google-issued identity, with no key, expiring daily (PR2); default-deny egress and screened ingress, so an injected prompt cannot reach a secret or the internet (PR3 — the egress deny is what enforces; the ingress screen is Model Armor, never a boundary); and logs sent somewhere it cannot delete, with somebody paged if they stop (PR4). It is protected by a kill switch outside its project, drilled (PR5), and by autonomy that rises on evidence, never on the calendar, and only when a human raises it (PR6). It is spared re-arguing its compliance classification per auditor, because the gate does it once (PR7); implementing any control the tier above needs (PR8); and rewriting the ladder, validator or approval surface, which are services (PR9).

What every agent must accept

Most demands follow from the standing constraints. D1: a register row (owner, tier, purpose, data classes, EU AI Act class, TISAX class) before the agent exists in any project; the factory refuses without it. D2: Agent Identity, a gateway binding and a factory-made project, with no exceptions below Tier P and dated exceptions in it; whether D2 is enforced by folder constraints or only a CI check waits on spike P4, half closed by P42. D3: no credential in the reasoning layer; an agent that writes does so through an action service that holds the credential and decides. D5: audit rows in the platform schema with the correlation keys, insert-only and written ahead. D6: every peer agent is principal type `agent`, at ladder level L0 for writes, tainted on receipt. D8: every feature graded, nothing detection-grade alone. D10: removable, so deleting the project removes the agent and nothing else, its evidence having already left. D11: no write on any repository, Artifact Registry, deploy identity, its own ladder or its own ceilings. Four demands need their reasoning stated.

D4: never decide and act, never grade your own work, never loosen your own autonomy. One rule in three forms: no component checks itself. If an agent's choice of action is also its permission, nothing can refuse the action, so the reasoning layer proposes and separate deterministic code decides. An agent measuring its own quality has the incentive and opportunity to measure wrongly, so numbers are recomputed by a validator the proposer cannot reach and graded blind. An agent that can widen its ceiling has none. The charter rule, the contract validator and a humans-only raise path enforce it.

D7: cross a project boundary only through a grant on the resource, never a project-level role. A project-level role grants everything in the project today and whatever is added tomorrow; a resource grant names one thing. Only the second keeps reach enumerable, so the design can state what a compromise of each project reaches. The drift job asserts the anti-grants. The platform's own folder-level principals are named exceptions ([topology §3.1](#)), explained in Chapter 5, Architecture overview.

D9: re-qualification on every model pin change. Evidence of good behaviour is about one combination — prompt, model pin, framework version and Model Armor template version, the fingerprint tuple — and when any member changes, the agent that earned the autonomy is not the one running. A change resets every ladder cell above L3 to L3, where a named human approves each action, until evidence is gathered again: a model upgrade costs autonomy for a while, deliberately. Ladder in Chapter 9, fingerprint rule in Chapter 17.

D12: safety interlocks as plain authenticated REST, never over an agent protocol. Halt and approve must work when the model layer is wedged, hallucinating or looping ([Wall-E architecture §7.4](#)). Over an agent protocol, whose messages models generate and read, the layer being stopped could screen, reformulate or ignore the interlock; a REST endpoint invocable only by named principals can be called by a deterministic job or a human and is refused to everyone else.

4.8 What the platform does not do

The refusals are as much design as the controls; each closes an argument that would otherwise reopen agent by agent ([HLD §16](#)).

1. **It does not make Eve's control path structurally unreachable by a super admin inside the tenant's organisation.** Nothing Google offers prevents a super admin reaching it; evidence, incident record and pager move to the witness organisation, the rest is detective, and relocating the control path is the recorded end state (P15, proposed: built when IT security operates the witness, gated on Tier X, not the grant). Chapter 16.
2. **It does not narrow a super-admin account; nothing in Workspace or Google Cloud can.** The perimeter is custody, scope split, a split control plane, detection latency and the witness, said openly.
3. **It does not automate the Admin console under any robot session, by browser or computer use.** An interactive login on the robot account is an incident, the one control that survives Super Admin intact; console automation would be a lane around the action service, where every check lives. Band C is instructions for a human, plus verification.
4. **It does not let any model produce an approval, a signature, a halt, a veto or a refusal.** A model may narrate and page a human at severity 2; nothing it writes is read by the gate. Reasons in sections 4.2 and 4.4.
5. **It does not evaluate model capabilities, detect deception or claim AGI containment.** Capability evaluation is the model provider's responsibility and deception-robust monitoring is research; the platform gates on measured behaviour within a catalogue. Tier X stays closed until its conditions hold (Chapter 14, Scale and AGI readiness).
6. **It does not count three unverified mechanisms in any safety case until answered:** the Principal Access Boundary for Cloud Run invocation, which it does not fence (P60, proposed, closing P9); the Admin console Context-Aware Access level, unverified for super admins (P7, open); and the deny policy's agent principal-set spelling (P8, spike narrowed by P61). Section 4.2 applied to the design's own gaps.

7. **It does not run a security operations centre.** It buys acknowledgement for Tier P, runs Google's detections for the rest, and feeds the organisation's own centre if one exists; section 4.6 forbids designing one nobody can operate. The SIEM choice is P10, open.
8. **It does not place the folder in Assured Workloads EU Data Boundary while the agent products are outside the package.** The package would refuse them or flag standing violations, a paper exception on the services the platform is built around; a compensating set applies instead (P110, proposed; revisit trigger P12, open; Chapter 12). The HLD names two products outside the package, Agent Gateway and Agent Registry ([HLD §8.2](#)), while page 08 and P110 name three, adding Agent Identity ([08 §7.1](#)).
9. **It does not host a second super-admin agent, a third-party agent without a supplier row, or any agent without a register row.** The compensations are sized for one super-admin agent, so a second P-SA row fails CI until the first is retired (Chapter 7). A third party's assurance cannot come from the platform's own tests, hence the supplier procedure (P138, proposed; Chapter 14). An agent without a register row is a shadow agent (D1).
10. **It does not train or modify models.** Training, fine-tuning or substantially modifying a model could make the organisation a general-purpose AI model provider under the EU AI Act; no modification avoids the threshold question (Chapter 20, EU AI Act).
11. **It does not grant domain-wide delegation to anything.** Section 4.4.
12. **It does not back up Workspace.** The platform recovers its own control plane, compute and evidence (Chapter 13, Supply chain, keys and recovery); an agent's Workspace changes are undone by the inverse operation its manifest declares per operation family, and beyond that by Google's own recovery ([09 §3.1](#)).
13. **It does not run code execution below Tier X.** Code execution turns generated text into arbitrary behaviour. Agent Runtime Code Execution is EU-resident but not adopted and is off fleet-wide, enforced by means other than an organisation-policy constraint, which does not exist (P121, proposed). The Tier X sandbox is GKE Agent Sandbox, generally available since 2026-05-21 (P122, proposed); Tier X stays closed on its other conditions.
14. **It does not promise EU AI Act or TISAX outcomes.** It promises mechanisms and evidence; the regulator and the assessor decide (Chapters 20 and 21).
15. **It does not create per-agent organisation sinks, registries, Mo instances or workforce pools, or hand-made cross-project grants after Stage 0.** Each would copy something set once at the folder, and each copy drifts. The tenant gateway's registry in `GEMINI_PROJECT` is a CI-generated working set, not an inventory; a hand-made grant would sit outside the grant table the factory reads.

Key decisions and where to read next

Register states on 2026-09-14: **P33 decided** (Wall-E holds Super Admin, designed around; deviation signatures pending); **proposed**: P1 (tier model), P15 (control path to the witness as end state), P34 (Eve's reporting path, report-only), P60 (closing P9, the Principal Access Boundary's grade), P110 (Assured Workloads not now), P121 and P122 (code execution), P138 (suppliers); **open**: P7 (Context-Aware Access on the robot), P10 (SIEM), P11 (Security Command Center Premium funding), P12 (Assured Workloads revisit); **spikes**: P4, half closed by P42 (custom constraints behind D2), P8, narrowed by P61 (deny-policy principal spelling).

Canonical pages: [HLD Status](#) for the standing constraints and the operability sentence; [HLD §0.1](#) and [§0.2](#) for the thesis, the grading rule and CP1–CP6; [HLD §1](#) for the charter; [HLD §11](#) for the tier as unit; [HLD §16](#) for the refusals; [README Status](#) for the four cells; the [P33 decision record](#). In the brief, Chapter 5, Architecture overview, shows these principles as layers and trust boundaries, and Chapter 7 turns the tier into folders and mandatory controls.

Part II — The platform

Part II answers Chapter 3's risk themes at [platform level](#), layer by layer; every tenant, Wall-E, Eve and Mo included, inherits it. Chapter 5 draws the structure against tenant compromise; Chapter 6 fences the front door against shadow agents; Chapter 7 opens tiers only as their people exist; Chapter 8 narrows the credential; Chapter 9 holds autonomy to evidence; Chapter 10 screens injected content; Chapters 11 and 12 defeat manufactured silence; Chapter 13 keeps halts through restores; Chapter 14 confronts third-party and AGI-class agents.

5. Architecture overview

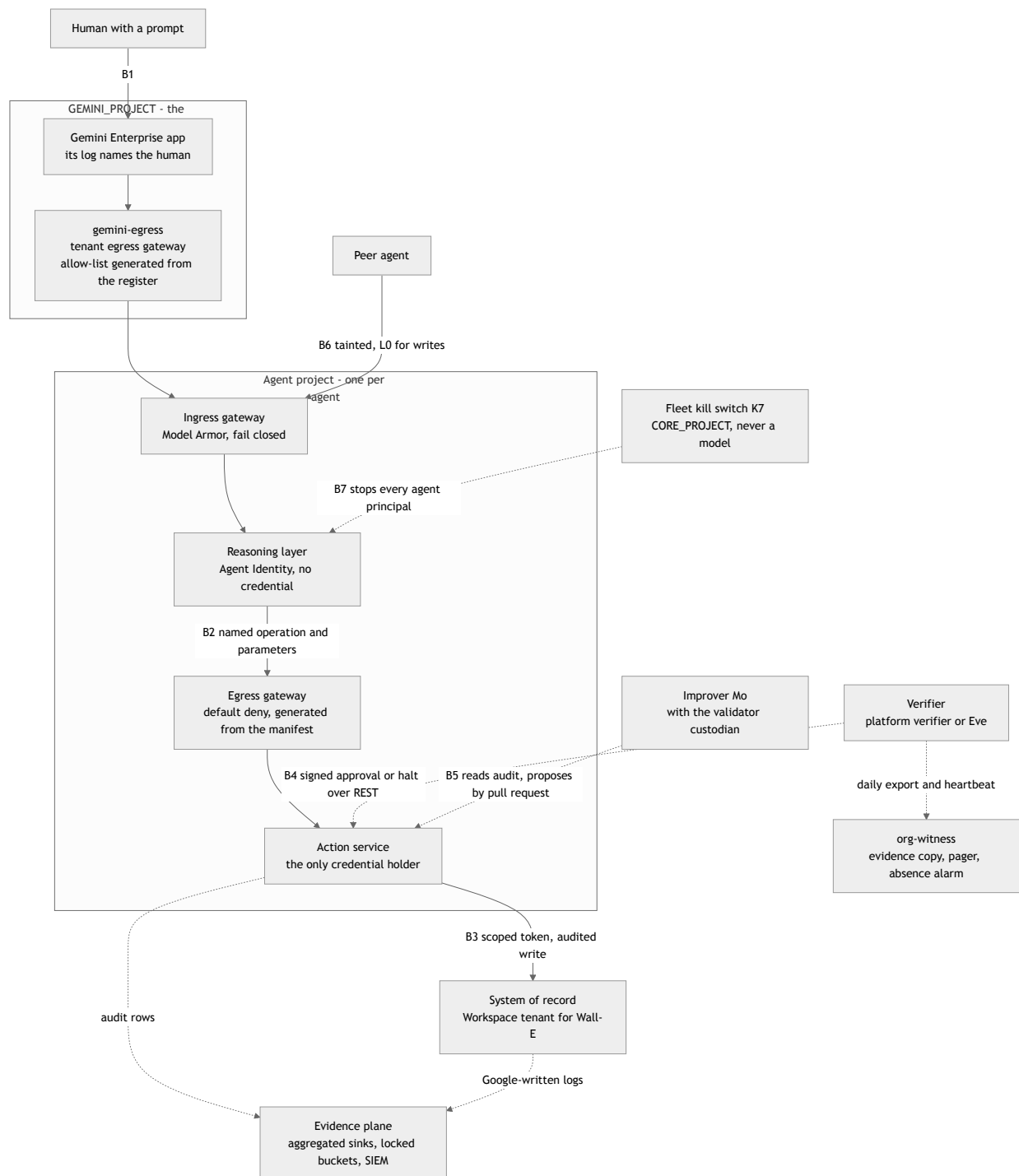
What this chapter explains

By the end of this chapter the reader can draw the platform from a human's prompt to a change in a system of record, say where each part lives and why a second organisation sits outside the tenant's, name the seven trust boundaries every agent inherits with their grades, and state the one rule for crossing a project boundary with its named exceptions.

It answers three risk themes of Chapter 3, The problem and its risks, structurally: tenant compromise through the robot credential, a controller reachable by what it controls, and manufactured silence. Traceability to the objective is Chapter 2, The objective and what it demands; the grades are Chapter 4, The principles.

5.1 The platform in layers

The platform is a request path of six layers with five parts beside it. The tier decides which layers an agent has: a Tier C agent lives inside the tenant app with no project, a Tier R agent has no action service, and from Tier W every layer is present (Chapter 7, Landing zone and the tier model).



From the prompt to the system of record

The front door. One Gemini Enterprise app per tenant, in `GEMINI_PROJECT`, fronts every human-facing agent. It signs the human in, and its Data Access log is the one record that names the human; downstream the human travels as a surrogate in the correlation keys. Agents no human talks to, such as Eve's control path and Mo's jobs, are not published in it (Chapter 6, The Gemini Enterprise environment).

The tenant egress gateway. The app reaches agents through `gemini-egress`, whose access policy is generated from the register, so an unregistered engine is unreachable from the front door by network rather than convention. Agent Gateway supports the app only in egress mode; the fence refuses nothing until the last of its three stages (P57, a spike; staging in Chapter 6).

The agent's ingress gateway. Every engine a machine calls, the tenant app included, sits behind its own project's ingress gateway with a Model Armor extension that fails closed. The owner cannot remove the screen, and its failure stops the call. Gateway and Model Armor share an **Assumption**: 99.5 % monthly objective; an outage stops every fail-closed agent, by design (Chapter 10, Agent Gateway, Model Armor and the perimeter).

The reasoning layer. The engine runs under Agent Identity, a keyless Google-issued principal with a daily certificate. It holds no credential, the folder deny policy refuses it every secret, and its egress gateway's default-deny allow-list names its action service and no Workspace or Admin SDK host. Whatever an injected document persuades the model to request, it can only request from deterministic code. Cloud Run reasoning services carry a dated service-account exception until Agent Identity for Cloud Run leaves Preview (P5, open; Chapter 8, Identity, privileged access and the fleet kill switch).

The action service. From Tier W, a Cloud Run service in the agent's project is the only holder of the credential to the system of record. It takes a named operation with parameters, checks the catalogue, policy chain and autonomy ladder, writes a write-ahead audit row, calls the API and verifies by re-reading. Wall-E has two such services so its broad scopes never share a process with the catalogue (Chapter 15, Wall-E, the doer).

The system of record. A business system for a Tier W agent; the Workspace tenant for a Tier P agent. For the Super Admin robot Google refuses nothing beyond the consented scopes, so the action service is the only gate and detection the primary control (P33).

Beside the path

Five parts sit beside the path, each in a project the agent cannot administer.

- **The verifier** approves, vetoes, halts and demotes over plain authenticated REST with a key the agent cannot reach and no model on that path: the platform verifier for Tier W, a dedicated Eve in `EVE_PROJECT` for Tier P, with Eve's report-only reporting path in `EVE_ADVISOR_PROJECT` (Chapter 9, Registry, governance and the autonomy contract; Chapter 16, Eve, the independent controller).
- **The improver**, one Mo per platform in `MO_PROJECT`, reads audit data and reaches production only through a pull request humans merge; the validator custodian in `VALIDATOR_PROJECT` re-derives every number it cites (Chapter 17, Mo, continuous improvement).
- **The evidence plane**, two aggregated sinks into `LOGGING_PROJECT` with locked buckets, the evidence lake in `CORE_PROJECT`, Eve's own Workspace sink and the SIEM feeds, holds Google-written records the agent and its owner cannot delete (Chapter 11, Monitoring, detection and incident response; Chapter 12, Data, logging, retention and sovereignty).
- **The witness**, `org-witness`, receives Eve's daily export and heartbeat and owns the severity 1 and 2 channels and the absence alarm (section 5.3; Chapter 16).
- **The fleet kill switch K7** is pulled from `CORE_PROJECT` by a human through PAM or by a deterministic job on a severity-1 SIEM rule, never a model. It stops every agent principal in the tier folders and spares controllers, core and tenant app so Eve keeps paging (P70, proposed; Chapter 8).

What is enforced and what is only detected

Every layer mixes both grades, and the design names which is which (**HLD §0.2**). At the **front door**, sign-in and control-surface access levels are enforcement; nightly matching of console-made Tier C agents to the register is detection. At the **gateways**, the egress allow-list and fail-closed ingress extension are enforcement; the Model Armor project floor on the model's own calls fails open and is detection. The constraint binding each engine to its gateways is enforcement only once a throwaway engine has been refused in nonprod; until then a CI check stands in. In the **reasoning layer** the deny policy and the Principal Access Boundary (PAB) are enforcement, but the deny policy's principal-set spelling is an **Assumption**: (P8, a spike) and the constraint forcing Agent Identity is a spike (P4), so that half is a CI check. In the **action service**, catalogue, policy chain, ladder and hard-denied list are enforcement because they sit outside the agent's process and fail closed, yet they are code in the component under audit; invocation is IAM-only until the perimeter spike passes (P3). At the **system of record** under Super Admin, the scopes and Workspace multi-party approval over role assignments (P66, proposed) are

Google's only refusals; the SIEM's super-admin set and Eve's reconciliation are detection. **Beside the path**, the verifier is enforcement by the absence of a model, the evidence plane is detection with an absence alarm, and K7 is enforcement, its first lever's effect on running Cloud Run instances an **Assumption**: measured in the monthly drill.

5.2 Trust boundaries B1–B7

The seven boundaries are Wall-E's five generalised plus two fleet boundaries. Every agent's design page lists all seven with platform mechanism, agent code and grade, so no owner can quietly drop one and agents compare on the same seven lines ([HLD §15](#)).

B1, human and reasoning layer. The model sees the request, never the credential. Platform: Gemini Enterprise sign-in and request log, `gemini-egress`, Model Armor on the tenant, Identity-Aware Proxy with Context-Aware Access on control surfaces. Agent: its prompt-security design. Enforcement, from Tier C. The identity the app passes is asserted, not bound, so an action service re-checks group membership on every write.

B2, reasoning layer and action service. The model names an operation; deterministic code decides. Platform: Agent Identity, an egress allow-list reaching only the action service, the deny policy on secrets, the PAB. Agent: catalogue, policy chain, ladder. Enforcement, from Tier W.

B3, action service and system of record. The only credential holder; scopes as the Google-enforced ceiling; every write pre-stated, verified and audited. Platform: keyless service account, regional secret, IAM-only invocation and then internal-only ingress once P3 passes, the perimeter. Agent: operation implementations and inverses. Grade: enforcement by scope, plus minute-latency detection for a super admin, where Google enforces nothing but the scope split. From Tier W.

B4, agent and verifier. Approvals signed by a key the agent cannot reach, halts over plain REST, no model on the authority path. Platform: separate project, HSM key, deny policy, a project-level service restriction keeping the model API out of `EVE_PROJECT`. Agent: predicates from the manifest. Enforcement by absence, from Tier W with the platform verifier and Tier P with Eve.

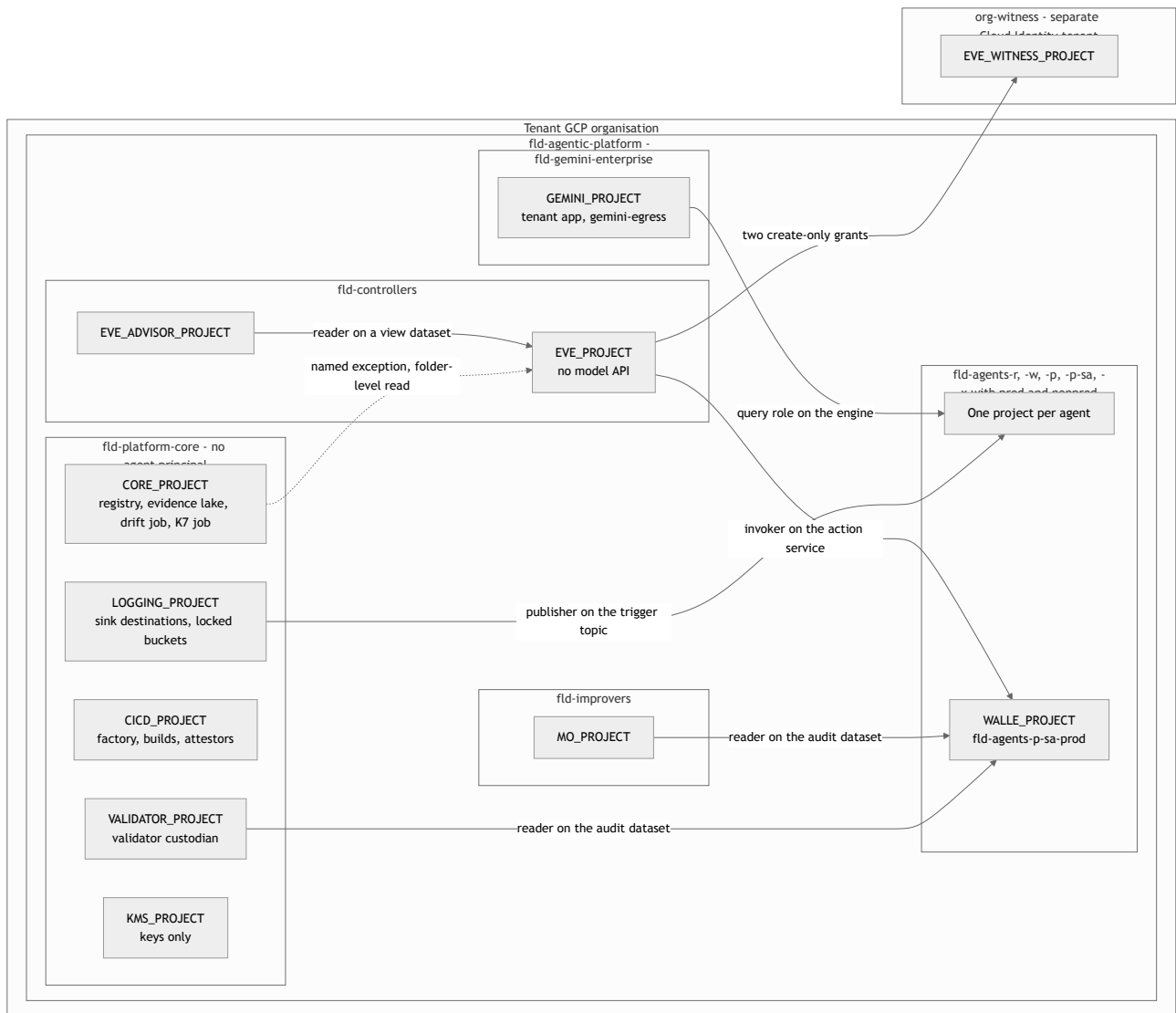
B5, agent and improver. Every number re-derivable by a custodian the proposer cannot reach; changes reach production only by a human-merged pull request. Platform: validator project, branch protection, agent-authored label. Agent: metric pack. Enforcement, from Tier W.

B6, agent and peer agents. A peer is a principal of type agent, L0 for every write, tainted on receipt, with egressor bindings limited to the manifest. Platform: ingress gateway with Model Armor, registry-based egressor list. Agent: taint handling. Enforcement, from Tier R.

B7, agent and platform. The agent cannot reach outside its folder, deploy itself or silence its logs. Platform: PAB, deny policy, aggregated sinks, K7. Agent: nothing, by design. Enforcement for the deny policy, sinks and K7, and for the PAB on the families it blocks: engine queries, secrets, keys, storage, BigQuery, Pub/Sub. The PAB does not block Cloud Run invocation, so an agent calling a foreign action service is stopped only by resource-level invoker grants and the deny policy (P60, proposed, closing P9; [page 04 §4.3](#)). From Tier R.

A Tier R agent inherits B1, B6 and B7 almost entirely from the platform; a Tier W agent adds B2 to B5, where its own code carries weight.

5.3 Placement



Arrows run from the principal's project to the resource carrying the grant; the dotted arrow is a named exception (section 5.4). On 2026-09-14 every project is planned except `GEMINI_PROJECT`, which exists (Assumption:) and is to be imported (Chapter 6).

One folder, folder classes, one project per agent

Every platform project sits under `fld-agentic-platform` in the tenant's GCP organisation, in `europa-west1` with BigQuery in EU, made by the factory and never by hand after Stage 0. The folder carries what Google enforces once: organisation-policy baseline, deny policy, PAB bindings, Model Armor floor, aggregated sink, Data Access audit configuration and PAM entitlements. Folders by class let one class be stricter without per-project exceptions, such as no model API on the controller's authority path. The tree, and why Google forces one project per agent, are Chapter 7, Landing zone and the tier model.

What each project hosts and must never host is canonical in [project-topology §2](#); in short:

Project	Hosts	Must never host
<code>GEMINI_PROJECT</code>	tenant app, its service agent, <code>gemini-egress</code>	any agent's identity, secret or data; any engine; any Workspace credential

Project	Hosts	Must never host
Agent project (WALLE_PROJECT)	engine, gateways, action services and secrets, control plane, audit dataset	a verifier's key or evidence; improver resources; a local Agent Registry
EVE_PROJECT	control path, HSM approval key, Eve's credential and datasets, locked evidence bucket	the model API, ever; Wall-E principals beyond three carve-outs; Mo resources
EVE_ADVISOR_PROJECT	the report-only reasoning path	any signer, invoker, secret, or reader on Eve's source data
MO_PROJECT	Mo's identities, metric datasets, proposal drop box	any credential, secret or key; the audit dataset or a copy
Core projects	registry, evidence lake, jobs, K7; logs; supply chain; validator; keys	any agent principal; any secret beyond one paging secret
EVE_WITNESS_PROJECT	evidence mirror, incident copy, custody records, paging channels, absence alarm	anything that approves, halts or executes; a tenant super admin as administrator

EVE_ADVISOR_PROJECT is not built until P34 (proposed) is signed and P19 (open, legal) answered.

The witness sits in a second organisation

EVE_WITNESS_PROJECT is the only project outside the tenant's GCP organisation: it sits in `org-witness`, a separate Cloud Identity tenant, and receives exactly two create-only grants from EVE_PROJECT, as the diagram shows. Why a super-admin robot makes that second organisation necessary, what it costs and what it still leaves open (P14, P15) are Chapter 16, Eve, the independent controller ([Eve HLD §1](#)).

5.4 The one rule for crossing a project boundary

The rule and its reason

A principal in one project reaches a resource in another only through a grant on that resource (a service, job, dataset, topic, key, bucket or engine), never through a project-level role in the other project. A project-level role is lateral reach by definition; with resource grants in separate projects the credential holder has no principal where Eve's key lives. Where Google offers no resource-level form, the grant is dropped or becomes a named exception; absences that matter are anti-grants asserted by the drift job. BigQuery shows the pattern: a dataset-level reader in the data project plus a query-job role at home. The rule is charter demand D7 of Chapter 4 ([project-topology §3.1](#)).

The named exceptions

A few platform principals serve the whole fleet. Each is in Eve's drift job's expected set, so any further foreign principal in EVE_PROJECT still fails:

- the drift job's read-only security-reviewer role at the platform folder, inherited by every project below it, EVE_PROJECT included, with its reconciliation roles (P73, proposed; two role names unverified);
- the factory identity on controller and singleton projects, present only during an approved one-hour PAM grant (P142, proposed);
- the folder deny policy and the PAB bindings, administered from the organisation because Google allows nothing lower;
- the K7 entitlements for the executor job and for humans;
- the CI identity's standing Discovery Engine editor role on GEMINI_PROJECT (P49, proposed);
- the Sensitive Data Protection discovery agent scanning at the folder;
- and the project-level Discovery Engine role on an agent project, only if the spike of topology decision 42 fails.

Each belongs to the platform, holds a read-only role or none standing, and sits on Eve's anti-grant list.

The grant table is a factory input

[Project-topology §3](#) is the complete table: 46 rows with principal, resource, level, maker and source, rows 45–46 proposed with an **Assumption**: until Eve's E-21 is signed. The factory takes each row as module input; credential-path bindings are applied in its privileged phase by a human through PAM, and after Stage 0 no grant is hand-made. Some rows await verification, notably whether an engine-scoped query role suffices for the tenant app across projects (row 1).

What the rule does not bound

Every row bounds a service account or group; none bounds `walle@`, which can reach Organization Administrator. A compromised credential is answered by detection and the witness (Chapter 19, Threat model and residual risk).

5.5 What is shared in platform-core and what stays per agent

Share what must be single to be true: inventory, evidence copy, custodian, supply chain, kill switch. Keep per agent whatever is a trust boundary or would turn one compromise into all (P45, proposed; [page 02 §5](#)).

Shared: the register and shared Agent Registry, evidence lake, drift, reconciliation and K7 jobs in `CORE_PROJECT`; sink destinations and locked buckets in `LOGGING_PROJECT`; the supply chain in `CICD_PROJECT`; the validator in `VALIDATOR_PROJECT`. The Model Armor template standard, monitoring baseline, schemas and egress hostname set are shared as modules instantiated per project; hostname matching is exact, so one versioned list lets one change fix the fleet.

Per agent: engine and gateways; action services, OAuth clients and secrets, since a shared secret project shares a credential; control plane and `ladder.yaml`; audit dataset; Model Armor templates and floor, as quota is per project; verifier keys, since a shared key is one key to steal.

The shared approval surface, refused (P46)

One shared approval page is refused (P46, proposed): it must verify the exact request hash against the executing action service, so a shared page would be a write path into every credential holder. Only routing is shared, as one audience-group pattern and one token-verification library; the cost is one surface per Tier W or higher agent. Page 04's PAB rules list the approval surface among the core resources an agent may reach ([page 04 §4.3](#)), which reads against its per-agent placement in [page 02 §5](#).

Key decisions and what to read next

States on 2026-09-14 ([register](#); Chapter 25, Decisions awaiting the owner):

- P33 decided, deviation signatures pending: why B3 carries detection.
- P34 proposed, P19 open: Eve's reporting path and its project.
- P45, P46, P60 (closing P9), P70, P73, P142, P49 proposed: the split, the approval surface, the PAB grade, K7's scope, the named exceptions.
- P3, P4, P8 (narrowed by P61), P57 and topology decision 42 spikes; P5 and P14 open; P15 proposed.

Chapter 19, Threat model and residual risk, carries what remains: a super-admin credential ignores folder and grant table alike; Eve's control path is only detectively independent inside the organisation until P15; the PAB for Cloud Run invocation, the Admin console access level (P7) and the deny-policy spelling (P8) stay out of every safety case; the front-door fence is not in force until `gemini-egress` enforces.

Canonical pages: [HLD §0.1](#), [§1](#), [§13](#), [§15](#), [§16](#); [page 06 §1](#); [page 02 §2.1](#) and [§5](#); [project-topology §2](#), [§3](#) and [§3.1](#).

6. The Gemini Enterprise environment

What you will understand by the end

The objective's first sentence asks for "a secure Gemini Enterprise environment" through which every agent is secured. By the end of this chapter the reader knows why the platform keeps exactly one tenant app as the human front door, how it reaches a secure baseline, how an agent is admitted, shared, reviewed and removed at each tier, what the front door enforces and only detects, and which parts are still a spike.

Of the risk themes in Chapter 3, The problem and its risks, this chapter contributes to three: shadow and third-party agents, manufactured silence and tenant compromise through the robot credential. Nothing here is built; on 2026-09-14 the app's project, `GEMINI_PROJECT`, exists (Assumption) and is to be imported.

Why one app is the only front door

One Gemini Enterprise app per tenant is the front door for every human-facing agent, from a no-code agent made in an afternoon to Wall-E (HLD §2.1). Agents no human talks to, such as Eve's control path and Mo's jobs, are not published in it. There is no second production app; a spike gets a throwaway app deleted at the end (P59).

One app means one log naming the human, one set of toggles to drift-check, one population to gate and one gateway to bind; a second app would be a second front door without the controls. The app project hosts no engine, identity, secret, key or dataset of any agent, so its compromise reaches the front door and the query grants, never a credential or an audit table (03 §2).

Three Google facts fix the shape. The app project's Discovery Engine service agent calls every engine, so every agent project must grant it something. Agent Gateway supports Gemini Enterprise only in egress mode, so the front door gets an egress fence and no ingress screen. And a live app cannot be re-created without losing chat history and data stores, so the existing app is brought under management rather than replaced.

Bringing the app to a secure baseline

Placement

The factory's `tenant-app` module imports `GEMINI_PROJECT` in place and moves it under `fld-gemini-enterprise` in a dated change window with the Gemini Enterprise administrators' agreement; the window closes on the drift job's zero difference (03 §3). If the administrators do not agree, the project stays in place as the one project outside the folder, and the module re-applies the floor, deny policy, `discoveryengine` Data Access configuration and sink at project level, with a review date (P48).

This departs from topology decision 52, which left the project outside the floor: once `gemini-egress` enforces the register, the app project is a publication enforcement point and must sit under the controls that make it auditable. Organisation policy has a limit: no documented `Engine` field covers the gateway binding or the console Model Armor setting, so both are detection-grade at the policy layer, watched by the drift job and a Security Health Analytics module whose support for the resource type is *tbd*.

Location and encryption (P50)

The app lives in `eu`, with at-rest and processing residency in the EU multi-region (03 §5.1). `global` is allowed only for a needed feature `eu` lacks, as a dated exception, never by moving the app. If GE-0 finds the app outside `eu`, the runbook stops: a new app is a decision record.

Encryption is where the import costs something (03 §5.2): customer-managed keys protect only apps and data stores created after the key is registered, and the existing app is assumed to predate it (Assumption, checked at GE-0). The position is Google-managed encryption for the imported app and the europe key gemini-cmek for everything created after GE-4, recorded once with the TISAX label decision (P20). Re-creating the app for a key was rejected because it loses history and data stores.

Identity provider (P51)

Google allows one identity provider type per location and recommends Google Identity (03 §6). The platform chooses it because the human in the request log then joins the Workspace audit stream and every agent's audit row, an action service can re-check group membership live, and K5 needs a Google-identity super admin anyway. A workforce pool (P24) is "no" for the tenant app and open only for operators without a Google account.

The choice precedes the first user because changing the provider deletes conversation history and forces data stores to be re-created; a later change is a decision record stating that loss.

Administration and feature management (P49, P54)

Changes to the front door are privileged and brief; reads are standing (03 §4). ge-admins@ holds the Gemini Enterprise Admin role only through a one-hour Privileged Access Manager entitlement; ge-readers@ holds the viewer role standing for the drift job; the CI identity holds roles/discoveryengine.editor as the one foreign principal. No human group holds the user role at project level, because that binding reaches every app in the project regardless of app-level policy.

A permission fact verified on 2026-09-13 shapes the lifecycle: editor can register an agent but not share it. Sharing stays a human act through PAM; a custom role letting CI share was rejected, because the pipeline could then publish to every user. PAM makes every toggle, share, Model Armor flip or gateway unbind a justified, windowed, logged act. Google refuses self-approval, so with one person at Tier C the entitlement activates on a mandatory justification without approval, and the record says so. The entitlement catalogue is Chapter 8, Identity, privileged access and the fleet kill switch.

Feature Management's 23 toggles are a committed file, so any mismatch is a drift finding (03 §8). Chat agents and workflows are on for ge-builders@ and off for the population (whether they can be scoped to a group is unverified; if not, sharing approval alone governs builders). The model selector, memory, session sharing, skills and media generation are off. Sharing without administrator approval is off, because that approval admits a Tier C agent, which still has a register row.

The user population: three gates (P55)

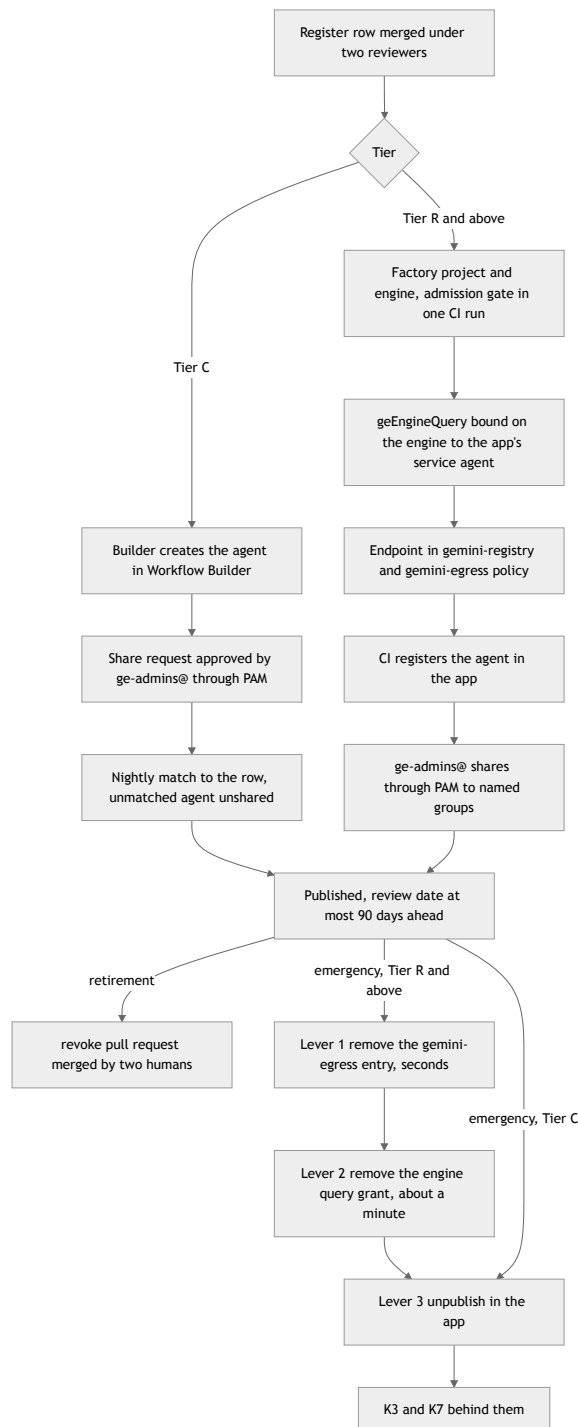
A person reaches the assistant through three gates in series (03 §7). The Workspace service toggle is on for the organisational units of ge-users@'s members and off for the robot accounts' unit, where turning it on is severity 1: a front-door session under a super-admin identity would be a second path into the tenant. App-level IAM grants the user role to ge-users@ and ge-builders@ only. Licences are assigned at first sign-in, which is safe behind the first two gates, and reviewed quarterly against membership.

On the assistant, Grounding with Google Search is off because Google's compliance controls do not apply while it is on; enterprise web search is off until a row needs it; uploads stay on because Model Armor screens them; the banned-phrases list carries the super-admin tier's hard-denied vocabulary as a detection-grade screen (03 §5.3).

Three neighbours live elsewhere: the console Model Armor setting (on, Block on failure, Tier C only) is Chapter 10, Agent Gateway, Model Armor and the perimeter; conversation retention (30 days as an Assumption until the DPO decides under P13) is Chapter 12, Data, logging, retention and sovereignty; the app's detections are Chapter 11, Monitoring, detection and incident response.

An agent's life in the tenant app

Every tier starts with a register row merged under two reviewers, carrying `publish_to_gemini`, the audience groups, the EU AI Act class and the supplier rows ([03 §10.1](#), [HLD §2.2](#)).



Tier C

A Tier C agent has no engine. The builder creates it after the row merges, an administrator approves the share, and nightly reconciliation against the register treats an agent without a row as a shadow agent, severity 2, unshared within one business day. A Marketplace agent enters through the Agent Gallery's request flow, approved only against a merged row with a supplier row. Reconciliation itself is Chapter 9, Registry, governance and the autonomy contract.

Tier R and above

The agent first passes the factory and the admission gate (Chapter 9). CI then binds a query-only custom role `geEngineQuery` on the engine to the app's service agent, imports the endpoint into `gemini-registry` and the `gemini-egress` policy, and registers the agent with a description stating that the responder is an AI system. `ge-admins@` shares it through PAM to named groups; the drift job checks daily that the identity shown for the agent equals the engine's.

The grant is engine-scoped (P56) because Google's documented project-level role also carries create, update and delete on engines: "the front door can ask" becomes "the front door can replace". If the engine-scoped role fails, the project-level role is applied for that project only, as a dated exception re-tested at every redeploy, with a severity-1 detection for an engine mutated by the service agent. Two canonical pages disagree on who registers: [03 §10.1](#) has CI register, while step 13 of [05 §7.1](#) has `ge-admins@` register through PAM.

Review, retirement and emergency unpubish

Every row's review date is at most 90 days ahead or the share is removed; privileged rows are reviewed quarterly by the security reviewer. A Tier C agent retires by unsharing. Above Tier C, retirement is the factory operation `revoke`, a pull request merged by two humans: gateway and registry entries, query grant and app registration go, a writing agent is halted, and project deletion follows the confirmed evidence export. A Tier P revoke is also K3.

In an emergency, for Tier C, the on-duty administrator unshares at any hour through PAM. Above Tier C, three levers are pulled in order of speed — the `gemini-egress` entry in seconds, the query grant in about a minute through the agent project's CI, then unpublishing — with K3 and the fleet kill switch K7 behind them (both Chapter 8). Who removes the gateway entry is unverified: the HLD names `ge-admins@` through PAM, while [03 §4](#) gives the policy write to the CI identity. While the gateway is in dry run, the first lever cuts nothing.

What an app administrator can and cannot do

The administrator can register, unregister, share and unshare any agent, turn Model Armor off, change retention, flip toggles, unbind the gateway and see the human behind every request ([03 §10.2](#)). The administrator cannot change an engine, its code, identity, gateway or templates, which live in the agent project; cannot read an agent's audit tables or secrets; and cannot act silently, since each act is an Admin Activity entry under a PAM grant. Registering an unknown engine does not make it reachable without the agent project's grant and a register-generated gateway entry.

The tenant egress gateway `gemini-egress` (P57, P6)

What it is for

Without a fence the app could reach an engine nobody registered. `gemini-egress` is an Agent Gateway in `europa-west1`, the region Google requires for an `eu` app, in egress mode with default deny ([03 §11](#)). Its access policy is generated from the register; Google states that binding routes all the app's traffic through it, LLM calls included. Because a foreign-project engine must be registered in the gateway's project, `GEMINI_PROJECT` holds `gemini-registry`, written only by CI as a working set derived from the register, not a second inventory. Which principal the app presents to the policy is an Assumption until the dry-run log shows it.

Three stages

P6, whether the app can be bound, is a spike carried by P57's protocol and stays in the register's `later group` until enforcement ([03 §11.2](#)). Stage 1 binds a throwaway app in dry run to learn whether dry run applies, which principal and hostnames appear, whether engine requests are routed, and the added latency. Stage 2 binds the

tenant app in dry run for 30 days, the first honest inventory of what the front door reaches. Stage 3 enforces, making "unregistered means unreachable" a network fact. P57 requires enforcement before the first Tier W publication.

The price is availability: the front door joins the gateway and Model Armor availability domain (SLO Assumption: 99.5 %), probed every five minutes, and the platform never unbinds to recover. Rollback is an unbind by the same API call (Assumption), losing the fence and nothing else. If Stage 1 fails, the connector allow-list and per-engine grant stand as a recorded compensating control, re-tested at each Agent Gateway release.

What it does not give

No ingress screen, which Google does not support for the app; no per-operation gating on plain REST; no screening of payloads to custom agents, which Chapter 10 places at each agent's own gateway (03 §11.3). It gives one thing: the front door reaches exactly the engines the register names, bypassable only by an audited UpdateEngine.

Connectors and data sources (P58)

A connector is a credentialed data path into the tenant, so its allow-list is organisation policy at `fld-gemini-enterprise`, not a console list (03 §12). Google's managed constraints bind only perimeter projects or projects listed by number, so the app project is listed. The initial list is first-party Workspace sources only (source ids *tbd*); each addition is a pull request with a supplier row and data-class declaration. The block on custom MCP data stores stays enforced: an MCP server reaches the front door only as a gateway-governed endpoint of a Tier R or higher agent.

No connector carries a Workspace write credential, because Wall-E is the one write path; a write scope found in the quarterly OAuth review is revoked as an incident. Data stores are EU only; every new source waits for review.

Audit logging of the app

Gemini Enterprise is administered in the Google Cloud console and logs to Cloud Audit Logs under `discoveryengine.googleapis.com`, not to the Workspace admin stream; a detection written against the Workspace stream would stay silent (03 §13). Admin Activity entries, always on, record configuration, registration and sharing. Data Access entries, off by default, record requests and are switched on at the platform folder with no exemptions.

The StreamAssist Data Access entry is the only log that names the human behind a request; without it no agent's audit row ties to a person. It is routed to the locked bucket in `LOGGING_PROJECT` and the SIEM, kept 400 days (Assumption), and given a log view for the correlation query. It is also personal data, treated in Chapter 22, Personal data, employees and the works council. Only the per-unit service toggle is a Workspace admin-audit event.

The runbook to baseline

Fifteen steps, GE-0 to GE-14, run in order, each with a verification (03 §16). They record the tenant facts, bring the project under management, set the app, stage the fence, publish each Tier R or higher row, load the detections, and extend reconciliation and drift to the app. GE-14 includes a penetration test of the front door and its sharing, and closes the Tier C gate (HLD §0.4).

The runbook needs Stage 0's folder and `CORE_PROJECT`, not a factory ready for agent projects. The pages word this differently: the [design README](#) says it needs no factory, while GE-2 uses the factory's `tenant-app` import module. Because steps run in order, the 30-day dry run falls before GE-14, so Tier C opens no sooner than about a month after the gateway is first bound.

What is still unverified

None of these counts in a safety case until closed ([03 §18](#)).

Unverified	Closed by
Dry run on an app binding; unbinding by an empty value; the principal the app presents; whether engine requests traverse the gateway	GE-9 spike
Whether the app calls engines with <code>streamQuery</code>	request logs at GE-12
Whether the app predates CMEK; the edition that gates assistant settings	GE-0
Context-Aware Access on the web app	GE-1
The data-store ACL field for Workspace sources; data-source ids	GE-4
Group-scoped builder toggles; the user and service-agent permission lists	GE-6; GE-5
Security Health Analytics support for <code>Engine</code> ; Autokey coverage	building the module; explicit key regardless
Google's TISAX coverage of Gemini Enterprise	P32, open
Who removes the <code>gemini-egress</code> entry in an emergency	<i>tbd</i>

Key decisions and what to read next

On 2026-09-14 the register holds as proposed: P48 placement (superseding topology decision 52), P49 administration, P50 location and encryption, P51 Google Identity (P24 "no" for the tenant app, open for operators), P52 retention at an interim 30 days under P13, itself open with the DPO, P53 the console Model Armor setting, P54 Feature Management, P55 the three gates, P56 the engine-scoped grant, P58 connectors and P59 one production app. P57 is a staged spike carrying P6.

Chapter 19, Threat model and residual risk, carries from here: the gateway binding and the Model Armor setting are detection-grade at the policy layer, so an administrator's change is seen, not prevented; until the gateway's third stage enforces, publication control rests on nightly reconciliation; custom agents have no ingress screen at the front door; the imported app stays on Google-managed encryption; Google's TISAX coverage is unconfirmed.

Read next: [03-gemini-enterprise-environment.md](#), especially [§15](#), [every control](#); [05 §7.2](#) for revocation and suspension; [06 §3.5](#); [07 §6.4](#) for the app's detections; [08 §5.2](#) for retention; and the register's [group before the folder exists](#).

7. Landing zone and the tier model

What you will understand by the end

Why the platform is a folder tree, a factory and a tier model; what tiers C, R, W, P (with the super-admin singleton P-SA) and X are, how an agent is placed in one and what each mandates; how a project is made, named, labelled, budgeted and constrained without hand work; and which folder constraints Google enforces today and which are still spikes.

The chapter answers four risk themes of Chapter 3, The problem and its risks. Shadow agents: a hand-made or misnamed project is refused or found. A controller reachable by what it controls: Eve and Mo sit in folders where the identity that builds agent projects holds nothing. Tenant compromise through the robot credential: the super-admin agent is a singleton in the strictest folder. Notional two-person rules: from Tier W, making a credential holder takes two people.

Why a folder, a factory and a tier model

Hundreds of agents, run at first by one administrator, force two things. Controls Google can enforce once — locations, enabled services, grantable principals — must sit above the agents, where one person owns them and no agent owner can undo them. Controls needing a second person, a bought desk or a sandbox tenant attach only to the agents that need them, so harmless tiers open with the people who exist (Chapter 4, The principles; [HLD §11](#)).

The tier is the unit everything keys on: folder, factory module, monitoring baseline, metric pack, staffing, compliance gate. The factory makes one project per agent affordable, since a hand-followed runbook per agent is drift waiting to happen. None of it is built on 2026-09-14.

The tiers

Letters, not numbers

The tiers are lettered because the autonomy ladder already uses T0–T3 for trigger classes (chat, scheduled, event, inbox), and two vocabularies sharing symbols would put the wrong ceiling in code ([§1.1](#)). "T1" is always a trigger class; a tier is always its letter. Controllers (Eve's shape) and improvers (Mo's) are folder classes, not tiers, and inherit the W-grade baseline.

The admission test

The platform owner sets the tier in the register row; only a new row changes it. The test is mechanical so nobody can argue an agent down ([§1.2](#)). An agent that runs only inside the Gemini Enterprise console is Tier C. Otherwise: one that executes code it wrote, sets its own goals or has capabilities its designers cannot enumerate is Tier X, and its row is refused with `tier_x_closed`; one with no component holding a credential that can change a system of record is Tier R; one whose credential is not a tenant-level administrative right is Tier W; otherwise Tier P, or P-SA if the role is Super Admin.

Three rules close the loopholes. The credential decides, not the intent: a "read-only" agent whose token carries any write scope is Tier W. The highest component decides: an admin-role action service makes the whole agent Tier P. X is asked first, because no such agent is admitted in 2026.

What each tier mandates

Each tier inherits the one below and adds controls, each with resource, owner, verification and failure in the design (§1.3, HLD §11.1). In outline:

Tier	The platform enforces or requires, beyond the tier below	The agent's code must carry
C	Register row first, console Model Armor, feature toggles, EU data stores, connector allow-list, named-group sharing	Nothing the platform trusts
R	Factory-made project, Agent Identity, default-deny egress gateway bound at creation, fail-closed ingress gateway if machine-called, no Secret Manager, monitoring baseline, registry card, kill-switch reach, budget and labels	Read-only manifest families, declared hostnames, taint handling, the injection regression suite
W	Action service as sole credential holder, keyless per-duty accounts, platform verifier, Binary Authorization, private egress, recoverable Firestore, nonprod, named blind grader, second operator	Catalogue, policy chain, playbooks, <code>ladder.yaml</code> , hard-denied list, REST interlocks
P	Tier P gate line green before any credential, robot user account, dedicated Eve, SIEM and witness, internal-ingress perimeter, HSM approval keys, quarterly privilege review	As W, against a dedicated verifier
X	Empty service allow-list	Nothing is trusted

The split tells a builder what exists before the repository and cannot be changed by the agent's owner, and an assessor whether a control's evidence is folder policy Google enforces or code CI checks. The Tier W cap by grading capacity (P25, open) is Chapter 14, Scale and AGI readiness; the tier gate is Chapter 24, Roadmap and cost; the per-agent admission gate is Chapter 9, Registry, governance and the autonomy contract.

P-SA: the super-admin singleton

Exactly one agent may hold `privilege: super_admin` — Wall-E. CI fails a second such register row until the first is `retired`, and the factory will not run for the P-SA folder until that check passes (HLD §11.3, §1.3 Tier P).

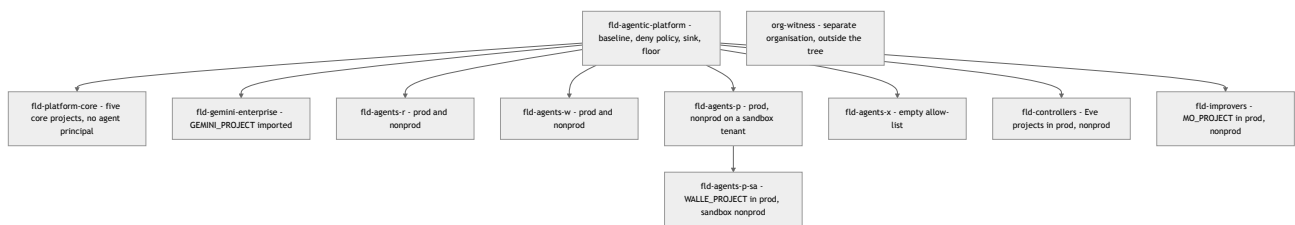
This is a policy, not a Google limit: nothing narrows a super admin (Chapter 3), so the compensation is to watch one actor closely. The P-SA folder is stricter than Tier P: a service allow-list generated from Wall-E's row, its own Model Armor floor with the hard-denied detectors, its own kill-switch binding drilled separately. It has no deferred control — the grant waits for the perimeter spike rather than running on IAM-only invoke as Tier W may. The robot account and the thirteen compensations are Chapter 15, Wall-E, the doer.

Changing tier

A tier change is a new register row, a new project in the new folder and a `revoke` of the old; a project is never moved (§1.5; P43, proposed). A move changes every inherited policy at once with no dry-run, and a "promoted" project would keep an engine created under a looser service list. Machines may only demote: Eve or the verifier can set a row `halted`, never write `tier`. The project-mover role is a PAM entitlement approved by the security reviewer, and a move raises a SIEM rule. The one exception is the import of `GEMINI_PROJECT` (Chapter 6, The Gemini Enterprise environment).

The folder tree

Everything sits under `fld-agentic-platform`, which carries the once-set controls (Chapter 5, Architecture overview); no project sits directly under it (§2.1).



What each folder is for (§2.2):

- **Core** holds five projects, KMS_PROJECT among them (register §7 row 6); what is shared there is Chapter 5.
- **Tier folders R, W, P** hold one project per agent; service lists widen by tier. R lacks Secret Manager and signing keys, so it has no write path to enable; W adds credential and control-plane services; P adds Access Approval, HSM-only key rings and a second approver on deploy grants.
- **P-SA** sits under P inheriting all of it and tightening it.
- **X** cannot hold anything until a dated decision records each opening condition (Chapter 14).
- **Controllers** allow Vertex AI at the folder but deny it on EVE_PROJECT at project level, because a folder denial would strip the reporting path of its model; Eve's "deterministic by absence" rests on that drift-checked project constraint.
- **Improvers** hold Mo, with no Secret Manager, no keys and no invoker on any credential holder.

The controller and improver nonprod folders exist because Eve must be drilled against the sandbox tenant before the super-admin grant, not against production with a robot already holding Super Admin (P40).

Why project-per-agent is forced

Google leaves no safe alternative (topology §1, §3.1). All Agent Runtime agents in one project and region bind to the same gateways, so two agents would share one egress allow-list. The tenant app's documented cross-project grant, the Discovery Engine service agent role, is project-wide over every engine with create, update and delete; the platform uses an engine-scoped role instead, but a fallback must touch one agent only. Model Armor quotas are per project, ExternalProcessor counted where the gateway lives. And deleting a project should remove one agent and nothing else. The cost of hundreds of projects is a register row per agent, because the factory makes each and the drift job checks it.

The factory

What it is built on

Cloud Foundation Fabric's project-factory, folder, organization, billing-account and agent-gateway modules, pinned at v58.0.0 and re-pinned only by pull request, wrapped by thin platform modules and run by Cloud Build in CICD_PROJECT (HLD §3.2, §3.2; P35, proposed, closing P2). Fabric already manages projects, IAM, policies, labels, sinks and budgets from YAML, and a one-person team should not maintain a second factory; what Fabric cannot express becomes a wrapper resource, never a fork. FAST stages were rejected because they assume ownership of the organisation's IAM, sinks and billing; Config Controller because it is a permanently running control plane with a powerful identity; Infrastructure Manager until the team is larger than one.

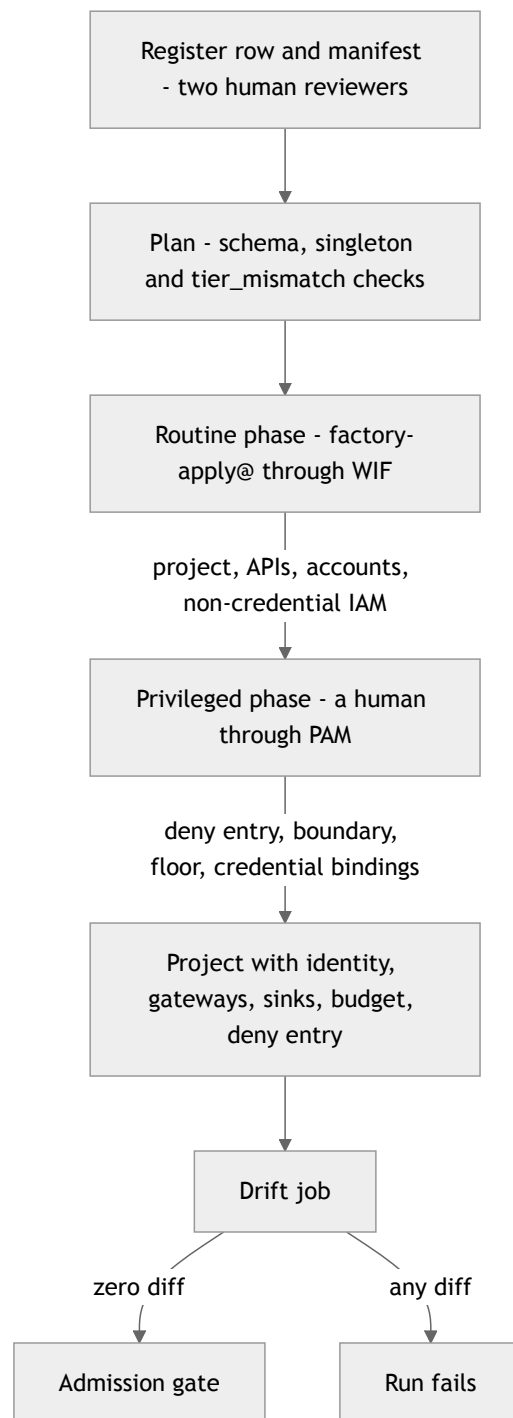
Inputs and modules

The register row and agent-manifest.yaml are the only inputs; nothing is typed at a command line. Cross-project grants are list fields in those inputs, so a grant exists only because a reviewed row asks for it (Chapter 5). Five modules exist (§3.3): the three project wrappers agent-project, verifier-project and improver-project, plus tenant-app for the one-off import and revoke for retirement.

In under an hour an agent gets a project with APIs, identities, gateways, datasets, budget, labels, registry card and deny-policy entry; secrets are created empty and filled by the agent's runbook. Every run ends with the drift job reporting zero diff for project and folder; any diff fails the run and the admission gate. Standing `roles/owner` is removed after the run, and later repair is a PAM grant (Chapter 8, Identity, privileged access and the fleet kill switch).

The CI identity and the two-phase apply

The identity that can create any project is the platform's most attractive target, and the folder controls must not be changeable by the identity that runs forty times a month. Each run therefore has two phases held by different identities (§3.4; P36, proposed, narrowed by P142, proposed 2026-09-13).



Routine phase. `factory-apply@CICD_PROJECT` is impersonated through Workload Identity Federation pinned to the git host's numeric owner and repository ids and `main`; there is no key. Impersonation gives one auditable principal that a boundary (`pab-core-ci`, confining the factory and drift identities to the platform folder) and the deny policy can name, and survives a change of git host (P22, open). It may create projects, services, accounts and custom roles on the R, W, P and improver folders, and is the sole standing registry writer. It binds only non-credential roles inside projects, through conditional bindings, and deny rule R6 fences the same permissions from the other side. It holds nothing on the P-SA and controller folders.

Privileged phase. A human with a time-boxed PAM grant applies what could redraw boundaries or reach a credential: deny entry, boundary binding, policy exceptions, project floor and credential-path bindings. At Tier R the platform owner runs both phases; from Tier W the security reviewer approves. P-SA and controller projects are applied end to end under `ent-factory-singleton`, requested by the factory and approved by two named approvers for P-SA, or the Eve owner or security reviewer for controllers, never the Wall-E owner.

Grade. The fence is detection until a nonprod negative test (the factory binding Secret Manager access and reading a canary secret) is refused on both counts; it reruns at every factory release, and a success is severity 1 that disables the factory trigger. **Assumption:** the platform may link projects to the billing account; if not, billing links and budgets move to the privileged phase.

The organisation-policy baseline

The families and why

The baseline is Terraform at the platform folder, applied in the privileged phase and drift-checked within minutes; every new constraint spends at least 14 days in dry-run first (HLD §3.3, §4.1; additions P41, proposed). Each family removes a class of misconfiguration:

- **EU residency;** `global` only as a dated exception if the first factory run proves the floor-setting write needs it.
- **Keyless service accounts:** no key creation or upload, no automatic grants to default accounts.
- **Allowed member domains:** the tenant plus an enumerated list, never the witness; the nonprod P folders add the sandbox tenant.
- **Bindings, not attachments:** no cross-project service-account use.
- **Storage:** uniform bucket-level access, public-access prevention, detailed audit logging for the evidence buckets.
- **TLS and network:** no TLS 1.0 or 1.1, no external IPs, no default network, no public Cloud SQL.
- **Contacts and federation:** Essential Contacts in the tenant domain; only the git host may federate in core.
- **Keys:** HSM-only with a 30-day destruction delay; CMEK constraints held (Chapter 13, Supply chain, keys and recovery).
- **Cloud Run:** Binary Authorization on four folders — W, P (so P-SA), controllers and core, because the kill and authority paths are Cloud Run; private egress on W, P and controllers. Internal-only ingress is written but held until P3's spike; until then IAM-only invoke is the enforced boundary and a Security Health Analytics module flags open ingress (Chapter 10, Agent Gateway, Model Armor and the perimeter).

Two open edges: the access-policy-binding constraint is spelled singular in Google's constraints reference and plural on its Agent Gateway set-up page and in the Wall-E set, confirmed at the first factory run (§7 row 10); and no policy can require a registry entry, which stays reconciliation (Chapter 9).

Service allow-lists

`gcp.restrictServiceUsage` runs in allow-list mode on every folder (§4.2; P44, proposed). It carries several claims: Tier R cannot enable Secret Manager; X is empty; no tier folder allows the Agent Registry API; the Gemini folder never allows Vertex AI. It is also the fleet kill switch's first lever: allow and deny modes exclude

each other, so the lever replaces a tier folder's policy with a pre-written one lacking Vertex AI and Cloud Run (Chapter 8). The exact lists are an **Assumption**: until the first nonprod factory run, where a missing service fails closed and the fix is a pull request, never a console edit.

Custom constraints and their spikes

Custom constraints turn detection into enforcement only where Google supports the resource type and a test has proved the refusal (§4.3; P42, proposed with three spikes; P4, spike, half closed).

Verifiable today: Google's two gateway constraints binding an engine to its gateways; a Cloud Run constraint requiring the Binary Authorization annotation, closing P4's Cloud Run half; Preview project-id, folder-name and auth-provider constraints; a data-store ACL constraint in dry-run (Chapter 6). Internal ingress is verifiable but held with P3. The gateway constraints target ReasoningEngine, absent from Google's supported custom-constraint types on 2026-09-13 though Google publishes them, so they count as enforcement only after a throwaway engine is refused in nonprod.

Spikes: an allow-policy constraint against basic roles and foreign members (does it fire on PAM's own grants; does the organisation principal set cover agent identities); identityType on ReasoningEngine, P4's other half; and, low priority, a log-sink constraint against actor exclusions. Requiring labels is impossible, since a project exposes only parent and id. For identityType the register records the resolution (§7 row 8): the spike reruns at each factory release, and until it passes the engine half of D2 is a CI check graded detection.

Non-production and the sandbox tenant

Nonprod is optional at Tier R, mandatory from Tier W and for controllers and improvers (§3.5; P40, proposed): a gate change must not first execute as the production credential holder, and Tier R has no credential to protect. Nonprod uses the same manifest and ceilings, holds no production credential and is unreachable from the tenant app. Promotion is an attestation on the same digest, or the recorded bundle hash for Agent Runtime, detection-grade there.

Tier P and P-SA nonprod is a separate sandbox Workspace tenant, never an organisational unit: Super Admin cannot be limited to an organisational unit, so a sandbox OU contains nothing once its robot is a super admin. The member-domain constraint admits the sandbox only in the nonprod P folders. The sandbox must exist before Wall-E's Stage 1 — another tenant for one administrator to run.

Naming, labels, budgets, contacts and quotas

Naming and labels

Reconciliation and SIEM rules attribute by name (§3.6; P37, P38, proposed). Folders are fld-<purpose>[-<tier>] [-<env>]; project ids agp-<tiercode>-<agent>-<env>, such as agp-psa-walle-prod; handles like WALLE_PROJECT remain variables the register maps.

Names can be refused at the API by the Preview constraints; labels cannot, so they are validated before creation and reconciled daily, for billing export and log views, while inherited folder tags serve policy conditions, hence tier and env twice. The register holds exact values; the label is an index. A label disagreeing with its row is severity 3; a tier label disagreeing with its folder tag is severity 2, a hand edit to change a default. The registry entry has no labels either; its metadata is a fixed first description line carrying the row's hash (Chapter 9; registry page §3.1).

Budgets, contacts and billing export

Each project gets a budget at its tier default, alerting at 50, 90 and 100 % of actual and 100 % of forecast, with an aggregate per tier by label; events publish to budget-events in LOGGING_PROJECT (§3.7; P39, proposed). Nothing disables billing automatically: that would stop the evidence pipeline first. Essential Contacts go to the

security and owner groups. The defaults — Assumption: 100 EUR a month at R, 300 at W and core, 500 at P and P-SA, 200 for controllers and improvers, nonprod half — are P31, open. A label-keyed billing export feeds cost metrics, marked unavailable when stale, never estimated.

The quota register

A Model Armor quota error behind a fail-closed gateway stops the agent, so quotas are tracked (HLD §3.4). First row: the tenant app's 1,200 QPM sanitize quota, which serves all assistant traffic and scales with headcount. Then Model Armor 1,200 QPM sanitize and 600 QPM ExternalProcessor per agent project; Agent Gateway 5,000 resources; Agent Registry 100 entries per project and 1,200 requests per minute per region, increase requested at 60 % occupancy; Agent Runtime *tbd*. The platform owner reviews it quarterly; values sit under P31.

How the landing zone is verified as a whole

Continuously, not once (§6). An asset feed and a nightly Terraform plan catch any difference as severity 2, naming its maker; Terraform wins within one business day. Nightly checks confirm constraints are enforced rather than in dry-run, allow-lists and the factory identity's bindings match (a forbidden role is severity 1), and no project breaks the pattern. The kill switch is drilled monthly per tier folder, P-SA separately; the Tier P gate checklist is checked on every pull request; the witness's separation is attested quarterly.

What remains open

The shape costs attention more than money: a security reviewer, who does not exist on 2026-09-14, for every Tier W factory run; a second Workspace tenant; 14 days per new constraint. Unsolved: the `identityType`, allow-policy and log-sink spikes; gateway constraints awaiting a refused test engine; the factory fence awaiting its negative test; internal ingress awaiting P3; allow-lists, the `global` exception and a constraint spelling awaiting the first factory run; labels detection-only; budget and quota numbers; the git host. Chapter 19, Threat model and residual risk, keeps the engine identity constraint out of every safety case until its spike passes.

Key decisions and where to read next

Decision	State on 2026-09-14
P35 factory tooling (closes P2)	proposed
P36 CI identity and two-phase apply, narrowed by P142	proposed
P37 naming, P38 labels, P39 budgets, P40 nonprod, P41 baseline additions, P43 tier as folder, P44 allow-lists	proposed
P42 custom constraints	proposed, three spikes
P4 engine identity constraint; P3 perimeter	spike
P31 budget and quota amounts; P25 Tier W cap; P22 git host	open

- [Landing zone and the tier model](#) — every control, folder, module, constraint and allow-list by name
- [HLD §3](#) and [§11](#)
- [Project topology §1](#)
- [Register §2, before the folder exists](#)
- Chapter 8 for the deny policy, boundary and kill levers; Chapter 9 for the register row and admission gate; Chapter 24 for the tier gate and build order

8. Identity, privileged access and the fleet kill switch

What you will understand by the end

This chapter answers the first risk theme of Chapter 3, tenant compromise through the robot credential, from the identity side; Chapter 11 answers it with detection and Chapter 15 with Wall-E's code. It also carries part of two other themes: notional two-person rules, by saying which Google enforces and which rest on people; and a controller reachable by what it controls, since Eve stays outside the fleet kill switch.

By the end you will know:

- who and what may act on the platform, how each principal authenticates and what it may never hold;
- the two fences around every agent principal and what each cannot stop;
- how a human reaches a dangerous permission briefly, with a justification and visibly;
- how the super-admin roster stays at three with the robot never the recovery account;
- how K7 stops every agent in a tier from outside its own project.

The design of record is [page 04](#). Nothing here is built.

The principles, stated once

1. **Identity is issued by Google or does not exist on the platform.** No keys, no passwords in code, no shared accounts. `walle@` and `eve@` are the only user accounts a machine drives.
2. **Dangerous rights are never standing.** Anything that can redraw a trust boundary is a time-boxed grant with a justification. From Tier W, the approver is not the requester.
3. **Two fences that fail differently.** The deny policy is exact but covers only the permissions it names. The Principal Access Boundary is broad but only as strong as its enforcement version. Neither alone is the safety case.
4. **One door for humans.** Every control surface is reached through Identity-Aware Proxy, with an access level, by a factory-made group.
5. **A kill switch no agent project can undo.** It is pre-written and drilled monthly.
6. **Workspace's two-person mechanisms are turned against the robot,** because the robot is a super admin.
7. **No domain-wide delegation, for any agent, at any stage** (a constraint of Chapter 4). Delegation is limited only by OAuth scopes, so a compromised delegate can act as anyone, a super admin included, and a delegated verifier could impersonate the robot it verifies. Each robot holds its own consented refresh token and is never impersonated; no other agent holds a Workspace credential. Granting delegation is under multi-party approval and on the hard-denied list ([page 04 §1](#)).

Agent Identity for every reasoning layer

Every layer that reasons runs under a Google-issued agent identity, not a service account someone could impersonate, with 24-hour certificates and bound tokens.

For Agent Runtime the identity type is GA; the factory sets it and CI refuses an engine config without it. The constraint that would make Google enforce it is spike P4 (Chapter 7, Landing zone and the tier model); until then it is a CI check graded detection.

Agent Identity for Cloud Run is Preview on 2026-09-13 and goes to production when GA (P5, open); meanwhile a production Cloud Run reasoning service on a service account is a dated Tier R exception, refused from Tier W. Gemini Enterprise no-code agents carry the product's own identity.

One environment line removes the protection against reusing an agent's token on Google Cloud services; CI refuses it fleet-wide, and a daily Security Health Analytics hit is severity 1, with K3 on the agent.

Google's two automatic agent roles have unverified permission lists, so they are diffed at every release and a forbidden permission blocks it. The Vertex AI Express User role is never granted: bound at project level, it would let an agent query its own engine as any operator ([page 04 §2.1](#); [HLD §4.1](#)).

The three principal populations

Agents, meaning their reasoning layers, hold:

- invoker on their own action service, granted on the resource;
- the automatic roles;
- basic usage, browser and log-writer roles in their project.

They never hold a secret read, an IAM write, a deploy permission, a key or anything outside `fld-agentic-platform`.

Machines that are not agents are keyless service accounts, one per duty, each holding exactly the rows the factory generates from the register.

Humans use the tenant's Google identities, on admin accounts separate from their daily ones above Tier R. They hold group memberships, PAM eligibility and IAP access. They never hold a standing owner or editor role, a catalogue role, or impersonation on a credential holder ([page 04 §2.2](#); [HLD §4.2](#)).

Naming "all agents in a project" is not settled: Google's allow-policy, boundary and deny pages use three different spellings. The factory emits the allow spelling for allow and deny and the boundary spelling for boundary bindings. Whether a deny policy accepts an agent principal set is **Assumption:** until a throwaway engine proves it (P8, narrowed by P61), and the template is corrected from that evidence, never from a page. Register row 11 stays open: Wall-E's identity page carries only the allow spelling ([register §7](#)).

Service-account policy

Seven rules are set at the folder, applied by the factory and asserted by the drift job ([page 04 §2.3](#)).

- **SA-1, no keys.** Also denied; an existing key is severity 1.
- **SA-2, no cross-project attachment.** Every crossing is a binding on a resource.
- **SA-3, one account per duty.** An account that reads a credential never holds a deploy permission, and the reverse.
- **SA-4, no standing owner or editor after the factory runs.** The CI identity's limits are Chapter 7 (P142).
- **SA-5, impersonation is enumerated.** Only an agent's operator-caller account and its deployer can be impersonated. No human ever impersonates an action service or `eve-controller@`.
- **SA-6, every account's reach is a generated row.** Anti-grants are asserted daily: the agent reads no secret, Mo invokes no credential holder, and no agent appears in another agent's project.
- **SA-7, default service accounts get nothing.**

Groups and workforce identity

A human is never bound directly to a resource; a group is, carrying the irreversible security-group label that admits only domain members.

`factory-groups@` creates agent groups from each agent's two-reviewer `operators.yaml`. It holds the Workspace Groups Admin role (**Assumption:** assignable to a service account through the Admin console), and drift in agent groups is corrected on its next run.

The **control groups** (owners, security, approvers, app admins, Eve's owners, Wall-E's operators) are on a hand-managed, two-human-merged list the job refuses in code. A live membership change without a merge is a severity-1 page, never auto-corrected: a robot that could edit `eve-owners@` would be a path around Eve's independence (P65, proposed).

No workforce pool exists until operators without Google identities exist (P24, open for operators). If one is needed, P64 fixes its shape: one organisation-level pool, one-hour sessions, programmatic sign-in disabled and services limited to the control surfaces.

Such an operator has no `gcloud`, so can pull K0, K1 and K4 from a page but never K2, K3 or K5, and gets no device-based access level, so never reaches a Tier P surface. Whether Google identities and a pool can share one IAP surface is unverified, so a workforce population gets its own (page 04 §2.4, §2.5).

The identity drift job

`platform-drift@CORE_PROJECT` holds the security reviewer role at `fld-agentic-platform` and receives the folder's Cloud Asset feed, which surfaces IAM and organisation-policy changes within minutes. It asserts the service-account rules, groups, identity types, deny rules, boundary bindings, access conditions, the break-glass role set and K7's levers absent in normal state against the committed copy. A missing report for 26 hours is itself an alarm.

The folder-level role breaks the rule that cross-project reach is a grant on the resource, and, inherited into `EVE_PROJECT`, decision 48. It is a named exception dated 2026-09-13, accepted because one reader is the only way to see drift across hundreds of projects (page 04 §2.6; topology §3.1).

The folder deny policy

`deny-agents-platform` is attached at `fld-agentic-platform` and evaluated before any allow grant. It names each agent project's agent set and service-account set, plus `MO_PROJECT`'s accounts, so Mo is fenced by enforcement rather than by a missing grant.

No core, controller or Gemini Enterprise principal is denied under R1–R5, because the drift job, the K7 executor and Eve must keep working under every lever. The rules:

- **R1, secrets.** Exempt: each action service's own account and `eve-controller@`, limited to their one secret.
- **R2, signing and key IAM.** Exempt: `eve-controller@` alone, so no agent, Mo identity or deployer can sign an approval.
- **R3, impersonation and keys.** A separate rule, R3b, lets the per-project deployer act as its attached accounts without lifting the rest of R3.
- **R4, self-modification of services, jobs, engines, artefacts and builds.** Exempt: the deployer.
- **R5, governance and evidence.** No exceptions: policy, sinks, log buckets, IAM, boundaries, custom roles, floors, registry entries and PAM.
- **R6, the routine factory identity.** It is denied every credential permission, and a canary secret read at every release proves it.

Every permission name was checked on 2026-09-13 against Google's list of deniable permissions, because an unlisted name raises no error and silently never matches. The check changed three things:

- the streaming-query name is absent, so the rules use the engines wildcard;
- Scheduler is not deniable, one reason K7 has a lever of its own for it;
- deny policies themselves are not deniable, so deny administration is PAM-only and every deny-policy write is severity 1.

Changes usually apply within two minutes but can take seven or more. The grade is enforcement, with the principal spelling still a spike (P61). Beside it sit `pab-core-ci`, confining the factory and drift identities to the platform folder (Chapter 7), and `deny-core-agents`, which denies every agent principal everything on the core folder once P8 proves the principal forms, with the drift job asserting absence until then ([page 04 §3](#); [page 02 §4.4](#)).

The Principal Access Boundary

`pab-agents` is an organisation-level policy, bound by the factory to each agent project's set. Its resources are the platform folder plus the named core resources agents need, never a whole core project. The singleton binds a stricter twin whose only resources are `WALLE_PROJECT` and the approval surface. The enforcement version is pinned to 4, so a bump is a reviewed change.

A boundary has no effect on permissions outside its enforcement version. Version 4 blocks Vertex AI (engine queries included), secrets, keys, impersonation, storage, BigQuery, Pub/Sub, organisation policy, Artifact Registry, Cloud Build, Cloud Run deploy and job runs. It does not block Cloud Run route invocation. The boundary is therefore enforcement-grade for engine queries and the blocked families, and **no fence for Cloud Run invocation**. "An agent cannot invoke a foreign action service" rests on resource-level invoker grants plus the deny policy.

This is P60, which closes P9 and sets trust boundary B7's grade in Chapter 5, Architecture overview ([page 04 §4](#), [§4.3](#)).

Privileged Access Manager

No standing owner exists anywhere. Humans reach dangerous roles through entitlements that require a ticket or incident id, notify `platform-security@` and are reviewed quarterly. Facts verified on 2026-09-13 shape the catalogue:

- **No self-approval, enforced by Google.** One-person operation at Tier R activates without approval on a mandatory justification, recorded as such, until a security reviewer exists.
- **Durations.** An entitlement lasts at most seven days, and no grant is shorter than 30 minutes.
- **Approval levels.** Two-level approval is Preview, so for now two named approvers share one level.
- **No legacy basic roles.** PAM does not support them, so the per-project repair entitlement bundles predefined roles instead of `roles/owner`.
- **Organisation-only roles.** Organisation-policy, deny and boundary administration sit at the organisation, the highest entitlement, with two approvers.
- **PAM cannot bootstrap itself.** So the PAM administrator role is the one standing administrative role, held by `platform-owners@`. Its use outside a change window is severity 2.

The catalogue ([page 04 §5.2](#)) covers project repair (up to two hours), deploying a credential holder outside CI (never approved by the agent's owner), reading one secret (30 minutes), folder and platform policy, tenant app administration, the `GEMINI_PROJECT` move, singleton applies, witness export repair and two K7 entitlements.

The K7 entitlements need no approver, because a fleet stop must not wait at 03:00; their second person is the page every activation sends, and the two-human recovery. A standing catalogue role is severity 1 and is removed by the pipeline. A grant outside a change window without an incident id is severity 2 (P62, proposed; [page 04 §5.1](#)).

Human access to control surfaces

Every control surface (approval pages, Eve's console, ladder-state page, registry viewer, `k7-console`) is a Cloud Run service with IAP on it, admitting one group under an access-level condition. If any of the three is missing, the pipeline removes the proxy's invoker binding, so the surface goes dark rather than open.

- **al-platform-operator** requires a managed, encrypted, screen-locked device on an approved operating system and the corporate network. Device attributes need a Chrome Enterprise Premium licence, which is *tbd*.
- **al-platform-operator-lite**, IP ranges plus business hours, serves Tier R, and every surface until the licence exists, as a dated exception. The super-admin approval page never accepts lite.

"Signed in with a security key" comes instead from two Workspace settings: key-only 2-Step Verification and hourly Google Cloud re-authentication with a key (P63, proposed).

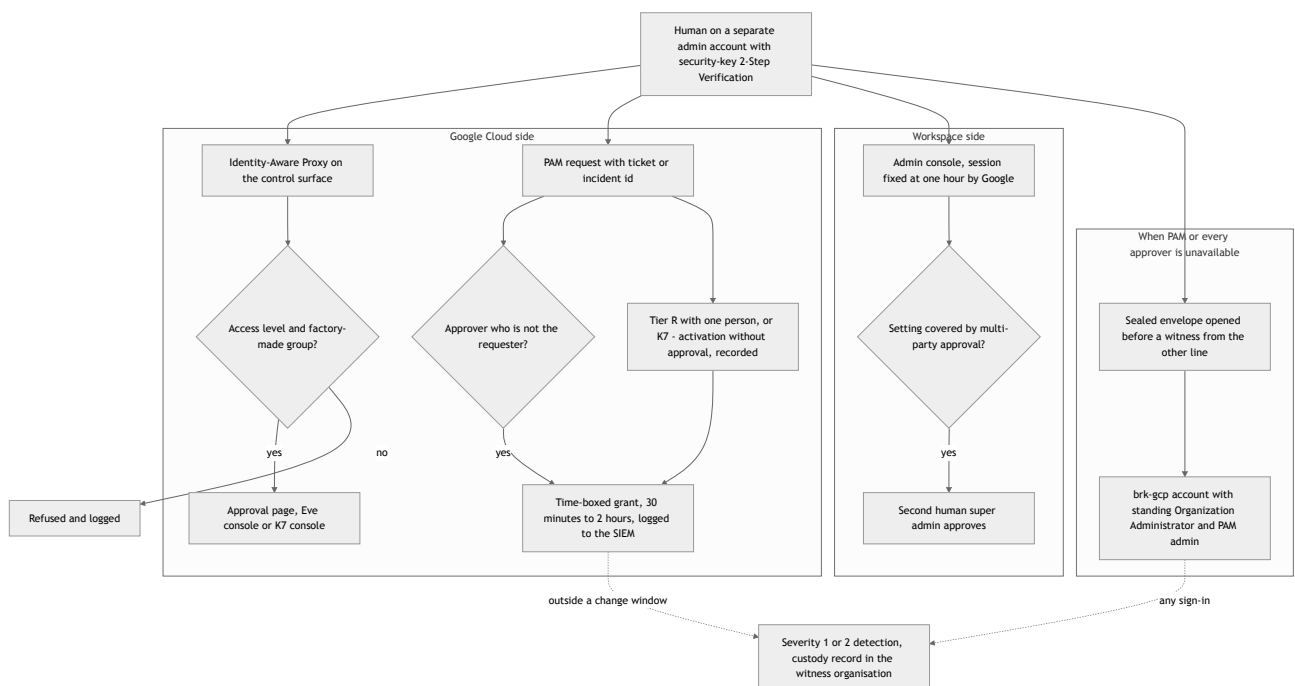
No human holds invoker on an action service, impersonates a credential holder, signs in to `walle@` or `eve@` after bootstrap, or drives the Admin console under the robot's session (page 04 §6.3, §6.4, §6.5)

Break-glass

Break-glass covers the two failures PAM cannot: PAM itself broken, or every approver unreachable. On Google Cloud it is two Cloud Identity accounts, `brk-gcp-1@` and `brk-gcp-2@`, in their own unit, with key-only 2-Step Verification and no recovery options. They hold standing Organization Administrator and PAM administrator, because break-glass is for when PAM cannot be used.

- **Custody.** Each hardware key is sealed in the safe and each password is in the vault under a separate custodian. Key 1 is the platform owner's, key 2 the second human's in IT security.
- **Opening.** Opening an envelope needs a witness from the other line and a custody record in the witness organisation's bucket, which survives a tenant compromise.
- **Detection.** Any sign-in is severity 1, and so is any change to the two roles.
- **Drill.** Every quarter, alternating accounts: open, sign in, activate nothing, re-seal, rotate the password, all within 30 minutes.

Workspace has no PAM, so there the two human super admins are the break-glass. Each has a separate admin account, two keys with the spare in the other's custody, sealed backup codes, and self-recovery Off, so recovery runs through the other super admin or Google Support (P69, proposed; page 04 §7).



The robot accounts' shared rules

walle@ and eve@ share one set of rules. Each account's full hygiene set belongs to Chapter 15, Wall-E, the doer, and Chapter 16, Eve, the independent controller.

- **Placement and sign-in.** Both sit in /Automation/Service Identities, with the tenant's own hardware-key-only 2-Step Verification, since Google's admin enforcement is a gradual, edition-limited rollout. Two keys per account are in the safe.
- **No recovery.** An unmonitored recovery channel is a takeover channel, so there are none.
- **Sessions.** Google fixes the Admin console session at one hour, and Google Cloud session control applies.
- **No interactive login, ever.** One is severity 1.

The robot unit also carries an Admin console Context-Aware Access level that no device satisfies. It is graded **detection-plus-friction**, Assumption: , until Google confirms whether it binds super admins (P7, open); no Admin SDK API access level exists. What survives Super Admin is the rule that an interactive login is an incident (HLD §4.6; page 04 §8.2).

The super-admin roster and key custodians

The steady-state roster is exactly three (P68, proposed):

- sa-1-admin@, the platform owner;
- sa-2-admin@, the second human, in IT security, outside the Wall-E administration line and the sole recipient of reports about the administrator;
- walle@.

Each human recovers the other. The robot is **never the only super admin and never a recovery super admin**; its own recovery is a human re-running its consent with a key from the safe. Self-recovery is Off at the top unit and drift-checked on every child unit, because Google's default is On for most editions. eve@ is on the roster file as a non-admin.

Eve's daily roster check and the SIEM page the second human and the desk on any role added or missing, or an admin's security settings changed. A third human is allowed only as a dated hand-over exception.

Custody means no one person holds both keys of any robot or break-glass account. Robot keys have cross-line custodians, swapped between walle@ and eve@. Each human's spare key is in the other's custody. That makes eight keys in the safe and ten in all, with every opening witnessed and recorded in the witness bucket (page 04 §8.1, §8.3).

Multi-party approval and the two-person rule

With multi-party approval on, a second administrator must approve changes to sensitive Workspace settings, including role assignments, domain-wide delegation, 2-Step Verification, recovery, SSO and Context-Aware Access. P66 (proposed) turns it on for every covered setting before the super-admin grant. It is **the only two-person rule Google enforces over the robot's credential**: that credential alone cannot complete a role assignment, even though Wall-E's code already refuses one.

It has limits:

- **Edition and roster.** It needs named editions and two or more super admins, and the tenant's edition is *tbd*.
- **What it does not cover.** User deletion, unit moves, log-sharing settings and activity rules stay code-refused and detected. Coverage of making a user an admin is Assumption: until tested in the sandbox tenant.
- **The robot is never an approver.** An approval by walle@ is severity 1.

- **Turning it off.** Switching approval off is `Assumption`: not itself protected. So "approval switched off" is on the [hard-denied list](#), and finding it off is severity 1 with `K0 no_writes` on the super-admin action service ([page 04 §8.4](#)).

Across the privileged tier, the second person is carried by mechanisms of different strength ([page 04 §8.5](#)):

- **Google enforces it** for Workspace role, delegation and security settings (multi-party approval), and for organisation policy, boundaries, deny, floors, sinks and folder IAM (PAM).
- **Wall-E's code enforces it** for a band B super-admin request, approved by a different human super admin.
- **Branch protection enforces it** for a deploy outside CI, register rows, raises above L3, revocations, K7 reverts and Eve's configuration.
- **Organisation plus detection** carries K5, K6 and break-glass envelopes.
- **Detection alone** carries control-group membership.

The fleet kill switch K7

K7 stops every agent in the selected tier folders, or the whole fleet, at Google's API layer from outside every agent project: for an unknown compromised agent, a suspect platform, or 03:00 with nobody answering.

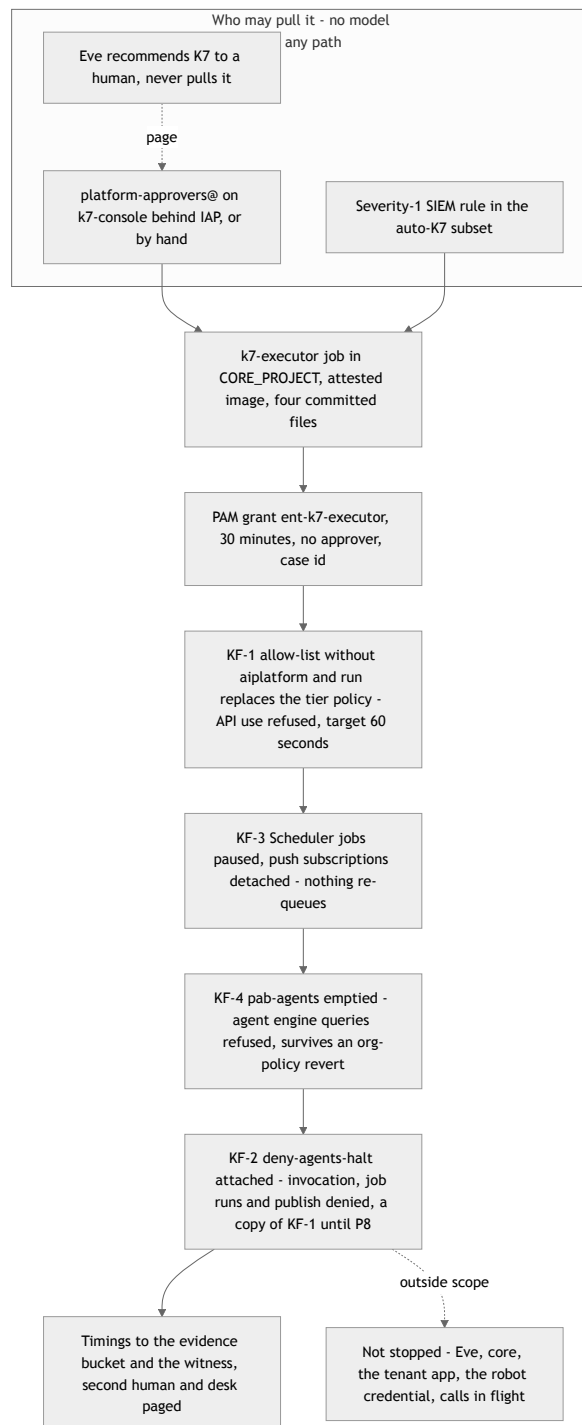
Its scope is `fld-agents-r`, `-w`, `-p` and `-p-sa`, with their production and nonproduction children. It never touches:

- `fld-controllers`, so Eve keeps paging;
- `fld-platform-core`, where the drift job, the evidence and K7 itself live;
- `fld-gemini-enterprise`, so Tier C keeps serving (P70, proposed).

K7 is **not** a credential revocation. It does not invalidate the robot's refresh token or remove Super Admin. A Workspace call in flight completes, and an access token already minted lives up to 60 minutes.

K7 is pulled by a human in `platform-approvers@`, from `k7-console` or by hand, or by the deterministic job `k7-executor` on a severity-1 SIEM rule over plain authenticated REST. It is **never pulled by a model**.

The job's attested image reads four committed lever files and activates its own 30-minute entitlement with the case id. The rules that may call it are Chapter 11, Monitoring, detection and incident response; that path stays dry-run until the SIEM's outbound identity exists (P10). Eve only recommends K7 to a human. If the job cannot activate its grant, the contingency is a workload-federation principal, then a narrow standing custom role as a dated residual.



The levers are applied in a fixed order, each counted only for what it verifiably stops ([page 04 §9.3](#)):

1. **KF-1 comes first because it ignores who the caller is and is fastest.** It replaces the tier's service allow-list with one lacking Vertex AI and Cloud Run; logging stays outside the constraint, so evidence keeps flowing. It is enforcement-grade. Assumption: a running Cloud Run instance finishes the request it is serving rather than being killed, and takes no new ones; every drill measures it.
2. **KF-3 is second.** A paused Scheduler cannot re-queue work when KF-1 lifts.
3. **KF-4 is third.** An emptied boundary survives an organisation-policy revert. It is counted for engine queries, never for Cloud Run invocation.
4. **KF-2 is last.** It propagates slowest, its principal spelling is still a spike, and it stops a mistaken KF-1 revert silently restarting the fleet ([page 04 §9.4](#)).

Lifting K7 is a change, never a button.

- **The change.** A pull request reverting the four files, reviewed by the security reviewer (and the second human when P-SA is in scope), applied through the two-approver platform-policy entitlement; the exit is the drift job's zero diff.
- **How agents return.** Tier P agents come back at K0 `no_writes`, and every Tier W cell is demoted one level.

A fleet stop is when the platform is least sure of itself, and machines lower while humans raise (page 04 §9.5).

The drill calendar is P67, proposed (page 04 §9.6):

- **Monthly in nonprod.** Pass: KF-1 under 60 seconds and all four levers under 5 minutes.
- **Quarterly, manual and SIEM paths.** Pass: under 15 and under 10 minutes respectively.
- **In production.** KF-3 quarterly and KF-1 twice a year, both on `fld-agents-r/prod` only.
- **P-SA.** Never drilled in production; its K7 is proven in the sandbox tenant.

A missed drill freezes raises. A drill older than 30 days blocks any P-SA promotion.

K7 beside each agent's K0 to K6

K0 to K6 are per-agent switches, owned by Chapter 15, Wall-E, the doer. K7 replaces none of them; KF-3 is K2 for a whole folder, and KF-2 and KF-4 are K3 for every agent at once.

Order matters because KF-1 also makes each agent's control endpoints unreachable. K0 is therefore pulled first, and K4 before K7 whenever the credential is suspect. The Tier P-SA crisis order is:

1. K0 `halt_all`;
2. K4;
3. K7 on the P-SA folder;
4. K5;
5. K6 if the account itself is suspect.

Evidence preservation and the incident commander follow. With an unknown Tier R or W agent, K7 on its tier folder comes first. The containment targets are held once in Chapter 11 (page 04 §9.7; page 07 §9.2).

What is unverified, and what closes each

What closes each gap (page 04 §14):

- **The deny principal spelling:** the P8 spike, before the folder baseline.
- **Multi-party approval's coverage of making an admin, protection of its own off switch, and whether the robot counts towards two super admins:** a sandbox tenant test before the grant.
- **The tenant's Workspace edition:** the platform owner reads it in the Admin console.
- **Context-Aware Access on super admins:** Google's answer (P7).
- **Whether a condition in a PAM entitlement scopes impersonation to one account:** the first nonprod activation.
- **Groups Admin on a service account:** the first factory run.
- **Whether running instances finish under KF-1:** the first drill.
- **Mixed identity sources on one IAP surface:** a test.
- **The GA track of the PAM command:** at build.
- **The Chrome Enterprise Premium licence:** procurement.

One tension is unresolved: the monthly drill wants all four levers within 5 minutes, but deny changes can take 7 minutes or more to propagate, and page 04 does not say whether KF-2 is timed at application or propagation.

Key decisions and what to read next

States on 2026-09-14:

- **Decided:** P33, Wall-E holds Super Admin, the premise.
- **Closed:** P9, by P60.
- **Proposed:** P60, the boundary grade; P62, PAM; P63, IAP and access levels; P64, conditional on P24; P65, groups; P66, multi-party approval; P67, K7 drills; P68, the roster; P69, break-glass; P70, K7 scope and recovery; P142, factory identities; P16, no machine-invocable account stop for now.
- **Open:** P5, P7, P10, and P24 for operators.
- **Spikes:** P4, and P8 through P61.

P61, P62, P65, P67 and P70 gate the folder; P63 and P64 gate Tier W; P7, P60, P66, P68 and P69 gate the super-admin grant ([register §2](#), [§3](#), [§4](#)).

Chapter 19, Threat model and residual risk, carries what remains. A leaked robot credential is still a tenant compromise, met by detection and kill switches rather than prevented. Four facts stay out of every safety case until answered: the boundary for Cloud Run invocation, the Admin console access level (P7), the deny spelling (P8) and the engine identity constraint (P4).

Read next:

- [page 04](#);
- [HLD §4](#) and [§11.4](#);
- [page 07 §6.5](#);
- [Wall-E's account hygiene set](#) and [Eve's Workspace robot](#);
- [the Super Admin decision record](#).

9. Registry, governance and the autonomy contract

What this chapter explains

By the end of this chapter the reader knows why the platform's inventory of agents is a YAML file in git rather than a Google product, how an agent that bypassed that file is found, and what an agent must pass before it reaches production. They know how autonomy becomes versioned data that only humans raise, on evidence a machine recomputes, and anyone with standing lowers in seconds, and what that costs in independence at Tier W.

The chapter answers two risk themes of Chapter 3, The problem and its risks: **shadow and third-party agents**, and **autonomy outrunning evidence**. Tiers and the factory are Chapter 7, Landing zone and the tier model; principals, the drift job and kill switches are Chapter 8, Identity, privileged access and the fleet kill switch; the heartbeat proving an agent feeds the SIEM is Chapter 11, Monitoring, detection and incident response.

Four things that are not each other

Four artefacts have confusable names ([registry page §1](#)).

- **The register:** one YAML file per agent under `platform/agentic-platform/register/`, the inventory of record. The owner proposes; the platform owner approves, joined by the security reviewer from Tier W and the DPO at Tier P. CI refuses to build anything without a row.
- **The registry:** Google's Agent Registry, one `Service` resource per agent, MCP server or endpoint. It is the governed view and the discovery surface, written only by CI from the register.
- **Independent observation:** what Google's services say exists (Cloud Asset Inventory, Security Command Center's AI asset inventory, the Gemini Enterprise app's agent list), written by no agent owner.
- **The manifest:** `agent-manifest.yaml` in the agent's repository, stating what the agent is allowed to be, hashed into the register row.

A row without a manifest is a Tier C or Tier R agent with nothing to ceiling; a manifest without a row fails CI; an entry or engine with neither is a shadow agent.

Why the inventory of record is a git file

The Google facts behind the choice

Four facts, re-verified on 2026-09-13, stop Agent Registry from being the record ([registry page §2.1](#); [platform HLD §5.1](#)). Its IAM is **project-level only**, so an editor can alter every entry, including the `readOnlyHint` and `destructiveHint` annotations Google itself warns about. **Automatic registration lands only in the runtime's own project**, so a central inventory needs manual cross-project registration. **No organisation policy can require registration**. And the SCC AI asset inventory **holds no owner and no classification**, the first things a TISAX assessor or the EU AI Act asks for.

Two more facts shape the details: the `Service` resource has no labels field, and the agent framework treats a card fetched from the registry as trusted configuration, so a registry write carries the weight of a deploy. A good view, then, and a poor record.

One shared registry, written only by CI (P71)

P71, proposed, chooses one shared registry, over per-agent or per-tier ones, in `CORE_PROJECT`, `europa-west1`, since manual registration is refused in the `eu` and `us` multi-regions ([registry page §2.2](#)). `CORE_PROJECT` holds no agent principal, the only place a project-level registry role is safe.

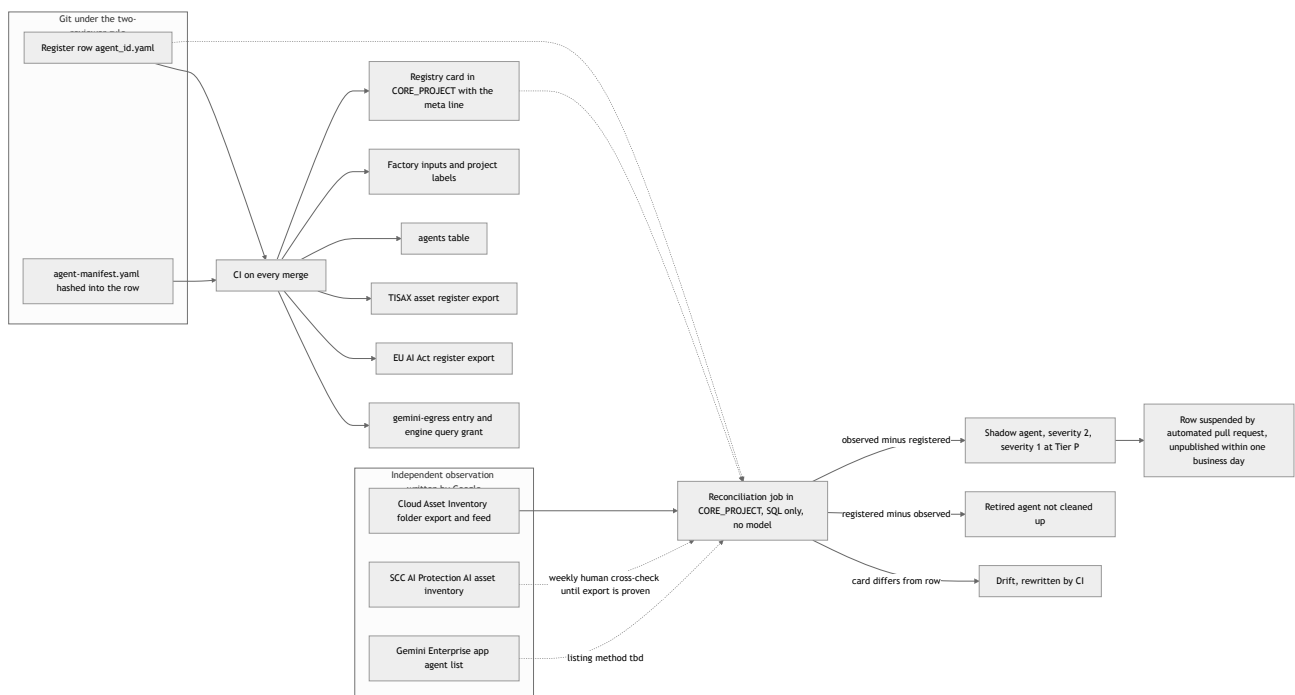
Agent projects never enable `agentregistry.googleapis.com`: it is absent from every tier folder's service allow-list, so automatic registration has nowhere to land. That rests on an **Assumption**: Google does not state, that automatic registration needs the API in the runtime's project. A nonprod spike at the first factory run tests it, and that an engine and its gateway still work with the API disabled; if either fails, a CI-generated working-set registry per agent project is added by a dated register row. The one other registry by design is `gemini-registry` in `GEMINI_PROJECT`, the tenant gateway's working set, never an inventory. The default quota is 100 entries per type per project; an increase, requested at 60 % occupancy, is not guaranteed, and per-tier-folder registries are the fallback. No agent principal reads the registry.

The rule under all of it: **registration never authorises**. A card lets a peer find an agent; reaching it needs a resource-level grant, a gateway entry and an access-policy binding, each generated separately.

The register

One row, many outputs

Nothing about an agent is typed twice. On every merge CI generates the registry card, factory inputs and labels, the `agents table`, the TISAX asset register export, the EU AI Act register export and the `gemini-egress` entry; every day the row is compared with what Google observes.



Mandatory fields, status and review

A CI schema check fails the merge on a missing mandatory field ([registry page §3.2](#)). The groups matter more than the list: an immutable `agent_id`; a declared intended purpose signed in the merge commit, the EU AI Act anchor; owner and cost centre; tier and classes (TISAX class confidential by **Assumption**: until the organisation's scheme exists); model pin, gateway and principal; from Tier W a named grader with declared hours, a `verifier_owner` outside the administration line of the agents verified, the manifest hash and contract version. `privilege` is none below Tier P, and CI fails a second `super_admin` row while one is not retired. Tier X rows exist only to be refused: ceiling pinned at L0, never published.

The lifecycle is `idea`, `poc`, `pilot`, `prod`, `retired`, plus **suspended** (P74, proposed): set on a `pilot` or `prod` row by the reconciliation job or an incident, left only by a human pull request to `prod` or by retirement. Every `review_date` is at most 90 days ahead and an expired row loses its share until reviewed; every row with

privilege other than none is reviewed quarterly by the security reviewer against the signed super-admin roster ([platform HLD §5.3](#)).

The card metadata line (P72)

With no labels on the entry, **P72, proposed**, writes a fixed first description line, `meta:` with the row's key fields and `register_sha`, the hash of the merged row ([registry page §3.1](#)). "Card differs from row" becomes one string comparison: the row wins and CI rewrites; a rewrite by anyone but CI is a severity-2 write alert first.

Finding shadow agents

The sources

The job compares register and registry with three observed sources ([registry page §6.1](#)). Cloud Asset Inventory lists engines and Cloud Run services, exported daily and followed by a feed; the registry is read directly. Whether the SCC AI asset inventory can be exported or read by API is unverified, so a human reads it weekly until proven. The Gemini Enterprise listing method is *tbd*; meanwhile the app administrator files a nightly console export and the gap is recorded.

The job is a second schedule of the drift job under `platform-drift@CORE_PROJECT` (P73, proposed): daily in full, within 15 minutes of a feed event incrementally, SQL only. Reusing that principal avoids a second folder-level exception; two added role names are unverified until the factory run.

What each difference means

An engine, agent-shaped service or app agent with no row is a **shadow agent**: severity 2 at Tiers C to W, severity 1 at Tier P, unpublished within one business day ([registry page §6.2](#)). If its project has no `agent` label the factory was bypassed, and the job cuts the project's invoke or query grant; otherwise an automated pull request creates the row as `suspended`. A registry entry with no row is a shadow card, which CI deletes. A console agent with no row is a shadow Tier C agent; a builder's second occurrence removes them from the builders group. An asset SCC sees outside the folder gets no automatic action, since agents living under the folder is policy, not constraint. The same run finds empty `prod` rows, overdue reviews, silent agents, binding drift and Tier W verifiers without a recent seeded-fault record. Results are insert-only for 400 days and go to the SIEM; while a Tier P row exists, the job's heartbeat also reaches the witness organisation.

Why detection-grade is acceptable

No organisation policy can require registration, so the control is **detection-grade, stated as such**. It suffices because what an unregistered engine needs to be useful, a `gemini-egress` entry and a query grant, is generated from the register. A shadow agent can exist; it cannot be published or called through the platform.

Governance policies

The registry policies make "only CI writes" a mechanism ([registry page §4](#)). The routine factory identity alone holds the registry admin role; editor and user roles go to nobody; repair is a one-hour PAM entitlement the security reviewer approves. Every write not made by CI alerts, drilled monthly by a nonprod console edit that must page within five minutes. Reads are logged under P80, proposed, unverified until the canary's first run because Google's pages disagree (Chapter 12, Data, logging, retention and sovereignty). Cards are refused if a skill names a write, approval or control operation, and the action service has no registry client, so nothing in the registry changes what an agent may do.

Semantic Governance never sits on an authority path. It is Preview and Google warns its verdicts may be inaccurate. A gateway may use it as an extra refusal, which costs nothing when wrong; it never approves and its verdict is never evidence. Wiring it into approval is refused at admission, or severity 2 and reverted if found later.

Admission and revocation

The admission gate

Admission is one CI run in `CICD_PROJECT` whose code owners are the platform owner and IT security ([registry page §7.1](#)). After the row and manifest are reviewed and merged, the pipeline continues only if the baseline is applied, the row validates, the image is attested or the bundle hash recorded, the card registers, the compliance entry exists, the first heartbeat reaches the tier's desk within 30 minutes (Chapter 11), the gateway is bound, the floor conformant and bindings match peers []. From Tier W it also needs a restore drill, a validator-signed manifest and a seeded-fault record younger than 30 days ([platform HLD §5.3](#); [registry page §7.1](#)). Only then does CI grant the query right, add the `gemini-egress` entry and set `pilot`; sharing is a human act through PAM, and who registers the agent in the app is disputed between two canonical pages (Chapter 6, The Gemini Enterprise environment). A failed step stops everything after it. `pilot to prod` is a human pull request whose scorecard the validator recomputes.

Revocation and suspension

Retirement is the factory's `revoke` (Chapter 6), ending with project deletion scheduled at 30 days and the **TISAX 5.3.3 return-and-removal row** written ([registry page §7.2](#)). The row stays in git as `retired`, the platform's history of agents. Suspension, which any operator may trigger, removes reach, halts Tier W and above and deletes nothing. A revocation or suspension not confirmed within 15 minutes is severity 1, then a manual project cut-off, then the fleet kill switch on the tier folder (Chapter 8).

The compliance registers are exports

The TISAX agent register and the EU AI Act register are CI exports of the register, regenerated on every merge and never hand-edited, so neither can drift from what runs ([registry page §8.1](#)). The TISAX export serves ISA 1.3.1, 1.3.2 and 5.3.3, with protection need derived by the ISMS's mapping as an `Assumption:`, and attaches the reconciliation job's zero-difference report.

P75, proposed, makes registration a production gate ([registry page §8.2](#)): a row claiming the Art. 6(3) derogation or classed high-risk cannot carry `status: prod` without an Art. 49 registration id, and a derogation row also needs a dated Art. 6(4) assessment. On 2026-09-13 Wall-E's row claims the derogation with registration `pending`, so Wall-E cannot reach production, and cannot write, until it is registered. A reclassified `prod` row is suspended until the new class is met. Whether an id still resolves is a quarterly review item, as no EU database API is known (unverified). Classification is Chapter 20, EU AI Act.

Autonomy as data: the ladder's fleet rules

The eight rules

Wall-E's ladder is adopted unchanged as the platform's ([Wall-E ladder §1](#)). Autonomy belongs to a family and trigger pair, never to an agent. Humans raise, machines lower. One notch, one family, on evidence. Reversibility outranks risk tier. Every level is enforced in the action service, which never tells the agent why. Every write is verified by re-reading. No level is silent. Time alone promotes nothing.

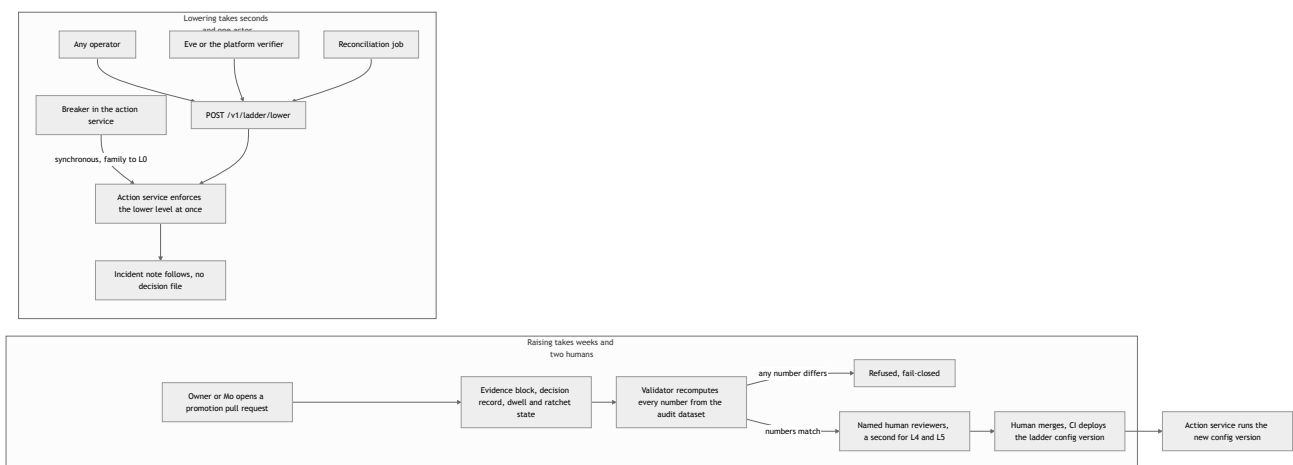
Six levels, four trigger classes and the agent column

L0 is off; **L1** shadow evaluates everything and never executes; **L2** proposes, with no execution path; **L3** executes on a named human's approval within four business hours or skips; **L4** executes after a verifier signs with its own key and a veto hold window passes; **L5** executes and is verified independently within 60 minutes ([Wall-E ladder §2](#)). There is no L6: "execute and tell nobody" is a defect.

Triggers are **T0 chat** (an authenticated human), **T1 scheduled**, **T2 event** (Google's payload, possibly an attacker's cause) and **T3 inbox** (attacker-controlled text, proposals only, permanently); each climbs independently ([Wall-E ladder §3](#)). A separate **agent** column governs callers that are other agents, by the peer rule below.

The raise-lower asymmetry

Raising needs a pull request, a dated decision record and a new config version, one notch at a time, with a second named human for any L4 or L5 promotion ([Wall-E ladder §6](#)). Lowering is one call to `POST /v1/ladder/lower` by any operator alone, the verifier, a breaker or the reconciliation job, with paperwork after. There is no raise API, and no agent touches its own ladder. The per-actor matrix is Chapter 18, How the three work together.



Dwell, the ratchet and one notch

Dwell before raising is two weeks to L2 and to L3, four to L4, six to L5; a demotion on any trigger restarts it for the family on every trigger, because the defect lives in shared code. **The ratchet**, after any automatic demotion, requires five business days at the lower level, a written root cause the validator checks exists, and a fresh decision record, with no false-positive exception. **One notch** forbids skipping above L3 and permits a skip below only on evidence cited by fingerprint and sample size; a new operation enters at L0. Mo computes all three from `ladder_events`, which reads `not_computable` until that table exists (Chapter 17, Mo, continuous improvement). Where the incident note lives is open ([open decisions §7, row 12](#); the one incident record is Chapter 11).

Ladder severity and automatic demotion

Severity 1 — an effect on a protected principal or out-of-scope target, an interactive robot login, a forged or agent-posted approval, an operation outside its frozen plan — halts writes, stops every autonomous trigger, sets every write family to L0 and freezes promotions for 30 days ([Wall-E ladder §9](#)). **Severity 2** — verification drift, a budget cap hit, an overturned verifier approval, a run outside its window — sets the family to L0, pauses the trigger class and freezes promotions for 14 days. **Severity 3** — a policy rejection, an unexplained failure, an audit gap — lowers the family one level. The error budget for a wrong autonomous write is zero. The pages disagree on drift: the severity table sends it to L0, the metric breach response one level down with an incident ([Wall-E ladder §9](#); [Mo metrics contract §7.2](#)). Platform detection severities and paging are Chapter 11.

The autonomy contract

Four artefacts, one version (P76)

Any Tier W or higher agent inherits the ladder by conforming to four artefacts ([registry page §9.1](#)): the **manifest** (§9.2); **ladder.schema**, typing the ladder config; **audit.schema**, the write-ahead, insert-only dataset carrying the correlation keys, the caller's verified principal type and the denial vocabulary `p:<reason>`, which agents extend but never redefine (§9.4); and the **validator**. The P76 register row lists `ladder.yaml` as the fourth where the section lists the validator.

P76, proposed, stamps a semantic `contract_version` on all of them; the current and previous major are accepted for 90 days, after which older rows are suspended, and audit columns are only ever added. The validator signs each manifest's hash with a key in `VALIDATOR_PROJECT`, and the action service's ceiling module, compiled from that signed artefact, refuses to start on a mismatch: the gate cannot be part of what it gates.

Defaults an agent may only tighten (P77)

P77, proposed, makes Wall-E's numbers (ceilings, dwell, ratchet, interval gate, blind sample, severity table, approval TTL, two-human rule, fingerprint reset above L3) fleet defaults an agent may only tighten, checked as a monotone comparison ([registry page §9.5](#)). The L4 hold window is *tbd*. Some rows are code: `WRITE_HIGH` never reaches L5; any `SUPER` operation is permanently L3 on chat under a two-person rule, L0 elsewhere and never in a playbook; inbox never writes. **Loosening a default is a platform decision the security reviewer signs**, never a manifest or page edit ([open decisions §1](#)). The gate statistics are Chapter 17's; Wall-E's ceilings are Chapter 15, Wall-E, the doer.

The validator custodian

One validator sits in `VALIDATOR_PROJECT`, owned by the security reviewer as custodian, run as a required CI check, deployed by digest ([registry page §9.6](#)). It reads every agent's audit dataset, and Eve's quality dataset if P30 (proposed) holds. For a promotion it re-executes the evidence against the agent's own audit data, never Mo's output, re-draws the blind sample and checks dwell, ratchet, decision record, two reviewers and, above L3, a recent restore drill. It is **fail-closed for raises and irrelevant for lowering**; golden fixtures and a monthly poisoned-bundle drill catch it drifting towards agreement.

The Tier W platform verifier (P79)

Eve is a hand-written second implementation of Wall-E's predicates at six engineer-days, which does not scale to hundreds of agents. **P79, proposed**, gives Tier W a platform verifier of Eve's deterministic shape with predicates compiled from the manifest ([registry page §9.8](#)). It still catches code bugs, tampering, forged approvals and widened ceilings. It **cannot catch a wrong specification**, such as a mis-tiered family, because it believes the manifest the owner wrote. Four compensations follow: a security-reviewer signature on family changes, the blind human sample, a monthly seeded-fault suite, and a differential test that catches compiler bugs and says it catches nothing else. A Tier W cell may sit at L4 only while a seeded-fault record younger than 30 days exists. Tier P keeps a hand-written Eve; Tier X has no verifier and every cell at L0.

The fleet-wide peer rule (P78)

A caller over an agent protocol is principal type `agent`, identified from the gateway's authenticated context ([registry page §9.7](#)). **P78, proposed** (bindings at Tier R, writes at Tier W), fixes it in the schema: **L5 for reads, L0 for every write, tainted on receipt**. A peer's write is refused before the ladder is read; a peer's reply is data, never evidence. Egressor bindings come only from `peers[]` and run 30 days in dry-run before enforcement. Since every agent applies the rule, no chain of agents turns a reader into a writer.

What remains

Chapter 19, Threat model and residual risk, tests these answers against what the design leaves open: shadow-agent detection stays detection-grade with two sources unproven; P71 waits on its spike and quota increases are not guaranteed; at Tier W a wrong manifest is caught only by human review and blind grading, capacity for which caps the tier (P25, Chapter 14); the EU database cannot be checked automatically; and the drift-severity and incident-note inconsistencies await the propagation stage.

Key decisions and what to read next

Key decisions

- **P71 — proposed:** one shared registry in `CORE_PROJECT`; no local registries; spike pending.
- **P72 — proposed:** card metadata in the description's first line.
- **P73 — proposed:** reconciliation under the drift job's principal.
- **P74 — proposed:** `suspended` and "registered implies feeding" as a continuous invariant.
- **P75 — proposed:** compliance registers as exports; no `prod` for a derogation or high-risk row without its Art. 49 id.
- **P76 — proposed:** contract versioning, 90-day N and N–1 window.
- **P77 — proposed:** tighten-only fleet defaults.
- **P78 — proposed** (bindings at R, writes at W): the peer rule.
- **P79 — proposed:** the Tier W verifier, its compensations and the L4 cap.
- **P80 — proposed:** registry read logging.
- **P25 — open:** the Tier W cap by grading capacity. **P30 — proposed:** validator read on Eve's quality dataset.

Canonical pages to read next

- [Registry and autonomy contract: §6.2, §7.1, §9.8](#)
- [Platform HLD §5.2, §12.1, §12.4](#)
- [Wall-E autonomy ladder §6](#)
- [Monitoring page §4](#)
- Next in the brief: Chapter 10, Agent Gateway, Model Armor and the perimeter.

10. Agent Gateway, Model Armor and the perimeter

What you will understand by the end

Which traffic is screened where; which screens enforce and which only produce evidence; why an outage of Agent Gateway or Model Armor stops agents on purpose; what the gateway does not see; how Model Armor is governed so no agent owner can weaken it unseen; and why the perimeter around credential holders is a spike to pass before it is a claim to make. Grades are those of Chapter 4, The principles: placement and failure mode, not accuracy.

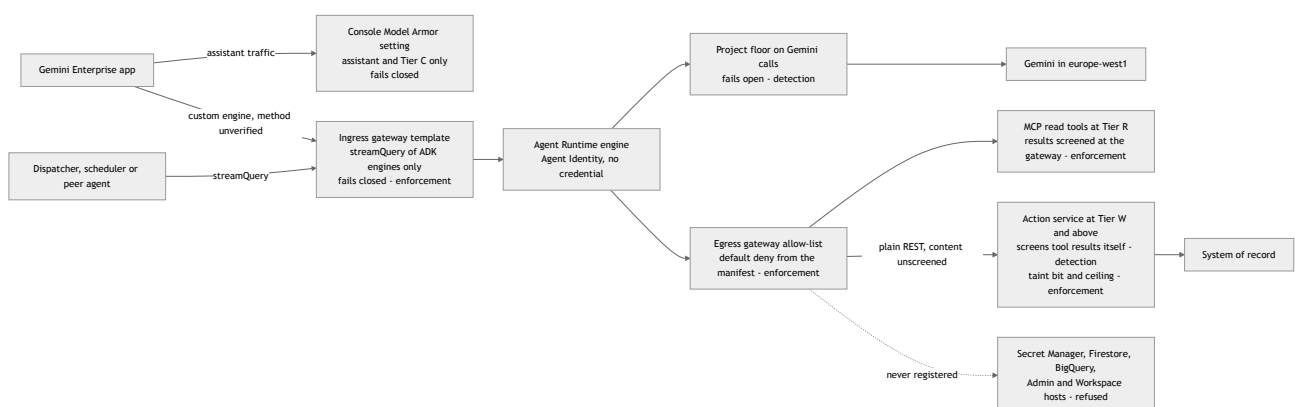
Of the risk themes in Chapter 3, The problem and its risks, this chapter answers part of three: tenant compromise through the robot credential (injected content steering the agent beside the credential; an internet-reachable credential holder), shadow and third-party agents (an unbound engine, an undeclared tool host) and manufactured silence (a floor lowered unnoticed). Nothing is built on 2026-09-14; Google facts were read on 2026-09-13 and are sourced on the canonical page (06 §8).

Why screening exists: the injection surface

Hostile instructions arrive with what a run reads, not with how it started. Wall-E's design inventories every channel through which attacker-writable text reaches a model (wall-e 11 §1), and every Tier W and higher threat model fills in the same template: the operator's prompt, documents, tool results (anyone who can set a display name writes to the model), the robot's mailbox, peer agents' output and the session history.

No prompt can be a boundary (Chapter 19, Threat model and residual risk). The answer is structural: the model holds no credential, and a run that reads attacker-writable content is tainted and capped (Chapter 15, Wall-E, the doer). Screening adds a block in front of the model on the one channel screenable before it runs, evidence joined to the audit row, a flag for the approver, and sensitive-data catches in both directions. It never carries a safety case: a classifier Google calls possibly inaccurate cannot guard a credential that can suspend an employee.

The screens on one request



The only fail-closed screen in front of the model is the ingress gateway, and it sees only `streamQuery`; the screen on the model call fails open.

The gateway rule

Egress: bound at creation, denied by default, generated

Every Agent Runtime engine above Tier C is created bound to its project's egress gateway (06 §2.1). Two folder custom constraints refuse an engine bound elsewhere, and daily reconciliation treats an unbound engine as severity 2, unpublished within one business day. Google allows one gateway of each kind per project-region, one of the facts forcing one project per agent (Chapter 7, Landing zone and the tier model). Bound engines must postdate 2026-04-29 and cannot have revisions, so promotion is an attestation.

The binding is not yet enforcement-grade: `ReasoningEngine` is missing from Google's custom-constraint supported-services reference, so the constraints start in dry run and the CI check is the control, graded detection, until a throwaway engine is refused in nonprod (spike P4).

The allow-list is generated from the register row and manifest, never hand-written (06 §2.2): the agent's own action service from Tier W, the essential Google endpoints (one versioned value, since wildcards are unsupported), and the exact hostnames of declared MCP servers and read APIs, each with a supplier row. What matters most is what is absent: Secret Manager, Firestore, BigQuery, the Admin API, every Workspace host and every other agent's action service, a second enforcement point for "the agent can read no secret". Nonprod gateways start in dry run to inventory what an agent really calls; prod enforces from the first deploy (a per-agent prod dry run was rejected as an unscreened window per agent), and a destination seen only in nonprod is a finding against the manifest, never a reason to widen prod. `gemini-egress` is the one exception (Chapter 6, The Gemini Enterprise environment). Kill switches, halt reads, reconcilers, sinks and task deliveries never pass a gateway, so an outage never disables stopping an agent.

Ingress: machine-called engines, fail-closed, `streamQuery` only

An engine is machine-called when anything other than a human in the tenant app may invoke it, as the register row's invoker list says (06 §2.3). Tier R agents published only in the app are egress-bound only; Tier W and above always have both gateways. The ingress gateway's Model Armor runs with `failOpen` false and a one-second timeout. It screens only `streamQuery` of ADK engines, so every machine caller must use `streamQuery`: CI checks callers, the dispatcher library offers nothing else, and a `query` call is severity 3 because it silently removes the only enforcement-grade prompt screen.

Two limits. IAP is unsupported at ingress, so the gateway screens content while IAM decides who calls, through a query-only role bound on the engine to named callers. And whether Gemini Enterprise itself uses `streamQuery` is unverified; the first machine-called nonprod engine reads it from the request log, and a `query` answer becomes a dated residual raised with Google.

What binding costs: Agent Platform Threat Detection

A gateway-bound engine forgoes Security Command Center's Agent Platform Threat Detection, a Preview, Premium-tier runtime detector (06 §2.4). The platform chose the gateway in every prod tier: at Tier R default-deny egress enforces and there is no credential to escalate; from Tier W the model-free verifier, behavioural baselines and, at Tier P, the super-admin detections cover the loss. The detector runs on at most one unbound nonprod engine per tier folder for at most 30 days, with no production credential: a learning window, revisited when the products become compatible or the detector reaches general availability (P82).

An outage stops agents, by design

Hundreds of fail-closed agents share one Google dependency, so gateway plus Model Armor is run as one availability domain (06 §2.5). The SLO is Assumption: 99.5 % monthly successful screened invocations per region, measured by a nonprod probe engine per region every five minutes with a benign and a hostile prompt; two failures in a row page the platform owner at severity 3 (P83). Both Model Armor quotas alert at 70 %, because a quota error stops an agent like an outage. The platform never flips `failOpen` to recover: a stopped

agent leaves an audit row, an unscreened one leaves nothing trustworthy. The runbook confirms with the probe, opens a Google case and tells owners their agents are stopped on purpose. The price is that the first fail-closed write agent is the first an outage stops.

What the gateway does not screen

The egress gateway's Model Armor sanitises MCP `tools/call` and `prompts/get`, A2A messages and agent cards, and model calls in the common chat-completions format; Google says anything unlisted passes unsanitised (06 §2.6). Plain REST is not screened, so a hostile display name returned by a REST tool reaches the model past every gateway screen (wall-e 11 §3).

The pattern is per tier (P88). Tier R read tools go over MCP through the gateway, so results are screened outside the agent's process, fail-closed; a REST read API needs a supplier row and a reason. From Tier W, tools are REST calls to the agent's own action service, which screens every attacker-writable field before returning it, inspect-only so a hostile profile cannot deny a legitimate read; a match sets the taint bit. The screen is detection by placement; the taint bit, turned into a cap by the ceiling module, is the enforcement. Exposing an action service as an MCP server is a per-agent Stage 3 choice once two open questions close, never a platform default.

Model Armor

Layers and grades

Model Armor sits at several points, and treating them as one control is the error to prevent (06 §3.1). The ingress gateway template is the enforcement-grade path for prompts, if callers use `streamQuery`. The egress template enforces on what it sees: all of Tier R's tool surface, none of a REST action service's. The project floor applied inline to Gemini calls is fail-open, since Google skips sanitisation and continues when Model Armor is unavailable, so it is detection-grade in every mode, `INSPECT_AND_BLOCK` included; its value is the sanitise log, and whether it inspects function responses is unverified. The floor's conformance check enforces one governance property, refusing weaker templates, and does not check Sensitive Data Protection. In-code configuration and ADK's in-process plugin are never counted; Semantic Governance, in Preview, is never on an authority path. And a classifier is never a trust boundary, whatever its grade.

The floor hierarchy

Google defines template conformance at organisation and folder level and inline enforcement only at project level, and a lower floor overrides a higher one, including a project floor set to disable (06 §3.2). "Never looser" is therefore a property of who can write a project floor and how fast a write is seen, not of the hierarchy.

The organisation floor requires prompt-injection and jailbreak at HIGH or stricter, malicious URL, logging and multi-language detection; the platform folder adds Responsible AI; the W, P, P-SA and controller folders tighten prompt injection to the level measured on each tier's benign corpus. All three govern template conformance only. The pages differ on ownership: the HLD gives all three to IT security, held by the platform owner meanwhile (HLD §6.2), page 06 only the organisation floor, with folder floors to the platform owner (06 §3.2); the handover date is *tbd*.

Inline enforcement is a custom project floor the factory's privileged phase writes into every agent project, never inherited or disabled: `INSPECT_ONLY` at Tier R and before measurement, `INSPECT_AND_BLOCK` at W, P and controllers after it, always at P-SA (P84). Inspection comes first because blocking on a fail-open path buys no safety case and costs benign refusals. Integrity is the enforcement: the folder deny policy (Chapter 8, Identity, privileged access and the fleet kill switch) refuses floor updates to agent principals, the role is granted only through Privileged Access Manager, and a daily drift compare makes any unauthorised difference severity-1 drift, with P-SA writes held at L0 until the floor is re-applied.

The template standard and the silent skip

Templates are regional in `europa-west1`, a prompt and a response template per engine, generated from one module and diffed by CI; owners may only tighten (06 §3.3). They carry what floors cannot check: Tier R adds basic Sensitive Data Protection, W and P a de-identify template so the sanitise-log copy is masked, and P-SA custom detectors for the hard-denied vocabulary, a detection-grade screen behind the action service's list, which enforces. An advanced template must re-list credential detectors or lose them silently; a regression case checks. Page 06 does not yet name the de-identify templates the data page defines, an open difference (register row 13; 06 §3.3, 08 §6.3) owned by Chapter 12, Data, logging, retention and sovereignty. Templates flip from `INSPECT_ONLY` to `INSPECT_AND_BLOCK` in prod by pull request once the tier's false-block rate on its benign corpus is below a threshold (Assumption: below 1 %) (P85).

Each filter has a token limit, 65,536 for prompt injection, Responsible AI and CSAM and 130,000 for Sensitive Data Protection (HLD §3.4). Above it the filter returns `EXECUTION_SKIPPED` with no error, so a long history passes unscreened while dashboards stay green; an alert on that verdict makes the skip visible.

Seeing writes, and where findings go

A floor write is a change window or an incident (06 §3.4). Admin Activity entries raise a log-based alert, and a SIEM rule from Tier P: severity 2 outside a ticketed Privileged Access Manager grant, severity 1 at Tier P for any writer but the platform's Terraform identity. The method name is an Assumption until seen at the first factory run, and Security Command Center's coverage of floor writes is unverified, so the log alert is the control (P86). Verdicts feed the monitoring baseline of Chapter 11, Monitoring, detection and incident response, and never demote an agent automatically. Findings reach Security Command Center as metadata; payloads stay in sanitise logs in each project's restricted content bucket, which the factory creates before the template (06 §3.6).

The console setting (P53)

Tier C agents have no gateway; for them, the assistant and uploads, the only prompt screen is Model Armor on the Gemini Enterprise app, configured per app (06 §3.5). The platform sets a template from the Tier C standard, failure mode Block, applied through Privileged Access Manager; a switch to Allow needs an incident reference and is detected. A daily drift check asserts the setting on every app; an app without it is severity 2. Google does not screen custom ADK, A2A or Dialogflow agents, so the setting covers Tier C only and the admission gate refuses a higher-tier safety case that cites it. P53 and its refinement P87 are proposed.

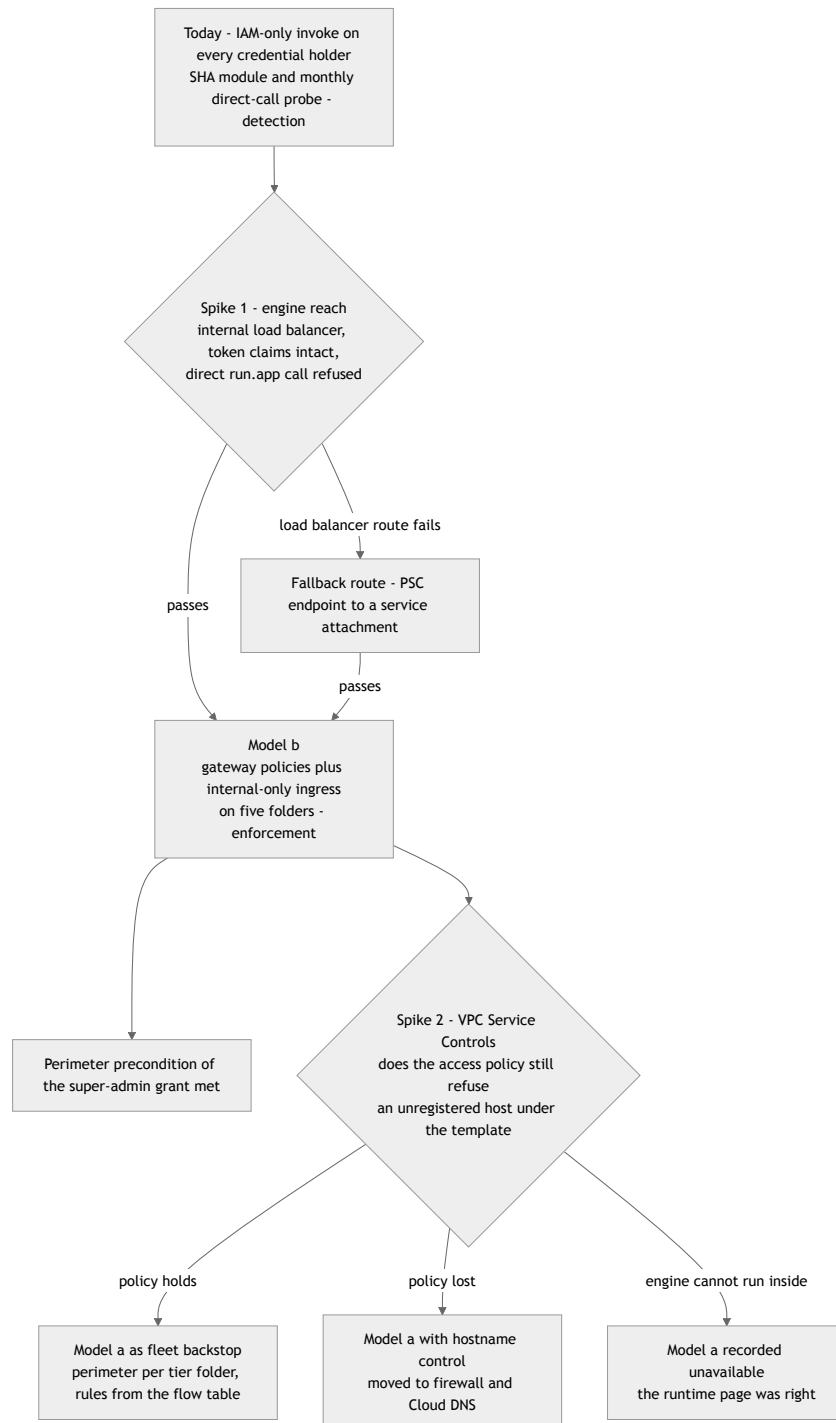
The perimeter

Why the deferral ended, and what Google says

A perimeter could wait for an agent that made no writes and held a narrow role; Wall-E's action service holds a Super Admin credential, so the perimeter is P3, a precondition of the super-admin grant (HLD §8.1).

Google's pages disagreed on 2026-09-13 (06 §4.1). The runtime deploy page (2026-09-08) says VPC Service Controls are not supported with Agent Gateway; the set-up page (2026-09-10) says they are, only for gateways created after 2026-09-08 with an `ALL_TRAFFIC` agent connectivity template, which cannot be added to an existing gateway. A sentence denying VPC Service Controls support for Unified Access Policies could not be re-read. The design's reading, that a template-less gateway egresses from Google's tenant project while an `ALL_TRAFFIC` one egresses through the customer network where a perimeter applies, is a hypothesis.

The decision, in order



Today IAM-only invoke by named principals is the enforced boundary. The action service cannot simply be made internal, because Agent Runtime egresses from a Google-managed tenant project that Cloud Run treats as external.

Model (b), gateway access policies plus internal-only ingress for every credential holder behind an internal load balancer, is adopted the day P3's first spike passes (06 §4.2). The spike passes if a bound engine reaches a stand-in action service through the load balancer with ID-token claims intact, a direct `run.app` call is refused, and the gateway log shows only the registered destination; a Private Service Connect endpoint to the load balancer, the route the HLD names, is the fallback. "Perimeter decision taken" in the tier gate means (b) applied, not (a) live.

Model (a), VPC Service Controls per tier folder, is the fleet backstop after spike 2, which passes if the gateway's access policy still refuses an unregistered host inside an enforced perimeter while out-of-perimeter egress raises a violation; its decision record will name which Google page was right. So that (a) stays reachable, Tier W and higher prod gateways are born with an `ALL_TRAFFIC` template if spike 1 passes on it, at one VPC, subnet, Cloud NAT and DNS zone per project (P89).

Credential holders are never internet-reachable (P90)

No credential-holding Cloud Run service (action services, Eve's gate and reconciler, the approval surface) accepts internet ingress (06 §4.3). The folder constraint on the W, P, P-SA, controller and platform-core folders is held in Terraform and applied the day spike 1 passes. Until then it is detection: a Security Health Analytics custom module flags ingress `all`, a monthly probe calls each `run.app` address expecting refusal, and a violation is severity 2 rolled back by CI.

Under model (a): the flow table and the position per tier

One perimeter over the whole folder would put verifier and verified inside one boundary, so (a) is a perimeter per tier folder, prod and nonprod apart (06 §4.4). The crossings are finite and listed once, from the tenant app querying engines to Eve's export to the witness; Workspace calls stay outside the perimeter by design. That table generates every rule, anything else is refused, and enforcement follows 30 days of dry-run logs (P91). On 2026-09-13 (06 §4.5) Tier C relies on the app, console setting and `gemin-egress`, Tier R on default-deny egress, and Tier W and above on IAM-only invoke pending both spikes.

What this layer does not do

It does not make the floor path enforcement-grade or count gateway Model Armor as a screen on REST tool traffic; it applies no ingress policy before spike 1 and no perimeter before spike 2; it lets no owner loosen a floor, template, egress list or `fail0pen`; and it puts no Preview detector, plugin or Semantic Governance in a safety case (06 §6).

Key decisions and what to read next

Key decisions

Register states on 2026-09-14. Spikes: P3 (spike 1 gates the super-admin grant, spike 2 the Tier W perimeter), P4 (binding constraint grade), P57 (carrying P6, `gemin-egress`). Proposed: P53 and P87 (console setting), P81 (binding standard), P82 (gateway over threat detection, adopted now), P83 (availability domain, Assumption value), P84 (floors), P85 (templates and flip rule), P86 (write alerting), P88 (tool-result screening), P89 (perimeter-ready gateways), P90 (never internet-reachable, applied when spike 1 passes), P91 (flow table). Register row 13 is open.

Chapter 19, Threat model and residual risk, carries from here: tool results from Tier W screened only at detection grade behind the taint bit; a fail-open screen on the model call; the front door's method unmeasured; the binding constraint detection-grade until P4; IAM alone guarding credential holders until spike 1; model (a) possibly unavailable; and an SLO no outage has yet tested.

Canonical pages to read next

- [06, Agent Gateway, Model Armor and the perimeter](#), especially §4
- [HLD §6.1](#) and [§8.1](#)
- [Wall-E 11 §2, the layers](#)
- [The register, before the super-admin grant](#)
- Next: Chapter 11, Monitoring, detection and incident response.

11. Monitoring, detection and incident response

What you will understand by the end

This chapter answers two risk themes from Chapter 3, The problem and its risks:

- **Tenant compromise through the robot credential.** Chapter 8, Identity, privileged access and the fleet kill switch, meets this from the identity side; this chapter meets it with detection.
- **Manufactured silence.** The watched actor switches off what watches it.

It also carries part of a third theme, staffing that makes two-person rules notional, because it decides who is paged about whom.

By the end you will know why detection is the primary control for the super-admin tier, which feeds the platform reads and why the SIEM is a contract before a product, which rules exist and which may stop the fleet, how silence becomes a halt, who is told how fast at each tier, and how an incident runs from the first page to a regulator.

The design of record is [page 07](#). Nothing here is built.

The rule: detection is the primary control for the super-admin tier

Below Tier P, detection proves that a refusal by Google or the platform happened. In Tier P-SA nothing at Google's end refuses `walle@`, the robot account that holds Super Admin, beyond the consented OAuth scope set (Chapter 3, The problem and its risks); every other ceiling is code. For that tier detection is the primary control ([page 07 §0](#)).

Three properties hold throughout this chapter:

- **The store is independent of the actor.** Every severity-1 rule about `walle@` lives in the SIEM and in Eve's projects, never in `WALLE_PROJECT`.
- **Absence is a signal.** Every feed has a heartbeat, and each heartbeat's alarm sits outside that feed's failure domain.
- **Nothing detection-grade stands alone.** Each rule names the enforcement it backs, or says it is the last line. For the super-admin set it is the last line, and the residual risk sits in the deviation signed under P33.

The cost is real: a detection starts a response but does not prevent the first action.

What the platform watches

Four feeds owned by the organisation

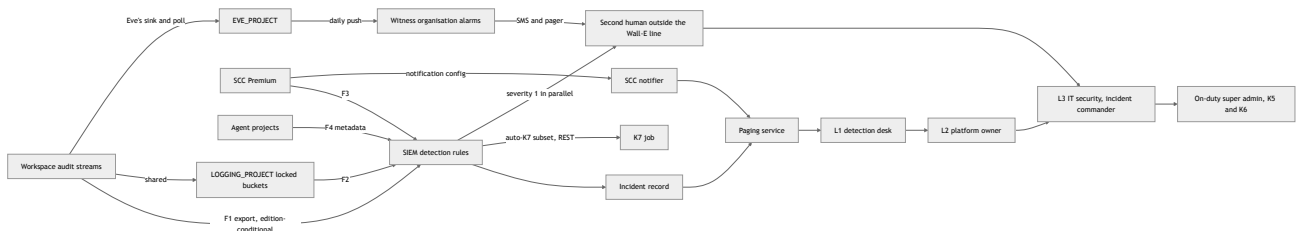
Four feeds reach the SIEM. None uses domain-wide delegation or a service-account key ([page 07 §1.1](#)).

- **F1, the Workspace export.** The Admin console's Google Security Operations export sends every supported Workspace event type, including the streams Cloud Logging never receives. It exists only on certain Workspace editions, and the tenant's edition is `tbd`; it delivers only events after connection, the first data can take up to 24 hours, and a human administrator configures it, never `walle@`. A delegated admin with the Reports privilege can change it.
- **F2, Cloud Audit Logs and the Workspace streams shared with Cloud Logging.** These land in `LOGGING_PROJECT` through the sinks of Chapter 12, Data, logging, retention and sovereignty. Whether the SIEM ingests them directly or through Pub/Sub is unverified. Sensitive Actions cannot read logs under CMEK or outside `global`, so the platform copies Google's `_Required` bucket and never redirects it.

- **F3, Security Command Center findings.** The SIEM ingests these by default.
- **F4, agent-layer metadata.** Each action service publishes its halts, denials, verifications and heartbeat to its project's Pub/Sub topic. Messages carry ids, reason codes and hashes, never a prompt or a payload.

Eve's own copies are not a SIEM feed but the verifier's evidence, exported daily to the witness organisation (Chapter 16, Eve, the independent controller).

Two switches can darken most of this with one click: **sharing options** stops F2's Workspace half, Eve's sink and the Workspace threat findings together; **the export setting** stops F1. The answer is topology. The SIEM and the witness are fed by different paths, so no single switch darkens both.



Security Command Center Premium and Audit Manager

Security Command Center (SCC) is activated at **Premium, at organisation level**. Enterprise is not chosen: it was deprecated on 2026-05-21 and shuts down on 2027-05-21 (page 07 §3).

- **What Premium brings:** Event Threat Detection with the Workspace findings, which need organisation-level activation and so make it a Tier C precondition; Security Health Analytics custom modules; AI Protection; Sensitive Actions; and Agent Platform Threat Detection, Preview and nonprod only (Chapter 10, Agent Gateway, Model Armor and the perimeter).
- **Funding** is P11, open.
- **Residency** is recommended as eu under P94, proposed, once the platform confirms which Cloud Run Threat Detection detectors residency disables, because the location is chosen at activation.

SCC does not page on its own. One notification configuration sends active CRITICAL and HIGH findings to a notifier in CORE_PROJECT, and a weekly synthetic finding proves the path.

Audit Manager runs three frameworks monthly into the evidence bucket: ISO 27001:2022, NIST AI 600-1 Privacy Controls, and Google Recommended AI Essentials. Organisation-level and scheduled assessments are still in Preview, so until GA the run targets the platform folder. A missing report is a drift finding.

The SIEM: a contract before a product

The SIEM choice is **P10, open with IT security**: the organisation's existing SIEM, or an own Google SecOps instance with a managed detection partner. So that the super-admin grant does not wait on procurement, page 07 writes the contract any SIEM must meet to open Tier P (P92, proposed while P10 is open), plus a default the factory provisions if P10 is still unanswered when the rest of the Tier P checklist is green (page 07 §2.1).

The nine clauses, S1–S9, require EU residency, retention to the schedule, ingestion of F1–F4 without delegation or keys, rules in git with replay tests, cases carrying the correlation keys, a 24x7 desk, an outbound REST call to the K7 job, search by principal, and readers administered by IT security with no agent among them. If the organisation's SIEM wins, the rules are rewritten in its language; the ids, tests and runbooks stay the same.

The default is P93, proposed: an own SecOps instance in the **Europe multi-region**, which keeps data in EU member states (page 07 §2.2).

- **Location.** SecOps has no europe-west1 location; europe-west3 is the fallback if the ISMS needs a nameable site.

- **Retention** is ordered at the smallest term of at least 400 days, an Assumption until the DPO decides P13. The SecOps default of 12 months and maximum of 60 are unverified on Google's primary page.
- **Cost.** F1 carries edition-wide Workspace activity, so it is the largest cost line (Assumption), and IT security pays from Tier P.
- **Playbooks** enrich and page. They never act, except for the one K7 call. The outbound identity for that call is *tbd*.

Below Tier P: the honest desk

Tiers C, R and W have no 24x7 desk. Their desk is SCC findings and absence alerts paging the platform owner. The target is "**next business morning**", written down as the honest number (HLD §7.1). The desk by tier as a staffing question is Chapter 23, Operating model.

Registered implies feeding the SIEM

Every agent project receives the **monitoring baseline module** in one of four variants (page 07 §4.1).

Variant	Tier	Heartbeat	Heartbeat absence alarm	Audit-row absence alarm
classical	C	none (no project; the evidence is the tenant app's Data Access log)	—	—
read	R	daily	—	—
write	W	hourly	2 h	4 h
credentialed	P	every 5 minutes	15 min	60 min

The module also brings the Data Access configuration and SIEM feed, span content switched off, SIEM entity registration from the register row, and drift detection.

One step of the admission gate (Chapter 9, Registry, governance and the autonomy contract) is "the first heartbeat landed" (page 07 §4.2): a heartbeat visible under the agent's `agent_id` within the lag budget, a populated entity list and a nonprod forced absence that paged the desk.

The failure that matters comes after admission: an agent that keeps acting while its evidence has stopped. The rule is therefore also a **continuous invariant** (P74 and P95, proposed). Behind the project's absence policies, the reconciliation job checks every production row against a silence budget: 24 hours at C and R, 4 hours at W, 15 minutes at P (an Assumption equal to Eve's own window).

A breach suspends the row by automated pull request and CI removes the agent's egress entry; at W the job also calls `halt_all`, and at P the finding is severity 1. Leaving suspension is a human pull request: machines lower, humans raise. Register row 9 resolves the budgets, once stated on two pages, to one set on page 07 (register §7).

The correlation contract

An investigation crosses a tenant and an organisation, so every audit row carries the same join keys (page 07 §5):

- `agent_id`;
- `invocation_id`;
- `run_id`, which ties the plan, the approvals and Eve's verdict together;
- `trace_id`;
- the human `sub`, a surrogate taken from the Gemini Enterprise `StreamAssist` log;
- the Workspace `insertId` of the resulting admin event.

Four committed queries use these keys, starting from a complaint, a Workspace event, an SCC finding or a page, and are timed in every tabletop.

The schema validator refuses a deploy whose audit writer omits a key. A row missing `invocation_id` or `run_id` is a severity-3 `audit_gap`. A robot event with no row at all is Eve's `reconciliation_gap`, and it halts.

The detection catalogue

Detection as code

IT security code-owns the rule files. The security reviewer owns their content, with the managed detection partner joining from Tier P. No agent owner can change a platform or super-admin rule.

A rule without a replayable fixture cannot merge; reviews are quarterly and a rule silent for 180 days is flagged as dead; coverage is scored against a public agent-threat taxonomy that P21, still open, will pick; and tampering with any evidence store, sink, audit configuration, floor, deny policy or the K7 plane is severity 1 ([page 07 §6.1](#)). This is P96, proposed.

The super-admin set

These rules exist because nothing else refuses the robot. They are hosted in the SIEM, never in `WALLE_PROJECT`, owned by IT security and severity 1, and each page reaches the desk and, in parallel, the second human outside the Wall-E line.

SA-01..SA-09, the Workspace side ([page 07 §6.2](#)), cover out-of-catalogue admin methods, admin-role grants, any posture change (the two switches included), interactive logins on `walle@` or `eve@`, foreign-client tokens, roster diffs, robot events with no audit row, unneeded applications and control-group changes. The switches' event names are unverified until observed on a sandbox tenant; until then the heartbeats detect those changes.

SG-01..SG-07, the organisation side ([page 07 §6.3](#)), watch the robot's reach through Organization Administrator (Chapter 16, Eve, the independent controller): IAM on the organisation, folders and core projects; sinks and audit configurations; policy, boundary and floor edits outside a privileged grant; core-project deletion; grants outside a change window; deploys outside CI. Access Approval requests (SG-06) alone are severity 2.

Eve's reconciler mirrors the Workspace rules, which gives two independent evaluators whose agreement is measured. Register row 11 records that Eve's pages do not yet carry six of the HLD's severity-1 rows.

The platform and agent sets

PL-01..PL-15 apply to every tier and gate Tier W ([page 07 §6.4](#)). They cover heartbeat absence, cross-project principals, secret access by agents, Model Armor and gateway changes outside CI, evidence-store and key state, the Data Access canary, and code execution outside the closed tier.

PL-10 holds the tenant-app detections:

- **severity 1:** a fence removed from the Gemini Enterprise app, a robot using `StreamAssist`, or an engine mutated by the Discovery Engine service agent;
- **severity 2:** an unapproved share;
- **severity 3:** four business hours with no `StreamAssist`.

Each agent's own rules (AG-*) stay in its project as the builder's liveness layer. They are listed in the catalogue, and the severity-1 ones are duplicated into the SIEM.

Which rules may pull K7 automatically

A severity-1 SIEM rule may invoke the fleet kill switch K7 (Chapter 8, Identity, privileged access and the fleet kill switch) over plain REST, never through a model, but not every one should: an interactive login on the robot is a Wall-E incident, not a platform one.

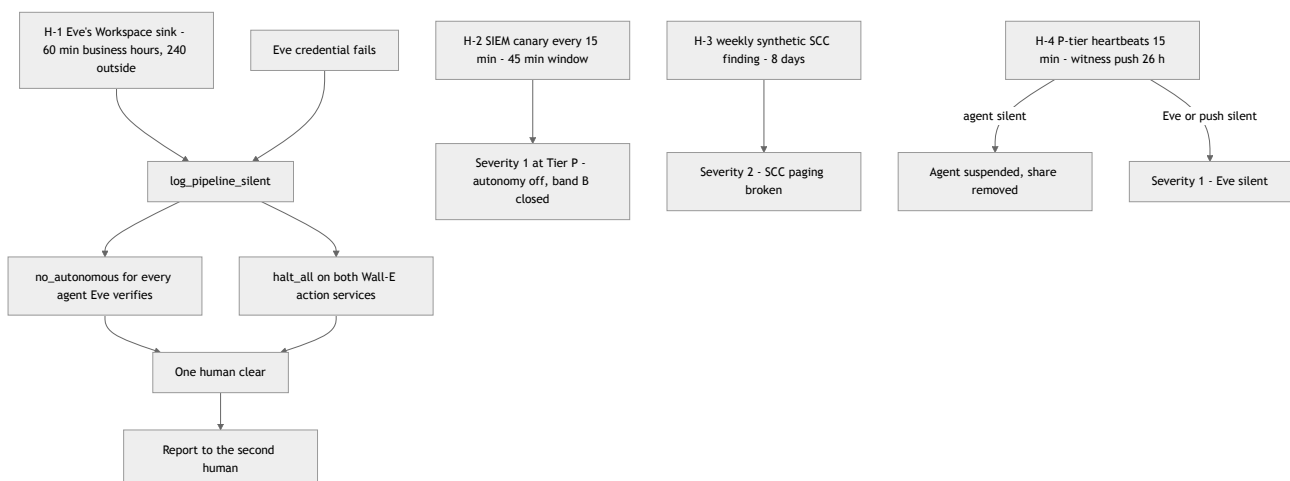
The **auto-K7 subset** covers the rules whose firing means the control plane itself is being altered: SG-01 by the robot or an agent principal, SG-02, SG-03, SG-04 and PL-02. A tampered control plane may be lying about everything else, and stopping the fleet costs only availability. These rules apply KF-1 and then KF-3.

The SA-* rules never kill the fleet. They trigger a K0 halt on the named agent and page a human.

Until the SIEM's outbound identity holds invoker on the K7 job, the subset runs as a dry run that writes a case. A machine may apply KF-1, but only a human may remove it (page 07 §6.5).

Silence becomes a halt

The robot can stop, in one console visit, the stream that every rule reads. The only defence that does not depend on that stream is a heartbeat whose absence alarm sits on a channel the stream's owner does not control. P97, proposed, sets four heartbeats and one credential check (page 07 §7).



When H-1 fires, or Eve's credential fails, Eve's reconciler sets **log_pipeline_silent**. Every agent Eve verifies loses autonomous work, and both Wall-E lanes take **halt_all**. Silence is what a super admin can manufacture, so the default state of silence is a halt, not an alert.

- **What may continue.** Band-A chat work at L3 may continue with a live operator re-check (Assumption; the Eve owner may choose **halt_all** instead).
- **Clearing the halt** takes one authenticated human call, reported to the second human as sole recipient.
- **Where the alarm lives.** H-1's alarm lives in the witness organisation as well as in **EVE_PROJECT**, for the reason Chapter 16, Eve, the independent controller, gives.

H-2 proves that the SIEM can see: a synthetic pair every 15 minutes (its form an Assumption), with receipts watched from outside the SIEM. H-2 missing while H-1 is healthy is severity 1 at Tier P, because the primary control is blind. The Eve owner holds H-1 and H-4, and the platform owner holds H-2 and H-3.

The platform reporting path

A verifier that reports only to the person it verifies is not a control. P98, proposed, makes Eve's contract the rule for every verifier (page 07 §8):

- the verifier's owner sits outside the administration line of every agent it verifies, and admission refuses a Tier W+ agent otherwise;
- severity-1 and severity-2 pages go to that owner in parallel with the desk;
- reports about a human with authority over the agent (level raises, halt clears, privileged grants) go from the witness to that owner alone;
- unacknowledged pages re-page the secondary, then the incident commander;
- three pages a week on one reason code trigger a review, never silencing.

Page 07 leaves one tension open. At Tier W the verifier owner is the platform owner until a second person exists, which sits uneasily with the admission rule. The second human's work is Chapter 16, Eve, the independent controller.

Incident response

Roles, escalation and targets

The roles include the incident commander from IT security, the on-duty human super admin (the only role that can pull K5 or K6), the second human, the platform and agent owners, the desk, the security reviewer, the DPO, communications, HR and legal. Separation holds in every incident ([page 07 §9.1](#)):

- whoever prompted the robot never commands the incident about that prompt;
- the agent owner never pulls K5 or K6 when the owner is the actor;
- a page about the administrator is acknowledged by the second human.

P99, proposed, sets one organisation-owned paging service, `agentic-platform`: IT security's on-call tool if it runs 24x7, otherwise a commercial one, with severity 1 also sent by SMS from the witness. Escalation runs L1 desk, L2 platform owner, L3 IT security; severity 1 pages the second human in parallel and reaches L3 automatically at twice the target. Below Tier P, L1 and L2 are the same person ([page 07 §9.2](#)).

Target	Tiers C–W	Tiers P and P-SA
Severity-1 acknowledgement	next business morning	15 min in business hours, 60 outside (Assumption)
Severity-2 acknowledgement	next business morning	4 business hours (Assumption)
K0 halt	under 60 s	under 60 s
K5 suspend the robot	—	within 30 min of acknowledgement (Assumption)
K6 remove Super Admin	—	within 60 min
K7	KF-1 under 60 s, 5 min end to end	the same

After K4 or K5, a token that has already been issued lives for up to 60 minutes, and every runbook says so. The rota is Eve's `oncall.yaml`. An uncovered rota period halts autonomous writes for the agents the absent person verifies.

One incident record

P100, proposed, keeps every incident in the SIEM's case system. The organisation's ITSM is used only if its cases cannot carry the mandatory fields ([page 07 §10](#)): the correlation keys, levers pulled with times, whether Eve saw it first, the regulatory flags and the decision record to resume.

Eve's incident row and the case are reconciled nightly, because two disagreeing records are what a regulator finds. On severity 1, evidence is snapshotted into the locked bucket before any remediation, and a copy reaches the witness within 24 hours. One inconsistency is still open: Wall-E's ladder page and Mo's artefacts page name an incident-note path that does not exist (register row 12).

Runbooks

Every runbook follows the same sequence: trigger, first 15 minutes, contain, investigate, recover, notify, exit (page 07 §11). The two crisis scenarios drive the design.

- **RB-01, leaked robot token.** The desk pulls K0 and establishes whether the events came through the committed clients (service compromise) or a third client (exfiltration); then K4 and K5, watching the hour a live token survives with K6 pre-staged, and K7 if an organisation rule fired. Recovery rotates both clients, rebuilds the robot, reverses the effects and freezes promotions for 30 days.
- **RB-02, interactive login.** No triage: K0, a human ends the sessions, then K5.

RB-03 to RB-09 cover Eve silent, self-silencing (any silent window longer than H-1's is severity 1), a SIEM outage, an out-of-catalogue action or human anomaly, a compromised CI or forged approval, a provider incident (the fail-closed state is the safe state) and injection reaching a write. Chapter 19, Threat model and residual risk, maps adversaries to runbooks; RB-10 and RB-11 are the regulatory clocks below.

The regulatory clocks

Every severity-1 case closes with two recorded assessments, each with the assessor's name and the time. P101, proposed, defines both (page 07 §12).

EU AI Act, Art. 73. A provider of a high-risk system reports a serious incident within these limits:

- 15 days of establishing a causal link;
- 10 days for a death;
- 2 days for a widespread infringement or an irreversible disruption of critical infrastructure.

The provider must not alter the system before informing the authority, which the evidence snapshot secures. No register row is high-risk today: Wall-E claims the Art. 6(3) derogation, and Annex III applies from 2027-12-02. The taxonomy therefore runs **voluntarily** until any row becomes high-risk.

The classes are:

- mass wrongful suspension, deletion or licence reclaim, which falls under fundamental rights with a 15-day clock (thresholds are an Assumption for legal to set);
- an effect on health, with 10 days for a death and 15 otherwise;
- a band-B error affecting at least three Member States, with a 2-day clock;
- a negative determination on critical infrastructure (Assumption).

The incident commander and legal assess within 24 hours, and the AI compliance owner reports. The entity (P23) and the authority are open. The Act overall is Chapter 20, EU AI Act.

GDPR, 72 hours. The desk flags any severity-1 case touching a personal-data store when the case opens, and awareness counts from acknowledgement. The DPO then works to these times:

- assessment within 4 business hours (Assumption);
- decision within 48 hours;
- filing within 72 hours.

Data subjects are informed where the risk is high.

TISAX 1.6 and the works council. This process meets event reporting, incident handling and crisis management; a human report opens a case exactly as a rule does. Employee representatives are informed before Stage 1 and, where national law requires it (Assumption), take part in the tabletops and receive the review of incidents that affected employees. Chapter 22, Personal data, employees and the works council, has the rest.

Tabletops and SOC metrics

Tabletops are P102, proposed ([page 07 §13](#)).

- **Cadence.** Quarterly until four clean Tier P quarters, then semi-annual. There is one before Stage 1 of the first Tier W agent and one before the super-admin grant.
- **Who runs them.** IT security runs them, never the platform owner. Both K5/K6 rota humans, the desk, the DPO, legal and HR take part.
- **The crisis scenario** is the abused robot credential, RB-01 and RB-02 combined. It runs at least yearly and as the pre-grant exercise.

SOC metrics are P103, proposed, produced **monthly** ([page 07 §14](#)). They cover response times, rule precision and coverage, pipeline availability, audit completeness, agreement between the SIEM's and Eve's evaluators, and regulatory-clock compliance.

The desk produces the platform-wide metrics from the SIEM and the cases, **never from MO_PROJECT**, so the management review sees numbers the improver did not compute about itself. Mo produces the Wall-E and Eve packs (Chapter 17, Mo, continuous improvement). Targets stay *tbd* until three months of data exist.

Key decisions and what to read next

The state of each decision on 2026-09-14:

- **Decided:** P33, which is this chapter's premise.
- **Proposed:** P74, P92 (with P10 open), P93, P94, P95, P96, P97, P98, P99, P100, P101, P102, P103.
- **Open:** P10 (SIEM), P11 (SCC funding), P13 (retention), P21 (taxonomy), P23 (legal entity).

By gate: P11, P21, P94 and P95 before the folder exists ([register §2](#)); P13, P74, P96 for PL-*, P98, P99, P100 and P103 before Tier W ([§3](#)); P10, P92, P93, P97, P101 and P102 before the super-admin grant ([§4](#)).

Still unverified: F2's ingestion path, the SecOps retention figures, the UDM field paths, the switches' event names and the tenant edition. Carried to Chapter 19, Threat model and residual risk: a leaked credential acts until detection and K5 meet it, a token survives up to an hour, and for the super-admin tier detection is the last line.

Read next:

- [page 07](#), in full;
- [HLD §7](#);
- [page 08 §4.3](#) on the Data Access canary;
- [page 04 §9.1](#) on K7;
- [Eve's reporting contract](#) and [page budget](#);
- [Wall-E's severity table](#).

12. Data, logging, retention and sovereignty

What you will understand by the end

This chapter answers the risk theme Chapter 3 calls manufactured silence, where the watched actor re-filters sinks or deletes evidence so that no alert looks like calm. Chapter 11, Monitoring, detection and incident response, turns silence into a halt; this chapter decides where evidence lives, who can shorten it and for how long. It also carries the evidence half of two other themes: tenant compromise through the robot credential, and autonomy outrunning evidence.

By the end you will know where every store is and what class of data it holds, who can silence or shorten the evidence, how long each class is kept and why the locks wait for the data protection officer (DPO), and why the platform does not use Assured Workloads today and what compensates.

The design of record is [page 08](#). Nothing here is built.

12.1 The rule: evidence leaves the reach of the judged thing before it is needed

Chapter 4, The principles, states the primitive: evidence the judged thing cannot forge or silence. Page 08 makes it three working rules ([08 §1](#)).

Every store comes from the factory, from its data class, owner, retention and readers. A store the schedule does not know is a drift finding, and a different number is a pull request on the register row, never a bucket edit.

Evidence exists three times, and each copy fails differently. The agent's own store fails when its project is torn down or its owner rewrites it; the central copy when an organisation administrator re-filters a sink; the verifier's locked bucket and the witness only if Google's retention lock fails. Only the third is preventive; the first two are detective, backed by absence alarms, and the design does not call them immutable.

Retention is decided once per class. The platform sets a floor and the DPO a ceiling. A locked period can be lengthened but never shortened, so nothing is locked until the ceiling is recorded.

12.2 Every store has a class (P109)

Retention, encryption, readers and the TISAX label all key on a single per-store value ([08 §2.1](#)). The organisation's own scheme is *tbd* with the ISMS, so the platform uses its own vocabulary, and the mapping to the organisation's scheme is an **Assumption**: . Page 08 and register row P109 call the vocabulary "five classes" but both list six; this chapter follows the list.

Class	Holds	Default retention
evidence	audit rows and streams, verifier findings, alert and incident history	400 days, locked where possible
content	prompts, responses, tool arguments, sanitize payloads	30 days ceiling, never locked
control	plans, approvals, halts, counters	life of the agent
record	decision records, compliance snapshots, drill records	10 years, locked
secret	credentials, keys, the surrogate mapping	rotation, never destroyed inside the evidence horizon (Chapter 13)
ops	project logs, traces, metrics, billing	30 days

The factory refuses a manifest without a `data_class`.

The inventory classifies 27 stores (08 §2.2). Mo's surrogate mapping is `secret`, because it makes every surrogate reversible; `platform-identity-logs`, holding every employee's sign-ins, is the densest personal-data store; and conversation history is `content`, not evidence, because the audit of what an operator asked lives in audit rows and the tenant app's Data Access entries. Memory Bank, Workspace data and the model's prompt retention are deliberately not stores.

12.3 The central logging project (P104)

Why one sink cannot do both jobs

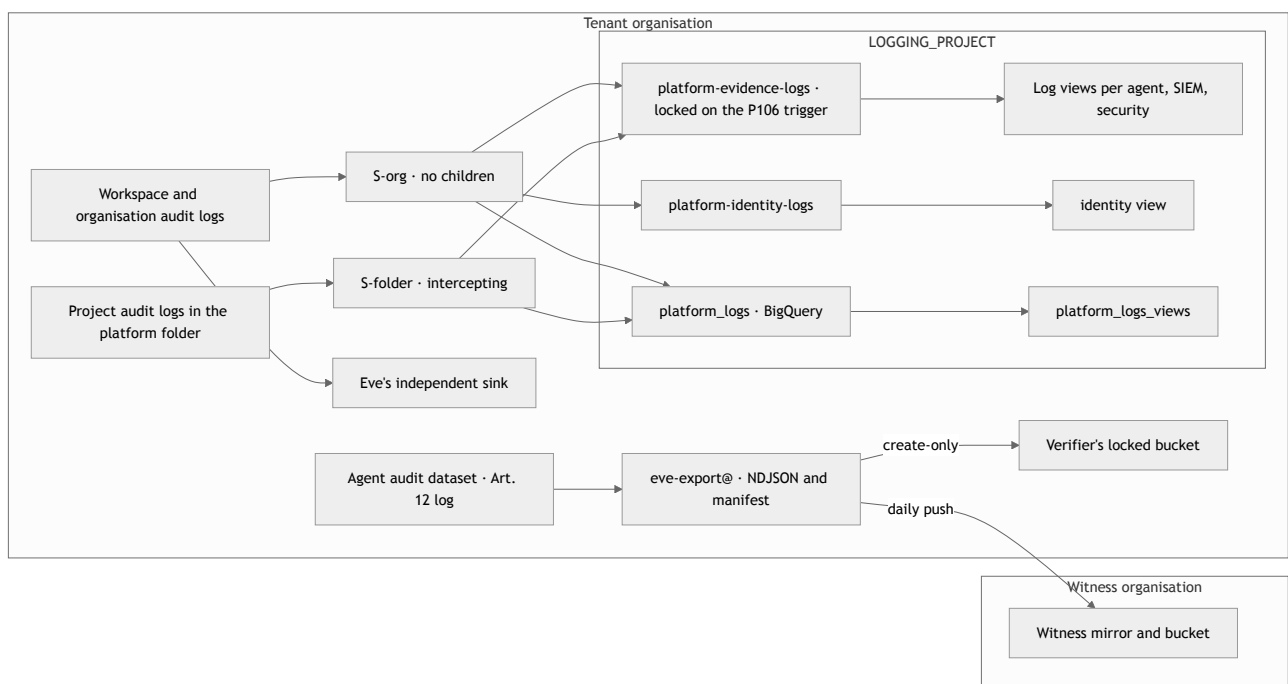
The HLD's single organisation-level aggregated sink (a log-routing rule that collects from many projects at once) becomes two sinks on page 08, as the register settles in page 08's favour (register §7 row 4). Three verified facts force the split (08 §3.1):

- **A sink has one destination.** It routes into a central project whose own sinks fan out, one hop only.
- **Workspace audit logs are organisation-level entries.** A folder sink never sees them.
- **An intercepting folder sink stops entries reaching child projects' sinks** (except `_Required`), so Data Access logs are stored once, not per agent project where each owner could shorten them. "The agent cannot silence its logs" becomes a property of the folder.

Two sinks and the fan-out

`S-org` sits at the organisation without children and carries the Workspace streams and the organisation's own audit logs; `S-folder` sits at the platform folder, intercepting, and carries only Cloud Audit Logs, so content and operational logs stay in the agent projects (08 §3.2). Both deliver to `LOGGING_PROJECT`, which fans out to the evidence bucket (locked on the P106 trigger), the identity bucket, a BigQuery dataset without employee sign-ins, and per-agent trigger topics. Wall-E's two organisation sinks are re-homed here.

Only the trigger sinks exclude the agent's robot as actor, or each write would start another run; the evidence copies carry no principal filter, because they exist to reconcile what the robot did against what the agent claims. Eve's sink stays independent: its absence alarm notices if `S-org` is re-filtered.



Log views and who reads what (P114)

Cloud Logging has no bucket-level permissions: access is granted per log view, a filtered window onto a bucket. A project-level logging reader, however, sees every view. `LOGGING_PROJECT` therefore has no standing project-level reader, and the drift job expects only the sink writer identities and the CI identity (08 §3.3).

Each agent gets an owner-and-operator view, its verifier a view that adds Workspace entries naming the robot, and the SIEM and security group see everything; no agent owner reads the identity view.

Google allows 30 views per bucket, so P114 opens one evidence bucket per tier folder past about 25 agents, through a factory variable that must exist before the lock ([register §5](#)). Page 08 does not reconcile that threshold with two views per agent plus the shared views, which would fill a bucket at about 13 agents.

Cost and who pays

Central log ingestion and locked retention are the design's largest cost line. The platform pays it from Tier R (08 §3.4). No price is quoted, because Google's pricing page rendered truncated on 2026-09-13. Workspace audit volume cannot be cut, because it is the evidence; Data Access volume follows the service list in section 12.4, billed (`Assumption:`, until the first invoice) to the project that stores the entries.

12.4 Data Access audit logging at the folder (P105)

One audit configuration sits on the folder's IAM policy (08 §4.1). Google takes the union of levels, and a child cannot disable what a parent enables. Silencing these logs therefore needs a folder-level policy write, itself logged, watched by a severity-1 SIEM rule and possible only through Privileged Access Manager. No member is exempt.

Each service answers a forensic question: who read a secret (Secret Manager), who produced an Eve approval signature (Cloud KMS), who reached control surfaces and plans (IAP, Firestore), who invoked an engine (Vertex AI), what the human actually asked (Discovery Engine, off unless enabled), who read the evidence (Cloud Logging), credential issuance (Agent Identity) and reconnaissance (IAM and policy reads). Storage Data Access logging runs only on the four evidence-holding projects. "All services" is left out as cost with no consumer, Cloud Run and Pub/Sub as volume no detection uses; Agent Gateway and Agent Runtime are absent from Google's audit-log services list.

The canary, and registry reads not yet proven (P80)

The configuration does not prove entries arrive. A daily job reads a canary secret under each tier folder, the folder policy, a canary Firestore document and the Agent Registry. It then finds its marked entries through the `security view` (08 §4.3). A missing entry other than the registry's is severity 1 and, for Tier P, the silent-pipeline halt of Chapter 11.

Registry reads (P80, proposed) are the exception: on 2026-09-14 Google's product page documented these entries while its general services list omitted the service. The design follows the product page and counts registry read logging as unverified until the canary's first registry row. Until then a missing row is severity 3, and the gap is recorded as "registry reads unlogged".

12.5 Retention (P106, P13)

Floor, ceiling and why the lock waits

The floor is the greater of the EU AI Act's six months and the organisation's standard, which is *tbd* (HLD §7.5; 08 §5.1). For evidence the floor is 400 days, an `Assumption:` until the DPO decides, beyond the "at least six months" of Art. 26(6) and Art. 19, which bind Annex III systems from 2027-12-02 and which the platform adopts

voluntarily now. Records are kept 10 years under Art. 18. Content logs and sanitize payloads are kept at most 30 days, a minimisation ceiling that may fall but not rise without a DPIA line.

The ceiling belongs to the DPO: one number per class, due before Stage 1 of any Tier W agent (P13, open). P106 sets the lock trigger. Locked stores are created unlocked at the floor and locked on the day the ceiling is recorded, at the larger of floor and ceiling. Until then, bucket changes need Privileged Access Manager and a severity-1 SIEM rule watches all three evidence projects. Before the DPO decides, central evidence is protected by detection, not a lock.

A lock does not make retention lawful: locked stores hold only the identifiers Art. 12 needs, and a data-subject request against one is answered by disclosure, not deletion (Chapter 22).

The schedule in outline

The schedule of record has 16 rows (08 §5.2):

- **400 days:** evidence stores; BigQuery cannot lock the agent audit dataset, so its daily export is locked instead. The identity bucket's 400 days is an **Assumption:**, where the DPO's number most plausibly differs.
- **Ten years:** records, Art. 73 reports and post-incident reviews.
- **30 days:** content, its de-identified twin (90 days if the DPO approves, a request recorded, not assumed), traces and operational logs.
- **Life of the agent:** Firestore.
- **At least 400 days:** the SIEM, whose SecOps default page 08 gives as 365 days, unverified on page 07, must be raised (Chapter 11).

Agent Runtime Sessions are not yet a row; **Assumption:** they take the content ceiling.

Conversation retention

Gemini Enterprise offers 1, 30, 60, 90, 120 or 180 days of chat history, defaults to 60, and needs the Plus edition to change it. The tenant's edition is *tbd*. The interim value is 30 days, marked **Assumption:**, and runbook step GE-6 sets it (03 §5.4; register §7 row 1). The chat is tenant content about named employees and not the Art. 12 log, so the six-month floor does not bind it. The DPO settles the number under P13, and a quarterly manual check confirms the setting.

The three identity streams

Sign-in, OAuth-token and SAML entries expire after 30 days in the organisation's **_Default** bucket unless routed (08 §5.3). A robot's interactive login is severity 1, so these entries are routed, to their own bucket so that the DPO can set a different ceiling on employees' sign-in history without touching the audit lock, and so that its readers differ. Eve's sink keeps a second copy. Some of these streams reach Google Cloud only on certain Workspace editions, so the edition is a Stage 0 precondition.

12.6 The daily export and the witness push (P107)

The agent's audit dataset, together with the frozen plan, is designated the Art. 12 log. It must therefore outlive the agent's project and its owner's rights over it (08 §5.4).

Each day, `eve-export@` exports yesterday's audit tables and Eve's findings, verdicts, incidents and pages as newline-delimited JSON (one record per line). Each export carries a manifest of row counts and SHA-256 hashes, so a reviewer can check it without trusting the exporter. It lands, create-only, in the verifier's locked bucket, and the same job pushes it into the witness organisation. Eve's verifier, which cannot write the bucket, recomputes the counts: a missing day raises the witness alarm, at severity 1 for Tier P, and a mismatch holds any promotion that cites that day.

The register rejected the verifier as exporter: one identity, one duty. The mirror is queryable, the export is immutable, and the witness sits outside the organisation (Chapter 16, Eve, the independent controller).

Assumption: Google allows the cross-location extract.

Monthly exports send incident cases and alert history to the evidence bucket for 400 days, and Art. 73 reports to the records bucket for ten years (08 §5.5).

12.7 Sensitive Data Protection (P108)

A declared class nobody checks is a claim. P108 runs discovery across the folder's BigQuery and Cloud Storage, excluding `secret` stores by their register label (08 §6.1). Discovery does not profile log buckets or Firestore. A daily job compares findings with each store's declared class: an `ops` store holding names is a finding against the register.

One template, `platform-log-deid-v1`, applies to every agent (08 §6.3). It turns identifiers into deterministic tokens and redacts credentials. The same person always becomes the same token, so graders can count distinct people without seeing one, while free text stays readable.

A daily job writes the de-identified twin, because Cloud Logging cannot transform on ingestion; graders and Mo read only the twin. An empty content profile means the de-identify job is broken. Content buckets carry restricted fields and never a linked BigQuery dataset, because BigQuery ignores field-level access.

This is still open on the agent pages. Page 06, Wall-E's prompt-security page and Mo's access page do not yet name the standard (register §7 row 13).

12.8 Sovereignty

Why not Assured Workloads today (P110, P12)

P110, proposed, keeps the agents folder out of the EU Data Boundary package of Assured Workloads (08 §7.1). On 2026-09-13 the package listed Gemini Enterprise, Vertex AI, Cloud Logging and Model Armor, but not Agent Gateway or Agent Registry. Page 08 and the register add Agent Identity, while the HLD names only the first two (HLD §8.2).

The package restricts its folder to supported products, refusing any other or reporting it as a standing violation, so the platform would have to drop its gateway and registry or accept a paper control. Cost is not the reason; the package is free.

Saying no costs Key Access Justifications; Google-run violation monitoring, replaced by drift detection; the package's policy set, replaced by the platform baseline (Chapter 7); and per-product boundary statements, replaced by a coverage request to Google (P32).

Adopting it later means a new folder and project moves. The revisit trigger, P12, is open: it fires when the products join the package, the TISAX label becomes Strictly confidential, or the organisation adopts the package elsewhere.

What compensates (P111, P113)

The compensating set (08 §7.2) has six parts:

1. **EU locations enforced at the folder.** For Agent Runtime this is an **Assumption:** and detection-grade until verified.
2. **Residency exceptions kept as dated rows.** These include Workspace audit logs, which Google stores without a selectable region, so the central `europe-west1` copy is the resident one.
3. **Access Transparency**, confirmed at Stage 0 and routed to the evidence bucket and the SIEM.

4. **Access Approval** on the Tier P and Tier W folders, the controllers, the witness and the core logging and platform projects, accepting approval delay to Google support. The HLD omits the Tier W folder. Neither Access Transparency nor Access Approval covers the gateway or the registry.
5. **The witness under the same EU policy.**
6. **The EU model-pin rule (P113).** An eu app keeps data and processing in the EU only for models that support it. On 2026-09-13 several Gemini Flash models were global-only. A model may be pinned only if Google lists EU residency and processing for it on the pin date, checked in CI against an allow-list. A model that leaves the list gets a 30-day re-pin window (Assumption:).

Keys for these stores are Chapter 13.

12.9 Asset owners per project

TISAX wants an owner per asset (08 §8). Each project names an asset owner, a data owner, a custodian and a classification reviewer, who signs each store's class at every stage transition; the ISMS supplies names. The platform owner holds the five core projects; the security reviewer owns the validator project and reviews the others; IT security owns the organisation-level stores and is custodian of the witness; the DPO owns the data in the identity bucket and conversation history. On 2026-09-13 most roles are one person (Chapter 23, Operating model); the tier gate of Chapter 24 changes that.

12.10 What could not be verified

No exception is open yet (08 §11). The following are unverified:

- log prices and billing;
- Terraform support for intercepting sinks;
- the cross-location export;
- the scan location;
- APIs for the retention and Access Transparency settings;
- engine residency;
- Agent Identity operation typing;
- registry reads;
- the tenant's Workspace edition;
- the organisation's retention standard;
- Google's per-service TISAX coverage.

Key decisions and what to read next

Register states on 2026-09-14:

- **Proposed, before the folder exists:** P104 sinks; P105 Data Access and canary; P108 discovery and de-identification; P109 classes and owners; P111 Access Transparency and Access Approval; P112 central keys; P80 registry reads, unverified.
- **Proposed, before Tier W writes:** P106 schedule and lock; P110 no Assured Workloads; P113 conversation retention and model pins; P52 aligned with P113. P106, P113 and P52 depend on P13.
- **Proposed, before Wall-E's Stage 1:** P107 export; P114 bucket per tier.
- **Open:** P13 the DPO's ceiling; P12 the revisit trigger; P32 Google's coverage; register row 13.

Carried to Chapter 19, Threat model and residual risk:

- Two of the three evidence copies are detection-grade.
- Nothing central is locked before the DPO decides.
- A re-filtered S-org is seen, not prevented.
- The gateway and registry sit outside Access Approval.

- Engine residency and registry read logging are unverified.

Read next: [page 08](#), [HLD §7.5](#) and [§8.2](#), [register §7](#), the [project topology](#), and Chapter 13, Supply chain, keys and recovery.

13. Supply chain, keys and recovery

What you will understand by the end

Why what runs in a credential holder is what was reviewed, scanned and signed, and where that is only detected; who holds which key, which stores are recorded exceptions, and why no approval or evidence key is destroyed inside the evidence horizon; how each asset class is recovered, why Workspace is never backed up, and why a restore cannot quietly undo a halt.

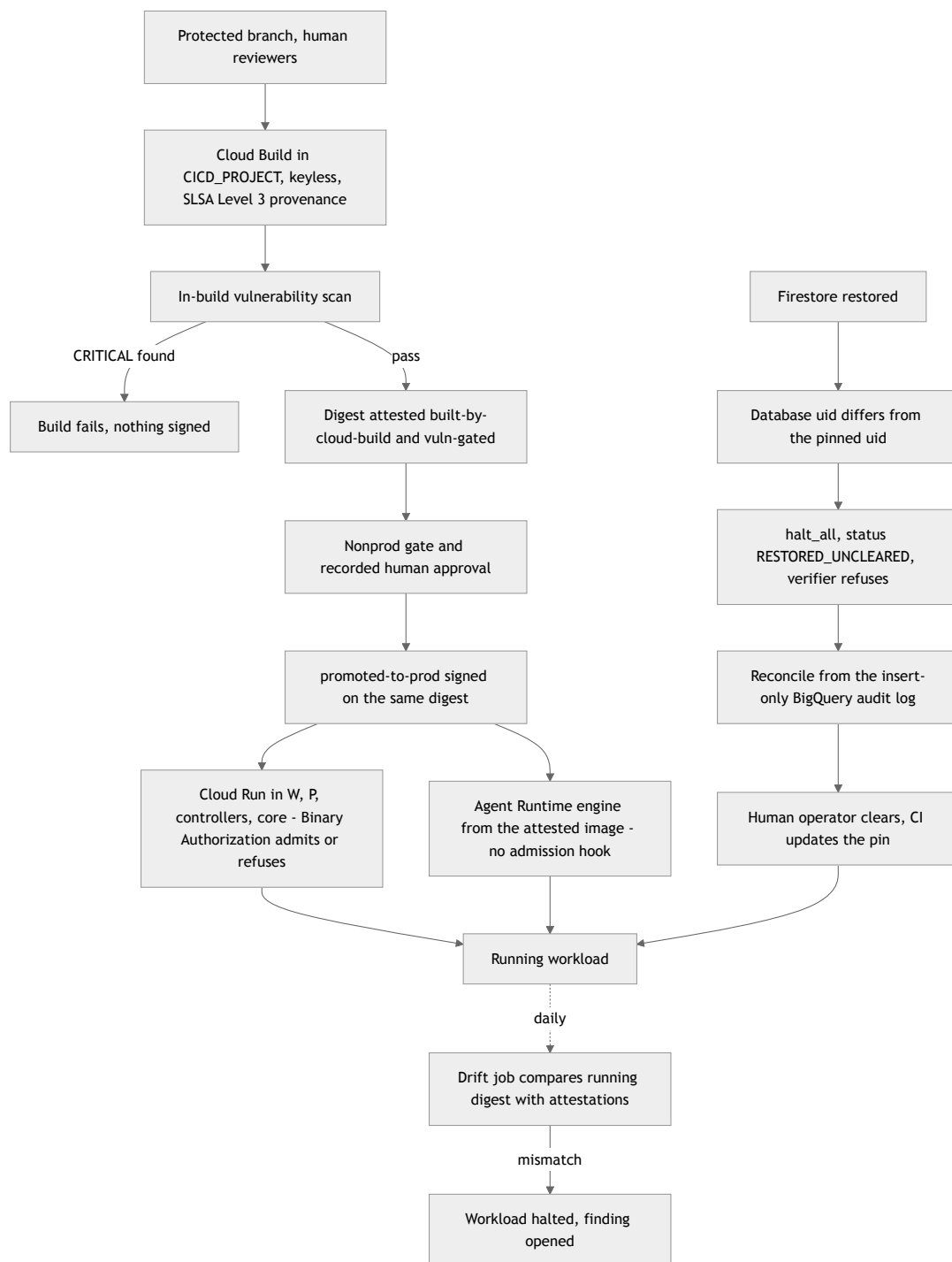
The chapter answers four risk themes of Chapter 3, The problem and its risks. Tenant compromise through the robot credential: whoever changes the action service's image or reads its secret holds the credential, so both paths are closed or watched. Manufactured silence: a destroyed key or a restored database could erase a halt or make evidence unreadable without an alert. A controller reachable by what it controls: Eve's keys stay outside the platform's key project. Shadow agents: only an attested image from the shared registry may deploy. A halt, an approval and an evidence row are worth something only if no later deploy, key operation or restore can cancel them. Nothing here is built on 2026-09-14.

The supply chain

The charter's rule: no agent writes to a repository, a registry, a deploy identity, its own ladder or its own ceilings. What writes is a keyless pipeline whose every output is signed, scanned and admitted by a policy the agent's owner cannot edit ([page 09 §1](#)).

From commit to running digest

Cloud Build runs in `CICD_PROJECT`, triggered only from protected branches, as a per-agent build account reached through workload identity federation, so there is no key to steal. CI lints every build file for the three conditions under which its provenance meets SLSA Build Level 3. Every deploy names a digest, never a tag ([§1.1](#), [§1.2](#)).



Two points enforce, the build gate and admission on Cloud Run; one detects, the drift job.

The shared registry and the vulnerability gate

One Artifact Registry per format in `CICD_PROJECT` holds a repository per agent. Public package indexes are reached only through remote repositories behind a virtual repository, the only endpoint a build may pull from, so no build reaches the public internet. That the build pool's egress setting enforces this is an **Assumption**: until the monthly drill tests it. Tags are immutable, lockfiles hash-pinned, and no human holds registry write (§1.3).

The vulnerability gate (P117) is a build step, not a report, and the platform's own because Google's Kritis Signer guide returned 404 on 2026-09-13. An on-demand scan before the push fails the build on any **CRITICAL** finding or malicious package, and only a pass lets the pipeline sign `vuln-gated` with its HSM key. After the push, the drift job reads rescan findings for every running digest daily; a new **CRITICAL** carries a 24-hour rebuild target,

and an untriaged HIGH blocks a Tier W promotion. The thresholds (no CRITICAL, HIGH triaged within seven business days) and patch cadences are `Assumption:` values the ISMS confirms. The attestation is not revoked automatically on a new CVE, because that would also block the rollback digest (§1.4).

Admission, and where it becomes detection

Binary Authorization on Cloud Run evaluates the policy of the service's own project, so the factory generates one per agent project (P115): both attestations required, `promoted-to-prod` added in production, images only from the agent's repository, and no policy-editor role for the agent owner. The constraint forcing it sits on the W, P (inherited by P-SA), controller and platform-core folders, the last two because Eve's gate and reconciler, the K7 job and the drift job are Cloud Run on the authority and kill paths (§1.5, register §7 row 5). Tier R, with no credential holder, is exempt. Each folder runs 30 days in dry-run first. A blocked deploy is not an outage — the previous revision keeps serving — and the one bypass, `--breakglass`, is always logged and opens a severity-1 case.

Admission ends at deploy. Continuous validation exists only for GKE, in Preview, so on Cloud Run the drift job and a Security Health Analytics custom module compare running digests with the attested set daily: detection-grade, and stated as such. Agent Runtime has no admission hook at all. Engines can deploy from a container image (confirmed 2026-09-13), so from Tier W up, and for controllers, every engine deploys from an attested digest, and the drift job halts one that does not match (P116). Only Tier R may still deploy a source bundle, recording its SHA-256; the HLD and page 02 still describe that substitute for engines generally, where page 09 limits it to Tier R (HLD §9, §1.6). Enforcement for engines comes from the folder deny policy, which refuses deploy, upload and build to every agent principal (Chapter 8, Identity, privileged access and the fleet kill switch).

Who may write

The drift job asserts daily that the registry's only writer is the factory identity and each project's only deployer is its own per-agent deployer (P142), so one compromised release cannot deploy another agent; that is why the single shared deployer was retired (Chapter 7, Landing zone and the tier model) (§1.7).

The git host is open (P22). Whatever it is must give protected branches, two required reviewers on credential-holder repositories, code owners for Eve's configuration and the ceilings, and admin bypass disabled with its audit log exported, because an unaudited bypass is a write path around every reviewer. Pull requests an agent opens cannot be merged by the agent, need two human reviewers with one outside the owner's line, and may never touch contracts, ceilings, Eve's predicates or CI configuration. Chapter 17, Mo, continuous improvement, and Chapter 18, How the three work together, cover what is proposed and who merges.

Environments, promotion and emergency change

Pre-production grows with the tier (§1.8). Tier R needs a nonprod project; Tier W adds a nonprod system of record, the denial tests, a golden-plan replay through the verifier, the kill-switch drill and the restore drill; Tiers P and P-SA add the sandbox Workspace tenant (Chapter 7), because Super Admin cannot be scoped to an organisational unit; controllers and core add the K7 drill.

Promotion is an attestation, not a copy: after a recorded human approval the pipeline signs `promoted-to-prod` on the digest that passed nonprod, with no rebuild in which something untested could enter. Rollback redeploys a previous attested digest. An emergency change uses breakglass with a ticket, and a second reviewer within one business day either signs the promotion retroactively or forces a rollback. Engines have no emergency path: redeployed from an attested digest, or halted.

Secrets

The conventions make a secret's reach readable from its metadata and checkable by a machine (§2.1).

- **Regional.** Every secret is regional in `europa-west1`; a global one is flagged as a residency incident. Refusal at creation waits on the P4 spike; regional secrets being GA is an `Assumption:`.
- **One reader.** Exactly one service account reads each secret, named in its `reader` label; a human reads one only through a 30-minute PAM entitlement (Chapter 8).
- **Pinned versions.** An action service reads a pinned version, so a new value takes effect only through a deploy, which passes every gate above ([Wall-E, where each secret lives](#)).
- **An access alert.** With Data Access logs on at the folder (Chapter 12, Data, logging, retention and sovereignty), any access by someone other than the labelled reader pages: severity 1 for a credential holder's secret.
- **Rotation as a runbook.** Secret Manager announces rotation but does not rotate; the subscriber opens a ticket and never mints a Workspace credential, because minting is a witnessed human act. An unrotated Workspace credential blocks that agent's next raise.
- **Outside Secret Manager.** Robot passwords are in the corporate vault and each robot account's two hardware keys are with custodians named in a witnessed custody record (Chapter 8); a missing record blocks the super-admin grant.

Keys

The HSM floor and the key project

Every key is HSM-backed by organisation policy at the platform folder, approval-authority keys included (P118), so no key class needs its own argument. The cost, a charge per key version, is accepted and unpriced. Two more constraints force a key version to be disabled before destruction and set a destruction window of at least 30 days ([§2.3](#)).

Cloud KMS Autokey, set at the folder, creates keys for the supported services in `KMS_PROJECT`, a fifth core project that holds keys only and never binds an agent principal ([register §7 row 6](#)). The reason is placement: no approval or evidence key may sit where an agent's teardown or owner reaches. Engines, which Autokey does not cover, get a single-region key per agent there. Eve's approval and evidence keys stay in `EVE_PROJECT`, so a `KMS_PROJECT` administrator cannot brick Eve's copy (Chapter 16, Eve, the independent controller), and the witness never uses a key from the tenant's organisation.

The recorded exceptions

The stance is recorded once so an assessor meets a dated exception with a reopening condition ([§2.2](#)). Firestore stays Google-managed (P119, exception 1): its CMEK is chosen only at creation and on 2026-09-13 sat behind an access-request form. The organisation `_Default` and `_Required` log buckets and Tier R content buckets also stay Google-managed (exception 2), since a 30-day content store's threat is its readers, not key custody.

The central evidence and identity buckets instead take an explicit HSM key at creation, and Tier W and above content buckets a key per agent (P112). They are outside exception 2 because CMEK can never be added to a bucket later ([register §7 row 2](#)). The accepted cost: a disabled key makes the evidence unreadable at once and, after Logging's three-hour buffer, unwritable. Disable-never-destroy, a severity-1 rule on any key state change, no KMS administrator outside PAM and evidence copies on other keys contain it.

Both exceptions reopen if the TISAX label becomes Strictly confidential (P20). Key Access Justifications exist only with Assured Workloads, not adopted today (Chapter 12).

One table, rotation and custody

Every key and secret is in one [cryptography table](#), by class, recording where each lives and who holds each side, never a value. Rotation follows the class ([§2.5](#)): approval keys manually on a dated schedule with 30 days' overlap, because Cloud KMS does not rotate asymmetric keys; attestor keys annually; Autokey keys yearly by

Autokey's verified default, explicit keys every 90 days, pending an organisation cryptography standard that is *tbd*; Workspace credentials on revocation, custody change or suspected leak, by two witnessed custodians.

Old approval and attestor key versions are disabled and never destroyed for 400 days, the evidence horizon and itself an **Assumption**: floor. An approval is evidence only while its signature verifies; destroying a version would turn a year of approvals into unverifiable claims, silence achieved through key custody.

Recovery

Six classes

Every project and register row carries a recovery class derived from its tier (§3.1).

Class	Protects	RPO	RTO
R-A evidence	audit, drill and decision records, Workspace logs	24 h	72 h
R-B control plane	Firestore: ladder, plans, approvals, halts	1 h	4 h to <code>halt_all</code> ; 1 business day to service
R-C agent compute	engines, action services, gateways	0, from git	1 business day
R-D shared services	registry, logging configuration, CI, state	24 h	1 business day
R-K keys and secrets	approval, attestor, robot credentials	—	keys never destroyed; tokens re-bootstrapped
R-W Workspace state	what agents changed	inverse operation per family	—

Compute is rebuilt through the factory from an attested digest. Workspace credentials are never backed up, because a backed-up refresh token is a second tenant credential; recovery is a two-custodian bootstrap, with the Admin console meanwhile (§3.5).

Why a restore boots at `halt_all`

The factory turns on point-in-time recovery, backups and delete protection for every Tier W and above database, beyond any agent owner's reach. The danger is what a restore brings back: Wall-E's decision 30 named halts, overrides, nonces and counters written after the restore point as silently lost, so a halted agent could wake unhalted. P120 makes "start halted" true by construction rather than a runbook step (§3.2).

- The action service pins the database's system-generated `uid`. A restored database has a new one, so start-up forces `halt_all` with status `RESTORED_UNCLEARED`, even after a restore nobody announced.
- It reconciles from the insert-only BigQuery audit log, marking approved or executing plans stale and replaying later halts and overrides: a replay of a record, not a guess.
- The verifier reads that status itself and refuses every plan, sharing no state with what it halts (Chapter 4, The principles).
- Only a human operator clears it, recording the new `uid`; CI then updates the pin, and the restore becomes an incident record.

A service that executes after a restore without clearance is a severity-1 defect. The cost is a human in the loop and service back within a business day, not minutes. One fact is an **Assumption**: that `uid` changes on in-place restore; the first drill proves it, or the pin moves to creation time.

Evidence has already left, and the shared services

Evidence recovery mostly means it was never at risk: the daily export to the verifier's locked bucket (Chapter 12), weekly table snapshots kept 400 days, and at Tier P Eve's mirror and the witness put it out of the agent's reach, so a project may be deleted once its export is confirmed (§3.3). A quarterly drill re-imports one day and diffs it; any difference is an incident.

The factory stops if Terraform state or the register of record is lost (§3.4). State has versioning, soft delete and a copy to a second EU region, europe-west4 as an Assumption: , because Backup and DR Service does not protect buckets; the register is git with a nightly bundle to the evidence bucket. Everything else is reproducible from state, proven monthly against a clean copy in nonprod.

What is not recovered

The platform never backs up Workspace: the tenant's state is Google's, what an agent changed is undone by the inverse operation per family, and beyond that by Google's own recovery. Single region europe-west1 is accepted for every tier because agents are not critical IT services; each Tier W and P manifest names its manual continuity, for Wall-E the Admin console operated by a human super admin, including that losing WALLE_PROJECT costs the tenant only the robot's convenience. The platform promises nothing above Google's SLAs. The one-page continuity statement feeds the TISAX impact analysis (HLD §10, §3.7); Chapter 21, TISAX, shows what a stale statement blocks.

The restore drill as a promotion criterion

An unrehearsed restore is a hope, so from Tier W the drill is in the promotion gate (§3.6). In nonprod the agent owner deletes the database, restores, observes RESTORED_UNCLEARED , reconciles and clears while a second operator witnesses; the record holds the recovery point, minutes to halted and to service, and discrepancies. One is required before Stage 1, then in every promotion gate above L3, and quarterly; the validator refuses a raise if the latest is older than a quarter or leaves a discrepancy open. Page 02's Tier W row asks instead for a record younger than 30 days at the first promotion above L3, a difference the register does not yet carry (page 02 §1.3).

What remains unverified

Unverified on 2026-09-13, with what closes each (§7): the engine service agent's cross-project registry read (a throwaway engine in the P3 spike week); uid on in-place restore (the first drill); build-pool egress (the monthly drill); the logged secret-access method (the first log at build); whose key signs built-by-cloud-build; the Autokey key-project rules (the first nonprod configuration); whether the Gemini Enterprise key covers conversation history (after GE-4); thresholds, rotation periods and the second region (the ISMS); deny permission names (P8).

Chapter 19, Threat model and residual risk, carries what remains: post-deploy drift on Cloud Run and all admission on Agent Runtime are detected, not prevented; build isolation is detection until proven; a key state change on the central evidence buckets is an availability risk; the restore mechanism rests on one Assumption: ; single-region operation is accepted, not engineered away.

Key decisions and where to read next

Decision	State on 2026-09-14
P115 admission, four folders, promotion by attestation; P116 engines from the attested image	proposed
P117 vulnerability gate	proposed, Assumption: thresholds
P118 HSM floor and KMS_PROJECT ; P112 central log bucket keys; P119 CMEK exceptions, narrowed	proposed
P120 restore boots at halt_all ; P142 factory and per-agent deployers	proposed

Decision	State on 2026-09-14
P22 git host and admin-bypass audit	open, deployer half closed by P142
P4 custom constraints; P8 deny permission names	spike
P20 TISAX label via P133; P12 Assured Workloads revisit	proposed, ISMS confirms; open

- [Page 09 §1, supply chain](#) and its [control table](#)
- [Page 09 §2.2, the CMEK stance](#) and [§2.4, the cryptography table](#)
- [Page 09 §3.1, recovery classes](#) and [§3.2, the restore sequence](#)
- [HLD §8.3, key management](#)
- [Register §7, values that differ between pages](#)
- Next in the brief: Chapter 14, Scale and AGI readiness

14. Scale and AGI readiness

What you will understand by the end

What "hundreds of agents" costs once the factory has removed the hand work, and why the limit is the people who grade agents' work blind rather than the number of projects. How agents, MCP servers, Marketplace apps, connectors and models the organisation did not write come in and go out. Why code execution does not exist below the top tier, and how that absence is enforced when Google offers no switch for it. And why a future AGI-class agent is a closed tier with written opening conditions rather than a promise.

The chapter answers three risk themes of Chapter 3, The problem and its risks: autonomy outrunning evidence, because the fleet cannot grow faster than humans can grade it; shadow and third-party agents, because nothing external binds without a supplier row; and staffing that makes two-person rules notional, because the cap is written in named people. Nothing described here is built on 2026-09-14.

Two readings of "hundreds of agents"

The design accepts that hundreds of agents can be made, placed, screened, watched and removed without a runbook per agent. It declines the reading that hundreds of autonomous agents can be supervised by the people who exist. Requirement R11 is met with that qualification: the cap is grading capacity, not projects ([HLD §0.6](#)).

What scales with the factory

Everything a machine can make from a register row scales with the factory: project, identity, gateway, budget, grants, registry card and monitoring baseline (Chapter 9, Registry, governance and the autonomy contract). A factory run makes the project in under an hour (Chapter 7, Landing zone and the tier model) for about half an hour of the platform owner's time ([landing zone §1.3](#)), and a registered agent is a watched agent (Chapter 11, Monitoring, detection and incident response).

What hundreds of projects multiply

Project-per-agent is forced by Google (Chapter 7), and a factory removes the effort, not the volume: every project has its own budget, IAM policy and owner group, every crossing is a grant and a drift-job row ([project topology §1.4](#)), and from Tier W each agent has a nonprod twin. Some Google limits bite at fleet size: a tier folder needs another evidence bucket past about 25 agents (P114, proposed; Chapter 12, Data, logging, retention and sovereignty), and the shared Agent Registry holds 100 entries per project, with an increase requested at 60 % occupancy — a request, not a right ([HLD §3.4](#)). Organisation-sink ingestion is the largest cost line, and BigQuery bills the project that runs the query. Budget and quota amounts are open (P31); cost figures are Chapter 24, Roadmap and cost.

Findings multiply too: below Tier P a hundred projects' findings page one person, the platform owner, by next business morning (Chapter 11).

What scales only with people

A factory cannot make a grader, a second operator, a security reviewer, or, at Tier P, a bought desk, a second human super admin and an Eve owner; who exists today is Chapter 23, Operating model. Register rows carry a review date at most 90 days ahead and privileged rows are reviewed quarterly; every such review is a human reading something.

The steady-state human cost per tier shows the shape ([landing zone §1.3](#)): nothing for Tier C, about half an hour a month for Tier R, about three hours a week plus a bought desk for Tier P. For Tier W, Chapter 23 quotes about one hour a week of blind grading per agent, two hours a week for the second operator and two hours a month

for the security reviewer, with at least two hours a week of grading for Wall-E at its S4 volume (derived in Chapter 17, Mo, continuous improvement). Hundreds of Tier C and R agents are within reach of the people who exist; hundreds of Tier W agents are a staffing decision; hundreds of Tier P agents are not a goal.

The cap is grading capacity (P25)

Grading binds because it cannot be removed without destroying what it measures. Precision at the upper autonomy levels is a human-graded quantity; the sample floor is per cell, so thinning it marks the cell not ready; and a model grading would replace the evidence with the thing under test ([Mo metrics contract §13.3](#)). If nobody grades, no cell reaches its promotion sample and the programme stalls on attention rather than on safety ([Mo staging](#)). That is the right failure: an ungraded agent does not become dangerous, it stays at the autonomy it has.

The design makes this an admission rule: a Tier W register row must name a blind grader with capacity, or the gate refuses it ([HLD §11.1](#)). The number of Tier W agents per grader is P25, and it is open: *tbd*, measured after the first Tier W agent's first quarter, owned by Mo's owner and the ISMS, blocking the second Tier W agent, and dependent on a second grader nobody has found (E-13, M-4; [register §3](#)). By arithmetic, not design, a hundred Tier W agents need about a hundred grading hours a week.

Tier P stays rare

Each Tier P agent is a licensed Workspace user on the admin-role review, paid by its owner's cost centre and reviewed quarterly; the target number of super-admin agents is one ([HLD §3.4](#)), under Chapter 7's singleton rule. The compensations for a super-admin robot, from the witness organisation to the detection set, are written for one actor; a second is a design not yet done.

Agents the organisation did not write

The platform cannot test a supplier's code, so assurance comes from the supplier's evidence, a contract and a technical position that assumes the worst about what comes back. One procedure covers every external agent, MCP server, Marketplace app, connector and model (P138, proposed; [TISAX page §8.1](#)), and Wall-E's position — no MCP server consumed or exposed, no skill loaded at runtime — is the default for every Tier P agent.

Onboarding

The dependency is declared on the consuming agent's register row before anything is bound; an allow-list entry, install or endpoint with no supplier row is a reconciliation finding and is removed ([§8.3](#)). The platform owner assesses what it is, who runs it, the data it will see, its residency and its evidence: at very high protection need a TISAX label or an equivalent independent assessment, questionnaires alone being rejected; at high need the same or a risk assessment the ISMS accepts. Personal data brings a processing agreement; a model brings no-training and retention terms and its EU AI Act Art. 25 position. The ISMS accepts, and a contract follows with an exit clause, a deletion commitment and notification duties.

Technical admission reuses the platform's rules. An MCP server enters only as a registered, gateway-governed endpoint of a Tier R or higher agent, with an explicit tool filter and no elicitation callbacks, since a server that can ask for input mid-call has a channel the declared tool list does not describe. An external agent is L0 for every write and tainted on receipt — Chapter 9's peer rule applied to strangers. No connector holds a Workspace write scope, and a model's pin is re-qualified on change. The one-run admission gate then checks "supplier row approved".

In service and exit

Supplier rows are reviewed annually; label expiry is tracked, and an expired label at very high need disables the dependency at the gateway. A change notice or incident reopens the assessment.

Exit is written before entry is needed (§8.4). A supplier's binding is revoked and its data returned or deleted with confirmation filed; a platform agent is unshared, deregistered, halted if it writes, its evidence export confirmed, and only then its project deleted. Export before delete is the rule that matters: a deletion before its export confirmation is severity 1 and restored from the witness copy, and a supplier unable to confirm deletion leaves a residual the ISMS records. The procedure is rehearsed yearly on a throwaway nonprod project, covers the end of the contract with Google, and states that the Workspace tenant is not the platform's to delete. P138 must exist by the super-admin grant at the latest (register §4), and in practice by the first connector beyond first-party sources. How an assessor reads the supplier controls is Chapter 21, TISAX.

Code execution

Code execution turns an injected prompt into an arbitrary program, so below Tier X it must be impossible, not merely unconfigured (P121, proposed).

None below Tier X, and how "none" is enforced

On 2026-09-13 Google offered no organisation-policy constraint disabling Agent Runtime code execution, and the engine resource is not a custom-constraint resource type (supply-chain page §4.1). "Off" is built runtime by runtime, with different grades (§4.2). GKE and the other compute services are enforced by absence from every tier folder's allow-list. Agent Runtime sandboxes are enforced by permission — no agent identity may create one, CI refuses packages that use the code-execution tool — with a severity-1 alert and a daily listing expecting zero for the residual, a human elevated through Privileged Access Manager; the alert's method name stays *tbd* until a first nonprod attempt logs it. Cloud Run sandboxes, Pre-GA with an unverified enabling field, are detection-grade through an image scan. Over all three, `capabilities.code_execution: false` is the only manifest value the validator accepts outside Tier X.

The Tier X sandbox, recorded in advance

A sandbox designed on the day someone asks for one is designed in a hurry, so it is written now (P122, proposed; §4.3): a private GKE Autopilot cluster per Tier X project in `europa-west1` with the Agent Sandbox add-on and gVisor; one short-lived sandbox per tool call; egress only to the agent's egress gateway; no identity or token inside; an attested base image; executed code logged; and K7's first lever stopping it with everything else.

GKE Agent Sandbox has been generally available since Google's announcement of 2026-05-21, which meets P27's stage condition (P27 proposed: stage met, tier closed). Residency no longer decides, because Agent Runtime Code Execution is also available in `europa-west1` and the `eu` multi-region. GKE is chosen for named isolation, a documented egress block, a sandbox with no identity, and GA; Agent Runtime Code Execution is the recorded second option, not adopted while its launch stage, isolation and egress path are unverified. The cost is a Kubernetes estate for a team that is one person on 2026-09-14; if GKE proves unoperable, the written fallback is no code execution in the EU.

Containing the top tier

Eight properties, three labels

Eight containment properties are graded enforcement or detection and labelled exists, buildable or research-grade (§5.1); "exists" means designed in the agent sets and generalised by the factory, not running. Existing: a capability ceiling enforced outside the agent, in the action service and validator; no credential in the model's process; default-deny egress, whose sandbox part is buildable. Buildable from GA products: the fleet kill switch K7, pulled by a human or a deterministic job and never a model (Chapter 8, Identity, privileged access and the fleet kill switch); EU-resident sandboxing; no self-modification, meaning no agent principal writes a repository, registry, deploy identity, its ladder or its ceilings. Partly buildable and detection-grade: capability-drift monitoring through behavioural baselines over audit data. Research-grade and provider-side: evaluation gates before a capability grant — the ladder gates operational capability, and nothing on Google Cloud gates dangerous

capability. Beside the eight, [HLD §11.4](#) lists the model-free monitor, re-qualification on model change, monoculture, transitive capability through peers (held by peers being L0 for writes and tainted) and deception-robust monitoring, the last research-grade.

The AI-control primitive

The one control a compromised, deceptive or more capable model cannot argue with is one containing nothing that reads its arguments ([§5.2](#)). The authority path — approve, halt, demote, veto, stop the fleet — holds no model by construction: typed predicates over plan inputs stated in advance, a plain authenticated REST halt, an organisation-policy fleet stop. Halts also go to the insert-only audit log, so a restore cannot lose one; machines only lower autonomy. The absence is enforced: the model API is denied on Eve's and every verifier project, CI forbids a model client in the gate's image, and the supply chain of Chapter 13, Supply chain, keys and recovery, makes that image the only one that runs. A model may narrate and page on the advisory path, and no gate reads what it writes (Chapter 16, Eve, the independent controller).

What it is not: it does not detect a capable model that behaves well while observed and badly otherwise. It bounds what any behaviour can reach and stops the fleet on a signal a human or a rule chose. That is control, not evaluation.

What the platform cannot buy

Dangerous-capability evaluation is the model provider's responsibility ([§5.3](#)). Google DeepMind's Frontier Safety Framework (version 3.0 of 2025-09-22, additions on 2026-04-17) defines critical capability levels and governs Google's launches; no deployer operates it and no Google Cloud product exposes a result per model. So the platform points at the evidence: each register row carries `capability_eval_ref` per model pin, a pointer to the provider's report, required for Tier X by a CI check (P124, proposed), and the EU AI Act risk file already says the platform gates on measured behaviour within a catalogue (Chapter 20, EU AI Act).

Deception-robust monitoring, a trusted monitor over an untrusted more capable model, is research; nothing packages it, and Google's Semantic Governance page says its verdicts "may not be accurate", which is why it sits on no authority path. The platform uses an honest subset — the model-free monitor plus blind human grading of a sample. Interpretability and alignment guarantees are claimed nowhere.

Model changes and monoculture

Evidence earned on one model says nothing about the next, so re-qualification on every model pin change is charter demand D9 ([HLD §1](#)): a fingerprint change — prompt hash, model id, framework version, filter version — returns every autonomy cell above L3 to its entry level at the next deploy, and the validator refuses evidence carrying a different fingerprint. Eve's advisor is re-qualified too, its paging thresholds reset on a new pin (P123, proposed). The scaling consequence: a fleet-wide model upgrade demotes many agents at once and hands the whole grading load back, so upgrades are scheduled against grading capacity.

Every agent and Mo's narrator run Gemini; the gate runs no model. For Tier X, advisory monitors must use a second model family so the watcher does not share the watched model's failure modes (P26, open, platform owner; [register §6](#)); the family must satisfy the EU residency allow-list for model pins (P113, proposed).

Tier X: a closed tier with written opening conditions

A tier, not a new design

The tier is the platform's unit — folder, factory module, monitoring baseline, metric pack, staffing, compliance gate — so a future AGI agent is a tier, not a new design, and proposing one means meeting conditions already written ([HLD §11](#)). The admission test asks the Tier X question first — code it wrote, goals it set, capabilities its designers cannot enumerate — and refuses a yes with `tier_x_closed` (Chapter 7).

The Tier X folder exists with an empty service allow-list, so Google refuses every API in it, and a non-empty value without a numbered decision is severity 1; each opening condition must become a dated line in the folder's decision file before the list gains a service ([landing zone](#), [Tier X](#)). Every containment primitive must be live and drilled for six months before the first Tier X row; a missed month resets the clock. "Host future AGI agent" is declined for 2026, replaced by something Google enforces today.

The opening conditions on 2026-09-13

From [HLD §11.5](#) and [supply-chain page §5.4](#):

Condition	Owner	State on 2026-09-13
Sandbox tier in the EU at general availability	Platform owner (P27, P122)	Met: GKE Agent Sandbox, GA since 2026-05-21
Provider capability-evaluation report per model pin	Platform owner; AI-safety reviewer once the role exists (P124)	Not met: the field is designed, nothing fills it
AI-safety reviewer role exists	Not named (<i>tbd</i>)	Not met
K7 drilled for six months	Platform owner; security reviewer	Not met: K7 is not built
Advisory monitor on an independent model family running	Platform owner (P26)	Not met: P26 open
Every buildable containment property live	Platform owner; security reviewer and Mo's owner for K7 and drift monitoring	Not met: properties 4, 6, 7 and 8 named not live; nothing is built

The pages count differently: HLD §0.4 and the supply-chain page's §4.1 and §5.3 say one met and four unmet, while HLD §11.5 and §5.4 enumerate five unmet, as above. The register also names Tier X as the gate of P15, relocating Eve's control path to the witness organisation, which §11.5 does not list. None of the unmet conditions is in reach in 2026.

What remains open

P25 has no number until a Tier W agent has run a quarter, and its second grader does not exist. P26 is undecided; nobody is named to create the AI-safety reviewer role. Agent Runtime Code Execution's stage, isolation and egress path, the Cloud Run sandbox field and the sandbox-creation method name are unverified. Registry quota increases may be refused; budget and quota amounts are P31, open.

Other limits are accepted facts: a model that behaves well under observation defeats every detection-grade control, and only enforcement outside it and a kill switch it cannot reach bound it; a supplier's assurance rests on its evidence and contract; a fleet without graders stops growing. Chapter 19, Threat model and residual risk, carries these as residuals under the autonomy, third-party and staffing themes; Chapter 23 turns the hours into roles and Chapter 24 places the tiers in time.

Key decisions and what to read next

Key decisions

States on 2026-09-14:

- **Open:** P25, the Tier W cap by named grading capacity; P26, the second model family; P31, budget and quota amounts.
- **Proposed:** P27, GKE Agent Sandbox (stage met, tier closed); P121, no code execution below Tier X; P122, the Tier X sandbox; P123, re-qualification of the reporting path; P124, `capability_eval_ref`; P138, the supplier procedure; P114, an evidence bucket per tier folder.
- **Charter demand:** D9, re-qualification on every model pin change.

Chapter 25, Decisions awaiting the owner, lists who decides each open row.

Canonical pages to read next

- [HLD §11, the tier model, §11.4 and §11.5](#)
- [Landing zone §1.3, the tier profile](#)
- [Supply chain, secrets, recovery and AGI-class containment §4–§5](#)
- [TISAX §8, supplier onboarding and exit](#)
- [Project topology §1.4 and Mo's metrics contract §13.3](#)
- [Open decisions §3, §4 and §6](#)

Part III — The agents

Part III presents the platform's [first three tenants](#) as instances of its rules, not exceptions to them. Chapter 15 asks how a doer can hold Super Admin and still be gated, graded and stopped. Chapter 16 asks how a controller without super admin can check it independently. Chapter 17 asks how the agent that improves both is kept from ever deciding. Chapter 18 asks why their separation makes the team safer than any one of them.

15. Wall-E, the doer

What you will understand by the end

Wall-E acts in the Workspace tenant when a human asks, and later on its own; it is the only tenant of Tier P-SA, the super-admin singleton. This chapter answers the Chapter 3 risk theme of tenant compromise through the robot credential from the side of Wall-E's code (Chapter 8 answers it from identity, Chapter 11 from detection), and part of three more: autonomy outrunning evidence, classification collapse and staffing that makes two-person rules notional.

By the end you will know:

- why the doer holds Super Admin, on what kind of account, and what remains unsigned;
- how a prompt becomes an action only through code that holds the credential;
- how "any super-admin action" becomes three lanes that code chooses;
- what replaced the Workspace role as a gate, and how strong each replacement is;
- how autonomy is enabled cell by cell, how Wall-E is stopped, and what can still go wrong.

Nothing here is built. The design of record is the [Wall-E set](#).

Why the doer holds Super Admin

The objective of 2026-09-13 gives Wall-E "a dedicated user account, with a google license and super admin roles" and any super-admin-level action on a human's prompt. The earlier design was built for the opposite: a narrow custom role that grew with the ladder. The owner decided the question that day as P33 ([decision record](#)), choosing among three options.

Keep the narrow role. Its virtue was two enforcement points, the action service and Google both refusing outside the role or the pilot unit, but it cannot deliver "any super-admin action", and the owner overruled it. **Super Admin on a keyless service account** would leave nothing to steal, but Google forbids it: a service account can hold any Workspace admin role except Super Admin. **Super Admin on a dedicated, licensed user account, contained by the platform** was chosen as the only option both possible and faithful to the objective. It keeps the typed catalogue as the declared intended purpose and moves every control that read "not in the role" into code that CI owns outside the agent repository. Its costs are Chapter 3's (The problem and its risks), and a second Google fact shaped everything: Super Admin cannot be limited to an organisational unit or a subset of privileges.

P33 is decided and not re-argued. Not settled: the TISAX deviation (P136, proposed) is unsigned by the security reviewer and not yet entered by the ISMS as risk row R-01 (P140); the two lists are unsigned (P29, open); the intended-purpose statement awaits legal (P28 via P125). The grant is blocked until every row of the [gate checklist](#) is green ([register §4](#)); on 2026-09-13 none is. The deviation record and its red-row rule are Chapter 21's; the argument for the compensations is below.

Where Wall-E sits and what it is meant to be

Wall-E lives in WALLE_PROJECT under fld-agents-p-sa-prod, in europe-west1, and the register's CI refuses a second super-admin row while one is not retired ([placement](#)). The platform enforces what an agent must not be trusted to enforce on itself: identity, gateway binding, the deny policy, admission, the fleet stop, deploy grants and the super-admin detection set. Wall-E's code carries what only Wall-E can know: its catalogue, policy chain, ladder, playbooks and prompt, and verification by re-read.

token can mint super admins, and only the hard-denied list, multi-party approval and a SIEM rule stop it. Scopes freeze at consent, so widening either needs a new witnessed sitting.

The consent sitting and a token that dies

User credentials need the user's consent, so one interactive sign-in is unavoidable ([getting a credential](#)). A human super admin takes a hardware key from the safe under a custody record, signs in as the robot in a clean profile, consents both clients, stores each token in its own secret and arms the login alert; the custody record makes that sign-in expected rather than a severity-1 page.

Each way a token can die becomes a rule, from a monthly refresh of the rarely used broad lane to a re-bootstrap with every password rotation; whether a password reset also kills the broad token is unverified until the sandbox test ([token failure](#)). `invalid_grant` is never retried: the lane is dead until a human re-runs the sitting, because a retry loop would hide an incident behind an outage.

The account hygiene set

Every item is a precondition of the grant ([hygiene set](#)); Chapter 8 states the rules both robot accounts share. The role cannot be unit-scoped but settings can, so the robot gets its own organisational unit (`Assumption: creatable`) with the strictest settings Google offers: security-key-only 2-step verification, a vaulted password whose custodian holds no key, and no recovery phone or email, because an unwatched channel is a takeover channel. Multi-party approval covers every setting it can, with the robot never an approver (P66, proposed). Whether an Admin console access level no device satisfies binds a super admin is unanswered (P7, open), so it counts as detection plus friction, never prevention. Three alerts close the set: any interactive login, the one control that survives Super Admin unchanged; any action by the robot on another admin, which is hard-denied and so means the credential acted outside the service; and role-assignment drift.

From prompt to action

Why a dispatcher. An on-request agent needs none; Wall-E's exists for three reasons ([dispatcher](#)). A halt must bite before the model spends tokens producing a plan. Run identity, budget and configuration version must exist before the agent speaks. And a trigger must be acknowledged in about a second while an agent turn takes minutes; a synchronous call would be retried and run twice. The dispatcher serves band A only.

Why the action service stays separate. Under Super Admin the service is the only gate in front of the credential ([separation](#)). In the model's process the token would be one read away from exfiltration. Tool arguments are generated text that can name `users.makeAdmin`, and Google would execute it, so the hard-denied list must live in the gate, not the prompt (Chapter 19, Threat model and residual risk). And Eve's reconciliation relies on a write-ahead audit row before every call, which a tool calling Google directly would skip. The price is one hop of roughly 50–150 ms, twice for band B.

The caller allowlist and the engine lock. Cloud Run grants invoke rights per service, not per path ([inventory](#)), so a per-endpoint allowlist generated from the manifest does that work in application code, each row with a negative test: the agent may plan and execute but never approve, operators and Eve may halt and demote, and Mo may use two read endpoints. Operators are checked against a committed list, so a halt still works when the Workspace credential is what failed. Because the user's email reaches the agent asserted rather than proven, the right to query the agent engine is locked to the Gemini Enterprise service agent and the dispatcher ([engine lock](#)); whether that grant holds across projects is Wall-E decision 42's spike.

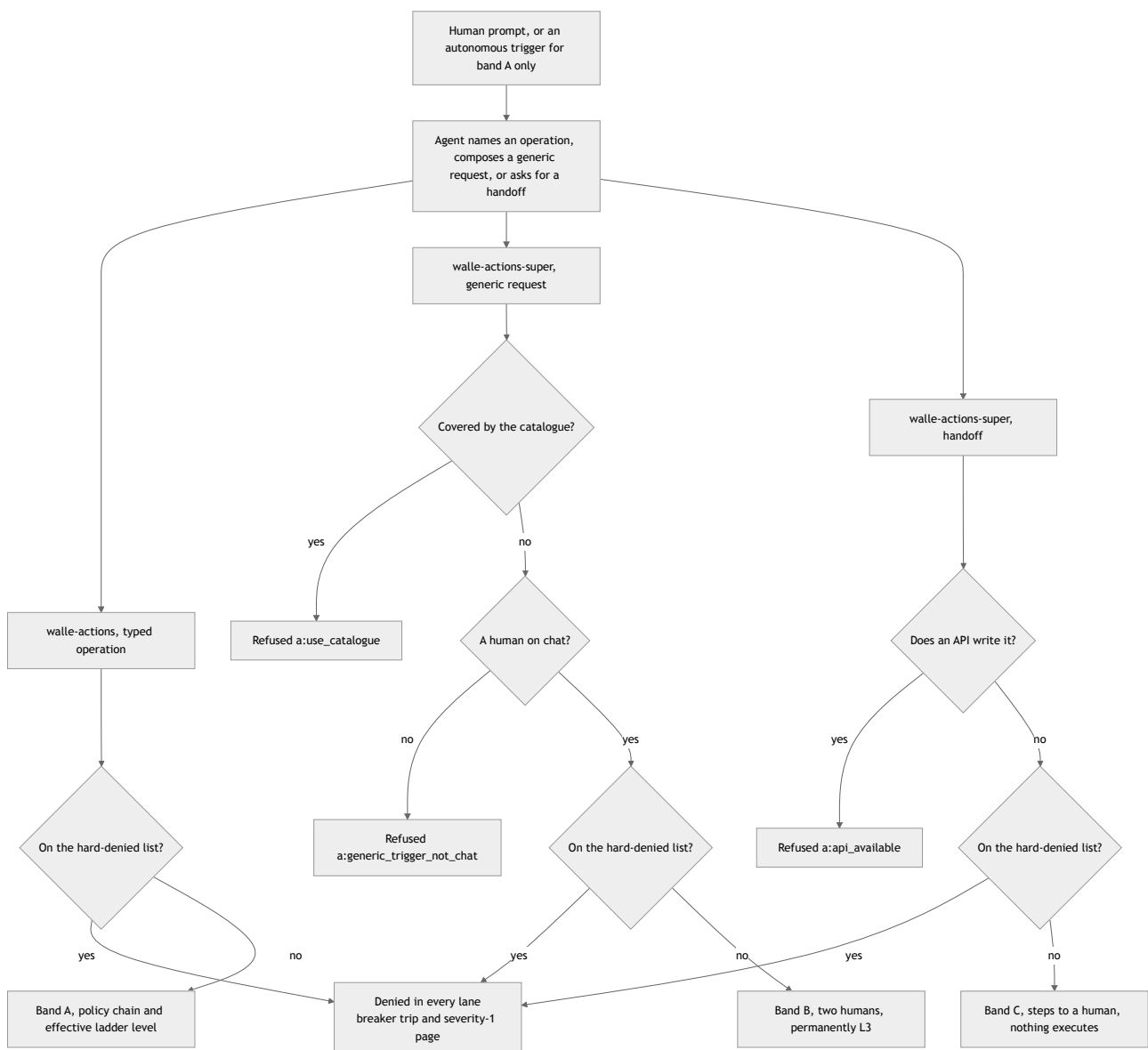
What the approval surface asserts. Every L3 statement rests on the approval carrying a per-human assertion the service verifies itself ([assertions](#)): an IAP-fronted page forwards the identity token verbatim for checking against the committed operator list. A text reply in Chat is refused, because a parsed message authenticates nobody, and without an acceptable surface no family goes above L2. Operators from an external identity provider wait for a captured sign-in, because their token format is undocumented.

Three bands decided by code

"Any super-admin action on a human's prompt" is delivered by three lanes, not a wider catalogue, and the lane is decided by code from the operation requested, never by the model ([the three bands](#)).

Band A is the typed catalogue on the ladder, served by `walle-actions` on the narrow client: the declared intended purpose and the only band that can climb, because only a typed operation carries the pre-state, inverse, taint declaration and re-read verification that autonomy needs. **Band B** is uncatalogued super-admin work, a generic Admin SDK request on `walle-actions-super`: permanently L3, chat only, two humans at tier SUPER. **Band C** is console-only work, defined by fact rather than choice: the Cloud Identity Policy API writes almost nothing and delegation is console-only, so settings such as 2-step verification enforcement, session policy and billing can be read but not written ([band C](#)). Nothing executes there: the service returns steps to the requesting human super admin, watches the Reports API for the matching event and closes the row as seen or not seen. The robot never touches the console, because automating it would make "an interactive login is an incident" routine.

Two routing rules stop the lanes being used to escape each other: a band B request the catalogue covers is refused `a:use_catalogue`, and a handoff for something an API writes is refused `a:api_available`. CI fails any playbook naming a band B row.



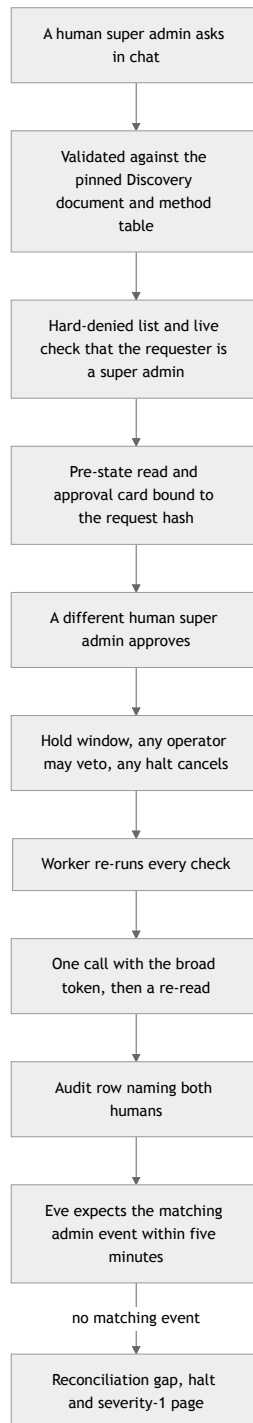
Band B end to end

A generic proxy loses the inverse, pre-state predicate and taint declaration; band B can do without them only because it never runs above L3, unattended or on one person's word ([band B](#); [request path](#)).

The request is validated only against Discovery documents committed to the repository, never fetched at runtime, and against a committed method table, so a method Google adds is unreachable until someone reviews it. The table tiers each method `READ`, `WRITE` or `SUPER`, with anything touching roles, security, domains, billing or API controls at `SUPER`, and its code owner is the security reviewer.

At tier `WRITE` one live-checked operator requests and one approver releases. At tier `SUPER` a live, fail-closed check confirms the requester is a human super admin, and a **different** human super admin, checked the same way, approves with a ticket reference bound to the hash of the request. The robot as either party is refused as escalation. This rule stops membership of the operators' group becoming a super admin's reach by proxy.

Band B writes have no inverse and are recorded irreversible. The flow below shows the rest: a hold window with veto, every check re-run at release, one call, a re-read, and Eve expecting the matching admin event within five minutes, whose absence halts the lane. The lane's rate limit and budget are *tbd*.



The two lists and what stays out of the catalogue

Wall-E decision 4, the must-never list, is re-ratified as two lists the owner must sign before the grant (P29, open). They bound every other control, and Chapter 20's Art. 6(3) position rests on them.

The hard-denied list is refused in every lane, handoff included, before the ladder is consulted, whoever asks and however many approve; a hit trips the lane's breaker and pages at severity 1 ([hard-denied list](#)). Its five closed reasons name the harms it prevents: the robot modifying itself, its controller, the control groups or its own OAuth clients; escalation, from `users.makeAdmin` to the robot approving anything; posture changes, from other admins' security settings to delegation, audit-log sharing, sinks and the rules watching the robot; deletion of an admin or

the tenant; and spend outside the second list. Targets resolve by immutable id, so aliases and nested groups do not evade it. Two entries wait on the P29 signature: `walle-owners@`, protected by the manifest though the platform HLD does not name it, and `walle-super-approvers@`, awaiting the owner's confirmation.

The tier- SUPER two-person list is the rest of what the old must-never list excluded, now reachable only through band B at **SUPER (two-person list)**: organisational-unit structure, deletion of non-admin users and of groups outside the security class, admin roles below Super Admin, domain adds, data transfer, and licence purchases where an API exists (**Assumption**: none does).

Never in the catalogue no longer means never executed (**never in the catalogue**): each excluded category splits by harm between the hard-denied list, band B and band C. No lane reaches GCP IAM or other people's Drive, and for the robot credential that rests only on the list, the scopes and detection, since a super admin can reach Organization Administrator (Chapter 16, Eve, the independent controller).

Protected principals (protected principals) are super admins, delegated admins, the robot, its unit and any group granting an admin role or controlling the three agents. An admin target is denied in band A, reaches band B only at **SUPER**, and comes back as steps in band C. Two mechanisms make silent failure loud. The **floor assertion** denies every directory write unless the computed protected set contains a committed floor of the human super admins, the robot, Eve's account and the control groups. **Group classification** is computed from transitive ancestors and admin roles, never declared, because a small list nested inside the operators' group looks harmless in the console; unclassified counts as security and is never writable.

What replaces the Workspace role

The role was the second gate, and each control it provided now has a named replacement with an honest grade (**what Super Admin removes; replacements**). What Google once refused outside the role or unit, code now refuses: the bands, the two lists, a unit allow-list and the protected-self rule. Operator reach becomes requester and approver entitlement, partly organisational. Google still enforces two subsets only, the narrow scopes on everything unattended and multi-party approval on role assignment and delegation. Detection, which once confirmed a refusal, now does the work itself. And a leaked token, once bounded by the role, is bounded by custody, the scope split and detection latency alone; the residual is a tenant compromise (Eve's detection in Chapter 16, the SIEM set in Chapter 11).

The thirteen compensations as an argument

The platform makes thirteen compensations preconditions of the grant, not S1 items (**platform HLD §13.1**), because from the minute of the grant a leaked token is a tenant compromise whatever the ladder says. They form four layers, each covering what the one before cannot.

Narrow what can execute, in code: the three bands (1), the two lists (2), the permanent ceiling that no super-admin-class operation is ever autonomous (9), and the role-scoping replacements as hard invariants proven by the denial suite (10). Strong against the model, weak against whoever deploys or compromises the service.

Narrow what a token can do, at Google: two credentials in two services with `cloud-platform` in neither (3); account hygiene with multi-party approval (6); and the perimeter (8), meaning ingress closed once spike P3 passes and P90 applies, Access Approval on the project, and a second reviewer on the deploy grant. This closes the deploy hole, not a leaked token.

See and stop: detection as the primary control, with absence alarms so silence is not calm (5), and kill switches, K6 above all (7).

People and paper: the band B requester rule (4), a second human outside the Wall-E administration line (11), the signed record (12) and the EU AI Act position (13), which make the residual an owned risk. On 2026-09-13 every row is not built, not signed or not named.

Five trust boundaries

Each boundary can still fail ([five boundaries](#)). Between human and Gemini Enterprise the email is asserted, hence the engine lock. Between agent and action service IAM is per service, hence the allowlist. Between model and credential, tokens live only in the two services. Between permitted and autonomously executed, the ladder, holds and breakers apply, but the taint bit fails silently on an undeclared field. Boundary 4, between the action requested and the action executed, is the one Super Admin damaged: it is now the policy engine alone, backed not by another boundary but by detection.

A control plane that fails closed

An outage must not disable a control ([fails closed](#)). Any control-store error denies; a missing override reads as L0, not L5; halt and override reads are never cached; and after 30 seconds without the store the process halts its own writes. The audit is write-ahead and insert-only, so if the sink is down, writes stop. A band B request is stored whole, secrets hashed, as the record of what two humans approved.

Denial reasons are a closed vocabulary that metrics, breakers and CI key on ([denial reasons](#)). A protected-principal denial on a human's chat request is an ordinary refusal; a hard-denied one trips a breaker and pages, because under Super Admin the prompting human is the escalation path. Aligning the platform's hard-denied code with the five reasons in the audit schema is *tbd*.

Autonomy, step by step

Chapter 9 owns the fleet rules of the ladder; this is Wall-E's instance. The values, family by family and stage by stage, are on [the ladder page](#); what follows is the reasoning behind them.

Why reversibility sets the ceilings. A level attaches to a family and trigger pair, and families are cut by how cheaply a mistake can be undone ([families](#)). Reads can reach L5; reversible writes such as suspension can reach L4; writes that grant access or move people between units stop at L3. Restore and rollback stay at L3 permanently, so that a loop cannot suspend and restore unseen, and free-text outbound is never autonomous. Above configuration sit ceilings in code, raisable only by a code change with security sign-off ([ceilings](#)): `WRITE_HIGH` never reaches L5, and the inbox never writes.

Why band B never climbs. The `SUPER` and generic-write rows are L3 on chat and L0 on every other trigger, fixed as code rows the platform validator refuses to see changed, and never allowed in a playbook. Without an inverse, a typed pre-state predicate or a taint declaration, no run of good history can show a generic request safe without a human.

The taint bit and the effective level. Injection arrives with what a run reads, not how it started ([taint bit](#)). Each operation declares its attacker-writable fields; once one reaches the model, the run takes the inbox ceiling for life, while a tainted human chat request keeps L3. The level applied is the minimum of the code ceiling, the configured level, the playbook's cap and the demote-only override, logged on every row ([autonomy config](#)).

Stages. The grant is a gate before S0, not a stage: Eve's observe-and-report layer is live and drilled first, and until the grant the robot is licensed and hardened and reads nothing ([the grant](#)). The stages then widen what Wall-E may do one trigger class at a time. S0 reads and runs every write in shadow; any real execution aborts it, as does an objection from the data protection officer or employee representatives. S1 allows chat writes at L3 in the pilot unit. S2 makes a templated notification the first autonomous write. S3 lets one human approve a frozen batch while Eve's gate observes; its exit includes Eve's acceptance test, on whose figures Wall-E's and Eve's pages still differ (Chapter 16). S4 lets Eve's signature replace the per-item human for families that earned it, an unreachable Eve meaning waiting. S5 is steady state. Durations and the cross-agent sequence are Chapter 24's.

Still open: the platform's EU AI Act caps on suspension and licences are not yet on Wall-E's ladder page (register row 14, [values that differ](#)); the caps are Chapter 20's.

Stopping Wall-E

Seven switches, K0 to K6, run from surgical to total, because each stops something the one before cannot; who pulls each and what each does not stop is in the [architecture table](#), and K7 with the crisis order, K4 before K7, is Chapter 8's. The first switches halt writes, demote a cell, stop new runs or cut the agent off, and any operator, Eve or a breaker may pull the lightest. None of these touches the credential, so the last three act at Google: revoke each service's token, revoke both grants or suspend the robot, and remove Super Admin.

Three choices carry the argument. K4 revokes at Google rather than disabling the secret, because a disabled secret stops only future refreshes; its endpoint is not yet in the LLD's table (*tbd*). A revoked grant still leaves an issued access token alive for up to an hour, which is why K6 matters most: removing the privilege stops even an already-minted token (**Assumption:** calls are authorised against current privileges, verified in the first drill). And K5 and K6 stay with a human super admin on a two-person rota, never the owner when the owner is the actor, with no machine stop for now (P16, proposed), because an automatic stop on a super admin is a lock-out path a compromised monitor could pull.

A switch nobody has pulled recently is a belief, not a control, so the drill runs before S0 and CI refuses a promotion citing one older than 30 days ([drill](#)). The switches that leave the credential intact are drilled monthly in production; K4 and K5 consume it, so they run in production only at commissioning and after an incident, and K5 and K6 quarterly on the sandbox tenant's robot twin. Whether that quarterly drill satisfies the gate's 30-day row is unverified. The denial suite proves the gate refuses what it should ([denial suite](#)): organised by boundary, it runs before every promotion and counts a pass for the wrong reason as a failure.

What Wall-E does not do

Three kinds of no ([non-goals](#)). **Permanently human:** band C steps, approving band B, raising a level, merging Mo's proposals, pulling K5 or K6. **Never autonomous:** super-admin-class work, `WRITE_HIGH` at L5, and anything irreversible in band A. **Not done at all:** the hard-denied list; acting as anyone but the robot; automating the console; bulk or emergency work; administering its own platform, true by construction on GCP and only by list, scopes and detection on Workspace.

Known structural weaknesses

Fourteen survive, listed on the [architecture page](#), and those that describe the service as the gate grow worse under Super Admin. One deploy grant defeats everything, so a compromised pipeline is now a tenant compromise; the gate is one process per service, trusting an asserted user identity. An injection can still reach the queue as a proposal. Recovery is slower than failure. A one-person rota, now a grant condition, is the weakness likeliest to stop the programme, and the credential holder is internet-reachable until P3 passes. Weakness 14 is P33's residual: a leaked token or login is a tenant compromise and a path into the GCP organisation.

Key decisions and what to read next

States on 2026-09-14:

- **Decided:** P33, Wall-E holds Super Admin on `walle@`, deviation signatures pending.
- **Open:** P29, the two lists; P7, the Admin console access level; P14, the witness organisation.
- **Proposed:** P16, P66, P68, P90, P136, P140, P125 with P28's content (its signature with legal open), and P143, owners and gates for the propagation stage that carries register rows 10–14 into the agent pages.
- **Spike:** P3. **Wall-E decisions:** 3 reopened as two lists, 18 landing now, 42 a spike.

Every row that gates the super-admin grant is in [register §4](#); the order in which the grant and Wall-E's stages open is Chapter 24, Roadmap and cost.

Chapter 19, Threat model and residual risk, carries what remains: a leaked token or login is still a tenant compromise, met by custody, scope split, detection latency and K6 rather than prevented; a compromised pipeline is a compromised action service; P7 stays out of every safety case.

Read next: the [Wall-E HLD](#), [identity and authorisation](#), [the LLD's bands](#), [the ladder](#), [the P33 record](#) and [the gate checklist](#).

16. Eve, the independent controller

What you will understand by the end

This chapter alone answers the Chapter 3 risk theme of a controller reachable by what it controls. It carries part of two more: manufactured silence, answered for the platform in Chapter 11 and for the robot here, and staffing that makes two-person rules notional, answered with roles in Chapter 23 and here with the work one of those roles does.

By the end you will know:

- how a program with read-only Workspace access and one signing key checks a super-admin robot;
- which part of Eve's independence is structural, which is only detective, and what the witness organisation adds;
- why no model sits on the path that approves, halts, demotes or vetoes, while a separate reporting path may reason;
- when halting and signing each arrive;
- what Eve cannot see, stated in every attestation.

Nothing here is built. The design of record starts at [Eve's HLD](#).

The thesis

Eve is a body of SQL, two deterministic Cloud Run jobs, a console and a key, in its own GCP project. Its only privileged act is a Cloud KMS signature over a hash it computed itself. Everything else Eve does is reading, comparing, recording, halting, demoting, vetoing and reporting.

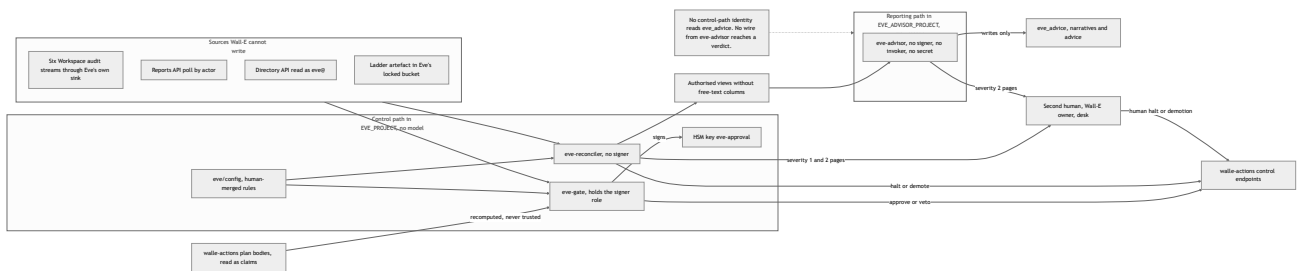
One premise shapes every mechanism. Everything `walle-actions`, Wall-E's action service, says is a **claim**. Eve recomputes what matters from sources Wall-E cannot write: Google's own audit streams, the Directory API read with Eve's own credential, a ladder artefact in Eve's locked bucket and Eve's own ceiling table. A lie has to be consistent across all of them to survive to a signature.

A controller whose approval can be talked into existence is not a control, and one that is a service can be down unnoticed. So Eve is small, deterministic and a client everywhere. The price is that it finds only what a rule names, which is why a reporting path exists.

What Eve is not

These negatives do more work than the positives ([Eve HLD](#), [what Eve is not](#)). Eve is **not an agent**: it has no agent card, A2A surface or HTTP endpoint, and talks to Wall-E over plain authenticated REST in one direction (Chapter 18, How the three work together). It is **not a component of Wall-E**: its key, secrets, datasets, identities and configuration sit outside Wall-E's project. It is **not a model on its authority path**. It is **not sufficient**, because Wall-E verifies Eve's signature and then re-runs its own full policy chain on every item. It is **not its own grader**: humans grade Eve's verdicts, never Eve and never Mo, or the controller would both decide and grade. And it is **not a Workspace writer or a super admin**, at any stage.

Two paths



The control path has no inbound surface

The control path is `eve-gate`, `eve-reconciler` and `eve-console` in `EVE_PROJECT`, plus the key. Nothing calls it. Eve polls for work, reads Google directly, and calls Wall-E's REST endpoints to approve, veto, halt and demote ([choice 2](#)). Nothing can be sent to Eve, and "Eve is down" can show only as an **absence**, the only alert that also catches a wedged process. A heartbeat endpoint was rejected because it could keep autonomy alive while Eve did nothing, and a subscription to Wall-E's event topic because it would be a channel Wall-E controls. Eve runs as scheduled jobs, which have no ingress and cost almost nothing while there is nothing to gate.

Deterministic by absence

"Eve contains no model" is worth nothing as a sentence and something as a build that fails when the sentence stops being true. Seven enforcements guard the control path ([the deterministic boundary](#)), and two of them bind: no model dependency in the image, checked by a lockfile scan, and no model permission on either runtime identity. A process that cannot reach a model, under an identity that cannot authenticate to one, cannot get a model to produce a signature. The other five guard against regression, from a project-level denylist on the model API to offline replay of archived verdicts that must match bit for bit. The invariant has a compliance reading: a model-free control path is recorded as outside the AI Act's definition of an AI system and as a human-oversight measure, and a model on that path voids the determination (Chapter 20, EU AI Act).

The reporting path may reason

"Report anything wrong" cannot be written as a closed vocabulary; enumeration stops at the deterministic catalogue. So `eve-advisor`, a Cloud Run job in its own project `EVE_ADVISOR_PROJECT`, may use a model. It narrates what the control path found and names what no rule covers ([the reporting path](#)). It is report-only by IAM rather than discipline: it reads through authorised views without free-text columns, writes only narratives and advice into one dataset, and holds no signer, no invoker on any action service, no secret and no write to Eve's configuration. Nothing it writes is read by the gate, the reconciler or either Wall-E action service; no wire lets it even turn an accept into a refusal, because that would put model output on the authority path. It pages at severity 2 only, inside the page budget, citing the deterministic finding behind each page, and a human who agrees acts through the existing human path.

Until legal settles its AI Act class (P19, open), it makes no finding about a named human unless a deterministic rule triggered it. Every model-pin change resets its paging thresholds and re-runs the seeded-fault set before it may page again (P123, proposed).

The path is P34, proposed, reopening "no model anywhere in Eve" for reporting only ([decision record](#), [register §5](#)). It awaits the Eve owner, a role the platform owner holds until the second human is named, and the security reviewer; until then Eve reports only what its rules name.

Eve's own project and its three carve-outs

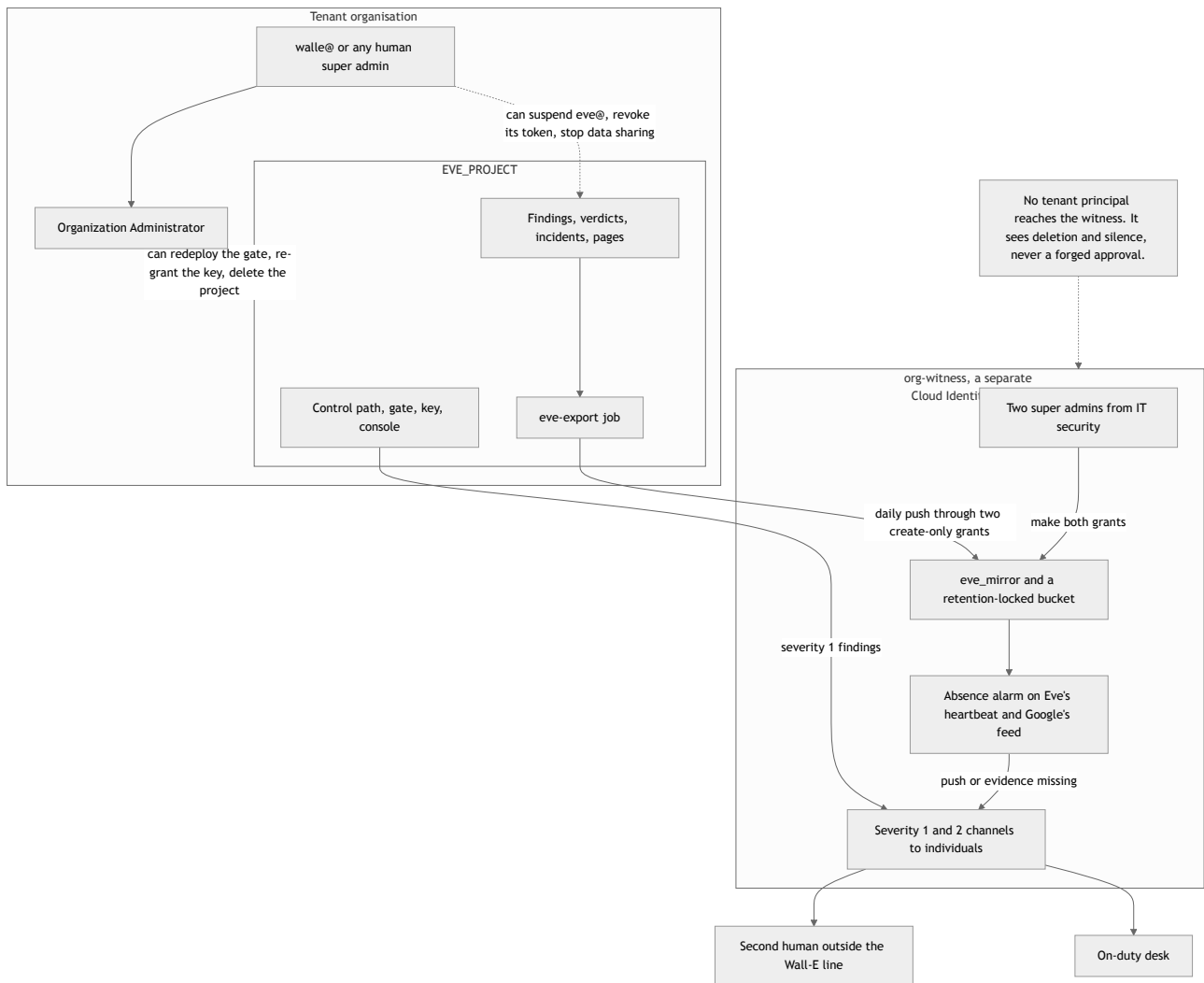
Why every agent has its own project is Chapter 7's (Landing zone and the tier model). Eve's particular reason: in Wall-E's project a project owner could grant themselves the signer role and mint an approval that only a daily drift row would notice. In `EVE_PROJECT` Wall-E's service identities and deployers have no principal, nor any role on the parent folder ([why Eve gets its own project](#)).

Exactly three Wall-E grants exist there, all at resource level (topology decision 48, [topology §8](#)): Wall-E's deployer may create, never overwrite, ladder artefacts; the action service may read the signing key's public half; and from S4 entry it may read an existence-only view of verdict receipts, in a dataset not yet named. Eve's daily drift job fails on a fourth. The boundary is only as real as the organisation chart: with one administrator it is notional, and the design says so.

Independence in two parts

A Workspace super admin can grant itself Organization Administrator on the tenant's GCP organisation (Assumption: the standing recovery right behind this, verified or refuted before the grant), and Wall-E's credential can suspend `eve@`, revoke Eve's token, switch off data sharing with Google Cloud and re-filter sinks. `EVE_PROJECT` sits inside that organisation. Eve's independence therefore has two parts ([choice 1](#)). Against Wall-E's project owners, deployers and service identities it is **enforcement**: the project boundary. Against the super-admin credential and any human super admin it is **detection only**: once Organization Administrator is reached, the gate can be redeployed, the key re-granted or the project deleted, and the SIEM's super-admin rules (Chapter 11), Eve's tenant-integrity rules and the absence alarms see it while nothing prevents it.

Every attestation carries the same sentence: Eve's control path stays inside the tenant's organisation, and its independence there is detective, not structural.



The witness organisation

The structural part is what leaves the organisation. `org-witness` is a second organisation on a separate, minimal Cloud Identity tenant, holding one project, with two super admins from IT security, outside the Wall-E administration line. Its edition and funding are open (P14, owned by IT security, blocking the grant; [register §4](#)); **Assumption:** Cloud Identity Free on a distinct domain.

Evidence travels by push, because a pull would need a witness principal inside the tenant. Once a day `eve-export@`, an identity that neither reconciles nor signs, pushes the previous day's evidence and a heartbeat row through exactly two create-only grants the witness administrators made, on one dataset and one retention-locked bucket; a compromised exporter can add rows but not rewrite them. The witness also holds the severity 1 and 2 channels, the kill-switch rota records and the absence alarm. The export's contents are in Chapter 12.

The witness sees `EVE_PROJECT` deleted within fifteen minutes, and it sees silence. It never sees a forged approval: a super admin who redeploys the gate and signs produces rows that look like Eve's own. It is deliberately small, one more tenant, two more hardware keys and a second supplier line, so that cost is never a reason to defer it.

The end state, dated now

Only one mechanism stops a super admin who reaches Organization Administrator from forging an approval or undoing a kill: moving Eve's gate, key and console into the witness. P15, proposed, records this as the end state, built when IT security operates the witness and gated at Tier X, not at the grant ([register §6](#)). Its costs are stated:

security services and policy sets in both organisations, cross-boundary exceptions and invoker grants, and a spike on whether perimeter rules can name identities in another organisation. No standing cross-organisation policy administration comes with it, and the fleet kill plane stays where Chapter 8 puts it.

The second human in Eve's design

The witness and the reporting rules need someone who is not the administrator Eve reports on ([platform HLD §13.2](#)). That person owns `eve-owners@`, administers the witness, reviews every change to Eve's configuration, receives every severity 1 and 2 page in parallel with the desk, and alone receives reports about the administrator. Eve's build does not wait for this person, but the grant does: E-2 was reopened as blocking. The role and today's one-administrator starting point are in Chapter 23, Operating model.

Two authorities on opposite schedules

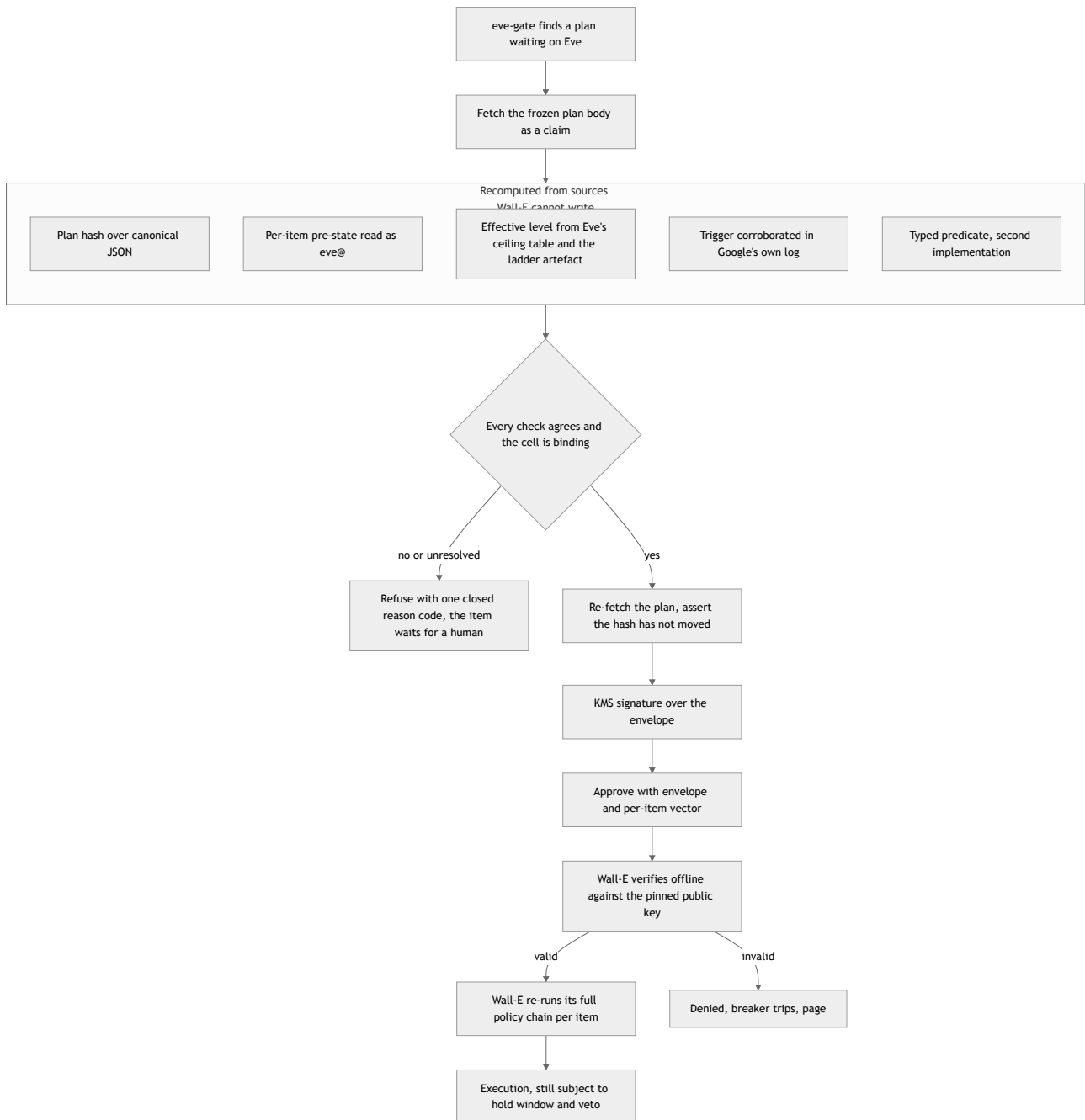
Eve's two authorities point in opposite directions, so they arrive at different times ([choice 4](#)).

Halting and demoting can only make less happen, so Eve gets them at S3 entry, or earlier for three triggers when the grant comes first; rate-based triggers only observe until their thresholds are calibrated on measured data. **Signing** can make more happen, so the key arrives only at S4 entry, after twelve seeded faults are caught at 100 %. A buggy Eve can halt the programme during the stage it is trying to prove itself in, which is accepted because one human can undo a halt in seconds.

"Halt when uncertain" would turn a degraded Eve into the outage. So at the approval point every unresolved comparison resolves to **refuse**, which costs an operator an approval; halting is reserved for a closed list of invariant triggers.

One field per ladder cell, `eve_authority`, switches signing on: `advisory` or `binding`, with an absent value read as advisory. It is at once the observe-or-enforce switch, the fail-closed default and the demotion target when an Eve approval is overturned; two flags were rejected because fields that must agree drift apart. Setting a cell to binding needs two approving reviewers, neither the author, and Wall-E refuses a signature for an advisory cell.

The pre-approval pass



The five recomputations

Every two minutes eve-gate fetches each frozen plan waiting on it and recomputes five things rather than trusting them ([the five recomputations](#)). It takes the plan hash itself, so the service's hash is compared, never signed. It re-reads each item's pre-state with its own token. It derives the effective level from its own ceiling table and a ladder artefact Wall-E's deployers cannot rewrite, which catches a lying policy chain as well as a lying plan. It corroborates the trigger in Google's own log, so it never co-signs a laundered suspension. And it evaluates the typed predicate through a second implementation. Eve's HLD counts trigger corroboration among the five while the LLD counts the ceiling-hash comparison instead; the checks and reason codes are the same either way ([Eve HLD](#), [Eve LLD §3](#)). Just before signing, Eve asserts that the plan's hash has not moved.

The approval envelope

The envelope is the only privileged artefact Eve produces (§5). It binds the plan, Eve's hash of it, a hash of the per-item accept-or-reject vector, configuration versions, an expiry, a single-use nonce and the key version. The vector hash makes batch approval safe: without it, one item's accept could be flipped outside the signature. And because a two-hour-old pre-state read proves nothing, a long hold window splits approval in two: an envelope at freeze opens the hold, and a short-lived release envelope, checked against fresh pre-state, authorises execution. A plan whose hold elapsed during an Eve outage has expired; it is not resumed.

The signing key and the PEM archive

The signature is asymmetric, so the verifier holds nothing that can sign. The key is HSM-protected, only the gate's identity holds the signer role, and every signature is logged (the signing key). Before a key version is first used, its public key is archived in Eve's locked evidence bucket and in Wall-E's repository under the ladder's code owners, and Wall-E verifies offline against the pinned copy (the PEM archive). No grant in Wall-E's project can then substitute a key, and a KMS outage stops signing but not verification. The stored signature and its archived public key are the only proof that Wall-E did not mint the approval itself, so manual rotation disables old versions and never destroys them inside the 400-day evidence horizon.

The line not to cut

Eve's second implementation of the typed predicate, differentially tested against Wall-E's, is at six engineer-days the largest single build item and the one not to cut (choice 5): without it, the verification metric that unlocks autonomy would measure itself. Tier W agents accept a weaker verifier compiled from their manifest (P79, Chapter 9); Eve does not.

Verdicts after the fact

Eve verifies reversible autonomous writes after they execute, and each verdict takes one of seven closed states, from verified to drift, reconciliation gap and unverifiable (§10). Behind the states is a split of evidence (the primary-evidence split). **Current state**, read immediately, proves the write happened, and the 60-minute target is measured on this read. **The admin event** proves the robot rather than a human made the change, and arrives on the audit log's slower clock. State confirmed with no event yet is a wait, and becomes a reconciliation gap only if nothing arrives within six hours. Calendar writes no audit stream at all, and Eve cannot read licence state; both are declared limits.

Watching a super admin

The evidence perimeter

A super-admin Wall-E can act outside any plan, so Eve watches every event attributed to the robot through two routes that fail differently (§13). Its own organisation-level sink carries all six Workspace streams with no actor excluded, though some streams depend on the tenant's edition, which is *tbd*. A Reports API poll by actor covers the robot, Eve's own account and every rostered super admin, and keeps working if a super admin switches data sharing off. A third route, a Workspace BigQuery export into the witness, is open (P17). A declared "records nothing" list names acts that leave no event Eve can read, such as Admin console views of user data (Assumption: per capability, verified before the grant). Any robot event in any stream without a matching audit row is a reconciliation gap, and it halts.

What "misbehaviour" means in practice

Three things run in the reconciler, never in the gate (§14).

The detection catalogue is merged by humans and has five classes. Tenant-integrity rules mirror the SIEM's super-admin set, so two independent evaluators can be compared. Other classes catch uncatalogued writes, posture changes and interactive robot logins, and deviations from baselines calibrated at S2. The fifth, prompt-to-action divergence, compares what executed with the signed human request, so Eve reports on human prompts as well as robot actions. A daily roster check pages on any addition to or removal from the admin roster. And an evidence heartbeat treats silence as a halt: if the sink goes quiet for an hour in business hours, or Eve's token is revoked, autonomous work stops until a human clears it (the platform's heartbeats are in Chapter 11).

"Any misbehaviour" ends where enumeration ends: what no rule names and no human reads is not caught (Chapter 2 declines the literal reading of the objective). The platform identity page adds six severity-1 rows that Eve's pages do not yet carry, among them break-glass sign-in and a fourth super admin ([register §7, row 11](#)).

Reporting

The reporting contract maps severity to channel and people ([§15](#)). Severity 1, from tenant integrity to missing evidence, goes through the witness channels to the second human and the desk in parallel, with the halt already applied and the Wall-E owner copied unless the owner is the actor. Severity 2, including the reporting path's findings, goes to the Wall-E owner and the second human; severity 3 stays on the console. Acknowledgement targets are `Assumption:` values, and an unacknowledged page escalates to a rota secondary outside the Wall-E line, then to the incident commander.

Reports about the administrator, such as level raises, halt clears, threshold edits and promotions of `eve_authority`, go only to the second human, out of band, so that a report never reaches only the person it is about.

Noise is a defect. Pages run inside a budget sized at S2 calibration, from which the evidence halt, tenant integrity, reconciliation gaps and roster changes are exempt; a reason code that pages too often opens a "threshold suspect" ticket; and a refusal is never a page ([the page budget](#)).

For the works council: Eve reads activity metadata, never content, and its prompt-to-action rule concerns what an administrator asked the robot to do. What may follow for operators is in Chapter 22, Personal data, employees and the works council.

When Eve is absent: Wall-E's sweepers

Eve cannot be relied on to notice its own absence, so `walle-actions` does ([Wall-E's side](#)). A plan waiting on Eve for four business hours stops autonomous work. An autonomous write with no verdict receipt freezes promotions after an hour and drops its cell to L4 after four; the receipt view shows only that evidence arrived, never what it says. A last-seen stamp on any Eve call feeds an absence alert. Nothing raises when Eve returns: only an operator restarts autonomous work.

Eve's Workspace robot

`eve@` exists so that Eve never verifies Wall-E's work through Wall-E's credential ([Eve's Workspace robot](#)). It holds a custom role with read privileges only, which never grows with the ladder, and it is never Super Admin. It follows the robot accounts' shared rules (Chapter 8) and sits among the protected principals. Its Workspace licence is Eve's largest recurring cost.

Scopes freeze at consent, so the set was widened before the one-sitting consent, which now happens before the grant (E-16): ten read-only scopes and no content scope ([the scopes](#)). Only super admins can use the Policy API, so Eve sees security settings change but never reads their state. The licensing scope was dropped because the only privilege that reads licence assignments also assigns them, so licence verification is event-only, backed by a heavier blind sample, and the family stays at L3 if that privilege cannot be scoped. E-16 also asks whether a

keyless service account could hold this role, which would remove the robot account altogether. A refresh token dies after six months unused, so a monthly exchange resets the clock, and a revoked token is a paging incident only a human re-bootstrap repairs ([the six-month clock](#)).

When each part arrives

Eve is staged in two layers ([the stage table](#)).

Through S2, Eve v0 is twelve scheduled queries, the ten ladder metrics plus reconciliation and drift, run under their own service account and read weekly by a human; no robot account, token or key exists before the grant. The six-stream sink arrives at S2, so that the first enforcing window has history behind it.

The observe-and-report layer is not a stage but a gate before Super Admin is granted, at whatever stage the ladder is ([the grant checklist](#)). Its seven rows, G-1 to G-7, require among others the second human named, the witness running with its absence alarm drilled, each detection mechanism proved by a seeded event, and the whole layer drilled end to end on the sandbox tenant. This layer halts but never makes more happen; the key still waits.

At S3 entry, halting and demoting go live. **S3 exit requires every one of twelve seeded invariant-class faults caught, with two negative controls silent**, after at least 30 days ([the exit gate](#)). The negative controls stop an always-refusing Eve passing. Agreement with human verdicts is reported for information only; a disagreement is the finding. Wall-E's ladder page still reads 95 % on seeded faults and agreement ([Wall-E's S3](#)); Eve's contract change CC-7 replaces that line before S3 exit, since 95 % over twelve invariant classes lets one class go entirely undetected ([CC-7](#)). A second grader who is not the ladder owner must exist by S3 exit (E-13). S4 entry adds the key, the gate and the first binding cells.

None of the gate layer should be built until an L3 to L4 promotion can state in numbers how much approval work it removes. **L3 with human approval is a legitimate permanent end state**. Durations and sequence are in Chapter 24, Roadmap and cost.

Eve's first job: the human super admins (2026-09-15)

The staging above describes Eve as Wall-E's controller; Eve's first job comes earlier. On 2026-09-15 the owner asked that the observe-and-report layer watch every human super admin from Eve's first run, before Wall-E exists ([platform HLD §13.2](#), [Eve LLD §14.1](#), P153 to P155). Nothing in the detection catalogue, the roster check or the reporting contract changes shape; the actor set does. From the first run the Reports API poll retrieves every application for every user, the catalogue's actor set is the committed roster, delegated administrators, break-glass accounts and every live admin-role holder, and `walle@` joins the robot set only when it exists. Before `walle-actions` exists there is nothing to halt, so a halting rule pages severity 1 and records a pending halt target; the halt call joins when Wall-E does. Findings go to the second human outside the administration line, with a copy in the witness, and a report whose subject holds authority over the platform, the platform owner included, goes to the second human only.

The full build ([setup 23 to 28](#)) builds it in this order, in parallel with Mo and never waiting on it: the project, datasets and the retention-locked evidence bucket (23); `eve@`, the one-sitting consent and the six-stream sink (24); the detections over the human super admins, with their schedules created, proven and left paused (25); the reporting contract and the witness export, which resumes the schedules after the route test (26); the witness administrators' create-only grants and the absence alarms (27); and the second human's independent proof on a seeded super-admin action, followed by the sandbox drills (28). The block ends with `EVE_H_LIVE_RECORD`, which the second human signs knowing what Eve does not see, and on which Wall-E's first file and every later one depend.

When Eve is wrong, compromised or alone

The fail-closed decision tree has four outcomes: refuse, halt, do not sign, and sign. No edge leads to a raise, and Eve holds no path to raise anything in code, IAM or its contract ([the decision tree](#)).

A **compromised Eve** can halt and demote freely, a denial of service a human clears in seconds. It can sign only for cells already marked binding, and the hold window, the veto, the budgets and Wall-E's per-item re-run still apply; it cannot raise a level, change a ceiling, flip `eve_authority` or touch Workspace ([when Eve is compromised](#)). Containment is two steps: revoke Eve's invoker grants in Wall-E's project and disable the key version. The residual is false verdict receipts that suppress the evidence sweeper, bounded only by the blind human sample, which is why the sample starts at S1; E-17 re-argues the receipt read at S4 entry.

Disagreement is asymmetric ([the threshold](#)). False refusals cost approvals, so a cell drops to advisory only when their rate is established statistically. A single wrong accept sends the family to L0 and demotes both agents.

The no-operator window covers holidays ([the window](#)). Eve warns 48 hours ahead and stops autonomous work when the uncovered period starts; chat work continues, and one returning human clears the stop. Eve halts rather than demotes because undoing a demotion above L3 needs two humans.

What Eve's independence does not cover

Five named limits go into every attestation for an affected cell ([five limits](#)):

1. Eve reads the plan from the service it checks. A service that shows plan A and executes plan B is caught afterwards, within half an hour, at a cost of one batch of reversible operations.
2. Google's log proves the robot acted, never who asked.
3. Licence verification is event-only.
4. The predicate has a second implementation, not a second author.
5. Independence from the ladder owner is not structural. It rests on a second reviewer and a second grader.

Beside them stand the [declared limits of watching a super admin](#) set out above. Limits 4 and 5 a well-built Eve cannot fix: they are organisational, and open.

Key decisions and what to read next

States on 2026-09-14:

State	Decisions
Decided	P33, Wall-E holds Super Admin
Proposed	P34, the reporting path, awaiting the Eve owner and the security reviewer; P123, re-qualification on a model-pin change; P15, the end state; P97, the heartbeats; P68, the roster; P107, the daily export and witness push
Open	P14, the witness (IT security, blocks the grant); P19, the reporting path's AI Act class (legal); P17, Workspace BigQuery export into the witness (Eve owner, gate Eve S2)
Eve's register	E-1 answered yes; E-2 reopened, blocking the grant; E-16 before the consent; E-18 at S2; E-13 before S3 exit; E-17 at S4 entry
Pages still differing	Register §7 row 11

Chapter 19, Threat model and residual risk, carries what remains: inside the tenant Eve sees a super admin but cannot structurally stop one; a forged approval stays invisible to the witness until P15 is built; a plan substituted by the service is caught only after the fact; and limits 4 and 5 depend on people not yet named.

Read next: [Eve HLD choice 1](#) and [the deterministic boundary](#); [Eve LLD §3](#) and [§13](#); [the grant checklist](#) and [Eve's failure modes](#); [the reporting-path decision record](#); then Chapter 17, Mo, continuous improvement.

17. Mo, continuous improvement

What you will understand by the end

This chapter explains how the component that improves Wall-E and Eve is kept from ever deciding, why a language model may sit inside it at all, what it measures and how its numbers are checked, and why the human grading it depends on decides how far the platform scales. It also carries the Art. 72 post-market monitoring plan.

Of the risk themes in Chapter 3, The problem and its risks, it answers autonomy outrunning evidence directly, and part of two more: a controller reachable by what it controls, because improving Eve must not weaken Eve; and staffing that makes two-person rules notional, because every gate here ends in human grades and reviewers. Nothing of Mo is built on 2026-09-14; the design of record is the [Mo set](#).

The thesis: numbers that have to be true

Mo is a body of committed SQL, one deterministic Cloud Run job, a bucket and, optionally and late, one model. Its organising property is one sentence: every number and every selection Mo publishes is re-derivable from the measured agent's audit dataset, `walle_audit` for Wall-E, and the gate re-derives it rather than believing it ([Mo HLD, thesis](#)).

A promotion pull request carries an evidence block: metric, value, the exact SQL at a pinned commit, window, fingerprint, sample size and seed. An external validator Mo cannot reach runs that SQL itself, refuses the merge if one value differs, and re-draws the blind grading sample; it and its custodian are the platform's (Chapter 9, Registry, governance and the autonomy contract).

That decision licenses a model in Mo: a compromised or hallucinating Mo can write a persuasive paragraph, but cannot produce a false number that survives CI. And an artefact that would change no human decision gets no pipeline.

What Mo is not

Four negatives carry more of the design than the positives ([Mo HLD, what Mo is not](#)).

- **Not callable.** No REST API, Pub/Sub event, agent card, A2A endpoint or MCP server, so nothing can steer a decision.
- **Not a decider.** Nothing Mo emits is an approval, a signature, a level, a halt, a sample or a gate input.
- **Not a credential holder.** No Workspace credential, secret, key or git credential; its three service accounts hold dataset-level reads and, for one, object-create on one bucket.
- **Not mostly a model.** A model appears in one place, from S4, writing prose about numbers it did not compute. It is legitimate never to build it.

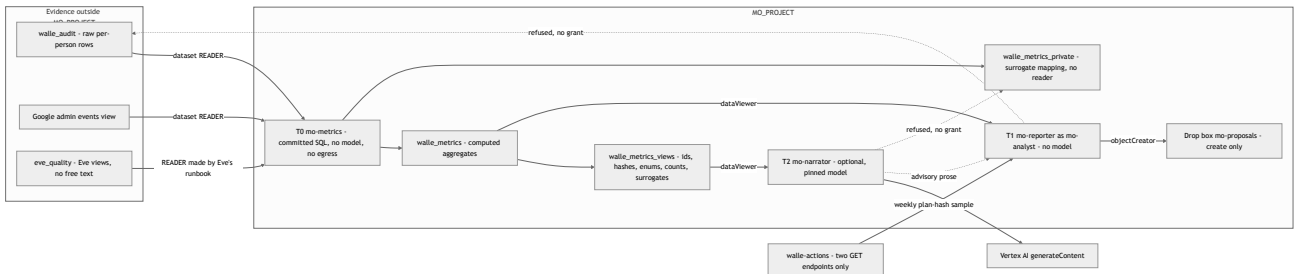
Three tiers and the seam between them

Mo runs as three identities in `M0_PROJECT`, each weaker than the last, and the boundary between code and model is IAM, not convention ([Mo HLD, the three tiers](#)).

T0, the metric queries, runs as `mo-metrics@`: about twelve pinned BigQuery scheduled queries, and the only identity that reads raw per-person rows, under dataset-level grants on `walle_audit`, Google's admin events and `eve_quality`. A scheduled query has no inbound surface and no egress, so the identity that sees raw evidence cannot be prompted. It computes every number and selection, the verdict included.

T1, mo-reporter, runs as `mo-analyst@`. It reads computed aggregates only, renders the artefacts, calls two read endpoints on Wall-E's action service to check weekly that audit rows match frozen plans, and writes bundles to the drop box.

T2, mo-narrator, optional from S4, reads only authorised views of ids, hashes, closed enums, counts and surrogate keys; the surrogate-to-person mapping sits in a dataset with no reader. An injected display name in an audit row cannot reach the model, because there is no free string to canonicalise ([Mo identity §3](#)).

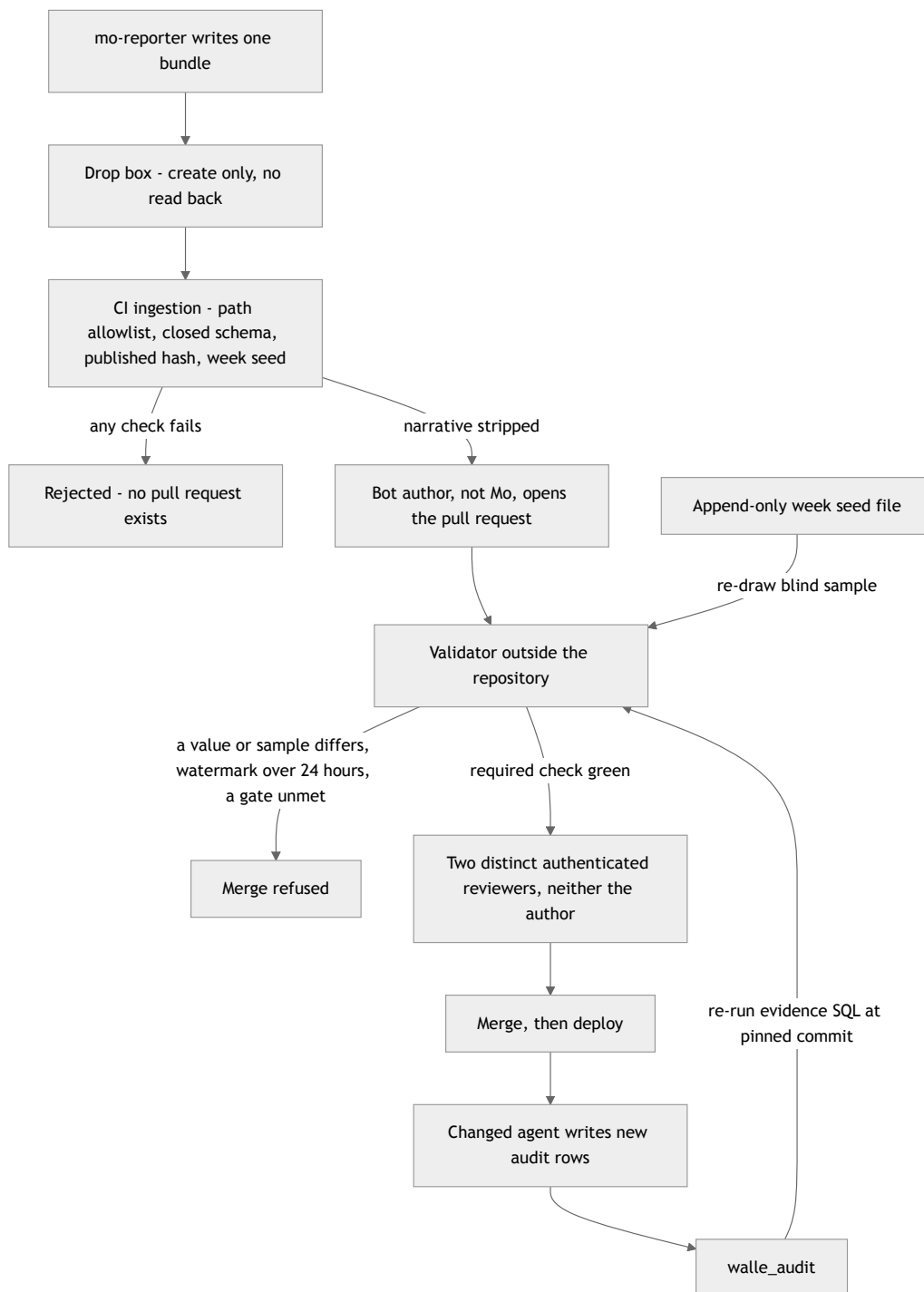


The deterministic boundary

Every number and selection that can move a level is computed by committed SQL; a model may only write prose about them. Six mechanisms hold the rule, in descending order of trust ([Mo HLD, the deterministic boundary](#)): the model cannot see the data; it cannot see a free string; the gate recomputes; evidence is hash-bound to a published scorecard; prose is stripped before validation and labelled advisory; and CI bans model libraries from T0 and T1. The reason array is a set union, so a model can add a `not_ready` reason and never remove one. The one imperfect place is named: T1 reduces the plan read's per-item pre-state to counts in its own code, a process boundary rather than an IAM one.

From proposal to production

A git credential in Mo would make it the one component whose compromise produces a plausible promotion pull request. So `mo-analyst@` holds only object-create on the bucket `mo-proposals`, which cannot read back, overwrite or delete ([Mo HLD, the drop box](#)). CI ingests each bundle from outside `M0_PROJECT`, checks it, strips the narrative and opens the pull request under a bot account that is not Mo; the validator recomputes; two distinct authenticated humans, neither the author, review ([Mo artefacts §3](#)).



A compromised Mo is therefore bounded by path before CI runs, and a forged promotion has to be true to pass. Mo's absence is more restrictive than its presence: no bundle is assembled, and the validator refuses every promotion whose metrics watermark is older than 24 hours (failure below).

What a bundle may declare is closed: eight types for Wall-E, with no ladder types through S2 and no template that emits a ceiling change (Mo artefacts §3.5). Mo may never propose a change to its own gating layer, from the metric SQL and fixtures to ceilings and the validator; such a bundle is refused at ingestion, and one pull request may touch at most one of them even when a human writes it. When Mo's evidence says its own arithmetic should change, it raises an `incident_note` and a human authors the diff (Mo artefacts §7).

One Mo per platform, and a remit that includes Eve

There is one `MO_PROJECT` for the whole platform, and every table, cell and artefact is keyed on `agent_id`; a new agent gets the metric pack its register tier names, not a Mo of its own ([platform HLD §13.3](#)). The remit includes Eve's detection quality and time-to-report, under four rules. Eve can lower a level; Mo can only propose. Eve reads nothing Mo writes, and a threshold change reaches Eve only as a Mo bundle a human merges. Mo is never Eve's grader. And numbers about Eve obey the source rule.

The source rule. A number about Eve never comes from Eve's verdicts alone, because a compromised Eve writes false receipts (Chapter 16). Independent sources are human grades of Eve, seeded-fault runs, golden-replay results and Wall-E's passive record of seeing Eve; a run fails if an evidence-eligible figure has none ([Mo metrics §7.3](#)). Eve's Mo-readable tables sit in `eve_quality`, granted by Eve's runbook. Human grades of Eve go into a dataset in `VALIDATOR_PROJECT`, proposed as E-21, a row the platform pages do not yet count ([register §8](#), [Eve open decisions](#)). Until the validator custodian holds a reader on `eve_quality` (P30, proposed), every Eve bundle is an advisory `eve_incident_note`.

Eve proposals are a closed set of four types on a narrower path, and the asymmetry is deliberate ([Mo artefacts §3.6](#)). A tightening may only produce more refusals, more pages or shorter lag budgets; a loosening needs the full evidence block, the security reviewer among two reviewers, a decision record and five business days' cooling; a seeded-fault proposal only adds. The 30-day cross rule refuses a loosening within 30 days of a Wall-E promotion on the same cell, in either order, because a level rising while its verifier relaxes is a combination neither repository sees alone. Eve's second reviewer is neither the ladder owner nor whoever runs Mo's CI, and Eve's predicates, ceilings, reason codes and `eve_authority` are never reachable. One seam is unreconciled: tighten asks for one reviewer while `eve/config` requires two; the stricter two apply meanwhile.

What Mo produces

Wall-E's five artefacts are the scorecard, the ladder-state page, the weekly digest, the regression explanation and the monthly cost report. The cost report comes first, at S1, because it feeds the stop-or-continue review; the others concern levels and arrive at S2 ([Mo artefacts §1](#)). For Eve, the misbehaviour coverage map lists every class a super-admin robot could commit and the detector that would see it, marked covered, never exercised or uncovered; it is Eve's improvement backlog, first edition before Wall-E's S1 (P143, proposed). The Eve scorecard labels every self-reported figure.

The Art. 72 post-market monitoring plan. For each system the register marks high-risk, Mo's artefacts are the plan, and the plan's text is one paragraph per system naming the artefacts, their cadence and reader, and two outside feeds: every Art. 73 assessment outcome and every Art. 86 explanation request ([Mo artefacts §1.8](#)). The Mo owner owns it and the AI compliance owner reads it; for Wall-E it exists from S2. Its loop runs from the audit log through metrics and blind grading to a human merge as a pre-determined change, and back to the log; its liveness control is the freshness alert, a silent Mo being a severity-2 finding. The artefact paths are an Assumption, and the re-cut into the Commission's Art. 72(3) template waits on an adoption date not verified. Art. 72 among the Act's other obligations is Chapter 20, EU AI Act.

What Mo measures

A metric pack is chosen by the register's tier, never by Mo ([Mo metrics §7.1](#)). Tier C gets cost and reliability with no grading; Tier R adds the Model Armor match rate, drift and freshness; Tier W adds the full ladder pack with blind grading and the interval gates; Tier P adds the Eve quality pack for its verifier; Tier X's evaluation gates are undefined. The human hours each pack costs are staffing numbers, in Chapter 23.

Wall-E's pack has ten metrics, audit completeness first ([Mo metrics §7.2](#)). With Super Admin the tenant no longer refuses an out-of-role call, so the one number that sees an action outside the catalogue is the join of Google's admin log to Wall-E's own rows: target 100 %, below which writes halt until reconciled. A companion metric

counts robot admin events matching no catalogue or band B operation, each one severity 1, halted and paged by Eve and the SIEM, never by Mo. The rest cover denials, precision, verification, breakers, reliability, latency and drill freshness.

How the numbers are checked

Plan precision is gated by intervals, not point thresholds, because a point threshold on twenty or thirty items promotes a playbook that is truly 90 % right about one window in five ([Mo metrics §4](#)). Promotion needs the lower bound of the interval to clear the target; demotion needs the upper bound to fall below it over a closed block of decided items. The sample floor is the smallest flawless sample whose lower bound can clear the promotion target, so floor and gate are one decision, kept in `gates.yaml` and never changed in the same pull request as a level. `unsure` grades leave the ratio up to a cap (an Assumption), and promotion must also clear a bound that counts them as wrong. Demotion blocks are disjoint and retired once they fire, so one cluster of errors cannot demote twice; that rule must still land in Wall-E's ladder page, since the components that demote never read Mo. A regression across a fingerprint change is described, never gated.

The validator re-runs the same SQL, so it inherits any arithmetic defect. A second implementation was refused, because false blocks pressure the validator to agree with Mo; four controls stand in ([Mo failure modes §3.1](#)). Golden fixtures hand-computed from the published constants are the test oracle, kept apart from the code they test, and some values are still to be computed ([Mo metrics §5](#)). Assertion queries fail the run on impossible states, the metric SQL sits under the ladder's reviewers, and an S2 back-test compares verdicts with decisions humans already took. No interval covers grader error.

Grading, the seed and attribution

The blind sample is the larger of 10 % and five items a week per family-and-trigger cell, and from S4 it is the only admissible input to L4 and L5 precision ([Mo metrics §13](#)). Membership is a published hash over a week seed that CI commits to an append-only file after the week closes, so nobody, Mo included, chooses the draw. The grading rules keep the measured away from the measurer ([Mo metrics §10](#)): grades count only from listed humans who did not author the playbook version under test, a `WRITE_HIGH` cell also needs second grades by someone other than the owner, and an unadjudicated disagreement blocks the cell. Eve's flow 7 disagrees, drawing daily and counting `unsure` as wrong where Mo's contract draws weekly from a CI seed and excludes `unsure` ([Eve flow 7](#), [Mo metrics §13.2](#)); the conflict awaits a dated decision.

Attribution uses a ten-field fingerprint, from playbook, prompt and model to the Model Armor filter version and configuration; four fields are not yet on the audit row, so attribution is labelled partial ([Mo metrics §11](#)). The promotion sample resets on any fingerprint change; the demotion evidence does not, or a prompt edit would escape a demotion. At a realistic change cadence L4 may therefore be unreachable, which the design treats as a decision, not a bug (M-2, open): Mo publishes both the strict count and a count under a material subset from S2, and the choice is made on data ([Mo failure modes §3.3](#)).

Staging, the acceptance test and the baseline

Mo's pieces arrive inside Wall-E's stages ([Mo staging](#)). The one part that must exist before Wall-E does is the toil baseline, four weeks of measured toil for the top three admin tasks plus monthly operating hours: a "before" cannot be measured once Wall-E runs, and without it the stop-or-continue review has no denominator ([Mo staging, before Phase 1](#)). At S0 the definitions are fixed before the first grade and every cell reads `insufficient_data`; nothing at S0 or S1 depends on a Mo verdict, and S1's one decision is about value. The drop box and validator arrive at S2 exit.

Before a promotion may cite Mo, Mo passes a six-part acceptance test at S3, from its arithmetic against the fixtures to four consecutive weeks of agreement with the validator and its refusal to call adversarially framed not-ready cases ready ([Mo staging, acceptance test](#)). Failure costs automation, not safety: promotions are argued

from hand-run queries. Trust does not grow with age; S5 trusts Mo with exactly what S4 did ([Mo staging, trust](#)). Stage durations are Chapter 24, Roadmap and cost.

The human grading cost

This number decides whether the programme survives ([Mo staging, run human](#)). The floor is per cell. At a S4 volume of about 200 executing items a week over about eight live cells, each cell carries about 25, so the floor of five binds everywhere: at least 40 graded items a week, about eight double-graded, plus adjudication. That is at least two hours a week, indefinitely, from a named human who is not the playbook owner, plus a second grader who does not yet exist, plus about 30 minutes a week on the digest and two hours a quarter of review. It cannot be automated, thinned or given to a model without destroying what it measures. At five a week a cell needs about seven weeks to reach the sample floor, longer than its four-week dwell, so the sample is the binding clock; grading everything in promotion mode is not adopted.

Mo does not create this cost but is useless without it, so it sits on Mo's line in the cost report: if nobody grades, the programme visibly stalls on attention rather than safety. Because grading scales with live cells, not volume, it caps the number of Tier W agents; the cap as named grading capacity (P25, open) is argued in Chapter 14, Scale and AGI readiness, and staffed in Chapter 23, Operating model. Mo's own estimates, all Assumptions, are 24–37 person-days to build, the Eve remit unpriced, and €25–60 a month to run.

What Mo needs from Wall-E

Mo computes almost nothing until Wall-E's set lands two schema changes and one grant ([Mo open decisions, Mo failure modes §3.2](#)): tables for grades, proposal verdicts and drills; a table of ladder events; and cross-project readers on the audit data. Mo does not route around the gap by reading the control plane's store; it reports `not computable`, so the gap shows in every digest rather than as a quietly wrong number. The full list of changes Mo forces and the rule for scheduling them with Wall-E are Chapter 18, How the three work together.

Failure, threats and residuals

Mo fails closed in both directions ([Mo failure modes §1](#)). When Mo stops, nothing rises: no bundle, a 24-hour watermark refusal, and an absence alert, because a threshold alert is silent exactly when data stops. Nothing else degrades: breakers, Eve's halts, CI's merge gates and the deploy tool never read Mo, which is tested. An outage costs promotion and visibility, never a brake.

The threat model assumes full control of each principal ([Mo failure modes §4](#)). The real blast radius is `mo-metrics@`: read disclosure of the whole audit history, per-person and tenant-wide now Wall-E holds Super Admin, which makes `MO_PROJECT`'s IAM part of the confidentiality boundary. A compromised reporter adds noise that must survive recompute and two reviewers; a steered narrator writes a labelled falsehood that changes no number; a compromised CI bot has no floor if the git host allows administrator bypass (P22, open). Mo as a processor of personal data is Chapter 22, Personal data, employees and the works council.

Six residuals are accepted, not mitigated ([Mo failure modes §5](#)). R1: the validator proves numbers match the committed SQL, not that the SQL is right. R2: a truthful, tendentious pull request two tired humans merge. R3: a wrong mental model shared by author and graders, invisible to blind sampling, because every grading statistic measures consistency, not correctness. R4: T0 reads per-person rows. R5: whoever runs CI can re-roll a candidate seed before committing it. R6: on a one-person pilot, Mo authoring Eve diffs adds a hand to one person's list, and until the second human exists Eve's thresholds do not improve through Mo at all.

Fifteen denial tests authored from Mo's side make these claims falsifiable and run before every promotion ([Mo runbook, Mo-12](#)); each can fail both ways.

Key decisions and what to read next

Key decisions

- **P30 — proposed:** the validator custodian's reader on `eve_quality`; until it exists every Eve bundle is advisory.
- **E-21 — proposed** in Eve's register: human grades of Eve in a dataset in `VALIDATOR_PROJECT`.
- **P25 — open:** the Tier W cap as named grading capacity, measured after the first Tier W agent's first quarter.
- **P143 — proposed:** owners and gates for the Mo-set edits, gated on Wall-E's S1, including the coverage map's first edition.
- **P22 — open:** the git host and audited administrator bypass, superseding M-7.
- **M-2 — open:** strict or material fingerprint scoping, before the first L4 promotion is argued.
- **M-4 — open:** the second grader, named before S2 entry.
- **M-8 — open:** whether the narrator is built, decided at S4 entry.
- **Eve v0 and Mo's T0:** the platform's objective review of 2026-09-13 keeps both as a differential check; [Mo's reopen table](#) still asks for a dated decision record on it and on the blind-sample draw, and none exists yet.

What Chapter 19, Threat model and residual risk, carries from this chapter: residuals R1 to R6 as stated above, the tenant-wide disclosure blast radius of `mo-metrics@`, and the dependence of every merge gate on branch protection binding.

Canonical pages to read next

- [Mo HLD](#), in full, and [identities and access §3](#)
- [Mo metrics contract](#), especially §4, §7 and §13
- [Mo artefacts and proposals §1.8 and §3](#)
- [Mo failure modes §5](#) and [Mo open decisions](#)
- Next in the brief: Chapter 18, How the three work together.

18. How the three work together

What you will understand by the end

Why three agents are safer than one only while they cannot collapse into one; which half of the outcome each owns; what each may do to the others and what only a human may do; the interfaces and data they share, and the connections deliberately missing; the changes each design forces on the others; and how a request, an attack, a halt and a detection travel through the team.

The chapter answers three risk themes of Chapter 3, The problem and its risks: **a controller reachable by what it controls**, because the team's separation is what keeps Eve and Mo out of Wall-E's reach; **autonomy outrunning evidence**, because no agent can raise anything; and, in part, **staffing that makes two-person rules notional**, because every loosening lands on named humans. Nothing described here is built on 2026-09-14, and no grant between the three exists yet.

Three rules that stop the team collapsing into one

The rules are written once, in [the team contract](#), and every change the three designs force on each other traces back to one of them.

No agent both decides and acts. Wall-E acts and never approves; Eve approves and never acts on Workspace; Mo proposes and does neither. An approval posted by Wall-E's reasoning layer is therefore denied as `approver_is_agent`, a hard invariant.

No agent grades its own work. Wall-E's re-read after a write is a sanity check, not evidence. Eve verifies with its own read-only credential against audit logs Google writes. Mo's numbers are reproduced by a validator from sources Mo cannot write, and humans, never Mo, grade Eve's verdicts. No verifier reaches its subject through the subject, which is why no Eve identity may query Wall-E's engine.

Only humans loosen anything. Eve can lower a level and halt; Mo can only propose; neither can raise. A raise is a pull request, CI validation and a dated decision record with a named human, two above L3, so no improvement loop promotes itself.

The contract's test: a change that would let one agent do two of decide, act and grade is wrong however convenient it is.

Who owns which half

All three share one outcome, Workspace administration done correctly and safely, and own different halves of it ([responsibilities](#)). Wall-E owns doing the work, and nothing else executes. Eve owns nothing bad getting through and stopping it fast when it does: independent verification, drift detection, halting and demoting, and reporting misbehaviour of Wall-E, or of a human prompting it, to a human outside the Wall-E line. Mo owns the system getting better rather than merely older, for Wall-E **and** Eve: it explains regressions, measures Eve independently of Eve's verdicts, and proposes changes.

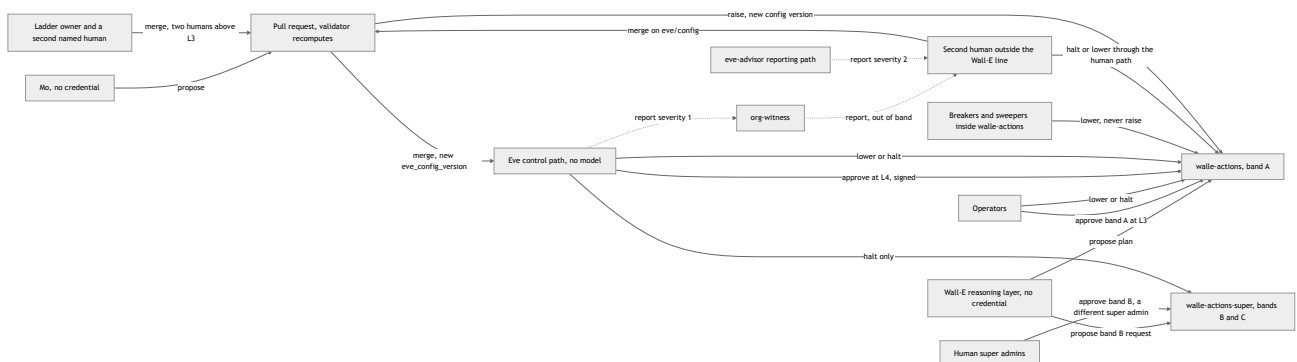
Humans keep deciding a raise, merging any change, grading and receiving reports, those about the administrator going only to the second human (Chapter 16, Eve, the independent controller).

Who may do what to whom

The matrix combines [Wall-E's ladder §6](#), the action-service callers and the proposal rules. Changing a ceiling is outside every row: it takes code review by two humans and security sign-off.

Actor	Raise	Lower	Halt	Veto	Approve	Propose	Merge
Any operator	No	Yes, alone, instantly	Yes; clearing a halt is human-only	Yes, during a hold window, on either lane	Band A at L3, on the out-of-band surface	—	—
Ladder owner, with a second named human for L4 and L5	One notch, decision record	Yes	Yes	—	—	Promotion pull requests	Yes
Human super admins	No	—	K5 and K6	As operators	Band B at tier SUPER : a different super admin from the requester	—	—
Second human outside the Wall-E line	No	Through the human path	Through the human path	—	—	—	Required reviewer on eve/config
Wall-E	Never	Only by refusing its own run	No	No	Never	Plans and band B requests	No
Eve control path	Never; it attests	Any level, one call per cell	Both action services	walle-actions only	L4, signed, on binding cells	A rollback, which a human executes	Never edits its own rules
eve-advisor	No	No	No	No	No	Narratives and severity 2 pages	No
Mo	No	No; a demote_proposal only	No	No	No	Closed type sets, as pull requests	No
Breakers and sweepers	No	Family to L0; no_autonomous on Eve's silence	Self-halt when Firestore is unreachable	—	—	—	—

The asymmetry is the design: everything that makes less happen is available to many actors in seconds, and everything that makes more happen needs humans, time and recomputed evidence. The fleet stop K7, pulled by a human or a severity-1 SIEM rule and never by a model, sits above all rows (Chapter 8, Identity, privileged access and the fleet kill switch).



Solid arrows carry authority; the three dotted arrows carry reports, which confer none. No arrow points at Mo, and none leaves eve-advisor towards anything that decides.

The interfaces between them

Eve reaches Wall-E through eight plain authenticated REST endpoints on `walle-actions`: read a plan or a run, approve, veto, halt, demote, read the ladder and a health check (LLD, [action service interface](#); ARCHITECTURE §7.4). Why a safety interlock is plain REST and never an agent protocol is principle D12 (Chapter 4, The principles).

Four details carry the weight. The per-endpoint caller allowlist (Chapter 15, Wall-E, the doer) keeps the agent off every control endpoint and Mo on the two read endpoints only. Demote refuses any value above the configured level, and **there is no raise endpoint at all**. The health check reports the last successful audit write, so Eve can halt when evidence stops. On `walle-actions-super` Eve holds halt and nothing else, since the lane is permanently L3 under two human super admins; a halt during the hold cancels every pending execution.

A CI stub caller exercises the endpoints from the first commit. Neither Eve nor Mo exposes an inbound surface, so neither can be told what to do.

One set of facts, three readings

Everything Eve and Mo need already exists in Wall-E's design, and neither asks Wall-E about itself ([shared data plane](#)). The meeting place is `walle_audit` in `WALLE_PROJECT`, read through dataset-level grants with queries billed in the reader's project, plus Google's Workspace audit logs and `ladder.yaml` in git, joined on `run_id`. A second meeting place, `eve_quality` in `EVE_PROJECT`, holds views without free text that Eve owns and Mo reads.

An absent edge is a decision with a reason ([absent edges](#)). Nobody subscribes to the `walle-events` topic: a five-minute poll of the audit table meets Eve's tightest duty twelvefold, and a topic Wall-E publishes is a channel Wall-E controls; the topic stays, owner and schema *tbd*. Mo reads no Firestore and holds no credential. Eve reads nothing Mo writes, nothing `eve-advisor` writes reaches a verdict, and no enforcement identity can read Mo's metrics.

Every crossing is a row of [the topology's grant table](#), always made in the resource's project; the rows between the three are:

Crossing	Rows	Level, and who makes it
Eve's identities invoke <code>walle-actions</code>	3	Service level; Wall-E's runbook, narrowed by the in-app allowlists
Eve's halt identities invoke <code>walle-actions-super</code>	27	Service level, halt only; Wall-E's runbook through PAM
Eve and <code>eve-export@</code> read <code>walle_audit</code>	4, 34	Dataset level; Wall-E's runbook
Wall-E verifies Eve's signature	14	No grant by default: a pinned PEM in Wall-E's repository
Wall-E's sweeper reads Eve's receipts; Wall-E's CI publishes the ladder artefact	15, 16	An existence-only view from S4; a create-only prefix; both made by Eve's owner
Mo reads <code>walle_audit</code> and invokes the two read endpoints	6, 8	Dataset and service level; Wall-E's runbook
Mo and the validator read <code>eve_quality</code>	28, 29	Dataset level; Eve's runbook, the validator's row under P30
Anything else into another agent's project	24, 25, 26	Anti-grants, asserted by drift jobs and denial tests

What each design forces on the others

Eve's design lists thirty-seven contract changes on Wall-E's set, CC-1 to CC-37 ([contract-change table](#)). They cover the bytes Eve signs and how Wall-E verifies them, the per-cell `eve_authority` switch, moving Eve's identities, key and secrets into `EVE_PROJECT` (CC-24 to CC-31), the stricter S3 exit gate (CC-7), the absence sweepers, and letting Eve halt band B and reconcile its rows (CC-34 to CC-37), each with a gate ([when each lands](#)).

Mo's design forces twenty changes, nineteen on Wall-E's set and one on Eve's ([Mo's list](#)); the three that block Mo entirely are in Chapter 17, Mo, continuous improvement. Change 15, a denial test proving no enforcement identity holds a binding in Mo's project, is the one a security reviewer should refuse to sign without, because without it "nothing Mo writes is read by anything that enforces" is a convention rather than a test.

The scheduling rule matters more than the count: a change lands on the schedule of the repository it edits, not of the agent that asks. Eve's side of Wall-E is about five engineer-days inside `walle-actions`; if Wall-E's plan omits these changes, Eve and Mo are unbuildable. One tension is recorded: Eve's page says it adds no endpoint, yet CC-33 proposes a pending-plan list endpoint, conditional on topology decision 44, still open.

Four journeys through the team

An Eve-gated execution ([Flow D](#)). From S4, for families that earned L4, a frozen plan waits at `pending_eve`. Eve recomputes and signs it through the pre-approval pass of Chapter 16. A 30-minute hold window opens in business hours and any operator's veto wins. If Eve is unreachable, items wait. A window that would end outside business hours is refused at plan time, or an attacker choosing the trigger time could aim every batch at an unwatched morning. If a human later reverts what Eve approved, the family drops to L0 and Eve's authority for it to advisory: both agents are demoted.

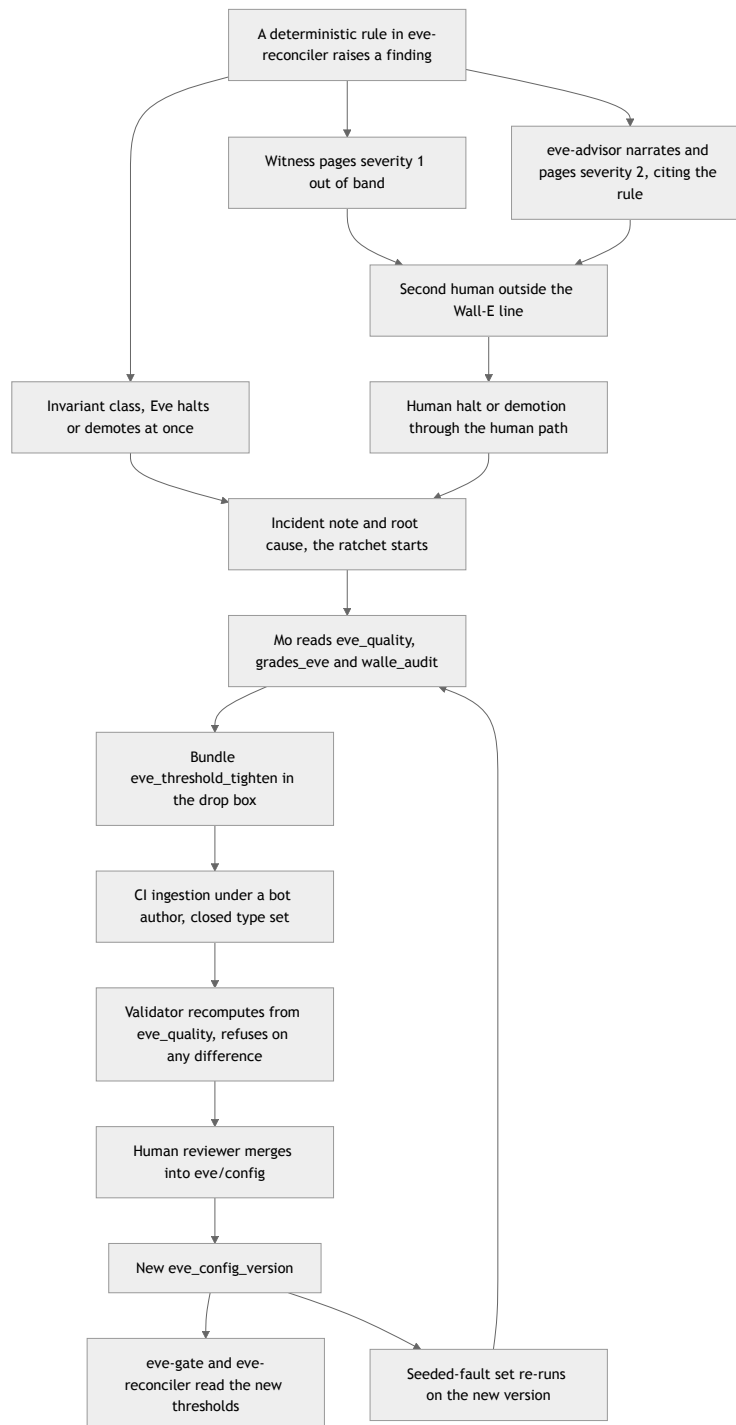
Autonomous execution ([Flow E](#)). At L5, reversible operations only and never `WRITE_HIGH`, Wall-E executes and re-reads, and Eve verifies independently within 60 minutes. When Eve disagrees it demotes the family within seconds, opens a rollback proposal only a human executes, and promotions freeze until a fresh decision record. Flow E demotes to L3 where the ladder's severity table sends verification drift to L0 ([ladder §9](#)); the pages disagree.

An injection in the robot's mailbox ([Flow F](#)). Suppose the prompt defence fails (Chapter 19, Threat model and residual risk) and the model proposes suspending a department and adding an outsider to the operators group. The action service refuses on independent grounds: no bulk target, an operation outside the playbook, L0 for that trigger, a hard-denied control group, an outside-domain member; band B is unreachable from a mailbox run. Google would refuse none of it; Eve's reconciliation would see a write that got past the code.

Halting ([Flow G](#)). An operator, Eve and a breaker can each stop Wall-E without asking the others, the endpoints targeted under five seconds; switches K0 to K6 are Chapter 15's and K7 Chapter 8's. Only a human clears a halt.

A detection becomes an improvement

The loop that turns a finding into a better Eve crosses every separation rule once, and each crossing is a human act.



Eve's control path reads only its control tables and `eve/config`, so a change reaches it as merged configuration, never as advice ([Eve HLD §3](#)). Every verdict carries the `eve_config_version` it used, and seeded faults re-run on every version, so Mo sees whether the change worked. The loop is drawn with a tightening, which needs neither a decision record nor a cooling period; the rules for loosening are Chapter 17's.

The loop is not yet available end to end. Until the validator holds a reader on `eve_quality` (P30, proposed), Mo may send only an advisory `eve_incident_note`; the tightening step waits.

When the team itself fails

The team's own failure modes are few, and each resolves towards less happening ([team failure modes](#)).

- **Eve down.** L4 waits and Wall-E's sweepers stop autonomous work (Chapter 16). Nothing falls through to execute.
- **Eve compromised.** Bounded as Chapter 16 sets out: it can approve within the current level's blast radius until the next sampled review, and cannot raise.
- **Persistent disagreement.** Neither agent wins; above threshold the family is demoted and the disagreement becomes the finding.
- **Mo proposes harm.** It still needs CI, a decision record and a human merge, two humans above L3.
- **All three unavailable.** Nothing happens, which is correct.
- **A human bypasses all three in the Admin console.** Legitimate; Eve sees a human event and no robot gap, and Wall-E's pre-state re-read stops the two colliding.

The failure no agent rule contains is human: one person writing a promotion, the Eve loosening beside it and running Mo's CI. Reviewer separation forbids it; whether enough people exist is Chapter 23, Operating model.

What a fourth agent inherits

A fourth agent does not get its own Eve or Mo. It inherits from the platform: at Tier W, a verifier of Eve's deterministic shape compiled from its manifest, which catches code bugs and tampering but not a wrong specification (P79, proposed); the one validator; a Mo metric pack chosen by tier; and the audit and ladder schemas ([registry page §9.8](#); Chapter 9, Registry, governance and the autonomy contract). The separation rules transfer unchanged; the hand-written second implementation stays Tier P's.

What remains open

Eve's set and Mo's set both claim Eve v0's scheduled queries and the blind-sample draw, and where grades of Eve are kept (E-21, proposed) is unsettled; both are in Chapter 17. `eve-gate`'s discovery of pending plans has no grant until topology decision 44 is answered. Wall-E reading Eve's receipts, the one dependency pointing the avoided way, is re-argued at S4 under E-17. P14, the witness, and P19, `eve-advisor`'s AI Act class, are open.

Chapter 19, Threat model and residual risk, carries what the team leaves: a compromised Eve approving within one level's blast radius until sampled review, Eve reading the plan from the service it checks, and a staffing base that can make the separation of reviewers notional.

Key decisions and what to read next

Key decisions

Decision	State on 2026-09-14
P33 Wall-E holds Super Admin on a dedicated licensed user account	decided; deviation signatures pending
P34 Eve's reporting path may reason, report-only	proposed
P30 validator custodian's reader on <code>eve_quality</code>	proposed
P79 Tier W platform verifier and its compensations	proposed
P14 witness organisation	open
P19 <code>eve-advisor</code> 's AI Act class	open
Topology decision 44 Eve's discovery of pending plans	open, before S3 entry
E-17 Wall-E's read of Eve's receipts	re-argued at S4 entry
E-21 grades of Eve in <code>VALIDATOR_PROJECT</code>	proposed

Chapter 25, Decisions awaiting the owner, lists who decides each open row.

Canonical pages to read next

- [The team contract](#), with its [identities](#) and [shared data plane](#)
- [Platform HLD §13](#), the three agents on the platform
- [Wall-E's flows D to G](#) and [ladder §6](#)
- [Project topology §3](#), cross-project grants
- [Eve's contract changes](#) and [what Mo forces on Wall-E's set](#)
- Next in the brief: Part IV, Proof: threats, compliance and people.

Part IV — Proof: threats, compliance and people

Part IV tests the design, promising mechanisms and evidence, never outcomes. Chapter 19 sets it against the threats and the residual risks accepted in writing, for the security architect and assessor. Chapter 20 reads it under the EU AI Act, for the AI compliance owner and legal; Chapter 21 under TISAX, for the assessor and the ISMS; both follow the [compliance frames](#). Chapter 22 takes the side of the employees whose accounts and data it touches, for the data protection officer and works council.

19. Threat model and residual risk

What you will understand by the end

This chapter tests the brief's case. Chapters 5 to 18 each answered risk themes of Chapter 3, The problem and its risks; here every answer meets the adversaries it must survive, and what remains is written down with its owner and disposition.

By the end you will know what the platform must never allow and the risk the owner took on; why no prompt is a control; for each adversary, the control that stops it, the detection that sees it, how fast, who is paged and which runbook starts; what a compromise of each class of project reaches; which facts are kept out of every safety argument; how each of Chapter 3's risk themes ends; and which residual risks are accepted in writing, by whom, and when they are reopened.

Detection rules, runbooks and response targets are explained in Chapter 11, Monitoring, detection and incident response, and cited here by id. The grading vocabulary is Chapter 4, The principles: an enforcement-grade control refuses the action from outside the agent's process; a detection-grade control only sees it and never stands alone ([HLD §0.2](#)).

The honest risk statement and the ceiling

What the owner took on

The organisation is giving a language model a path to administrative operations on its Workspace tenant, then removing the human from that path one step at a time. It is legitimate to build and the highest-blast-radius system in the estate. Every control exists so that when the model is wrong, manipulated or mistimed, the outcome is an audit row and a refused approval rather than an incident ([honest risk statement](#)).

Since 2026-09-13 that path ends at a super-admin account (P33, decided). Three statements hold, unsoftened: the action service is the only gate; the consented OAuth scope set is the only ceiling Google enforces; detection is the primary control ([HLD](#), [what this reverses and what it costs](#)). Three properties carry most of the remaining weight: the model never holds the credential, cannot authorise itself and cannot change its own leash.

The blast-radius ceiling

The ceiling is nine statements of what must never happen, N1 to N9, ordered worst first ([blast-radius ceiling](#)). In substance: Wall-E never changes the tenant's security posture; never causes permanent data loss; never escalates privilege through a group; never performs a mass action across an organisational unit; never acts on instructions found in content; never chooses outbound communication unattended; never touches a protected principal; never takes an action nobody can see; never acts as a person.

On 2026-09-13 the first, second and seventh moved off a Workspace role that refused and onto the action service's policy chain, the hard-denied list refused in every lane and, for the settings it covers, Workspace multi-party approval, a two-person rule Google enforces. The rows are not ratified: the owner's signature on the two lists (P29) is open, and the ceiling is only as firm as it and the denial test suite.

Who and what the platform defends against

The threat model assumes four kinds of adversary: an outsider who writes content the agent reads; an outsider holding a stolen credential or a compromised workload; an insider with legitimate access, the administrator included; and a supplier, from the model provider to a third-party agent. Non-malicious failure counts too: an invented call, a trigger storm, a poisoned upstream record, stale state between plan and execution, an outage of the controller ([threat model](#)).

One row dominates. A leaked robot credential is a **tenant compromise** with a path into the GCP organisation, Eve's and Mo's projects included (the Organization Administrator reach, Chapter 16, Eve, the independent controller). It is bounded only by custody, the scope split and detection latency, and accepted as deviation R-01.

What prompt-based defence cannot do

Every agent's system instruction says retrieved content is data, never instruction. The design keeps that instruction and assumes it will sometimes fail, because instruction and attack arrive on the same channel and the model cannot reliably tell them apart ([what prompt-based defence cannot do](#)). Four rules follow for every agent:

- No operation is promoted because "the prompt handles it".
- No autonomous run chooses a message recipient; templated notification to fixed recipients is its own family.
- No content decides a ceiling. The taint bit — any attacker-writable field reaching the model forces the inbox ceiling for that run — is the mechanism; the system instruction is a courtesy.
- Every ceiling is read as compensating for a prompt that has already failed. A control that works only when the prompt works is not a control.

Content screening, a probabilistic classifier, is likewise never a trust boundary (Chapter 10, Agent Gateway, Model Armor and the perimeter). What stops an injection is structural: no credential in the model's process, a tainted run capped, explicit targets, and approvals minted where the model cannot reach.

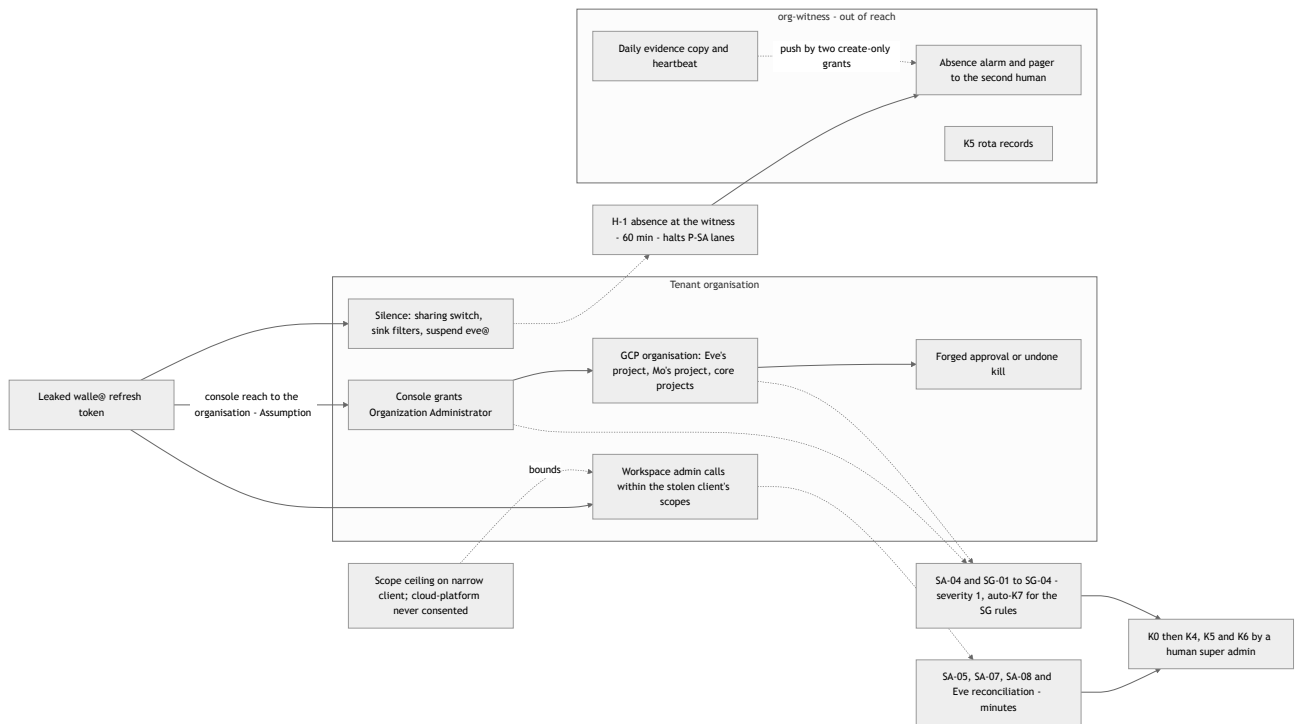
The adversaries, the controls that stop them and the detections that see them

Each entry cites its runbook ([runbooks](#)). Every super-admin rule is SIEM-hosted, severity 1, and pages the detection desk and the second human in parallel (Chapter 11; [super-admin set](#)). Tier P acknowledgement targets are 15 minutes in business hours and 60 outside, and K5 within 30 minutes of acknowledgement, all Assumption until the managed detection contract and the tabletop fix them ([targets](#)). Below Tier P the honest number is "next business morning".

A leaked robot token — RB-01

Nothing stops a stolen refresh token from working. Before the leak there is custody (Chapter 8, Identity, privileged access and the fleet kill switch); after it, a narrowed reach and a race. The narrow client keeps a Google-enforced scope ceiling on everything unattended; the broad client does not; `cloud-platform` is consented on neither, checked in CI.

Detection is SA-05, SA-07, SA-08 and SG-01 (foreign client, robot event without an audit row, unneeded application, organisation IAM change), with Eve's minute-latency reconciliation as a second, independent evaluator. Containment is K0 on both action services in under a minute, then K4 and K5 — revoke the grants, suspend the account — by the on-duty human super admin. An issued access token lives up to 60 minutes after suspension, so the desk watches that hour and pre-stages K6, a human removing Super Admin from the robot. There is no machine-invocable account stop (P16, proposed none now): an automatic lock-out is also a path a compromised monitor could pull.



On that path an approval can be forged or a kill undone; what has left for the witness cannot (Chapter 16, Eve, the independent controller). The end state that removes the forgery path is P15, proposed.

An interactive login on the robot — RB-02

After bootstrap nobody signs in to `walle@` or `eve@`, so SA-04 is severity 1 with no triage question. Nothing enforcement-grade refuses the sign-in: the Admin console access level is friction, not counted (P7, below). Key custody is the prevention; response is K0, ending sessions, K5, and a physical accounting of both keys. A session is worse than a token: it opens the console and the path into the GCP organisation.

Self-silencing of monitoring — RB-04, with RB-05 for an innocent outage

A super admin can stop the stream every rule reads in one console visit, so silence is never calm. The Workspace stream's absence alarm (H-1, 60 minutes in business hours, 240 outside) lives in Eve's project and in the witness, and sets `log_pipeline_silent`: no autonomous work for every agent Eve verifies and `halt_all` on both Wall-E lanes, cleared only by a human call that is itself a report about the administrator ([heartbeats](#)). SA-03 catches the posture change by any actor; SG-02 to SG-04 catch sink, audit-configuration, policy and project changes and may pull K7 automatically, dry-run until the SIEM's identity holds the invoker grant. The halt is the enforcement; everything else sees. The event names for the sharing and export switches are unverified, so until observed the absence alarms are the detector.

An out-of-catalogue super-admin action, or a human authority anomaly — RB-06

The stop for the robot is the hard-denied list, refused in every lane with a breaker trip and a severity-1 page, and band B's rule that uncatalogued super-admin work needs a requester and a different approving human super admin. The stop for human super admins is narrower: Workspace multi-party approval on the settings it covers. Detection is SA-01 (a robot method outside the allow-list with no band B audit row), SA-02, SA-06, SA-09 and SG-05, covering role grants, the roster, control groups and privileged access outside a change window. When the actor is the administrator, the second human alone receives the report and a different super admin suspends the actor's role pending review. Two colluding human super admins remain a residual: they could do the same work without the robot.

A compromised CI pipeline or deployer, a forged approval, image drift — RB-07

Anyone who can ship a revision of the credential holder bypasses every control in its code at once ([known structural weaknesses](#), weakness 12). The stops are a never-standing deploy grant, Binary Authorization admitting only attested images, and Eve's approval key beyond any Wall-E principal. Detection is SG-07, PL-06 and Eve's `bad_approval` finding. Post-deploy drift on Cloud Run is detection-grade, because continuous validation exists only for GKE (Chapter 13, Supply chain, keys and recovery). The residual: under Super Admin, a compromised pipeline is a tenant compromise.

A model-provider incident — RB-08

Model Armor and the gateway fail closed, so an outage is a severity-2 availability incident and the stopped state is the safe state; nobody fails a screen open to restore service, and PL-04 and PL-05 fire if anyone tries. A model behaviour change is met by re-qualification on every pin change, which resets every cell above L3. Access by Google personnel is seen through Access Approval (SG-06, severity 2). What is not contained is monoculture: every agent except Eve runs the same model family (R-10).

Injected content reaching a write — RB-09

The taint bit and the ceilings are the enforcement; the protected-principal check, explicit targets and the playbook's operation allowlist narrow what a steered model can name. Detection is a Model Armor match or content flag joined to an executed write in the same invocation, or Eve's prompt-to-action divergence finding. Response is K1 to L0 for the affected cell and `no_autonomous` for the agent. The accepted residual is a proposal an injection places in an operator's queue: visible, attributed, unable to execute. The gateway does not screen tool results.

A compromised Eve

In short, from Chapter 16, Eve, the independent controller ([when Eve is compromised](#)): the attacker gains halt and demote — a denial of service a human clears in seconds — and signing only for cells already marked binding, within the envelope's lifetime, still subject to hold windows, vetoes, budgets and Wall-E's per-item policy re-run; never a level raise, a Workspace write or its own thresholds. Detection is more than three Eve demotions in an hour, the blind human sample and the SIEM's independent evaluation; a human revokes Eve's grants and disables, never destroys, the key version, and a forged approval with a valid signature runs under RB-07. The named residual is false verdict receipts, bounded only by the blind sample.

A compromised Mo, or a narrator that misleads

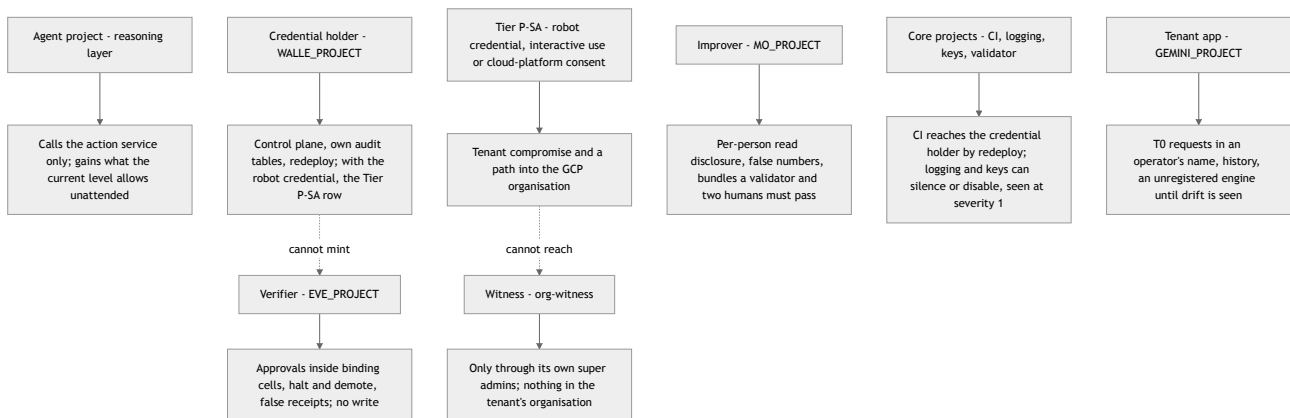
Mo's threat model holds each identity fully compromised ([Mo threat model](#); Chapter 17, Mo, continuous improvement). The worst case is confidentiality: the query identity reads the whole per-person audit history, tenant-wide since Wall-E holds Super Admin. Falsified numbers must survive the validator's recompute, the drop box's path allowlist and two human reviewers; the narrator can only write a persuasive falsehood under a labelled advisory heading, and `eve-advisor` can only write narratives and page at severity 2, read by no gate (P34, proposed). If the git host allows administrator bypass of branch protection, the two-reviewer rule has no floor. The runbook catalogue has no scenario for this adversary; Mo's own detection list is the response today.

Shadow and third-party agents

No organisation policy can require registration, so the shadow-agent control is detection-grade. Daily reconciliation against independent inventories finds an agent with no register row; a factory-bypass project loses its invoker grant and cannot be published or called through the platform ([reconciliation](#); Chapter 9, Registry, governance and the autonomy contract). A silent registered agent at Tier P is severity 1 within an assumed 15 minutes. Third-party agents, MCP servers, apps and models enter only through the supplier procedure, L0 for writes and tainted (P138, proposed; Chapter 14, Scale and AGI readiness). Only a card written outside CI has a runbook, RB-06.

What a compromise of each project reaches

"Compromise" means project-owner rights or any identity in the project. The topology page states each concrete project's reach ([compromise reach](#)); the classes are drawn here.



First, a compromised Wall-E project cannot mint an approval because it has no principal in Eve's project, though only against that project's IAM (Chapter 7, Landing zone and the tier model). Second, the Tier P-SA row reaches the tenant and the GCP organisation but not the witness; the console mechanism behind the Organization Administrator reach is an Assumption to verify before the grant ([trust boundaries](#)). That row counts the Admin console access level as a prevention; the HLD's non-goals and P7 do not, and this brief follows them. Third, the core projects' reach is not yet tabled as HLD §15 requires; the brief states only what their detections treat as severity 1.

Facts kept out of the safety case

Four facts are not counted in any safety case until answered ([what the platform does not do](#)):

Fact	What is assumed meanwhile	State on 2026-09-14
The Principal Access Boundary for Cloud Run invocation	The boundary counts for the permission families it blocks and for engine queries; invocation rests on resource-level invoker grants and the deny policy	P60 proposed: Google's list shows no effect on invocation
The Admin console access level on a super admin and on API tokens	Detection plus friction, never a boundary	P7 open, to verify with Google before the grant
The deny policy's spelling of the agent principal set	The deny lever of K7 counts only as a second copy of the service-denial lever	P8 spike, narrowed by P61; proven on a throwaway engine
The custom constraint on an engine's identity type	The engine half of "Agent Identity, bound to a gateway" is a CI check, detection-grade	P4 spike; the engine was not a supported resource type, re-run at each factory release (register §7 row 8)

Other Google facts unverified on 2026-09-13 are carried where they bite ([HLD sources](#)): the witness's Cloud Identity edition (P14, open, a grant gate); whether a delegated admin can suspend a super admin (P16); the tenant's Workspace edition, which decides one feed; Google's per-service TISAX coverage (P32, open; R-05); registry Data Access logging, where Google's pages disagree and the canary decides (P80); and which super-admin views leave no event, Assumption per capability until verified before the grant. One operational value stays Assumption until drilled: that running Cloud Run instances refuse new requests under the service-denial lever.

How each risk theme of Chapter 3 ends

Theme	Answered in	Residual that remains	Disposition
Tenant compromise through the robot credential	Chapters 8, 11, 15	A leaked token or interactive login remains a tenant compromise reaching the GCP organisation; a token survives up to 60 minutes after suspension; the single process and the pipeline stay single points	Accepted with compensation as R-01 (signatures pending); the thirteen compensations hold the grant shut until green
Manufactured silence	Chapters 11, 12	Silence becomes a halt, but a re-filtered organisation sink is seen, not prevented; two of three evidence copies are detection-grade; nothing central is locked before the DPO's ceiling (P13, open)	Mitigated ; the witness (P14, R-13) blocks the grant
Autonomy outrunning evidence	Chapters 9, 17	Grading statistics measure consistency, not correctness; a truthful, tendentious change can be merged; a wrong manifest at Tier W is caught only by humans	Mitigated ; grading capacity caps Tier W (P25, open)
A controller reachable by what it controls	Chapter 16	Inside the organisation Eve is detective; the witness sees deletion and absence, never forgery; Eve's independence from the ladder owner is organisational	Accepted until the end state (P15, proposed); witness and second human block the grant
Shadow and third-party agents	Chapters 9, 14	Registration cannot be required by policy; two reconciliation sources are unproven; supplier assurance rests on evidence and contract	Mitigated ; the supplier procedure (P138) is a grant-gate row
Classification collapse	Chapter 20	Legal may read band B as widening the purpose; the account's privilege is the fact most likely held against the derogation; eve-advisor's class is undecided (P19, open)	Blocks a gate : the Art. 6(4) assessment and Art. 49(2) registration before Wall-E's first write (P125 proposed, P28's signature open); high-risk fallback held ready
Staffing that makes two-person rules notional	Chapter 23	One person holds every load-bearing role today (R-02); a seed can be re-rolled before commit	Mitigated by gate : no tier above R opens without its humans; Tier R self-review accepted by the ISMS in writing

Three inputs are owned elsewhere: Eve's five named limits and the declared limits of watching a super admin (Chapter 16), Mo's residuals R1 to R6 (Chapter 17), and Wall-E's known structural weaknesses (Chapter 15).

The platform risk register (P140)

Residual tables inside design pages are not a register, and TISAX control 1.4.1 wants one with owners and acceptance. The security reviewer keeps it, the ISMS mirrors it under its own ids, and it is refreshed at every stage decision and management review ([risk register](#)). Likelihood and impact are scored one to three, an Assumption until the ISMS maps its own scale. Every row names a treatment, an owner and, for accepted rows, who signs and where.

Row one is the super-admin deviation, R-01: likelihood 1, impact 3, accepted with compensation, to be signed by the security reviewer and entered by the ISMS in the P33 record ([decision record](#)); the signature is pending on 2026-09-14. The sources disagree on its owner (Chapter 21, TISAX). Of rows R-02 to R-17, four — the one-person organisation, the unbuilt witness, the missing restore, penetration-test and audit records, and the unstarted data-protection artefacts — score likelihood 3 "today", mitigated by gate: each closes when what it describes exists.

An accepted row without its signed acceptance file at the TISAX assessment order stops the order. P140 is proposed.

Residual risks knowingly accepted in Wall-E's design

Wall-E's design records accepted residuals apart from defects ([accepted residuals](#)): two volume questions open until the pilot's account count is recorded; the action service as a single process, narrowed by the asymmetric Eve key and a create-only plan store; resource-level grants that whoever edits Wall-E's project IAM can rewrite, bounded by drift checks; a compromised action service laundering a forged trigger, narrowed by corroboration against Google's log; a chat requester's attribution resting on a record the action service writes; a catalogue that never covers an administrator's long tail, now carried by bands B and C; and irreversibility as a matter of degree, since a sent mail cannot be unsent.

Each is reopened when its premise moves ([reopen when](#)): the account count is recorded; a second or non-super-admin operator (fired on 2026-09-13, answered for band B); Eve's design set against these residuals (outstanding since 2026-09-12); an F3 or F3b cell proposed to leave L1; the agent shared beyond operators; Google shipping an acting console assistant or a no-code admin flow under a non-user principal; a deprovisioning connector appearing; a change of model pin, framework or Model Armor filter version; Agent Gateway's `europa-west1` availability settled; cost exceeding its estimate by a factor, or the Stage 1 review falling due; or a severity-1 event or false automatic demotion.

The residual risks a sponsor accepts by signing

In order of consequence, for Chapter 1 to summarise:

1. **A stolen robot credential is a takeover of the Workspace tenant and a route into the cloud organisation.** Key custody, detection within minutes and people pulling switches meet it, nothing prevents it, and a token can work for up to an hour after suspension. The security reviewer signs it as R-01; pending, and the role is unfilled on 2026-09-14.
2. **Inside the organisation, the controller watches a super admin but cannot structurally stop one.** Only what the witness organisation holds is beyond a super admin's reach, and the end state that closes the gap is proposed, not built.
3. **The safety of the design depends on people who do not exist yet.** One administrator holds every role on 2026-09-14 (Chapter 23, Operating model); tiers that need a second person stay closed until that person exists, a delay, not a control failure.
4. **The robot's gate is one process, and its build pipeline can rewrite it.** A compromised pipeline is a compromised gate; only Google's own audit log and detection remain beneath it.
5. **Manipulated content will reach the model.** It can put a proposal in front of an operator and a persuasive false narrative in front of a reviewer; screening is detection-grade and the ceilings are the enforcement.
6. **The regulator and the assessor decide outcomes.** The EU AI Act derogation may be read narrowly, and an assessor may refuse maturity 3 on least privilege despite the signed deviation.
7. **Some Google facts are unverified.** Four are excluded from the safety case; if the answers are unfavourable, the affected controls count for less than designed.
8. **Accepted operational limits.** One region, Google-side tenancy segregation the platform cannot see, some stores on Google-managed keys, and one model family across the fleet.

Key decisions and what to read next

Key decisions

States as held on 2026-09-14:

- **Decided:** P33, Wall-E holds Super Admin; the deviation signatures are pending.
- **Proposed:** P140, the risk register; P136, the deviation record; P60, the access boundary's reach; P15, relocation of Eve's control path to the witness; P16, no machine-invocable account stop; P34, Eve's reporting path may reason; P97, the heartbeats and the silence halt; P99, targets and escalation; P138,

supplier onboarding.

- **Open:** P7, the Admin console access level; P14, the witness organisation; P29, the two lists; P10, the SIEM; P13, the retention ceiling; P19, eve-advisor's class; P25, the Tier W cap; P32, Google's TISAX coverage.
- **Spike:** P4, the engine identity constraint; P8, the deny spelling, via P61.

Canonical pages to read next

- [Wall-E security and guardrails: risk statement, ceiling, threat model](#)
- [Monitoring page: runbooks and organisation-side super-admin rules](#)
- [Project topology: what a compromise reaches](#)
- [Eve's five named limits and Mo's residuals](#)
- [TISAX: the risk register and the deviation record](#)
- [Register: before the super-admin grant](#)
- Next in the brief: Chapter 20, EU AI Act.

20. EU AI Act

What this chapter explains

By the end of this chapter the reader knows the state of the EU AI Act the design rests on, which system on the platform is what under the Act and why, which obligations bite today and which from 2027-12-02, who owns each and what evidence will show it is met, and precisely what the objective's word "bulletproof" can and cannot mean.

The chapter answers the Chapter 3 risk theme **classification collapse**: a system claimed as narrow is treated as high-risk because its behaviour or positioning contradicts its declared purpose, or an agent enters service unclassified. Everything here is the design's position for legal and the data protection officer to sign or strike, not legal advice; on 2026-09-14 nothing is built, registered or signed. Operation families and bands are Chapter 15, Wall-E, the doer; the admission pipeline is Chapter 9, Registry, governance and the autonomy contract; the profiling boundary and the workers' side are Chapter 22, Personal data, employees and the works council.

The position in one paragraph

Classification follows the intended purpose the provider declares, not the privileges an account holds ([EU AI Act page §0](#)). The organisation is provider and deployer of Wall-E and Mo; Google provides the Gemini models and the Gemini Enterprise application, which the organisation deploys; Eve's control path is not an AI system. Wall-E's declared purpose is its catalogue, which places it next to, not inside, the Annex III 4(b) employment category. The provider claims the Art. 6(3) derogation, documents it under Art. 6(4), registers under Art. 49(2) before the first write, and adopts Art. 9 to 15 voluntarily as the engineering baseline. Today Art. 4, Art. 5 and Art. 50 bite; Annex III obligations bite on 2027-12-02. "Bulletproof" is declined as a promise and replaced by mechanisms and evidence.

The regulatory state on 2026-09-13

Dates re-verified on 2026-09-13 ([§1](#)). Regulation (EU) 2024/1689, "the Act", entered into force on 2024-08-01 and applies generally from 2026-08-02; Art. 4 literacy and the Art. 5 prohibitions since 2025-02-02, the general-purpose AI chapter and penalties since 2025-08-02.

Regulation (EU) 2026/1744, the Digital Omnibus on AI, entered into force on 2026-07-27. It moved **Annex III high-risk obligations to 2027-12-02** as a fixed date that does not wait for standards, rewrote Art. 4 as a duty to support literacy rather than guarantee it, added a prohibition on generating intimate-image abuse and child sexual abuse material from 2026-12-02, and slimmed the Annex VIII registration content. **Art. 50 has applied since 2026-08-02**; the Commission published final Art. 50 guidelines on 2026-07-20.

Two instruments the classification depends on are not final. The Art. 6 classification guidelines exist only as a **draft** of 2026-05-19, final text expected by the end of 2026; its paragraph 12 matters most: excluding high-risk uses in terms of service is insufficient when the positioning says otherwise, and the purpose must be described coherently across all materials. **No harmonised standard** is cited in the Official Journal, so no presumption of conformity exists; EN 18286 on quality management is the first candidate. Penalties under Art. 99 already reach up to 7 % of worldwide turnover for Art. 5 and 3 % for Art. 50.

The classification therefore cannot wait for 2027-12-02: the Art. 6(4) assessment and the registration are due before putting into service, which for Wall-E is its first write at Stage 1 ([register §5](#)). The ladder reaches Stage 5 inside that horizon (durations in Chapter 24, Roadmap and cost), so the voluntary baseline is the only way to be ready if a classification flips.

Obligation	Applies	Position on 2026-09-13
Art. 4 literacy, Art. 5 prohibitions	now	briefing designed; Wall-E's negative determination dated, not re-signed
Art. 50 transparency	now	mechanism designed (P128), not built
Art. 6(4) assessment, Art. 49(2) registration	before the first write	not signed, not registered
Art. 9 to 15, 17, 72, 73	2027-12-02, for a high-risk row	adopted voluntarily

Who is provider and who is deployer (P23)

The provider builds a system and puts it into service under its own name; the deployer uses it under its authority (§2). For Wall-E, Mo and a future eve-advisor the organisation is both, which concentrates every obligation on one entity. Google provides the models, as general-purpose AI model provider, and the tenant app, as a general-purpose AI system. Every future agent declares its role in its register row.

Which legal entity holds the roles is open (P23, legal). **Assumption:** the employing entity, or a group-level entity if the platform serves several subsidiaries. The entity that signs the Art. 6(4) assessment registers, and every deployer obligation and the competent authority follow it.

A role trap is recorded: publishing an agent through Gemini Enterprise does not make the organisation provider of Gemini Enterprise, but giving the app a new high-risk purpose would, under Art. 25(1)(c). The register's purpose field is therefore per agent and never for the app.

Classification, system by system

The register uses five classes: not an AI system, minimal, limited (Art. 50), Annex III-adjacent and high-risk (§3).

Wall-E: the catalogue is the purpose (P125, P28)

Wall-E is an AI system: a model infers a plan from a prompt. Its action services are rule-only, but they serve that model's purpose, so the system is classified whole (§3.1). An Art. 5 negative determination dated 2026-09-13, to be re-signed by legal, records no manipulation, social scoring, workplace emotion recognition or biometric categorisation, and no image, video or audio generation; it is re-run whenever a family is added.

The declared purpose describes an administration assistant that, on a named operator's request or a catalogued trigger, executes explicitly targeted operations on groups, profile fields, organisational units, licences and notifications, and suspends or restores an account **only when the HR process or a named operator has already decided it** (§3.1.1). Uncatalogued requests run only when one human super administrator has specified them and a second has approved them. It never decides who leaves, is promoted or monitored, never selects people by behaviour, never changes security posture, deletes data, assigns administrator roles or spends money.

That paragraph exists as **one paragraph with one hash**, identical in the register row, the manifest, the agent card, the Gemini Enterprise description and the instructions for use, and CI compares the five, because of the draft guidelines' paragraph 12.

Super Admin is a credential fact, never a purpose. The account holds it by the owner's decision P33 (decision record); it appears in the technical documentation and as risk-register row one, nowhere in the purpose. It does not change the classification but raises the evidence burden, because an account able to do everything is a positioning fact. The answer is the hard-denied list in code with CI ownership outside the agent's repository, the band structure, and the yearly reconciled count of robot admin events matching no catalogue or band B operation, target zero, attached to the Art. 6(4) file.

The rejected alternative. "Any super-admin action on a prompt" as the purpose would include user deletion and role assignment, collapse the narrow-task reading and make Wall-E high-risk under Annex III 4(b), needing the full programme and an EU declaration of conformity by 2027-12-02 with no standard to lean on. The objective's sentence describes the credential, not the use.

Family by family (§3.1.2; families in Wall-E ladder §5). Notifications, group membership on request, profile fields and organisational-unit moves are administrative attributes; their derogation rests on condition (a), a narrow procedural task. Suspension (F5) touches 4(b), since it executes the consequence of a termination or leave decision; its derogation rests on condition (b), improving the result of a completed human activity, and the plan carries the decision's reference. Licence reclaim by inactivity could touch it; the F7 split and the rule that no AI output selects a person by behaviour (P126, proposed) are Chapter 22's. Band B can reach 4(b) territory, so it stays at L3 permanently with two humans, and a write on a natural person's account must cite a decision record or the lane refuses. Band C only instructs a human.

The result is `annex_iii_adjacent`, role both, registration pending, and the registry refuses production status while it is pending: that is "registration before the first write" in practice.

The assessment and the registration. The Wall-E section of the EU AI Act page, frozen as a dated file, is the Art. 6(4) assessment (§3.1.3). Legal writes and signs it, the DPO signs the profiling part, the AI compliance owner keeps it current; it is due before Stage 1 and re-run within 90 days of the final guidelines. The P23 entity then registers in the EU database, which the platform cannot read, so a registration id that stops resolving is a quarterly review item.

The high-risk fallback is held ready. If legal reads band B as widening the purpose, Wall-E becomes high-risk with Annex VI internal control by 2027-12-02, costed as documents rather than a programme.

State: P125, the content, is **proposed**; P28, the owner's and legal's signature, is **open** and blocks the first write; P125 depends on P29, the two lists, also open.

Reclassification triggers (P132)

A classification signed once goes stale as the guidelines and the deferral move. Under P132, proposed and continuous, a fired trigger sets the register row `suspended` until the classification is re-signed (§3.1.6); it relies on the `suspended` state of P74 and is first armed at Wall-E's Stage 1.

CI enforces the triggers with a machine signal — a manifest change to a family, ceiling, trigger class or target rule, a purpose-paragraph hash change, a model client entering Eve's control path or `eve-advisor` gaining an input to the gate, an incident flagged as assessed under Art. 73. The AI compliance owner keeps the calendar items: P18 answered "profiling", the final Art. 6 guidelines, a cited standard, 2027-12-02, an unforeseen substantial modification. Training or modifying a model is a policy line, because the answer is "never".

Eve's control path: not an AI system, as an invariant

Eve's gate, reconciler and console are deterministic SQL and predicates with no model client (Chapter 16, Eve, the independent controller; Eve HLD §3). The Commission's definition guidelines of 2025-02-06 exclude systems running on rules defined solely by people, so the control path needs no classification or registration and counts as a provider-built oversight measure under Art. 14(3)(a) (§3.2). It is held as an invariant: CI forbids a model client in Eve's image, a service-usage denylist blocks the Vertex AI API, and reconciliation checks it stays disabled. A model client would void the determination, suspend the row and stop Eve's approvals counting as human-designed oversight. Eve's build runbook does not yet name the check as this invariant (register §7 row 14).

eve-advisor: class to be decided (P19)

`eve-advisor`, the report-only reasoning path P34 allows, is not built (§3.3). It would narrate anomalies about the robot and human administrators; whether that monitors persons in a work relationship is legal's question, **open** as P19. Until answered: nothing is registered, it pages at severity 2 only, names no human without the

deterministic rule behind the finding, writes nothing the gate reads, and a build without a class is refused. The design expects Annex III-adjacent under Art. 6(3)(c), but that is legal's call.

Mo: minimal risk

Mo measures outcomes and proposes changes as pull requests a human merges; it grades plans, not people, and meets no natural person but its reviewers (§3.4). It is minimal risk, role both. Where a model drafts Mo's prose, an "agent-authored" label and file header disclose it.

The Gemini Enterprise app and the Gemini models

For both the organisation carries deployer duties only; they are supplier rows, not agent rows (§3.5). The conversation store is not the platform's Art. 12 log, and its retention is the DPO's (P13, open; interim 30 days, Chapter 12, Data, logging, retention and sovereignty).

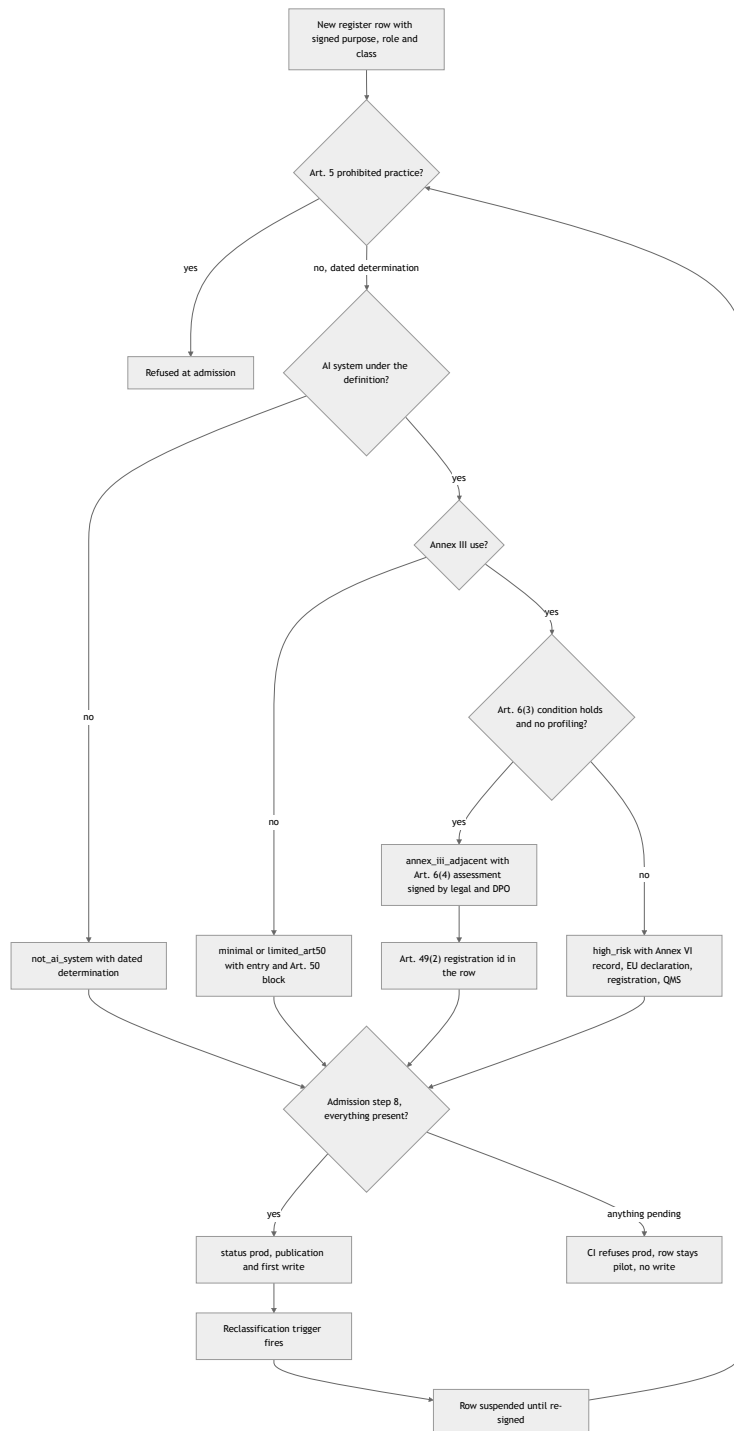
The **GPAI position** is one line: *the platform hosts third-party models and never trains, fine-tunes or substantially modifies them; any change reopens the general-purpose AI chapter and Art. 25*. The platform holds Google's Annex XII documentation per model pin.

The Art. 25(4) written position with Google is still to obtain (P32, **open**): what information, access and assistance the model provider gives so the organisation can meet its obligations. It is requested, gates Stage 1, and the supplier row says *tbd* until on file ([register §6](#)).

The classification gate for every future agent

The platform is infrastructure, not an AI system; every agent on it is its own classification question, which for hundreds of agents must be a gate, not a page (§3.6). The admission step is P75, proposed, in Chapter 9 ([registry §8.2](#)); this chapter owns what the gate asks (§3.7).

Each agent's entry follows one template, from roles, purpose hash and Art. 5 determination through the Annex III analysis per family to registration id and signatures. The AI compliance owner reviews it before legal signs.



The cost is lead time: no agent claiming the derogation reaches production faster than legal can sign and the entity can register.

The AI compliance owner (P131)

The platform's responsibility matrix had no row for whoever signs classifications, files registrations, answers an authority and owns the Art. 73 clock. P131, **proposed**, creates the role: legal's designate, or the DPO where legal delegates, accountable for roles, classifications, assessments, registrations, Art. 73 reports, the literacy content and the evidence register (§4.1).

It is deliberately **not** the platform owner or an agent owner: a classification signed by the builder is self-assessment an auditor rejects. The minimum is "consulted" at Tier W and "engaged, with a named deputy" at Tier P; the ISMS supplies names, and the role must exist before the super-admin grant ([register §4](#)). No owner means no signature and no Annex III-adjacent row in production. Staffing is Chapter 23, Operating model.

The obligations, theme by theme

Art. 4, 5 and 50 are mandatory now; Art. 9 to 15 are **adopted voluntarily now** for Annex III-adjacent rows and **mandatory from 2027-12-02** for any high-risk row ([HLD §14.1](#); [§4](#)). Each obligation has a mechanism, an owner, an evidence id and a failure consequence; most failures stop a stage rather than raise a finding.

Risk management: Art. 9

Art. 9 adds risk to persons to the existing security risk work ([§4.2](#)). The adversarial review gains a **fundamental-rights column**, and the risk register gains rows with stated residuals: wrongful suspension, up to the hold window plus the restore's approval time; loss of tools through licence reclaim; the discriminatory effect of inactivity reports on part-time, absent, sick and disabled staff, even when no action follows; the chilling effect of [eve-advisor](#); phishing-grade mail from a trusted account; automation bias in approvers, measured rather than eliminated. A promotion record without a residual-risk statement is refused. The agent owner writes, the security reviewer signs, the DPO reviews rows touching employees.

Technical documentation: Art. 11 and the freeze (P130)

Art. 11 needs the documentation of the version put into service, not a live wiki. Under P130, **proposed**, CI tags the wiki per agent and stage before the stage opens and copies the tree to locked ten-year records; no tag, no stage ([§4.3](#)). P130 also declares the ladder the record of pre-determined changes, so a promotion within manifest ceilings is not a substantial modification.

The agent sets still carry unapplied propagation edits, so **Art. 11 is not met until the pages are reconciled** (P47), a precondition of the Stage 1 tag.

Instructions for use: Art. 13

One operator-facing page per agent gives capabilities and limits, the declared accuracy floor of at least 95 % graded correct with current scorecard numbers, the ladder's pre-determined changes, oversight tools and how to read denial reasons ([§4.5](#)). It is part of the stage snapshot and doubles as the briefing text; its filename is *tbd*. Stage 1 does not open without it.

Human oversight: Art. 14 (P127)

The ladder is the oversight design: limits, the pre-state shown before approval, the veto window and the kill switches K0 to K7 ([§4.6](#)). Eve is not a natural person: at L4 human oversight is the veto window, at L5 it comes after the fact. Art. 14 requires that people can intervene, not that they approve everything; for Annex III-relevant families a human still stays before the effect.

P127, **proposed**, sets **caps**: suspension reaches L4 only on the HR system-of-record event, with holds that never expire outside business hours, and stays at L3 on chat or schedule, because a scheduled suspension has no human decision fresh enough for L4; reclaim of suspended accounts follows suspension; reclaim of inactive accounts, restore and band B stay at L3. CI validates the ladder against the caps, and P127 gates Wall-E's Stage 4. Wall-E's ladder page still reads suspension as "L4, and not before Stage 5" with no HR-event limit or F7 split; the EU AI Act page stands (register row 14).

Overseers are named roles with authority, training record and duty window. Against **automation bias**, which no product controls, each operator blindly grades a monthly sample of their own approvals, drawn by the approval surface, never by Mo; low agreement (threshold *tbd*) is a review item, never an automatic consequence

for the person. Mo's scorecard does not yet carry the metric. The K0 drill record proves people can stop the system. What the caps mean for employees is Chapter 22.

Transparency: Art. 50 (P128)

Art. 50(1) requires telling people they deal with an AI system; Art. 50(2) requires machine-readable marking where feasible (§4.7). Secondary sources read the final guidelines as requiring agents to disclose both their nature and whom they act for.

P128 is **proposed and already due: disclosure is injected by the action service, never written by the model**, which could be manipulated not to disclose. On every free-text mail, chat post or calendar item the service prepends a fixed line naming Wall-E as an AI system, the entity and whom it acts for, and sets a fixed mail header (name *tbd*); a body it cannot wrap is refused with `disclosure_missing`. Templates, the Gemini Enterprise description, agent card and first session reply carry a fixed AI statement; a CI test asserts line and header. Machine-readable marking of model text is provider-side and unverified: a Google staff forum answer of 2026-08-19 says API text is SynthID-watermarked, the documentation is silent. Signing the Transparency Code as a deployer is legal's *tbd*.

Still open on Wall-E's pages (register §7 row 14): the low-level design has no disclosure wrapper and no `disclosure_missing` refusal, and the Gemini Enterprise environment page lacks the description's first line.

Literacy: Art. 4

A one-page briefing per role covers what the agent can and cannot do, automation bias, the kill switches and how to report misbehaviour (§4.8). It precedes joining an operator group and is refreshed at every stage; a drift job removes untrained members. The AI compliance owner owns content, the ISMS records. For employees, the measure is Chapter 22's worker information.

Quality management: Art. 17 held ready

Art. 17 is mandatory only for a high-risk row and proportionate to size (§4.9). Instead of a second management system, the design maps Art. 17(1)(a) to (m) onto what the ISMS and platform already run. It is built only if a row turns high-risk, and such a row is suspended until the mapping is signed.

Obligations explained elsewhere

Art. 12 logging is Chapter 12; Art. 26(7), 26(11) and Art. 86, worker information and the explanation path (P129), are Chapter 22; Art. 72 post-market monitoring is Mo's artefacts in Chapter 17, Mo, continuous improvement (Mo §1.8); Art. 73 serious-incident clocks, run voluntarily, are Chapter 11, Monitoring, detection and incident response; Art. 15 robustness is Chapters 10 and 13. The Art. 27 impact assessment does not apply, on the `Assumption:` of a private organisation providing no public service.

The evidence register

The register lists fifteen artefacts, E-01 to E-15, that an authority, an assessor or the works council would be shown, with location, producer, cadence and retention (§5). Records are kept ten years; logs and metrics 400 days, an `Assumption:` until the DPO decides. The AI compliance owner walks it quarterly. Six are gating — assessment, registration, stage snapshot, instructions, worker information and literacy records — and a missing one blocks its stage. On 2026-09-14 none exists in its final, signed or frozen form.

What "bulletproof" can and cannot mean

What can be said (§6): the design holds most of the engineering an Art. 9 to 15 programme needs, often beyond what the Act asks of a system claimed not high-risk — an audit copy outside the tenant, a model-free verifier with halt authority, a ladder of pre-determined changes, a measurement loop that is a monitoring plan by

construction, and classification as a precondition of existence. Once the documentation is frozen (P130) and P23, P28, P18 and P19 are signed, it will exceed the Act's engineering expectations for the pilot and meet its legal ones as they stood on 2026-09-13.

What cannot be promised. The page's summary counts seven items; its residual list holds eleven, some closed by the organisation itself, and this chapter follows the list.

1. The Art. 6(3) claim rests on **draft guidelines**; closed by re-signing within 90 days of the final text.
2. **No presumption of conformity**; narrowed by an internal assessment against the articles until a standard is cited.
3. How an authority reads **licence reclaim by inactivity**; narrowed by P18 answered in writing.
4. The **Super Admin grant** weighs against the narrow-task reading; narrowed by one purpose hash, the hard-denied list and the zero out-of-catalogue count.
5. Oversight above L3 rests on **Eve, not a person**; narrowed by drills, veto statistics and caps.
6. **Documentation does not match** the system; closed by the Stage 1 tag.
7. **Hundreds of agents** multiply every row; narrowed by the generated export and shadow-agent reconciliation.
8. The **Art. 25(4) position** is not on file; closed by P32.
9. **Marking of model text** is unverified; closed by Google's written statement per model pin.
10. **eve-advisor's class**; closed by legal before any build.
11. **Penalty exposure** is real now, and the first Art. 50 evidence does not exist until Stage 1.

Instead of "bulletproof", the platform promises the mechanisms and the evidence, and lists what the regulator or the guidelines still decide.

What is unverified, and what closes each item

From the dated list (§9): the final Art. 50 guidelines' wording on agents (legal); SynthID on Gemini text per model pin and Google's compliance documentation (Google's written statement, the Annex XII files); whether the Omnibus changed registration timing (legal); the Art. 72(3) template and the final Art. 6 guidelines' date (calendar items); the draft's treatment of systems executing a decision already taken (legal confirms suspension under condition (b)); the competent authority (after P23); national consultation rules (**Assumption:** information before putting into service; HR and legal before Stage 1); SME status (not assessed); the mail header's survival in recipients' systems (the CI test); and accessibility of the operator surface (not assessed).

What remains

Chapter 19, Threat model and residual risk, records classification collapse as a residual that blocks a gate rather than one accepted: a classification resting on draft guidelines and on the Super Admin grant not being read against the purpose; four unsigned legal answers (P23, P28, P18, P19); no Art. 25(4) position (P32); Art. 11 unmet until reconciliation (P47). Chapter 21, TISAX, tests the same design under certification; Chapter 25, Decisions awaiting the owner, lists who must sign what.

Key decisions and what to read next

Key decisions

- **P23 — open** (legal): the legal entity. **P19 — open** (legal): **eve-advisor's class**. **P32 — open**: the Art. 25(4) position.
- **P28 — content proposed via P125, signature open**: Wall-E's purpose; blocks the first write.
- **P125 — proposed**: Wall-E's Art. 6 path and high-risk fallback.
- **P126 — proposed**, with **P18 open**: the profiling boundary (Chapter 22).
- **P127 — proposed**: Art. 14 caps and overseers. **P128 — proposed, already due**: Art. 50 injection.

- **P129 — proposed:** worker information before Stage 1 (Chapter 22). **P130 — proposed:** the documentation freeze.
- **P131 — proposed:** the AI compliance owner. **P132 — proposed, continuous:** reclassification triggers.
- **P75 — proposed:** no production without registration (Chapter 9). Register row 14 open.

Canonical pages to read next

- [EU AI Act page: §3.1, §4, §5, §6](#)
- [Platform HLD §14.1; open decisions §5](#)
- [Decision record: Wall-E holds Super Admin](#)
- Next in the brief: Chapter 21, TISAX.

21. TISAX

What you will understand by the end

The objective asks for a platform that is "TISAX compatible". A platform cannot hold a TISAX label. A site earns one by assessment, and a cloud platform is an asset inside that site's information-security management system (the ISMS). This chapter turns "compatible" into things an assessor can check, and says which of them do not exist yet.

By the end you will know the target label, level and scope; what Google carries and what the platform must show; where the design is strong and where it is unfinished; why separation of duties is the item most likely to stop an assessment; and how the super-admin deviation is signed, policed and re-signed. The design of record is [page 11](#). Nothing here is built.

TISAX on 2026-09-13

TISAX is run by the ENX Association for the VDA; its questionnaire is the VDA ISA ([page 11 §1](#)). Four verified facts shape the rest.

The catalogue is changing. ISA 6.0.3 (published 2024-04-25) is in force. ISA2027 (published 2026-07-01) is the basis of assessments ordered from 2027; the last day to order on ISA 6 is 2026-12-31. ISA2027 requires organisations with high protection needs to verify suppliers "through TISAX labels or equivalent assessments", and wants a rationale for every "aspects considered" item. Nothing is built in 2026, so any assessment will be ordered on ISA2027.

Labels set levels. Of the twelve assessment objectives, Confidential leads to AL2, a plausibility check of the self-assessment with evidence review and a web-conference interview; Strictly confidential leads to AL3, with on-site observation and unplanned interviews. Maturity runs from 0 to 5, and most controls target 3, "established". A result is valid for three years.

Scope is a site. Anything processed outside the assessed site's scope is an external IT service, governed by 1.2.4, 1.3.3, 5.3.3 and 5.3.4.

Google's label is per region. Google LLC is a participant under scope SYN0NK (assessments ATTRRN-1 and ATTRRN-2). Its Google Cloud regions, europe-west1 among them, and Workspace data regions carry Strictly Confidential and Very High Availability labels "for data classified as secret". The public page names no individual service, and the result is retrievable only over the ENX portal.

The target: label, level, scope and catalogue (P133)

P133 is proposed and supplies the value of the HLD's P20; the ISMS confirms it before any order ([page 11 §2](#)).

Label Confidential. Assumption: the ISMS adopts it. The platform's evidence, content and control data map to Confidential; only the secret class (credentials, the surrogate-key mapping) maps higher, and a secret store alone does not set a site's objective. If the ISMS's scheme classed Wall-E's audit table, the content or identity logs, or Gemini Enterprise conversation history as secret, the label would become Strictly confidential: AL3, on-site observation of the witness organisation and the key safe, and a reopening of the Google-managed-key exceptions (P119), Assured Workloads (P110) and its revisit trigger (P12). Without a signed classification mapping the order is not placed.

No availability label. Wall-E, Eve and Mo are not critical IT services; the manual Admin console is Wall-E's continuity plan. An availability label would bring Google's regional service levels into the organisation's own assessment for no partner's benefit.

AL2, with AL2.5 (full remote) accepted if the audit provider proposes it, because it keeps the AL3 path open at no design cost.

Scope location tbd. Assumption: the site where the platform owner and IT security sit. Google Cloud and every third party are external IT services of that scope; the witness organisation is an asset of the same site, not a second location.

ISA2027 with the 6.0.3 cross-reference, mandatory column for high protection need, maturity 3 on every applicable control. Assumption: ISA2027 keeps the 6.0.3 numbering; a reading of the redline found the same 46 controls, 44 edited. NIS2 goes to the legal register below. P133 rejects Strictly confidential at AL3 now: no partner requirement asks for it, and it would tie the platform to an on-site assessment of a site nobody has named.

Module scope (P134)

Information Security applies in full, chapters 1 to 7 ([page 11 §3](#)).

Data Protection is not an assessment objective now. Its labels are written for an Art. 28 GDPR processor. The platform administers the organisation's own tenant and employees' accounts, so the organisation is controller and 7.1.2 with its GDPR programme is the frame; the module's 9.x questions serve as the DPO's checklist of what the platform owes, almost none of it started (Chapter 22, Personal data, employees and the works council). The answer changes for any hosted agent that processes a customer's or an OEM's data on that customer's behalf: for that agent's scope the module becomes an objective. Hundreds of agents make that likely, so a register field enforces it: a row whose purpose names third-party-controller data sets `tisax_dp_scope` and cannot reach production without a dated DPO entry ([page 05 §3.2](#)). Register row 7 added the field to page 05, optional until the first processor-role agent ([register §7](#)); the gate check is still a build item.

Prototype Protection does not apply: no agent touches prototype parts, vehicles or events, a negative determination dated 2026-09-13. The admission gate's text check is detection-grade; the DPO and ISMS review of every new row is the control.

Shared responsibility with Google (P135, P32)

The split

Google is one external IT service with two contractual halves, Google Cloud and Google Workspace, and one TISAX result ([page 11 §4.1](#)). The split is kept per control group in three columns ([§4.2](#)): Google holds physical security, the underlying network, default encryption and its personnel controls; the platform configures and evidences every binding, key, sink, allow-list and drill; the ISMS owns policies, contracts and names. Most rows are shared, and the split records whom the assessor asks first. Control 1.2.4 wants the division "verifiably documented", so a Preview product reaching general availability under new terms has its row re-dated within 30 days.

The supplier file and per-service coverage

Page 11 §4.3 is the supplier file for Google ([§4.3](#)). Two fields decide whether an assessor accepts it. The **result share**: Google's public compliance page taken as proof is the mistake an assessor catches first; the ISMS's ENX account must request the SYN0NK result and file it, a control that does not exist until someone does. And **per-service coverage**: because the result names no service, every service the platform relies on carries coverage tbd: Agent Runtime and its Google-managed tenant project, Gemini Enterprise (whose own listing names ISO, SOC and BSI C5, not TISAX), Model Armor floor settings, Agent Gateway, Agent Registry, BigQuery EU, the organisation-level logging buckets, Google SecOps in the EU and the Gemini models. Each closes only from the

result share or Compliance Reports Manager, through P32, open. The model is its own supplier line, with no-training and retention terms confirmed per model pin and the Art. 25 position of Chapter 20, EU AI Act. The contracting entity, data-processing terms and service levels wait for contract review.

The segregation note (5.3.4)

Control 5.3.4 asks how a shared service keeps tenants apart, and the platform can only answer candidly (§4.4). Agent Runtime engines run in a Google tenant project the organisation cannot inspect; Gemini Enterprise is multi-tenant; BigQuery EU and Model Armor floor settings are shared infrastructure with per-project isolation. The organisation sees its own logs, Access Transparency and Access Approval entries and IAM state, never other tenants or Google's internal segregation controls, so a tenancy failure at Google would be invisible until Google disclosed it. No platform control changes that; the ISMS accepts the residual or does not, as a risk-register row (Chapter 19, Threat model and residual risk).

The control mapping, as themes

Page 11 maps every applicable control and gives each one status: **doc** (documentation finishable now), **built-by-design** (evidence exists once built), **missing control** (no mechanism, and no document can supply one) or **ISMS** (outside the platform's authority) (§5).

Strong once built, at maturity 3 or better (objective review §6.2):

- administrator-activity logging (5.2.4): every robot action on its own audit row, with Google's admin stream copied beyond the reach of the robot and the tenant's super admins;
- keyless identity and enumerated resource-level grants (4.1, 4.2), with privileged access management as review evidence;
- change control separated from what it gates (5.2.1, 5.3.1): autonomy as versioned data, CI-only deploys, a validator owned outside the agent repository;
- cryptographic proof of approval (5.1), on an HSM signing key;
- technical self-audit (5.2.6): denial suite, drift job, monthly kill-switch drills, injection suite.

Arguing each rejected alternative in place already meets ISA2027's rationale rule.

Unfinished, at the layer an assessor reads first: policies, separation of duties, the Google split as practice, the asset register and classification mapping, the risk register, the incident process with a staffed recipient for Eve's reports, pre-production, vulnerability management, a proven restore, the legal register and the DPIA.

Separation of duties: the item most likely to stop an assessment

On 2026-09-13 one person holds every role, security reviewer and recipient of Eve's pages included (Chapter 23, Operating model). At high protection need, 1.2.2 asks explicitly for separation of duties, and a design reviewed only by the person it constrains fails that question however good it is (HLD §14.2).

The design answers with a precondition, not a promise to hire (page 11 §7; P137, proposed). An incompatibility matrix names roles one person may never combine, each stage has a minimum number of distinct humans, a CI check tests the matrix against group memberships daily and on every merge, and the tier gate refuses a tier while a pair collides or a role has no name. Tier R may run on one person with self-review accepted by the ISMS in writing; nothing above it may. The counts and exception are Chapter 23; the tier gate is Chapter 24, Roadmap and cost. Until the ISMS supplies names, 1.2.2 is a missing control, and no document closes it.

The super-admin deviation (P136)

What is deviated

The owner decided on 2026-09-13 that Wall-E holds Super Admin (P33), and nothing here re-argues it. In ISA terms it deviates from one control, 4.2.1 least privilege ([page 11 §6.1](#)): a machine account holds a role that cannot be scoped to an organisational unit or a privilege subset, and the Workspace-side refusal that bounded the earlier custom role is gone. Privileged authentication (4.1.2) and privileged-activity logging (5.2.4) are met, not deviated. An assessor will also cite Google's guidance that super admins be few, human and not used daily; the answer is that daily use is bounded to the catalogue and the two-person generic lane, every action traceable to a human prompt or catalogued trigger, none autonomous at super-admin class. The thirteen compensations are argued in Chapter 15, Wall-E, the doer.

The record and its three signatures

The deviation is one file, the P33 [decision record](#), and the assessor is handed it and the evidence it points to, nothing else ([§6.2](#)): the loss table unsoftened, the residual risk, compensations with their status on the day of signing, review terms and signatures.

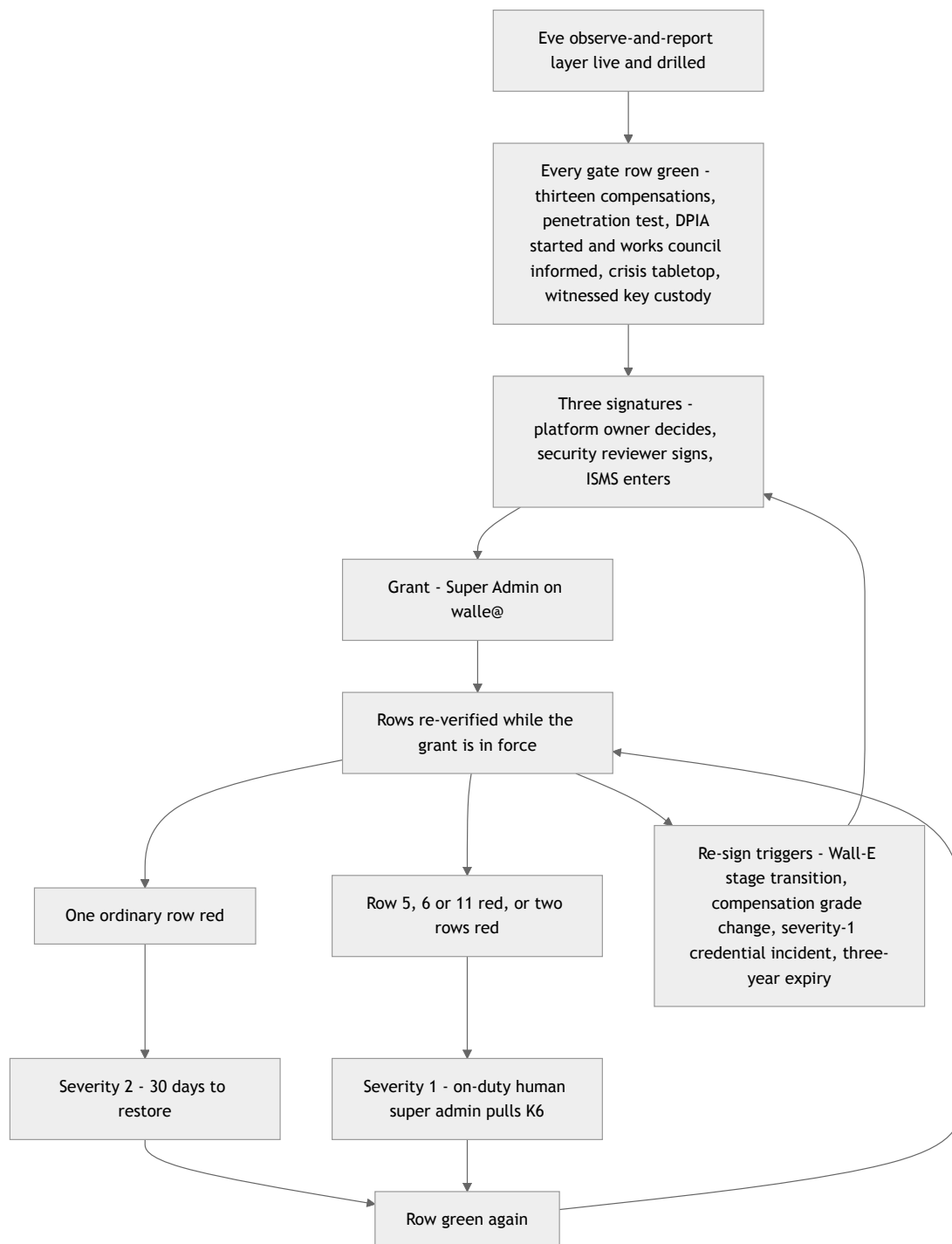
Three signatures: the **platform owner decides**; the **security reviewer**, who is not the platform owner, **signs** the deviation and accepts risk row R-01; the **ISMS enters** it in the site's risk register. 1.2.2 forbids self-signature, so a record signed only by its beneficiary is not a control. On 2026-09-14 only the decision is signed; the reviewer's signature waits for a second person in that role. Page 11 names the platform owner as R-01's owner while the decision record names the security reviewer ([page 11 §10](#)).

Compensations as gate conditions

Every compensation is a gate condition ([§6.3](#)). The thirteen HLD items become rows of Wall-E's gate checklist, each with a stated meaning of green, a verification, a date and a signer, joined by a penetration test with no open critical or high finding, a dated tabletop of the abused-credential crisis scenario and a witnessed hardware-key custody record. Page 11's checklist carries a fourth added row that P136's wording omits: a started DPIA with dated works-council information (Chapter 22, Personal data, employees and the works council). The grant runbook refuses while any row is not green, and the order is fixed: Eve's observe-and-report layer live and drilled, then the grant, then Wall-E's Stage 0 with every write family at L1. On 2026-09-13 no row is green, and several wait on register decisions ([register §4](#)): the two lists (P29, open), the witness organisation (P14, open), the SIEM choice (P10, open), the perimeter spike (P3), multi-party approval and the roster (P66, P68, proposed).

After the grant: the red-row rule

Any one row red is a severity-2 finding with 30 days to restore it. Two rows red at once, or row 5 (detection as the primary control), row 6 (account hygiene) or row 11 (the second human outside the Wall-E line), on which the rest depend, red at all, is severity 1: the on-duty human super admin pulls K6, removing Super Admin from the robot, until the row is green again. K6 is Chapter 15's and severities are Chapter 11's. Neither page 11 nor the decision record says what happens to an ordinary row still red on day 30; only for an open critical penetration-test finding does page 11 continue to K6.



Keeping the record honest over time

A deviation with no expiry becomes the norm. The record is reviewed quarterly with the super-admin roster, re-signed at every Wall-E stage transition and whenever a compensation's grade changes, and expires with the assessment result after three years or earlier on any severity-1 incident involving the credential. Register row P136 words the quarterly event as a re-signature, page 11 and the decision record as a review (§6.2). However strong the compensations, an assessor may still refuse maturity 3 on 4.2.1 for a super-admin robot; only the assessment settles that.

Assurance: penetration test, internal audit, management review (P139)

The platform checks itself continuously; 1.5.2 also wants independence, so P139, proposed, adds three activities nobody on the platform performs for themselves (page 11 §9).

Penetration test: bought, grey-box, owned by IT security, never run by the platform or agent owner. Its scope is every surface where a request becomes an action or an approval, kill-switch endpoints and the witness push path included; Google's infrastructure is out of scope. It is due before Stage 1 of any Tier P agent, for Wall-E before the grant; a scoped test of the approval surface and action service precedes Stage 1 of the first Tier W agent, because the first write is the first exposure; then annually and on any new lane or front door.

Internal audit by the ISMS's auditor, never the platform owner nor the deviation's signatory, sampling the mapping against live evidence, annually, first before the assessment order and after any severity-1 incident. An open finding on 1.2.2 or 4.2.1 holds the order.

Management review quarterly, covering the ladder, risk register, deviation, supplier tbd items and training, and annually into the ISMS's review, minutes kept ten years. Two quarters without one and the ladder does not raise.

The legal and contractual register (P141)

Control 7.1.1 asks which instruments apply. P141, proposed, keeps one register owned by the ISMS with legal (page 11 §11): the GDPR; the EU AI Act as amended (Chapter 20); national labour and works-council law, country tbd; NIS2, applicability tbd, with ENX's crosswalk of 2025-06-29 if it applies; the Google agreements and data-processing terms, titles tbd; the TISAX participation terms of 2023-07-16 (Assumption); customer and OEM security clauses, which set both the label and the supplier-verification bar; and internal policy ids. One row is an admission: several products the design relies on, Cloud Run Agent Identity and PAM two-level approval among them, are Preview products with different support and service-level terms, listed in full at build. An applicable instrument missing from the register is a finding on 7.1.1.

Documentation versus controls that do not exist

Page 11 splits "compatible" into two columns, each with the gate it blocks (§12). Writing finishes the first: the statements, mapping, Google split, supplier file and segregation note, deviation text, separation matrix, registers, procedures and policy tables.

Only building, hiring or buying finishes the second: the second, third and fourth humans; the compensations built; the result share and coverage answers; a CI-enforced register; Data Access logs with decided retention and a SIEM feed; pre-production, a sandbox tenant, a scanning gate and pinned dependencies; one recorded restore; a staffed recipient of Eve's reports; the data-protection artefacts; the penetration test, first audit and review; the first run of the supplier procedures; the witness organisation; and the separation and `tisax_dp_scope` gate checks. Roughly half of "compatible" is writing; the other half is not.

The **evidence pack** is assembled per control group from the evidence bucket and git by one export job the platform owner runs before the assessment and after every internal audit, kept ten years (§13).

What is unverified, and what closes it

(§15)

Unverified	Closes when
ISA2027 keeps 6.0.3 numbering; exact titles of 5.3.3 and 5.3.4; Data Protection module numbering	the ISMS reads the ISA2027 workbook and the redline of 2026-08-07
Google's per-service coverage	the ENX result share, Compliance Reports Manager, P32

Unverified	Closes when
Contract titles, versions and contracting entities	contract review by the ISMS and procurement
The operating site and its current label; classification scheme, policy ids, risk scale, cryptography standard	the ISMS
NIS2 applicability	legal
Maturity 3 on 4.2.1 with the deviation	the assessment itself

Key decisions and what to read next

States on 2026-09-14:

- **Decided:** P33, Wall-E holds Super Admin; the security reviewer's and ISMS's deviation signatures pending.
- **Proposed:** P133 the target (P20's value; Confidential an Assumption the ISMS confirms); P134 module scope and the register field; P135 the mapping page, supplier file and segregation note; P136 the deviation record; P137 separation of duties as a counted minimum; P139 the assurance cadence; P140 the risk register; P141 the legal register.
- **Open:** P32 per-service coverage with the Art. 25 position; P29 the two lists; P14 the witness; P10 the SIEM; P13 retention behind the 400-day Assumption.
- **Spike:** P3, the perimeter behind gate row 8.

P136 and P139 gate the super-admin grant, P137 Tier W and the grant, and P133 to P135, P140 and P141 the assessment order ([register §6](#)). Pointers only: the risk register is Chapter 19, supplier onboarding Chapter 14, Scale and AGI readiness, training Chapter 23.

Read next: [page 11](#) in full; [the deviation record](#) and [the gate checklist](#); [the responsibility split](#); [HLD §14.2](#) and [the tier gate](#).

22. Personal data, employees and the works council

What you will understand by the end

The platform acts on employees' accounts and records the people who operate it. This chapter is for the data protection officer (DPO), the works council, HR and legal.

By the end the DPO will know the organisation's position as controller, what the platform owes the DPIA and the records of processing and how far each input has got, and where personal data sits and for how long. The works council will know which of Wall-E's actions affect employees and how they are bounded, what is recorded about operators and what may never follow from it, when workers are informed and consulted, and how an employee obtains an explanation. Both will know which decisions are still open. Nothing here is built.

22.1 The position: controller, and internal processing

The platform administers the organisation's own tenant and employees' accounts, so the organisation is the **controller** and the platform its internal processing. The frame is therefore the organisation's existing GDPR programme and the data-protection control inside its ISMS, not a separate regime for AI (11 §3).

It holds only while every agent processes data for the organisation itself: an agent processing a customer's data on its behalf is a processor, and a register field with a dated DPO entry stops it reaching production as internal processing (P134, proposed; Chapter 21, TISAX).

22.2 What the platform owes the DPO, and where each input stands

The DPIA and the records of processing are the DPO's; the platform supplies the facts they rest on, and on 2026-09-13 most exist only as design (11 §3, HLD §14.2).

Input	Status on 2026-09-13	What is missing
Records of processing, one entry per agent	not started	entries for reads at Stage 0, writes from Stage 1, band B, Mo's metrics, the content logs and the identity log store
DPIA	not started	the DPIA itself; the platform supplies the residency table, the store inventory, the autonomy ladder and the worker-consultation record
Transfers	inputs exist	the DPO's assessment of the residency exceptions, the model's processing location and Google's sub-processors
Data-subject requests	store list exists	the written procedure and the query per store
Breach process	designed	operation; the path is Chapter 11, Monitoring, detection and incident response
Deletion capability	to build	the revoke operation and its return-and-removal record

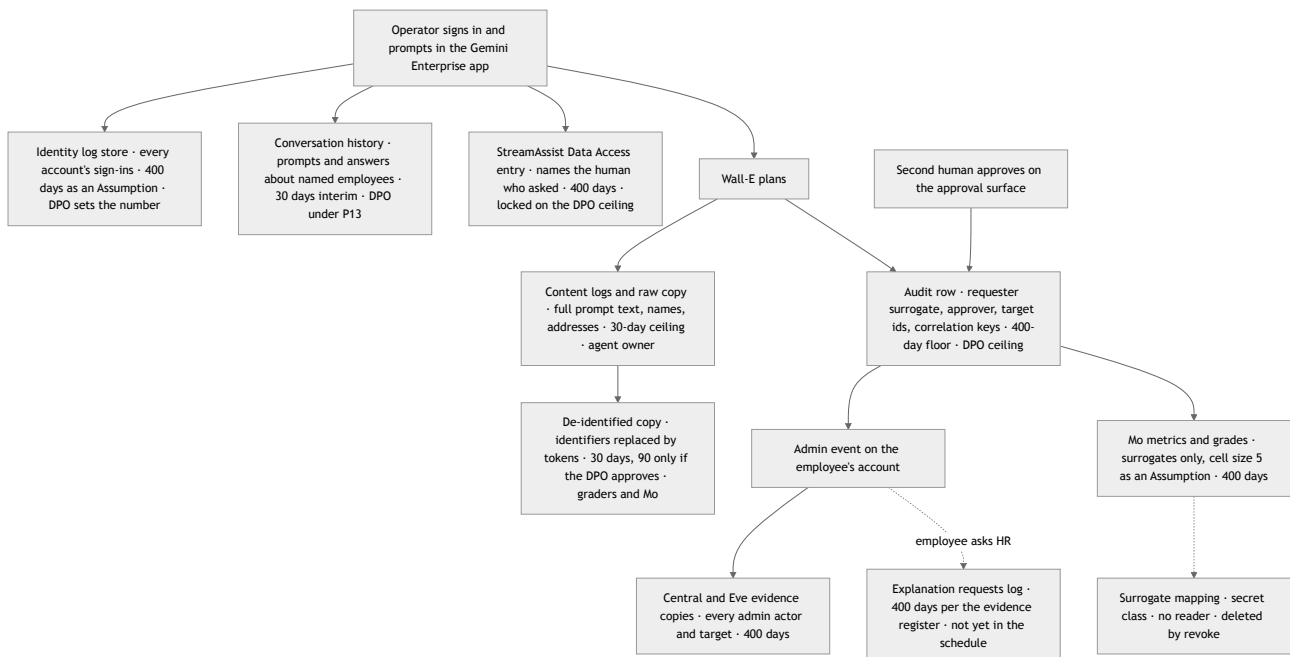
The DPIA is the longest lead item. The read-only stage already processes personal data on every employee. Wall-E's page calls that processing aggregated per organisational unit ([Wall-E weakness 11](#)), while Mo's design records per-person reads ([Mo open decisions](#)). Autonomous action is a second processing activity; both need assessing, the reads before the first report. Three Gemini Enterprise project stores are covered once, by the first Tier W agent's DPIA, and later agents inherit it ([03 §14](#)).

Transfers. The TISAX checklist refers to "the two residency exceptions" ([11 §3](#)), while page 08 keeps six dated exception rows ([08 §7.2](#)); the DPO should work from the six. Sovereignty is Chapter 12, Data, logging, retention and sovereignty.

Data-subject requests. The store inventory is the map a request is answered from (08 §2.2). A locked evidence store cannot delete early, so a request against one is answered by disclosure, not deletion, which the DPO's ceiling decision should state in writing (08 §5.1). Minimisation keeps this lawful: locked stores hold only who requested, who approved, what changed and on whom; content that would amount to a profile sits in a never-locked 30-day store.

22.3 Where a person is identifiable along one request

The diagram follows one request from an operator's prompt to a change on an employee's account; each store has its own retention and decision owner.



The **StreamAssist Data Access** entry is the only log that names the human behind a request (03 §13); the correlation keys carry that human, as a surrogate, into every audit row beside the approver and the target's id (07 §5). An investigator can go from an employee's complaint to the prompt, the approval and the Google event, so a breach filing can count data subjects, and the audit trail is personal data about operators as much as targets.

Graders read content only after de-identification: one template replaces recognised identifiers with deterministic tokens and redacts credentials (08 §6.3). Free text outside the recognised patterns stays, because a grader has to read the prompt. De-identification reduces identifiability without removing it.

The identity log store, every tenant account's sign-ins, is the densest personal-data store on the platform, kept apart so the DPO can set its ceiling without touching the audit lock; its legal basis, legitimate-interest balancing, is an **Assumption**: the DPO must confirm.

22.4 The actions that affect employees, and how they are bounded

Most of Wall-E's catalogue changes administrative attributes: group membership, profile fields, organisational units. Two families change whether a person can work. **F5 suspends an account; F7 removes or assigns a licence** (Wall-E ladder §5). Restore (F6) is permanently human-approved, so a loop cannot suspend and restore unnoticed.

Wall-E suspends only when HR or a named operator has already decided (Chapter 20, EU AI Act; 10 §3.1). A band B write on a natural person's account must also cite the decision record, or the lane refuses it (P125, proposed), leaving an audit row that shows the decision was a human's.

The caps in practice. Under Chapter 20's caps (P127, proposed), an autonomous suspension is possible only on the HR system of record's event, and even then waits in a vetoable hold that never expires outside business hours. A suspension asked for in chat or on a schedule, and licence removal from a suspended account, needs a human approval first. The residual, stated plainly: a wrongful suspension can last the hold window plus the restore's human approval, up to four business hours (10 §4.2). Wall-E's ladder page does not yet carry these caps (register row 14, open).

22.5 The profiling boundary (P18, P126)

Selecting accounts for licence reclaim by last sign-in and usage would evaluate people's behaviour at work; that may be profiling, and profiling makes an Annex III-adjacent system high-risk whatever else holds. P18 asks legal and the DPO whether it is, and on 2026-09-14 it is open (12 §5).

The design does not wait for the answer, nor rely on the untested argument that a single timestamp threshold is not profiling. Inactivity heuristics foreseeably discriminate against part-time staff and people on leave, off sick or disabled, a fundamental-rights risk whether or not it is profiling (10 §3.1.4). P126 (proposed) builds the boundary instead.

- **No AI output selects a person by behaviour.** F7 is split. F7-suspended removes licences from accounts someone else has already suspended, so Wall-E chooses nobody. F7-inactive removes licences from active accounts, and only from ids a human has listed explicitly.
- **The inactivity report is a read artefact for a human,** whose selector is briefed on its discriminatory risk; the DPO reviews the selection rule in the DPIA.
- **Two enforcement points.** CI refuses any playbook that binds a usage or sign-in report as a write target source; the action service refuses an F7-inactive plan whose targets a human did not enumerate, and pages at severity 2.
- **Held at L3 until answered.** F7-inactive needs a human approval until legal and the DPO answer P18 in writing. If the answer is "profiling", the design recommends removing F7-inactive rather than reclassifying Wall-E as high-risk; the owner chooses.

The cost is operational: reclaiming idle licences stays a human task. Two residuals remain. The bias sits in the report even when no action follows, and an inactive but employed person loses access until they ask for it back.

22.6 Operators as data subjects: the limits on monitoring

Operators and approvers are employees too. Their prompts sit in the conversation history and content logs, their identities in every audit row, and their competence and training records qualify them as named overseers (10 §4.6). An overseer without a training record leaves the operator group at the next stage transition: a consequence of a missing qualification, never of how the person has performed.

The self-grading sample. The automation-bias control of Chapter 20 is the platform's one deliberate measurement of individual judgement. Its limit: a fall below the threshold (*tbd*, Mo owner) opens a severity-3 review item, **never an automatic consequence for a person.**

The design has not resolved one tension. Mo publishes aggregates only, with a minimum cell size of 5 as an **Assumption:**, and by Mo's own rule an aggregate over a single surrogate is a person (Mo §4); a per-operator agreement metric is exactly that. Who may read it, and whether the works council sees it, belongs in the reader-set decision Mo's page holds open (M-3).

Reports that name people. Until legal classifies eve-advisor (P19, open), it names no human without the deterministic rule behind the finding (10 §3.3). A report about the administrator goes only to the second human, never to the person it concerns (Eve LLD §15). The chilling effect of monitoring administrators is named as a fundamental-rights risk, with no residual stated until P19 is answered.

22.7 Workers: information, consultation and the explanation path (P129)

When workers are told

P129 (proposed) moves worker information and consultation from Stage 3 to **before Stage 1 of any Tier W agent that acts on employee accounts**, and keeps it as a precondition of the super-admin grant (10 §4.10; HLD §0.4). The AI Act's workplace information duty binds high-risk systems only from 2027-12-02 but is adopted now; GDPR Art. 88 and national monitoring rules apply regardless; and a council told at Stage 3 would have been bypassed for two stages. Wall-E's decision register carries the new timing, but its prerequisites page still says the question blocks Stage 3 (Wall-E decision 8; prerequisite D7).

Which national labour and works-council law applies is *tbd*, because the operating site's country is not fixed (11 §11). Where that law requires consultation rather than information, the design keeps a consultation record, marked *Assumption:*.

The information pack, owned by HR and communications with the DPO and legal, explains the purpose, the caps, what Wall-E never does, what is logged and the explanation path. A separate employee notice, owned by the DPO, names Wall-E as an AI system acting on accounts, what it never decides, and a contact. Stage 1 does not open without the date of both and an existing explanation log.

What the works council is shown, and when it is told of incidents

The evidence register (Chapter 20) lists what an authority, an assessor or the works council is shown (10 §5); closest to employees are the worker pack, notice and explanation log, the fundamental-rights risk rows and the oversight roster. It does not say which rows the council receives, a choice to make with the council rather than for it.

When an incident touches employee data, communications and HR inform employees and the works council (07 §9.1). Where national law requires it (*Assumption:*), employee representatives take part in the monitoring aspects of the tabletop exercises and receive the post-incident review (07 §12.3). The clocks, including the GDPR 72-hour path with the DPO accountable, are Chapter 11's.

How an employee obtains an explanation

No decision on the platform is solely automated: suspension follows a human decision, and licence reclaim from active accounts a human target list. The Art. 86 path exists all the same. The employee asks HR, which obtains from the operator surface the frozen plan's rationale, pre-state, trigger and decision reference, redacted of other persons and the raw prompt, and answers within a number of business days still *tbd*. Every request is logged and counted in Mo's post-market monitoring loop; one unanswered past the deadline is a severity-3 finding.

22.8 The DPO's decisions and engagement points

The platform RACI shows the DPO as consulted for Tiers C to W and engaged before Stage 1 at Tier P (HLD §0.3). That understates the load: several DPO decisions gate the first Tier W write, not only the super-admin grant.

- **The retention ceiling (P13, open).** One number per data class, due before Stage 1 of any Tier W agent, and the trigger that locks the evidence stores (08 §5.1). It also settles conversation retention, 30 days as the interim *Assumption:*; the schedule is Chapter 12's.
- **P18, with legal.** The profiling answer of section 22.5.
- **The de-identified copy.** Whether graders may keep it for 90 days rather than 30, a request recorded but not assumed (Chapter 12).
- **The GDPR breach path (P101, proposed).** The DPO is accountable for the notification decision from Stage 1 of any Tier W agent (Chapter 11).

- **The DPIA, the records of processing** (section 22.2), the risk-register rows that touch employees, and the admission entry for processor-role agents (section 22.1).

22.9 Still open

- The explanation-request store has no row in the retention schedule. The evidence register keeps the log 400 days, but page 08 does not list it (register row 14, [12 §7](#)). Until it does, the store has no factory-set retention and no drift check.
- The explanation deadline and the country whose labour law applies are *tbd* (P141); the legal entity the employee notice must name is open (P23).
- The reader set for Mo's metrics, and so for the per-operator self-grading metric, is open (M-3).
- The HLD tier gate lists "the DPIA" among the super-admin preconditions, while Wall-E's setup gate asks only that it has started ([HLD §0.4](#); [Wall-E setup](#)). The DPO and the owner need to agree which it is.

Key decisions and what to read next

Register states on 2026-09-14:

- **Open:** P13 the DPO's retention ceiling; P18 whether F7 inactivity reclaim is profiling (DPO and legal); P19 the reporting path's class (legal); P23 the legal entity.
- **Proposed:** P134 the controller position and the processor-role register field; P126 the profiling boundary; P127 the oversight caps and the review-only self-grading; P125 the decision reference on band B writes; P129 worker information before Stage 1 and the explanation path; P101 the GDPR path; P106 the lock trigger; P52 and P113 conversation retention, both dependent on P13; P141 the legal register.
- **Open on the agent pages:** register row 14, including the missing explanation-request store; M-3 on Mo's page.

Read next: [11 §3](#), [10 §3.1.4](#) and [§4.10](#), [08 §5.2](#) and [07 §12](#); then Chapter 11, Monitoring, detection and incident response, for the breach clock; Chapter 12, Data, logging, retention and sovereignty, for store classes and sovereignty; and Chapter 21, TISAX, for the Data Protection module.

Part V — Delivery

Part V turns the design into a programme; nothing opens because it is drawn. Chapter 23 asks which people must exist, what each does and which duties one person may never combine. Chapter 24 asks in what order the platform opens, what must start on day one because it takes longest, and what it costs. Chapter 25 starts with what to do first, then walks the [143-row register](#) and every unresolved point across the five gates, asking which decision waits for whom.

23. Operating model

What you will understand by the end

This chapter answers the last risk theme of Chapter 3, The problem and its risks: staffing that makes two-person rules notional, where the second approval, the review or the page reaches the person who made the change.

By the end you will know the roles, which duties one person may never combine, how many distinct humans each stage needs and how that is checked, who runs each control per tier, what people must hold before the build, the hours, the detection desk, the training and the recurring calendar. Nothing here is staffed. The design of record is [HLD §0.3](#) and [TISAX page §7](#).

Who exists on 2026-09-13

One administrator: no security operations centre, no second super admin outside the administrator's own line, no security reviewer, no Eve owner, no engaged data protection officer (DPO), and no names supplied by the ISMS ([README](#), [maturity](#)). Platform owner, agent owner, deployer, operator, approver, grader, security reviewer, Eve's owner, Mo's owner and the recipient of Eve's pages are one person. Every "second person" in a control is today the first person again, and TISAX control 1.2.2 on separation of duties is the finding most likely to stop an assessment.

Under the operability principle (Chapter 4, The principles), a tier whose control needs a person who does not exist waits, so the gap shows as a closed tier, not a control nobody runs. Only Tiers C and R open with the people who exist; each gate's full contents are Chapter 24, Roadmap and cost.

The roles

The roles are defined in [HLD §0.3](#), with the Wall-E set's people list in [prerequisites §2](#). The ISMS records the names in the site's role register.

Inside the administration line. The *platform owner* owns the folder, factory, register, floors and baseline modules. One *agent owner* per agent owns its manifest, playbooks, register row and budget. The *deployer* runs the factory and the release pipeline. The *operator and approver* approves level-3 (L3) requests, pulls the halt and demote switches K0 and K1, and grades; from Tier W a *second operator* who is not the agent owner is required. The *Mo owner* runs Mo's CI and seeds the blind sample; from Tier W the *blind grader* never owns the playbooks graded.

Outside it. The *security reviewer* (Wall-E decision 37) reviews ladder raises, deny-policy and floor changes and Privileged Access Manager (PAM) approvals; at Tier P the reviewer signs the super-admin deviation and owns SIEM detection content with the managed detection partner. The *validator custodian* runs the recompute Mo cannot reach (Chapter 17, Mo, continuous improvement), from Tier W in the security reviewer's project. The *incident commander* leads severity 1 and talks to the DPO and the works council. The *detection desk* acknowledges pages and runs the detection catalogue.

The *second human super admin outside the Wall-E administration line* is an IT-security person who, at the grant, is also the *Eve owner*: owner of Eve's owner group and the witness organisation, required reviewer of Eve's configuration, member of no Wall-E group, parallel recipient of every severity 1 and 2 page, sole recipient of reports about the administrator's own actions, and second name on the rota for K5 and K6, the levers that suspend the robot and remove its Super Admin role. What this person does inside Eve's design is Chapter 16, Eve, the independent controller.

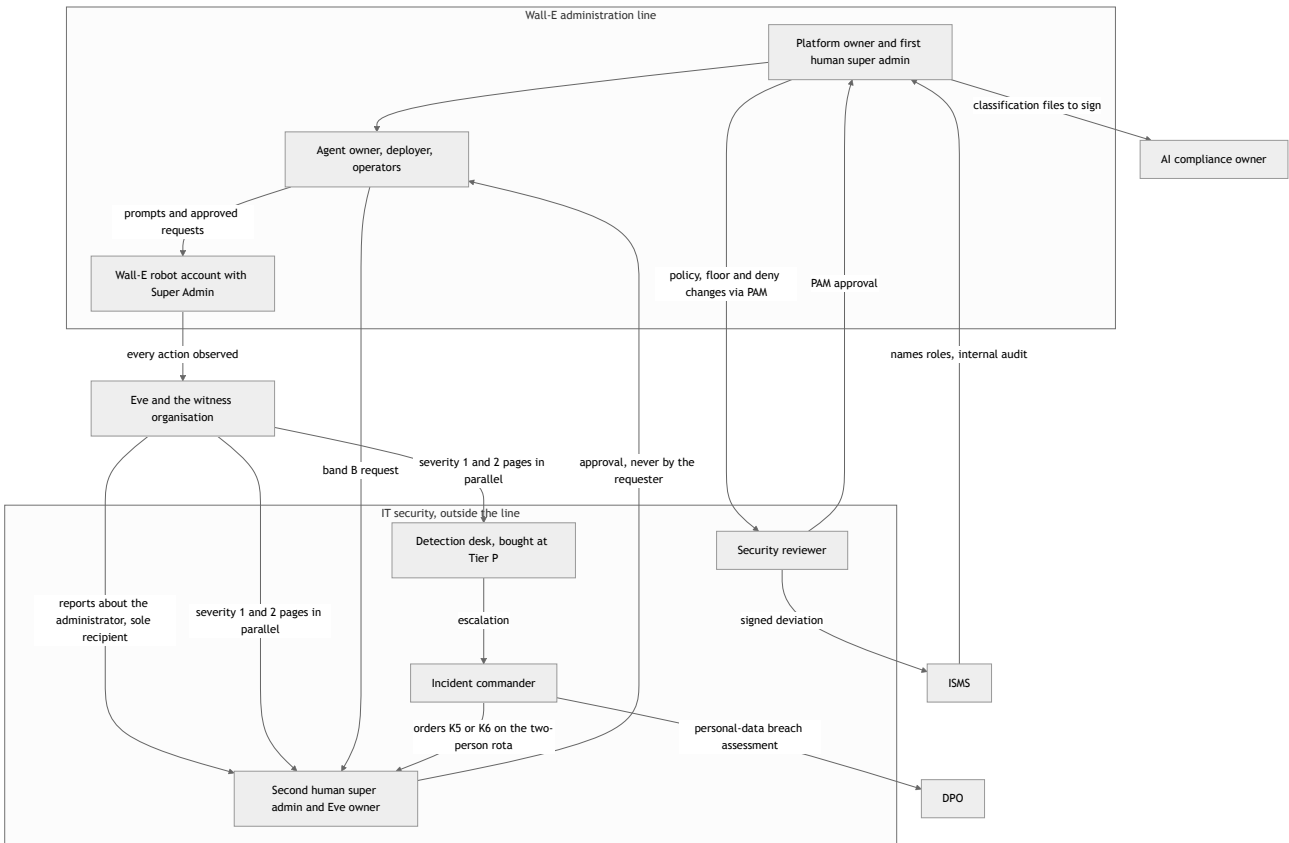
Consulted, then engaged. The *AI compliance owner* (P131, proposed), legal's designate and never the platform or an agent owner, signs classifications, files registrations and owns the serious-incident clock ([EU AI Act page §4.1](#)). The *DPO contact* owns the DPIA, records of processing and the retention ceiling. Both are consulted up to Tier W and engaged at Tier P: the AI compliance owner with a named deputy, the DPO before Stage 1.

What each tier adds

Tier	People added	What changes
C and R	nobody; at least one human super admin	the platform owner holds every role; security review is self-review, recorded as such
W	second operator; security reviewer from IT security; blind grader	a second reviewer on every credential-holder deploy; IT security commands incidents
P and P-SA	second human super admin outside the line as Eve owner; engaged DPO and AI compliance owner; bought desk	at least two human super admins, the robot never the recovery one; band B approved by a super admin other than the requester; an on-duty super admin to pull K5 and K6
X	AI-safety reviewer; independent review of the monitor	not open

Lines of authority and report

The people who build and run Wall-E form one line of authority with the robot beneath it; every check on that line is performed and received outside it.



Pages go in parallel to the desk and to a person outside the line, so owning a channel does not silence them ([monitoring page §8](#)). At Tier W the verifier owner is the platform owner until a second person exists, recorded as such.

Duties one person may never combine

The TISAX page's incompatibility matrix makes the roles countable (§7.1; P137, proposed): nobody approves, grades or reviews their own work, and nobody in the administration line controls the controller.

- The platform owner is never the IT security lead, security reviewer, AI compliance owner or second human, and at Tier P never the Eve owner or incident commander.
- An agent owner never approves its agent's requests, grades its playbooks or second-reviews its deploy; an operator never approves their own request.
- The Eve owner is never in the Wall-E line nor Mo's blind grader for Wall-E; the Mo owner is never Eve's second reviewer; neither the security reviewer nor the validator custodian runs Mo's CI.
- Both human super admins hold the role only on separate admin accounts with short sessions, and neither holds both keys of a robot.

Whoever prompted the robot never commands the incident about that prompt, and the agent owner never pulls K5 or K6 when the owner is the actor (monitoring page §9.1).

The minimum number of distinct humans

The matrix yields the fewest people per stage who fill the roles without a forbidden pair (§7.2; gate groups in register §3 and §4).

Stage or gate	Distinct humans	What the count makes true
Stage 0, Tier R	1, ISMS consulted	self-review recorded as such; PAM activation without approval, justification mandatory, recorded as the one-person mode
Stage 1, Tier W	3	a second operator who also grades; an IT-security reviewer who also second-reviews deploys and holds the validator
Super-admin grant, Tier P-SA	4 plus a 24x7 desk	the second human as Eve owner; incident commander from IT security; DPO engaged; a SIEM with round-the-clock acknowledgement contracted and its first heartbeat acknowledged, a grant precondition (HLD §0.4)
Stage 3, autonomous band A at level 4	4 and the desk already in place	a quarter of acknowledgement-time evidence from the desk
Second Tier W agent	3 plus grading capacity	P25's agents-per-grader number, open
Tier X	not open	an AI-safety reviewer

The grant precedes Wall-E's own Stage 0 (TISAX page §6.3; ladder), so the one- and three-person rows describe Tier R and Tier W agents and Wall-E never runs on fewer than four. **Assumption:** the security reviewer and the Eve owner may be one IT-security person at the first grant only as a dated ISMS exception, because the deviation's signer would then operate a control the deviation relies on; P137 calls five humans the clean state and four with that exception the floor, yet its worked assignment reaches four with the two roles apart, and no page says who the fifth is.

How the count is checked, and what failure does

A CI job checks every pair against group memberships and the roster on every merge and daily; a collision makes the admission gate refuse promotions above the stage where that pair is legal, and is a severity 2 finding to the ISMS. A role without a name recorded by the ISMS keeps its tier closed. An approval whose requester and approver are the same principal is void and severity 1 (§7.3).

After the grant, the second human is row 11 of the grant checklist: if the person leaves or joins a Wall-E group, that is severity 1 and the on-duty human super admin pulls K6 until the row is green (Chapter 21, TISAX). An uncovered rota period halts autonomous writes for every agent at Tier W or above whose verifier the absent person owns (monitoring page §9.2).

Who runs which control at each tier

The staffing view of the landing zone assigns each control per tier ([landing zone §1.4](#)):

- **Register row and publication gate:** the agent owner writes, the platform owner approves; the security reviewer joins at Tier W, the DPO at Tier P.
- **Factory run:** the platform owner runs both phases at Tier R; from Tier W the privileged phase needs the security reviewer's PAM approval, so making a credential holder's project is a two-person act from the first day.
- **Ladder raises and approvals:** from Tier W, the agent owner's pull request plus the second operator, the security reviewer above L3, and L3 approvals by the second operator; at Tier P, band B is never raised and a human super admin other than the requester approves.
- **Detection acknowledgement:** the owner at Tiers C and R, plus the security reviewer at Tier W, a bought 24x7 desk at Tier P.

The privileged tier's two-person rules, and which of them Google enforces, are Chapter 8, Identity, privileged access and the fleet kill switch.

The hours

These are the staffing numbers; Chapter 17 derives the grading figure ([HLD §0.3](#); [tier profile](#)).

Role or tier	Hours	From
Tier R steady state	about 0.5 hour a month	R
Second operator	about 2 hours a week	W
Security reviewer	about 2 hours a month	W
Blind grader, per Tier W agent	about 1 hour a week, not the playbook owner	W
Blind grader for Wall-E at S4 volume	at least 2 hours a week, indefinitely, plus a second grader who does not yet exist	Wall-E S4
Tier P steady state	about 3 hours a week, plus the bought desk and a second super admin on the rota	P

One Tier W agent needs roughly three and a half hours a week from people other than its owner. Grading grows with the fleet: at S4 the floor of five graded items a week binds in each of about eight live cells, and a missed week leaves cells not ready for promotion rather than thinning the sample ([Mo metrics §13.3](#)). The resulting Tier W cap (P25, open) is argued in Chapter 14, Scale and AGI readiness.

The detection desk by tier

A fifteen-minute target nobody meets is worse than an honest slow one ([HLD §0.3](#); mechanisms in Chapter 11, Monitoring, detection and incident response):

- **Tiers C and R:** Google-run. Security Command Center findings page the platform owner; the target is "next business morning".
- **Tier W:** central logging and absence alerts are added to what is watched (central logging exists before Tier R opens, [tier gate](#)); the owner and the security reviewer acknowledge, still next business morning.
- **Tier P:** bought. Google SecOps with a managed detection and response retainer, or the organisation's SOC (P10, open with IT security), and a paging service; escalation desk, then platform owner, then IT security. **Assumption:** severity 1 acknowledged within 15 minutes in business hours and 60 outside, severity 2 within 4 business hours, until the contract fixes them.
- **Tier X:** adds independent review of the monitor.

What people must hold before the build

From the Wall-E prerequisites (§3.1, §4.1), by who supplies them:

- **The platform owner** holds Workspace Super Admin on a separate admin account and Gemini Enterprise Admin on the tenant app, plus organisation, folder and billing roles, several now only for manual fallbacks.
- **IT security** supplies, by the grant, the second human super admin, who approves the assignment under multi-party approval and holds robot key B; by Wall-E's setup Phase 10, a security reviewer, a validator custodian and a re-bootstrap witness; and a second approver for Stage 4.
- **A second operator** is asked for at Phase 1; an empty value is recorded as a known risk.
- **The tenant** supplies Gmail-bearing licences for both robots and at least three sandbox accounts (five or six seats; the human admin accounts' and sandbox tenant's seats are *tbd*) and a Gemini Enterprise licence per operator. From Tier W each operator and approver needs a Chrome Enterprise Premium licence (P63, proposed; procurement *tbd*), with an IP-and-time access level until then.
- **Keys:** ten in total (four robot, two break-glass, two per human admin account), eight of them in the corporate safe ([identity page §8.3](#)). Custodians cross lines: robot key A with the platform owner, key B with the second human, swapped for Eve's robot. **Assumption:** a corporate password vault exists.

The data-protection question, works-council information and other lead-time items are Chapter 24.

Training

Each role has a one-page outline, delivered with the EU AI Act Art. 4 literacy measure so one record serves TISAX 2.1.3 and the Act, recorded in the evidence bucket and refreshed at every stage transition ([TISAX page §7.4](#)). Operators learn approval cards, severity 1, K0 and K1; the two human super admins K5, K6 and band B approvals; the incident commander runbooks RB-01 to RB-11 and the regulatory clocks.

A role holder without a completion record for the current stage does not count towards the minimum. The pages differ on who writes the content: the TISAX page names the platform owner; the [EU AI Act page §4.8](#) the AI compliance owner; both give the record to the ISMS.

The recurring calendar

Each item is owned elsewhere and gathered here for staffing ([drills](#); [tabletops](#); [assurance](#); [reviews](#); [restore drills](#)).

Cadence	Item	Run by
Monthly	K7 fleet kill drill, job path, in nonprod; K0 drill, with K1 from Tier W	platform owner; security reviewer witnesses and signs
Monthly	security operations metrics; seeded-fault suite; each operator's blind self-grading	security reviewer, desk-produced from Tier P; Mo owner; each operator
Quarterly	break-glass drill, alternating accounts; K7 by hand and through the SIEM; restore drill	platform owner; key custodians
Quarterly	tabletop until four clean Tier P quarters, then semi-annual; one before the first Tier W Stage 1 and one before the grant; the abused-robot-credential scenario at least yearly	IT security, never the platform owner
Quarterly	privilege review of privileged register rows against the signed roster; roster review of super admins; every register row within 90 days	security reviewer; platform owner
Quarterly	management review; deviation re-signed, also at each Wall-E stage transition	platform owner presents to IT security and the ISMS chair; security reviewer re-signs
Semi-annual	the service-denial kill lever in production at Tier R	platform owner

Cadence	Item	Run by
Annual	penetration test, plus gate tests before the first Tier W Stage 1 and the grant; internal audit; management review with the DPO; supplier review and exit rehearsal	IT security; the ISMS's auditor; ISMS
Each stage transition	training refresh	ISMS

A missed K7 drill is a severity 2 finding that freezes every raise; two quarters without a management review stop the ladder raising. One cadence differs between pages: the staffing view drills K5 and K6 quarterly at Tier P ([landing zone §1.4](#)), while grant checklist row 7 requires a K6 drill record younger than 30 days ([TISAX page §6.3](#)).

When "the four owner groups are one person" expires

Project-per-agent (Chapter 7, Landing zone and the tier model) gives the Gemini, Wall-E, Eve and Mo projects four owner groups, notional while one person is in all of them ([topology §1.4](#)). The design records that as a state that expires on the super-admin grant date ([tier gate](#)).

On that day the gate checks that Eve's owner is in no Wall-E group, that the super-admin roster holds exactly the two human admin accounts and `walle@`, and that the K5/K6 rota in the witness names two people. It does not require four people for four groups; it requires the group owning the controller to sit outside the line it controls, kept so by the daily separation check.

Key decisions and what to read next

States on 2026-09-14. Unsolved: no role but the platform owner's has a name, the fifth human is unnamed, and the Tier X reviewer exists nowhere.

- **Decided:** P33, Wall-E holds Super Admin, which makes the second human a precondition; deviation signatures pending.
- **Proposed:** P137 separation of duties as a counted minimum; P131 the AI compliance owner; P68 the roster; P69 break-glass and custody; P98 the reporting path; P99 on-call and targets; P102 tabletops; P139 assurance cadence; P63 access levels and licences; P127 overseers and self-grading.
- **Open:** P10 the SIEM and desk; P14 the witness organisation the second human administers; P25 the grading cap; P24 for operators; P13 the retention ceiling the DPO owns.

Read next: [HLD §0.3](#) and [§0.4](#); [TISAX page §7](#); [landing zone §1.4](#); [monitoring page §9](#); [Wall-E prerequisites §2](#). Then Chapter 24, Roadmap and cost, for when these people are needed, and Chapter 25, Decisions awaiting the owner, for whom to ask.

24. Roadmap and cost

What you will understand by the end

The platform does not open on a date. It opens gate by gate, each green only when its decisions, people, bought services and spikes exist. By the end you will know:

- what must exist, be bought and be hired before each tier opens, and why the super-admin grant is a gate with its own checklist;
- how the register's five gate groups form the roadmap, and which are red on 2026-09-14;
- what can start with the one administrator who exists, and what must start on day one;
- the builder's order, the first spikes, and what a failed spike changes;
- the minimum durations of the three agents' stages, and the edits their designs still owe the platform;
- what the work costs by driver and payer, and what nobody has priced yet.

Chapter 23, Operating model, says who the people are; Chapter 25, Decisions awaiting the owner, says who decides each open row.

Where the programme starts

On 2026-09-13 nothing is built: no platform folder, factory run, gateway, security monitoring service, witness organisation or robot with Super Admin, and no spike has run. The Google Cloud project behind the Gemini Enterprise app exists and is to be imported. The organisation is the one administrator described in Chapter 23, Operating model ([maturity](#)).

The tier gate

Each tier is a lettered folder with its own mandatory controls (Chapter 7, Landing zone and the tier model). The tier gate adds the decisions, purchases and people the organisation must supply before a tier opens ([tier gate](#)).

Tier C, classical agents in the Gemini Enterprise app. It opens when the register exists and the tenant app reaches its baseline at GE-14, the last step of the app's runbook. The licences exist. The one purchase is Security Command Center Premium at organisation level, whose funding and ownership IT security has not decided (P11, open; Assumption: a platform budget line until then). Nobody new is needed.

Tier R, read-tool agents in their own projects. It opens when the factory, the folder baseline, central logging and the shared registry exist, buying nothing more and needing nobody new.

Tier W, agents that write to a system of record. It needs the autonomy contract, the platform verifier, a validator custodian, the nonprod folder and one restore drill. If the agent acts on employee accounts, the works council is informed before its Stage 1 (P129, proposed). The Binary Authorization pipeline costs build time, not licences. It adds a second operator, a part-time security reviewer and a blind grader (Chapter 23), and device-posture licences for operators (P63).

Tier P and the super-admin singleton P-SA. Everything in Tier W, plus every precondition of the super-admin grant. The purchases are Google SecOps in the EU or the organisation's own SIEM, a managed detection and response retainer covering the super-admin detection set, a paging service and hardware keys. The people are the second human super admin as Eve's owner, an engaged DPO and an incident commander from IT security.

Tier X, AGI-class agents. Not open. Of the six conditions in Chapter 14, Scale and AGI readiness, one is met on 2026-09-13 (the sandbox stage) and five are not; HLD §0.4 counts four unmet and §11.5 five, a difference Chapter 14 records. Opening it means buying the GKE Agent Sandbox tier and a second model family for advisory monitors, and creating an AI-safety reviewer role.

The cost of the gate is speed: a sponsor who funds the build but not the people gets a read-only platform.

The super-admin grant is a gate, not a phase

The day walle@ receives Super Admin (P33, decided) has its own checklist: thirteen compensations, a penetration test, the DPIA started, works-council information given, a crisis tabletop and witnessed custody of the hardware keys ([checklist](#)). The grant happens on the day the last row turns green, and the runbook step that makes it refuses while any row is red; the state "the four owner groups are one person" expires that day. A row turning red after the grant is Chapter 21, TISAX.

The register's gate groups are the roadmap

The register holds 143 decisions, grouped by the gate each blocks, in gate order ([register in one screen](#)). A gate is green when every row in its group is decided, closed, proposed or a passed spike; one open row keeps it red ([how the register works](#)).

Gate group	What turns on when it is green	Rows keeping it red on 2026-09-14
Before the folder exists	the platform folder, the factory's first run, Tier C, Tier R	open P5, P11, P21, P31; spikes P4, P8 via P61, whose venue before the folder exists is unsettled
Before any Tier W agent writes	Tier W and the first write of the first writing agent	open P13, P22, P25, P24 for operators; spikes P3, P57
Before the super-admin grant	Tier P and the credential on walle@	open P7, P10, P14, P29; P33's deviation signatures
Before Wall-E's Stage 1 and later stages	Wall-E's first super-admin write; F5 and F7 above L3; eve-advisor	open P17, P18, P19; P28's signature
Later	the TISAX assessment order, the perimeter backstop, Tier X	open P12, P23, P26, P32; spike P6 via P57

A decision that blocks two gates sits in the earliest, its later effect noted where it bites: P3's first spike also blocks the grant, and P32's Article 25 position blocks Stage 1. Even the first gate is red on four decisions held by four parties: P5 (Agent Identity on Cloud Run at general availability) waits on Google, P11 on IT security, P21 (the threat taxonomy for detection coverage) on a security reviewer nobody is (so the platform owner holds it as self-review), and P31 on the owner alone. Several of these rows already carry a working fallback, and whether such a row counts against its gate is the owner's first decision (Chapter 25, Decisions awaiting the owner).

What can start with the people who exist

Tiers C and R are the only tiers the existing organisation can staff, and the build of record opens them in that order: Tier R first, Tier C after it (SD-13) ([blocks](#)). The first act of the programme is not a platform step but the toil baseline, TB-1.1, which cannot be taken later; day one is files 01 to 05 (conventions, the toil baseline, decisions and people, purchases by lead time, the read-only Gemini Enterprise inventory). Then the organisation (06 to 08, the witness organisation in parallel under IT security), Tier R (09 to 18: folders and SCC, core projects, keys, PAM, policies, logging, paging, the register, the module equivalents and the Tier R record, then the floor, spikes and K7), and Tier C (19 and 20): the tenant app baseline, GE-0 to GE-14, from importing the app's project to staging the tenant egress gateway ([runbook](#)), which needs the folder, the core projects and the module equivalents of 17, though no agent project. The set's README and the app's runbook still state the baseline's dependence on the factory differently (Chapter 25).

The earliest dates, assuming one platform owner and people available when named, are the setup set's ([critical path](#)); every date is an earliest date, not a commitment:

Milestone	Record	Earliest
Decisions and people signed	03	2026-09-29 to 2026-10-27

Milestone	Record	Earliest
Toil baseline complete	TOIL_BASELINE_FILE (02)	four ISO weeks after the first Monday after the HR works-council answer, whose date is <i>tbd</i>
Tier R open	TIER_R_RECORD (17)	2026-11-10 to 2026-12-08
Tier C open	TIER_C_RECORD (20)	2026-12-08 to 2027-01-19
Eve-H live	EVE_H_LIVE_RECORD (28)	2026-12-22 to 2027-01-19, <i>tbd</i> on Eve code
Pre-grant Wall-E built	PENTEST_RECORD (37)	2027-02-02 to 2027-03-16, <i>tbd</i> on Wall-E code
The grant	GRANT_RECORD (38)	<i>tbd</i> ; not before 2027-03
Stage 0	STAGE0_RECORD (39)	one to two weeks after the grant
Mo's first merge	FIRST_MERGE_RECORD (40)	13 to 18 weeks after Stage 0

That is six to seven months to Stage 0. Two shorter sets exist beside the full build and hand over to it with nothing torn down. The proof of value ([pov](#)) runs Tiers C, R and W on the production tenant with a doer that holds no Workspace admin role and no super admin to any agent, Eve over the human super admins: 20 to 26 person-days of procedure and 40 to 64 engineer-days of code, 16 to 20 weeks elapsed with a dedicated engineer, 26 to 34 weeks if one person does both. The three-day build ([3-day](#)) is two people and six person-days on three consecutive days, four projects, Eve polling the admin audit log through the Reports API before any doer exists, a doer holding one organisational-unit-scoped privilege over four synthetic accounts, and Mo's scorecard: a demonstration, not compliance evidence, which hands over to the proof of value.

Day-one lead-time items

Some items gate only later tiers but take longest to obtain, so they start now, in the setup set's purchase order, longest lead time first ([purchases and lead times](#)):

- **The data-protection question and works-council information**, the longest item in the plan. The DPO's retention ceiling (P13, open) blocks the first Tier W write and the evidence lock. The prerequisites page still dates the question to Stage 3; Wall-E's decision 8 carries the platform's change (worker information before Stage 1, DPO engagement before the grant, P129), and no register row names the stale line.
- **The witness organisation**, run by IT security (P14, open; Assumption: Cloud Identity Free; Chapter 16, Eve, the independent controller).
- **SIEM and managed detection procurement** with 24x7 acknowledgement (P10, open).
- **Hardware keys and custodians**, and **five or six Gmail-bearing seats**, a purchase if none are free.
- **Organisation-level role grants and policy exceptions**, approved by the organisation administrator.
- **The approval surface**, the IAP-fronted page that [Wall-E's identity page §5.3](#) takes as its position (Chapter 15): real engineering, blocking any family above L2 and Stage 1. That page also accepts a Chat app, and the prerequisites page still lists both.
- **Quotes for the unpriced services**: SCC Premium, SecOps with the retainer and the penetration test from IT security, and Chrome Enterprise Premium licences through procurement (P63).

Mo adds one that cannot be recovered later: four weeks of measured toil for the top three admin tasks before Wall-E's first phase, without which the Stage 1 stop-or-continue review has no denominator ([Mo stage table](#)).

The builder's order

The build order is the setup set's block order, platform, then Mo and Eve, then Wall-E, driven by what cannot be changed after creation ([blocks](#)):

1. **Day one (01 to 05)**. The toil baseline first, TB-1.1 before any other step, because its recording weeks cannot be recovered; then conventions, decisions, people and the platform repository, purchases by lead time, the read-only Gemini Enterprise inventory.

2. **The organisation (06 to 08).** Roster, break-glass and the removal of the organisation-creation defaults, then billing; the witness organisation in parallel, performed by IT security.
3. **Tier R (09 to 18).** Folders and SCC, the core projects, the keys (every key is HSM by folder policy, Chapter 13, Supply chain, keys and recovery), PAM, which withdraws the bootstrap exception, the deny policy and the Principal Access Boundary before the first project inherits (Chapter 8, Identity, privileged access and the fleet kill switch), central logging and its buckets, whose per-bucket CMEK is set only at creation and whose retention lock cannot be shortened and waits for the DPO's ceiling (Chapter 12, Data, logging, retention and sovereignty), paging, the register, the module equivalents and the Tier R record, then the floor, the spikes and K7.
4. **Tier C (19 and 20),** after Tier R (SD-13): the tenant app to baseline and its gateway, in parallel with 21 to 29, closed before 35.
5. **The sandbox tenant (21),** before Eve, because nonprod Eve and the Wall-E twin need a tenant.
6. **Mo and Eve (22 to 29),** one block run in parallel; Eve's first half never waits on Mo and ends with `EVE_H_LIVE_RECORD`.
7. **Wall-E (30 to 39),** starting only on `EVE_H_LIVE_RECORD`: Workspace side, project and data plane, consents, action services and approval surfaces, the identity spike and Model Armor, engine and gateways, the joins to Eve and Mo, the sandbox rehearsal and penetration test, the two-person gate and grant, Stage 0.
8. **After Stage 0 (40 and 41):** Mo's first merged proposal, Eve S3 and S4; and the standing gate, drill and evidence file (42), whose evidence half runs as soon as central logging exists.

Two spikes do not fit this order. P4's engine half (custom constraint CC-8) and P8's principal-set spelling (via P61) sit in the first gate group, and P8's spelling must be proven on a throwaway engine before the folder deny policy is applied, so they cannot wait for the spikes of 18. The pages define a spike as a test on a throwaway resource in nonprod but not where that engine lives before the folder and factory exist ([P8 and P61](#); [custom constraints](#)): a throwaway project outside the platform folder, or the folder created at step 3 with the deny policy held back and CC-8 in dry run until both pass. Until the platform owner records one, this is an open sequencing question (Chapter 25), and the diagram shows the two spikes on their own path.

The first spikes: what the design holds until each passes

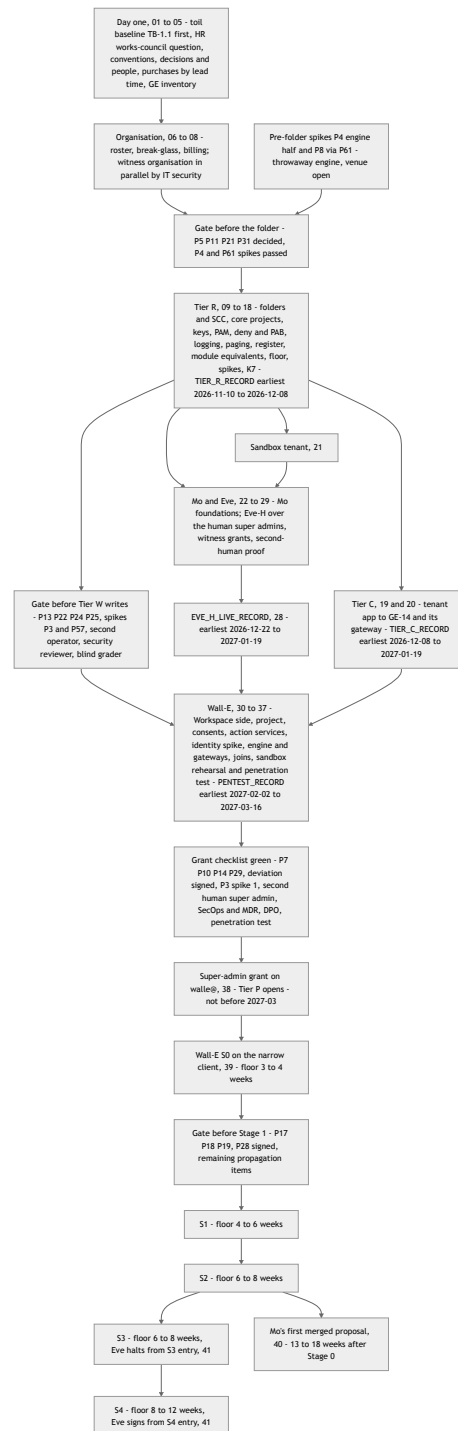
Spike	Position held until it passes	If it fails
P3 spike 1, engine reach to an internal-ingress action service through an internal load balancer	IAM-only invoke is the enforced boundary, open ingress is detected, the folder rule P90 is written but not applied, and perimeter model (b) waits	Retry through a Private Service Connect endpoint; if only the private-ranges gateway configuration works, the factory uses it and the perimeter backstop is unreachable for that tier. The grant checklist requires spike 1 passed
P3 spike 2, VPC Service Controls over a gateway-bound engine	No perimeter backstop, model (a)	If the access policy fails under the connectivity template, hostname control moves to VPC firewall and Cloud DNS. If the engine cannot work inside a perimeter, (a) is recorded as unavailable
P4, the <code>identityType</code> custom constraint on engines	Cloud Run half answered (custom constraint CC-3); the engine half of D2 stays a CI check graded detection, re-run at each factory release	Detection stays the grade
P42 sub-spikes	CC-6, allow-policy rules: the drift job detects standing owners and foreign members. CC-8 is P4's engine half. CC-11, sinks excluding the robot: Eve's completeness metric detects it	CC-6 dropped if it fires on PAM's own grant, detection kept; if agent identities fall outside the organisation principal set, the rule names the trust domain, syntax <i>tbd</i>
P57, <code>gemini-egress</code> bound to the tenant app	Throwaway-app spike, then 30 days in dry run, enforced before the first Tier W publication	The connector allow-list plus the per-engine query grant stand as a dated compensating control, re-tested at each Agent Gateway release

Spike	Position held until it passes	If it fails
P61 with P8, the agent principal-set spelling in a deny policy	Names verified; the spelling stays an Assumption: , the factory emits one spelling for allow and deny and another for PAB, and kill lever KF-2 counts only as a copy of KF-1	The factory template is corrected from the spike's evidence, never from a page

Sources for the table: [perimeter decision](#), [the folder rule and spike protocols](#), [custom constraints](#), [tenant egress gateway](#), [principal populations](#). The perimeter models themselves are Chapter 10, Agent Gateway, Model Armor and the perimeter.

The pattern is deliberate: apart from P3's first spike, which the grant needs, a failed spike lowers a control's grade from enforcement to detection rather than stopping the programme.

The opening sequence



Tier C and the Mo and Eve block run in parallel after Tier R; Wall-E starts only on `EVE_H_LIVE_RECORD`, and Tier C closes before Wall-E's engine registration (35) and before the grant (38), so the grant waits for whichever finishes later.

The super-admin grant sequence

The order is fixed ([the grant](#)): Eve's observe-and-report layer live and drilled, then the grant, then Wall-E's Stage 0 on the narrow OAuth client with every write family at L1, then Stage 1. Before the grant the robot account exists, licensed and hardened, but holds no admin role and reads nothing, since no interim read role exists.

The Eve layer needed first is the one that **reports** misbehaviour, with seven checklist rows ending in an end-to-end drill on the sandbox tenant ([Eve's rows](#); Chapter 16). Eve's gate layer, which approves plans, comes much later: the grant needs detection, while approval is earned on evidence.

Stage floors across the three agents

Stage durations are floors, not plans: a stage lasts at least this long and ends only when its exit criteria are met ([stage overview](#)). The floors, not build estimates, set the calendar, because they wait for evidence. What each stage permits is Chapters 15, 16 and 17.

Wall-E. S0 3–4 weeks, S1 4–6, S2 6–8, S3 6–8, S4 8–12, S5 ongoing: S5 at least 27 to 38 weeks after S0 begins, and only if every exit criterion is met first time. The grant gate comes before S0, and the setup runbook puts it at weeks to months.

Eve. Eve declares what exists inside Wall-E's stages ([Eve stage table](#)). The observe-and-report layer precedes the grant; halting and demoting go live at S3 entry, which runs at least 30 days and exits only on catching all twelve seeded faults; signing arrives at S4 entry.

Mo. Measurement arrives before judgement ([Mo stage table](#)): S1 ends in a stop-or-continue review on value, and at S4 the blind sample becomes the only input to L4 and L5 precision. Mo's staging page places its Eve reads between Mo's S1 and S2 as an `Assumption:`, while [the grant order](#) puts Eve's layer before Wall-E's Stage 0, to which Mo's stages are keyed; the calendar position is unresolved. Mo's trust never rises with age.

The propagation stage

The Wall-E, Eve and Mo designs were written for a robot that never holds Super Admin. The platform design lists 26 edits they must carry ([HLD §18](#)). P143 (proposed) gives each an owner and a gate ([before the grant](#)):

- **Wall-E items 1–10**, owned by Wall-E's agent owner, with the security reviewer signing items 1–4. Items 1–5 (identity, bands, ladder rows, guardrails) gate the grant; items 6–10 gate Stage 1.
- **Eve items 11–18**, owned by the Eve owner. Items 11–16 gate the grant, since they are the observe-and-report layer and the witness. Items 17–18 gate Stage 1.
- **Mo items 19–24**, owned by the Mo owner, gate Stage 1.
- **Shared pages, items 25–26**, owned by the platform owner, gate the factory's first run unless an item says otherwise.

An item closes with a dated pointer line citing the platform row; the reconciliation job reports any item still open when its gate is evaluated. The README records the stage as not yet run, although some pages already carry their item. The stage also closes register rows 10–14 ([values that differ](#); Chapter 25). The edits are small, but they gate the grant and Stage 1, and today every owner is the same person.

Which runbook creates what, and the effort shape

A grant on a resource is made by that resource's project runbook ([which runbook](#)). Since 2026-09-13 creating a project is a factory call, credential-path bindings go through the factory's privileged phase under PAM (P142), and Wall-E's setup script is a helper only, under decision SD-37: the manual steps in setup files 30 to 39 are canonical, a subcommand may replace a manual step only after its listed defects are fixed and its self-test has a live read-only mode, and until then every step that cites the script is BLOCKED for the script and gives the manual commands ([what the set replaces](#)). Eve's build gains a pre-grant block for the observe-and-report layer (setup 23 to 28); IT security builds the witness (08).

The effort is lopsided ([file table](#)). The setup set takes its hands-on and elapsed figures from each file's own estimate where the file carries one, because the plan's figures had under-booked six of them, all in the direction of other people's diaries; the superseded SETUP.md §0.4 figures are kept only where a file quotes them, each

recording what that phase did not include (the Workspace side was costed at 2 h and included neither the repository, nor the roster entry, nor the witnessed custody; it is about 3 h hands-on and a day elapsed).
Assumption: summing §3.2's rows, Wall-E's files 30 to 39 are about sixteen hands-on days, of which the sandbox rehearsal and penetration test (37) are about 31 hours over nine sittings and Stage 0 (39) about 25 hours over eight, with about four weeks elapsed on the rehearsal and weeks to months on the gate; the code Wall-E deploys is weeks of engineering on top. The whole build is 85 to 90 person-days hands-on, thirteen appointments and thirteen purchase rows, six to seven months to Stage 0 and nine to twelve months to Mo's first merged proposal ([against the full build](#)). None of this is the critical path: the blocking decisions take days to weeks of other people's time and the grant gate weeks to months, so programme effort goes first into decisions, purchases and people.

Cost

Cost classes

No price is quoted: pricing pages were not read, and every amount is *tbd*. The design names driver and payer ([cost classes](#)):

Cost	Driver	Paid by	From tier
SCC Premium	organisation-wide, all projects	IT security (Assumption: platform line until then)	C
Central log ingestion and locked retention	Workspace audit volume plus Data Access logs, the largest line	platform	R
Model Armor	requests screened per project	agent budget	R
Chrome Enterprise Premium licences (P63)	one per operator and approver, for device-posture access levels; an IP-and-time level until bought	platform	W
Google SecOps with managed detection	events per day, retention months, retainer	IT security	P
Workspace licence per Tier P agent	one licensed user each, rare by policy	agent owner's cost centre	P
Witness organisation	one tenant, project, bucket, dataset, channels, two hardware keys	IT security	P
Human hours	the roles of Chapter 23	—	every tier

Log ingestion cannot be cut by cutting evidence: reconciliation needs Google's record of organisation-wide admin activity, not only the robot's. The binding cost is human hours.

The agents' own estimates

All are **Assumption:**, to be confirmed against the first billing cycle.

- **Wall-E at Stage 0:** infrastructure in the low tens of euros a month, model spend below that; a runtime instance kept warm around the clock is the easiest waste ([Wall-E cost](#)).
- **Eve:** 36–45 engineer-days, eight to ten weeks with Wall-E's side of the contract; under €50 a month on Google Cloud plus one Workspace licence; under half an hour a week of human time in steady state ([Eve cost](#)).
- **Mo:** 24–37 person-days; €25–60 a month billed to Mo's own project; at least two hours a week of blind grading at Stage 4 volume from a named human who is not the playbook owner ([Mo cost](#)).

Eve's own conclusion applies to the whole ladder: L3 with human approval is a legitimate permanent end state, and the gate layer should not be funded until a promotion can state in numbers how much approval work it removes.

What is not yet priced

Line	What pricing it needs	Priced before
Eve's observe-and-report layer	build days and run cost of the all-stream layer	the super-admin grant
The Reports API poll and the wider sink	ingestion volume over six streams	the super-admin grant
The witness organisation	edition, billing linkage (P14)	the super-admin grant
eve-advisor and its model	a model pin and a class (P19)	its build
Mo's Eve remit	days for the Eve quality pack, scorecard and coverage map, outside the 24–37	Wall-E's Stage 1
Every per-tier budget amount (P31)	an owner for the numbers; the budget mechanism already exists	Tier R, in the first gate group

Nor is any cost-class line priced, and each needs a named person to obtain a figure:

Line	Who obtains the price	Priced before
SCC Premium at organisation level	IT security (P11)	Tier C
Central log ingestion and locked retention	platform owner, since the platform pays	Tier R
Chrome Enterprise Premium licences (P63)	procurement	Tier W
The penetration test, scoped then full	IT security, which buys the engagement	the first Tier W Stage 1 (scoped); the grant (full)
Google SecOps with the managed detection retainer, or the organisation's SIEM (P10)	IT security	the super-admin grant
The paging service (P99)	the incident commander role in IT security, with the platform owner	Tier W for the channel; the grant for the 24x7 line
Hardware keys, ten in total	procurement	Wall-E's Phase 3, before the grant
The sandbox tenant's licences	platform owner; the seat count is <i>tbd</i>	Tier W on the TISAX page; before the grant on Wall-E's prerequisites page

Sources: [Eve's unpriced lines](#), [budgets per tier](#), [before the folder exists](#), [what does not yet exist](#), [on-call tool](#), [purchases and lead times](#). P31 is the sharpest: the factory writes a budget per project and quota alerts fire on numbers that remain guesses.

The recurring cost of project-per-agent

Why each agent has its own project is Chapter 7. Each carries its own budget, IAM policy, API list and owner group, and every crossing between projects is an explicit grant and a drift-job row ([topology cost](#)). The factory makes this a register row per agent rather than a runbook, but the volume remains, checked daily. BigQuery bills the querying project, so each agent's analysis cost lands on its own line.

Key decisions and what to read next

States on 2026-09-14:

- **Decided:** P33, Wall-E holds Super Admin, deviation signatures pending.
- **Proposed:** P1, the tier model and the tier gate; P39, the budget mechanism; P63, device-posture access levels; P90, the ingress folder rule, applied the day P3's first spike passes; P129, works-council information before Stage 1; P137, the staffing count; P143, the propagation stage.
- **Open:** P5, P11, P21 and P31 hold the first gate red; P13, P22, P24 for operators and P25 the second; P7, P10, P14 and P29 the grant.
- **Spike:** P3, P4, P6 via P57 and P8 via P61; P42 carries three sub-spikes.

- **Page disagreements and open sequencing:** register rows 10–14 are open until the propagation stage runs. The Tier C baseline's dependence on the factory is stated differently in the set's README and the app's runbook; Mo's calendar position for its Eve reads differs from the grant order; where the P4 and P61 spikes run before the folder exists is unsettled. All three are in Chapter 25's list of unresolved points.

Read next: [the tier gate](#), [the register's gate groups](#), [the grant checklist](#), [Wall-E's stages](#), [the propagation stage](#), [the setup set's order](#) and [purchases and lead times](#). Chapter 25, Decisions awaiting the owner, names who must answer each open row.

25. Decisions awaiting the owner

What you will understand by the end

Nothing on the platform is built, and beyond the first two tiers nothing can be until a few people answer a few questions. By the end you will know what to do first, how a platform decision is made and recorded, which decisions are the owner's and which wait for IT security, legal, the data protection officer (DPO), the information security management system (ISMS) or a test against Google's products, every unresolved point the brief raises, and every open row with who must act.

The register of record is [page 12](#); every state below is as of 2026-09-14. Gate order and cost are Chapter 24, Roadmap and cost; the roles are Chapter 23, Operating model.

First actions

The design is almost wholly proposed; a handful of answers holds the first gate red, and mostly other people's lead time holds the later ones. The owner's own answers come first, because some change what the requests must say, and every request goes out in the same month, because the longest sets the calendar.

What the owner does alone this month

1. **Record the gate-counting rule.** Write down how an open row with a recorded fallback counts towards its gate (see "Rows that fit the gate rule awkwardly" below). Read literally, the rule keeps the first, second and grant gates red for reasons nobody can act on, so every other schedule waits on this answer. It has no register row yet; a new row would take P144.
2. **Read the tenant's editions in the Admin console.** The Workspace edition decides whether the F1 feed exists, whether multi-party approval (P66) is available and which identity streams reach Google Cloud, which makes it a Stage 0 precondition. The Gemini Enterprise edition decides whether conversation retention can change from its 60-day default at step GE-6 (Chapter 8; Chapter 11; Chapter 12).
3. **Set P31**, the quota and per-tier budget amounts, or adopt the **Assumption**: numbers in writing.
4. **Choose P22**, the git host and the audit of admin bypasses, which Tier W needs.
5. **Start Mo's toil baseline**: four weeks of measured toil for the top three admin tasks plus monthly operating hours, before Wall-E's first phase; it cannot be reconstructed once Wall-E runs (Chapter 17, Mo, continuous improvement).
6. **Decide where the P4 and P61 spikes run** before the folder exists (Chapter 24).

The requests to send, by recipient

Recipient	What to ask for	Lead time recorded	What it unblocks
DPO	P13, the retention floor and ceiling; P18 with legal; start the DPIA; plan the works-council information with the owner (P129)	the longest item in the plan	the evidence lock and the first Tier W write; F7 above L3; the grant
IT security	P10, the SIEM and managed detection partner; P11, SCC Premium funding; P14, the witness organisation; name the second human super admin and the security reviewer; quotes for SCC Premium, SecOps with the retainer and the penetration test	weeks to months, much of it bought or hired	Tier C; Tier W's reviewer; the grant
Legal	P23, the legal entity; P28, Wall-E's intended purpose, signed with the owner; P19, the class of eve-advisor ; designate the AI compliance owner (P131)	not recorded	Wall-E's first write; eve-advisor ; the grant
ISMS	role names under P137; confirm P133; enter P33's deviation; rule in writing on self-review at Tiers C and R; request and file Google's TISAX assessment result share	not recorded	Tier W; the grant; the assessment order

Recipient	What to ask for	Lead time recorded	What it unblocks
Google	P7, whether Context-Aware Access binds super admins and API tokens; P32, per-service TISAX coverage and a written Art. 25 position; P5, Agent Identity on Cloud Run at general availability, re-read each factory release	not recorded	the grade of Context-Aware Access; Wall-E's Stage 1; Tier R prod without exceptions
Procurement	Chrome Enterprise Premium licences (P63); ten hardware keys; five or six Gmail-bearing seats if none are free	procurement	Tier W access levels; Wall-E's Phase 3

The first spikes

The platform owner runs P4's engine half and P8's spelling (via P61) first, on a throwaway engine whose location is action 6 above. After the first factory run, the first nonprod project runs P3's two spikes with the security reviewer, P42's CC-6 and CC-11 sub-spikes, and P57's throwaway-app spike with the Gemini Enterprise admin, ahead of its 30-day dry run. Chapter 24 gives the order and the position held until each passes.

How a decision is made and recorded

One sequence, five states

Every platform decision has an id in one sequence, P1 to P143: P1–P34 from the high-level design (HLD), P35–P141 from the ten detailed pages in page order, then P142 and P143. Each row names its owner, the gate it blocks and where the reasoning lives. To be admitted, a row's "why it matters" must name one thing that cannot be built, verified or defended while it is open; anything else is a preference and stays out.

A row is in one of five states (§1):

- **decided:** the named owner decided, on a stated date.
- **closed:** a later row or a verified fact answered it; the row stays so the closing reference is not lost.
- **proposed:** a detailed page proposed a value, which stands, with the factory, validator and runbooks written to it, until the named owner overturns it in writing.
- **open:** nobody has decided, and no page proposes anything beyond the HLD's recommendation.
- **spike:** a test on a throwaway resource in nonprod decides it, against pass criteria on the recording page.

"Proposed" lets the design move without pretending anything is signed. The price is that silence counts as consent: an owner who never reads a proposed row has accepted it. That is deliberate, and it is why this chapter names the owners.

Who changes a row, and how a gate closes

Only a row's owner changes it, by a dated pull request on the register page; once its gate has passed, a new row supersedes it. Loosening a fleet default (P77) needs the security reviewer's signature. New ids start at P144 and are never reused. No program answers a row: raising a level, widening a scope and answering a decision are human acts, recorded by hand.

Rows are grouped by the gate they block, in gate order: §2 before the folder exists, §3 before any Tier W agent writes, §4 before the super-admin grant, §5 before Wall-E's Stage 1 and later stages, §6 later. A row that blocks two gates sits in the earlier. A gate is green when every row in its group is decided, closed, proposed or a passed spike; one open row or unpassed spike keeps it red. The admission gate reads this state, so an unanswered decision shows up as a refused register row for an agent.

Rows that fit the gate rule awkwardly

Six open rows either cannot close when their gate is evaluated or already carry a position the design works to. The register resolves none of them:

- **P31** (quota and budget amounts), §2: work proceeds on **Assumption:** numbers.
- **P5** (Agent Identity on Cloud Run in production), §2: work proceeds on dated service-account exceptions, and only Google can close it.
- **P24** (a workforce pool for operators), §3: needed only if non-Google operators ever exist, so nothing prompts an answer.
- **P25** (the Tier W cap per grader), §3: measured after the first Tier W agent's first quarter, and it blocks the second Tier W agent, not the first write.
- **P7** (Context-Aware Access on the robot), §4: waits on Google, yet the design already counts the control as detection plus friction, never as part of the safety case.
- **P10** (the SIEM), §4: P92 has the factory provision a default if P10 is unanswered when the rest of the Tier P checklist is green.

Read literally, the rule keeps §2, §3 and §4 red however much else is done, which is why the counting rule is the owner's first action.

Two places for every decision

The reasoning lives on the page named in the row's "Recorded in" column, edited when the answer lands. **The answer** is a dated file in the append-only decisions directory, id on its first line ([decision log](#)), for P rows and the agents' own rows alike. On 2026-09-14 the directory holds two records:

- **Wall-E holds Super Admin, P33, accepted.** Decided by the owner on 2026-09-13; also the TISAX deviation record (P136). The security reviewer's signature and the ISMS's risk-register entry are pending, and the grant stays blocked until every precondition in it is green.
- **Eve's reporting path may reason, P34, proposed.** Dated 2026-09-13; accepted once the Eve owner and the security reviewer sign.

No Wall-E, Eve or Mo row has its own file yet. Anything else that looks settled is settled on a design page, not by a signature.

The register in one screen

The register has 143 rows, each id once (§0).

Of the **HLD's 34 rows**, three are decided or closed (P33 decided; P2 closed by P35; P9 closed by P60), nine proposed, eighteen open (P5, P7, P10–P14, P17–P19, P21–P23, P25, P26, P29, P31, P32, with P28's signature and P24 for operators) and four spikes (P3, P4, P6 via P57, P8 via P61). Of the **pages' 109 rows**, 107 are proposed and two, P57 and P61, are spikes; P42 carries three sub-spikes, and P89 and P90 wait on P3's first spike. Eleven proposed page rows depend on something open or carry an **Assumption:** value to confirm: P39 (on P31); P52, P106 and P113 (on P13); P64 (on P24); P92 (on P10); P119 and P133 (on P20); P126 (on P18); and the values of P83 (the 99.5 % gateway SLO) and P117 (the vulnerability thresholds).

What is missing is a thin layer of signatures, bought services and tests, most of it from people who did not exist on 2026-09-13 (Chapter 23, Operating model).

Who must answer what

The gate each row blocks is in the final table; this section says why each answer matters.

The owner's own

- **The gate-counting rule, no row yet.** First action 1, above.
- **P33, decided.** Wall-E holds Super Admin (Chapter 15, Wall-E, the doer). The deviation still needs signatures the owner cannot supply: TISAX rejects self-signature.

- **P29, open.** Sign the two lists that replace Wall-E's never-list: the hard-denied operations, refused in every lane, and the operations reachable only through band B with two human super admins (HLD §13.1). This re-ratifies Wall-E's decision 4. The lists are the Art. 6(3) boundary; unsigned, the deviation record has no scope.
- **P28, signature open.** Sign Wall-E's intended purpose with legal, as P125 records it (Chapter 20, EU AI Act).
- **P68, proposed.** Approve the roster of three super admins: two humans, one outside the Wall-E administration line, plus walle@; shared with the second human, it waits for a name.
- **P34, proposed.** The owner holds the Eve owner role until the second human is named; P34 also needs the security reviewer, so it waits for both.

The owner also owns the proposed rows P1 (the tier model), P15 (with IT security) and P16 (with the security reviewer).

IT security

- **P10, open.** The SIEM, the organisation's or a platform Google SecOps instance, and a managed detection partner, meeting the P92 contract.
- **P11, open.** Who funds and owns Security Command Center Premium, Tier C's detection desk; the platform line carries it as an Assumption meanwhile.
- **P14, open.** The witness organisation's domain, Cloud Identity edition (Assumption: a free edition) and billing linkage, on which every claim that evidence sits beyond the super admins' reach rests.
- **P15, proposed, with the owner.** Eve's control path moving into the witness, dated now as the end state so today's independence is not mistaken for the final position; it gates Tier X, not the grant (Chapter 16, Eve, the independent controller).

Legal and the DPO

- **P13, open (DPO).** The retention floor and ceiling per store and the conversation retention period. A locked bucket can never be shortened, so evidence stores lock only once the ceiling is recorded. Interim: 30 days for conversations and a 400-day evidence floor, both Assumption (Chapter 12, Data, logging, retention and sovereignty).
- **P18, open (DPO and legal).** Whether reclaiming licences from inactive users (F7) is profiling. Until then F7-inactive stays at L3; a "yes" removes the operation from the catalogue rather than making Wall-E high-risk.
- **P19, open (legal).** The EU AI Act class of `eve-advisor`, which decides whether it may page at severity 2 and must be registered. P19 depends on P34.
- **P23, open (legal).** The legal entity holding the provider and deployer roles, named by the Art. 26 obligations, the Art. 49 registration and P131's determinations.

The DPO's input checklist is in Chapter 22, Personal data, employees and the works council.

The ISMS

- **P20 via P133, proposed.** The Confidential label (Assumption), assessment level AL2, no availability label, scope location *tbd*; without confirmation no assessment is ordered (Chapter 21, TISAX).
- **P131 and P137, proposed; names awaited.** An AI compliance owner designated by legal and engaged before the grant; the counted separation-of-duties minimum.
- **Also:** map the data classes to the organisation's scheme (P109), confirm P117's thresholds and P119's key exceptions, and enter P33's deviation in the risk register.

Google, and the spikes that decide grades

These rows decide whether a control is graded enforcement or detection, not whether it exists. None of the four spikes had run by 2026-09-13: P3 (engine reach, which the grant needs through P90, and the Tier W perimeter), P4 (Agent Identity required on engines), P6 via P57 (the tenant app bound to `gemini-egress`) and P8 via P61 (the principal-set spelling behind the deny policy and KF-2). Chapter 24 gives the position held until each passes, Chapter 10 the perimeter models.

- **P7, open: verify with Google.** Whether the Admin console's Context-Aware Access level applies to super admins and can bind API tokens; until then detection plus friction (Chapter 8, Identity, privileged access and the fleet kill switch).
- **P5, open.** Agent Identity on Cloud Run at GA; it was Preview on 2026-09-10.
- **P32, open.** Google's TISAX coverage per service and a written Art. 25 position.

The Google pages behind each item are in the HLD's [sources](#).

Other open platform decisions

- **P12 (platform owner).** Date the "no" to Assured Workloads with a re-ask trigger, or neglect makes it permanent.
- **P17 (Eve owner).** Whether the Workspace BigQuery export lands in the witness, giving Eve's reconciliation source a copy beyond the super admins.
- **P21 (security reviewer).** The public agent-threat taxonomy that gives detection coverage a denominator; the platform owner holds it, as self-review, until a reviewer is named.
- **P22 (platform owner).** The git host and the audit of admin bypasses; branch protection is what confines Mo to merged pull requests.
- **P24 (platform owner).** A workforce pool for operators, needed only if non-Google operators exist; the tenant app needs none (P51).
- **P25 (Mo owner, ISMS).** The Tier W cap in agents per named grader (Chapter 14, Scale and AGI readiness).
- **P26 (platform owner).** A second, EU-resident model family for Tier X's monitors.
- **P31 (platform owner).** The quota and budget amounts.

The agent-set registers

Each agent keeps its own register, which the platform indexes (§8). A platform row **supersedes** an agent's decision when it replaces it for every agent, **depends on** it when it cannot pass its gate without it, and **generalises** it when it stays true for its agent and becomes the fleet rule.

Wall-E 1–52. Decisions 1–41 are on [Wall-E's page](#); 42–52 are on the [topology page](#), hence Chapter 5's "topology decision 42". The objective of 2026-09-13 moved the answer of twenty-two of them; P33, for example, closes decision 26 by fact. A new Wall-E choice that is really a platform matter opens as a P row, not as 53.

Eve E-1 to E-21. [Eve's page](#) holds twenty-one rows; E-21, where `grades_eve` lives, is proposed. E-2 (the Eve owner) and E-16 (Eve's credential) block the grant.

Mo M-1 to M-11. On [Mo's page](#); some Mo pages still cite them as 42–52, in order. P22 supersedes M-7, and P25 depends on M-4.

The dated pointer lines in each agent set come from the propagation stage (P143), not yet run.

Where the pages still disagree

The register records conflicting values rather than silently picking one (§7). Rows 1–9 are resolved and applied, among them conversation retention at 30 days until P13, two sinks, five core projects and P4's engine half kept as a spike.

Rows 10–14 stay open until the named agent pages carry the platform's value, mostly through the propagation stage: row 10, constraint spellings, nonprod folders and project ids; row 11, Eve's missing severity-1 rows and a principal-set spelling; row 12, an incident-note path that does not exist; row 13, de-identification, residency text, Eve's lock timing and graders' content; row 14, EU AI Act changes to Wall-E, Eve and retention.

Every unresolved point the brief raises

Beyond the register's rows, the chapters raise points no row yet owns: open sequencing, values that differ between pages, and facts still *tbd*. Where no row names an owner, "Who decides" names the owner of the pages concerned.

Unresolved point	Raised in	Who decides	Gate it blocks
How an open row with a recorded fallback counts towards its gate	Ch. 25	Platform owner	every gate
Where the P4 and P61 spikes run before the folder and factory exist	Ch. 24	Platform owner	before the folder exists
The tenant's Workspace and Gemini Enterprise editions, <i>tbd</i>	Ch. 8, 11, 12	Platform owner reads them	Tier C at GE-6; Wall-E's Stage 0; multi-party approval before the grant
An ordinary grant-checklist row still red on day 30	Ch. 21	Platform owner, in page 11 and P33's record	standing, after the grant
K5 and K6 drilled quarterly on the sandbox twin, against checklist row 7's K6 record younger than 30 days	Ch. 15, 23	Platform owner, with Wall-E's agent owner	the grant
Who the fifth human is in P137's clean state	Ch. 23	ISMS	the grant, where four with a dated exception is the floor
Whether the DPIA must be complete or only started at the grant	Ch. 22	DPO with the platform owner	the grant
Whether Wall-E's scheduled, event and inbox triggers qualify requirement R3	Ch. 2	Platform owner, in the HLD's traceability table	none recorded; the first non-chat trigger
Blind sample daily with unsure counted wrong (Eve) or weekly from a CI seed excluding it (Mo)	Ch. 17	Eve and Mo owners	S3 entry
Verification drift sends a family to L0, one level down with an incident, or L3	Ch. 9, 18	Wall-E's agent owner, with the Mo and Eve owners	the first autonomous family
Who registers an agent in the app: CI or the app admins through PAM	Ch. 6	Platform owner	the first agent published above Tier C
Who removes an agent's gemini-egress entry in an emergency: the app admins or CI	Ch. 6	Platform owner	P57's enforcement, before the first Tier W publication
One evidence bucket per tier past about 25 agents (P114), where two views per agent fill a bucket at about 13	Ch. 12	Platform owner	before the buckets lock
Restore-drill age: a quarter, or under 30 days at the first promotion above L3	Ch. 13	Platform owner	Tier W promotions above L3
Who owns the Model Armor folder floors, and when IT security takes them	Ch. 10	Platform owner with IT security	none recorded
Who owns risk row R-01: the platform owner or the security reviewer	Ch. 21	Security reviewer and ISMS (P140)	the assessment order

Unresolved point	Raised in	Who decides	Gate it blocks
The Tier W verifier owned by the platform owner until a second person exists	Ch. 11, 23	ISMS (P137)	Tier W
Who writes role training: the platform owner or the AI compliance owner	Ch. 23	ISMS, with the AI compliance owner	Tier W, since an untrained holder does not count
Mo's Eve reads between Mo's S1 and S2, or with Eve's layer before Wall-E's S0	Ch. 24	Mo owner	the grant
The Tier C baseline's dependence on the factory: none in the README, the tenant-app module in the runbook	Ch. 24	Platform owner	Tier C
Wall-E's prerequisites page still dates the DPO question to Stage 3	Ch. 24	Wall-E's agent owner, through P143	Stage 1
Tier X conditions: four unmet (HLD §0.4) or five (§11.5)	Ch. 14	Platform owner	Tier X
P29's second list: the protected principals (register) or the tier- SUPER two-person list (HLD §13.1, Wall-E's guardrails)	Ch. 25	Platform owner	the grant
The approval surface as a core resource (page 04 §4.3) or in each agent's project (page 02 §5)	Ch. 25	Platform owner	any family above L2
Agent Registry Data Access logs, described differently on Google's two pages (page 08 §11)	Ch. 25	Platform owner, from the canary's first registry row	none recorded
The register cites E-1 to E-20; Eve's page holds E-1 to E-21	Ch. 25	Platform owner	none
Register rows 10–14	Ch. 25	Owners named in P143	the grant; Stage 1

What the register does not do

The register decides nothing itself; each row's content is on its recording page. It only indexes the agent sets' decisions, does not replace the signed P33 and P34 records, and does not track build status (§9).

Every open row and unsigned signature

Ordered by who must act, so the table doubles as the list of whom to ask for what. "Gate" is the register section.

Id	State	Who must act	Gate	What stays closed until answered
—	gate-counting rule, no row yet	Owner	every gate	a green gate wherever a fallback row is open
P29	open	Owner	§4	the grant; the deviation's scope
P28	signature open	Owner with legal	§5	Wall-E's first write
P68	proposed; second human unnamed	Owner with second human	§4	the grant
P33 / P136	decided; deviation unsigned	Security reviewer signs; ISMS enters	§4	the grant
P34	proposed; unsigned	Eve owner, security reviewer	§5	the eve-advisor build
P10	open	IT security	§4	the Tier P desk
P11	open	IT security	§2	Tier C
P14	open	IT security	§4	the grant; the witness
P13	open	DPO	§3	any Tier W Stage 1; the evidence lock
P18	open	DPO and legal	§5	F7 above L3
P19	open	Legal	§5	eve-advisor paging; registration

Id	State	Who must act	Gate	What stays closed until answered
P23	open	Legal	§6	P131's determinations
P20 / P133	proposed; unconfirmed	ISMS	§6	the TISAX assessment order
P131, P137	proposed; names awaited	ISMS	§4, §3	the grant; Tier W
P3	spike	Platform owner, security reviewer	§3	the Tier W perimeter; the grant, via P90
P4	spike	Platform owner	§2	enforcement of D2's engine half
P6 / P57	spike	Platform owner, Gemini Enterprise admin	§6 / §3	the register as publication enforcement
P8 / P61	spike	Platform owner	§2	the folder deny policy; KF-2
P7	open; verify with Google	Platform owner	§4	the grade of Context-Aware Access on <code>walle@</code>
P5	open; verify GA	Platform owner	§2	Tier R prod without exceptions
P32	open	Platform owner, ISMS	§6	Stage 1 (Art. 25); the assessment order
P12	open	Platform owner	§6	a dated re-ask of Assured Workloads
P17	open	Eve owner	§5	Eve's Stage 2
P21	open	Security reviewer; platform owner until named	§2	a detection coverage figure
P22	open	Platform owner	§3	Tier W
P24	open for operators	Platform owner	§3	a workforce pool (P64)
P25	open	Mo owner, ISMS	§3	the second Tier W agent
P26	open	Platform owner	§6	Tier X
P31	open	Platform owner	§2	Tier R budgets and quota alerts

Key decisions and what to read next

- **Not yet a row:** the gate-counting rule, the owner's first decision.
- **Decided:** P33, deviation signatures pending.
- **Proposed:** P34; P131, P133 and P137 awaiting ISMS names; P143, the unrun propagation stage that closes rows 10–14.
- **Open:** P29, P10, P11, P13, P14, P18, P19, P23 and P32.
- **Spikes:** P3, P4, P57 and P61, none run; where P4 and P61 run before the folder exists is unsettled.

Read next:

- Register [§0](#), [§1](#), [§4](#) and [§7](#)
- The [decision log](#)
- The [tier gate](#)
- The grant checklist in [page 11 §6.3](#)
- The propagation stage, [HLD §18](#)
- Wall-E's [lead-time items](#)

A. Glossary

What this appendix gives you

By the end you can look up any identifier, term, product or abbreviation, with the chapter that explains it ("Ch. N"), and tell apart families that share letters. Facts are the design pages' on 2026-09-14, launch stages as of 2026-09-13; where they disagree, the design page is right.

Identifier families

Family	What it numbers	Ch.
R1–R16	Requirements drawn from the objective of 2026-09-13	2
CP1–CP6	Containment primitives	4
PR1–PR9, D1–D12	Charter promises to, and demands on, every agent	4
B1–B7	Trust-boundary template; B6 and B7 are fleet boundaries	5
GE-0..GE-14	Tenant-app baseline runbook; GE-14 closes the Tier C gate	6
C, R, W, P, P-SA, X	Tiers: classical, read tools, write, privileged, super-admin singleton, AGI-class (closed)	7
CC-1..CC-12	Folder custom constraints; the brief cites CC-3, CC-6, CC-8 and CC-11	24
SA-1..SA-7	Service-account policy rules	8
R1–R6	Rules of the folder deny policy	8
K7, KF-1..KF-4	Fleet kill switch; levers applied KF-1, KF-3, KF-4, KF-2	8
L0–L5	Ladder levels, off to autonomous with independent verification	9
T0–T3	Trigger classes: chat, scheduled, event, inbox	9
F1–F4	Organisation-owned SIEM feeds	11
SA-01..SA-09, SG-01..SG-07	Super-admin detections, Workspace and GCP side	11
PL-01..PL-15	Platform-wide detection rules	11
H-1..H-4	Pipeline heartbeats	11
S1–S9	SIEM contract clauses (P92)	11
RB-01..RB-11	Incident runbooks; RB-10 and RB-11 are the regulatory clocks	11
R-A, R-B, R-C, R-D, R-K, R-W	Recovery classes	13
Bands A, B, C	Wall-E's lanes: catalogue, request approved by two human super admins, console handoff	15
F1–F10	Wall-E's operation families	15
S0–S5	Stages, keyed to Wall-E, used by Eve and Mo	15
Phase 1..Phase 18	Build phases of Wall-E's setup runbook; never stages	23
K0–K6	Wall-E's kill switches, K0 halt to K6 remove Super Admin	15
G-1..G-7	Pre-grant checklist rows for Eve's observe-and-report layer	16
T0–T2 (Mo)	Mo's tiers: metric queries, mo-reporter , optional mo-narrator	17
MD-1..MD-15	Mo's denial tests	17
R1–R6 (Mo)	Mo's accepted residual risks	17
CC-1..CC-37	Contract changes Eve forces on Wall-E's set	18
N1–N9	Wall-E's must-never-happen statements	19
R-01..R-17	Platform risk rows; R-01 is the super-admin deviation (P140)	19
E-01..E-15	EU AI Act evidence register	20

Family	What it numbers	Ch.
P1–P143	Platform decisions, one sequence; new ids from P144	25
Wall-E 1–52, E-1..E-21, M-1..M-11	Agent-set decisions; Wall-E 42–52 sit on the topology page, hence "topology decision 42" in Ch. 5	25

Families that share letters

- **T.** T0–T3 are trigger classes (tiers took letters to avoid the earlier T0–TX); Mo's T0–T2 are components.
- **R.** Bare R is a tier; R1–R16 requirements; R1–R6 deny rules (Ch. 8) or Mo's residuals (Ch. 17); R-A..R-W recovery classes; R-01..R-17 risk rows.
- **P.** P and P-SA are tiers; P3 is a decision, not a tier.
- **S.** S0–S5 are stages, S1–S9 SIEM clauses, S-org and S-folder log sinks; a Phase is a build step.
- **F, SA, CC, E.** F1–F10 families, F1–F4 feeds; SA-1..SA-7 service-account rules, SA-01..SA-09 detections; CC-1..CC-12 folder constraints, CC-1..CC-37 Eve's contract changes; E-1..E-21 Eve's decisions (the platform pages cite E-1..E-20, Ch. 25; [eve/09, 12](#)), E-01..E-15 evidence rows.
- **K.** K0–K6 stop Wall-E; K7 stops the fleet through KF-1..KF-4.

Platform terms

- **Action service.** Deterministic Cloud Run service; from Tier W the sole holder of the system-of-record credential, which decides, audits and verifies (Ch. 5; Ch. 15).
- **Admission gate.** The one CI run an agent passes before prod, the registry, a gateway list or the tenant app (Ch. 9).
- **Assumption:** / **tbd** / **Unverified.** An inferred value, every cost figure included / a value nobody has decided / a fact not checked against its source on 2026-09-13 (Ch. 0).
- **Blind sample, blind grader.** A weekly seeded sample per cell, graded by a named human other than the playbook owner; grading capacity caps Tier W (P25, open) (Ch. 17).
- **Data class.** A store's label, driving retention, readers and integrity: `evidence`, `content`, `control`, `record`, `secret`, `ops` (the page's heading says five) (Ch. 12).
- **Decision states.** `decided`, `closed`, `proposed`, `open`, `spike` (Ch. 25).
- **Detection desk.** Whoever acknowledges pages: "next business morning" below Tier P, a bought or in-house 24x7 desk at Tier P (Ch. 23).
- **Deterministic by absence.** Eve's control path has no model because dependency, permission and API are absent (Ch. 16).
- **Dispatcher.** `walle-dispatcher`, band A only; checks `halt`, owns `run_id` and budget before the agent runs (Ch. 15).
- **Drop box.** The `mo-proposals` bucket, create-only for Mo; CI turns each bundle into a pull request under a bot author (Ch. 17).
- **Enforcement-grade** / **detection-grade.** The first refuses from outside the agent's process and stops on failure; the second only produces evidence and never stands alone (Ch. 4).
- **eve_authority.** Per-cell `advisory` (default) or `binding`, only ever lowered automatically (Ch. 16).
- **eve-advisor.** Eve's reporting path; it may reason, but nothing it writes reaches a verdict (P34, proposed) (Ch. 16).
- **Factory.** Cloud Foundation Fabric modules with thin wrappers, run by Cloud Build from register row and manifest (P35) (Ch. 7).
- **Fingerprint.** Prompt hash, model pin, framework and Model Armor template versions; a change resets cells above L3 (D9, Ch. 4; Ch. 17).
- **halt_all.** Posture in which an action service executes nothing; a restored control plane boots into it (P120) (Ch. 15; Ch. 13).
- **Hard-denied list.** Operations refused in every band however many approve; with the tier-SUPER two-person list, "the two lists" (P29, open, worded differently in the register) (Ch. 15).

- **log_pipeline_silent.** Halt reason when evidence goes silent: verified agents lose autonomy, Wall-E goes to `halt_all`, one human call clears it (P97) (Ch. 11).
- **Manifest.** `agent-manifest.yaml`: what an agent may be, hashed into its register row (Ch. 9).
- **Observe-and-report layer.** Eve's detective layer, live and drilled before the grant; halting and demoting follow at S3, signing at S4 (Ch. 16).
- **Platform verifier.** Tier W verifier in Eve's deterministic shape, compiled from the manifest; catches code bugs, not a wrong specification (P79, proposed) (Ch. 9).
- **Protected principals.** Principals no write may target: administrators, the robot, its unit, the control groups (Ch. 15).
- **reconciliation_gap.** A robot-attributed Google event with no matching audit row; halts Wall-E and pages severity 1 (Ch. 16).
- **Register / registry.** The register, one git YAML file per agent, is the inventory of record; the registry, Google's Agent Registry, is a CI-written discovery view that never authorises (Ch. 9).
- **Second human.** A human super admin in IT security outside the Wall-E line; Eve owner and sole recipient of reports about the administrator (Ch. 23; Ch. 16).
- **Shadow agent.** An agent running with no register row; severity 2 at Tiers C–W, 1 at P (Ch. 9).
- **Signed deviation.** The robot's TISAX 4.2.1 least-privilege exception, in P33's file, awaiting signature and ISMS entry (P136) (Ch. 21).
- **Super-admin grant.** The day `walle@` receives Super Admin; a gate with its own checklist, before Wall-E's S0 (Ch. 24).
- **Taint bit.** Set when attacker-writable content reaches a run's model; the run keeps the inbox ceiling (Ch. 15; Ch. 10).
- **Tier gate.** A tier opens only when the people and bought services it needs exist (Ch. 24).
- **Validator custodian.** Runs the platform validator (from Tier W the security reviewer), which refuses any cited number it cannot recompute (Ch. 9).
- **walle@.** The licensed Workspace account holding Super Admin; P33 decided 2026-09-13, signatures pending (Ch. 15).
- **Witness organisation (org-witness).** Separate Cloud Identity organisation run by IT security, holding Eve's evidence copy and alarms beyond the super admins (P14, open) (Ch. 16).

Google products and features

- **Agent Gateway.** Managed ingress and egress proxy with IAM access policies and Model Armor; GA 2026-06-18 (Ch. 10).
- **Agent Identity.** Keyless Google-issued agent principal, daily certificates; GA on Agent Runtime, Preview on Cloud Run (P5, open) (Ch. 8).
- **Agent Registry.** Catalogue of agents, MCP servers and endpoints; GA 2026-06-18, skills Preview (Ch. 9).
- **Agent Runtime.** Managed runtime for agent engines; code-execution sandbox off fleet-wide (P121) (Ch. 8; Ch. 14).
- **Assured Workloads.** EU Data Boundary package, not adopted (P110) (Ch. 12).
- **Binary Authorization.** Attestation policy per agent project (P115); on Cloud Run, breakglass is the only bypass (Ch. 13).
- **Cloud KMS Autokey.** Folder-level automatic CMEK keys in the key project; Firestore unsupported (Ch. 13).
- **Context-Aware Access.** Access levels; on the robot, detection plus friction until Google confirms it binds super admins (P7, open) (Ch. 8).
- **Gemini Enterprise.** The tenant app, the one human front door; Workflow Builder, formerly Agent Designer, builds Tier C agents (Ch. 6).
- **GKE Agent Sandbox.** gVisor-isolated sandbox, GA 2026-05-21; the recorded Tier X sandbox (P122) (Ch. 14).
- **Google SecOps.** Google's SIEM; proposed default a Europe multi-region instance with at least 400 days of retention (P93), the choice P10, open (Ch. 11).

- **Model Armor.** Prompt and response screen, gateway integration GA 2026-06-24; probabilistic, so never a trust boundary (Ch. 10).
- **Multi-party approval.** Workspace setting requiring a second admin for covered changes; the only Google-enforced two-person rule on the robot (P66) (Ch. 8).
- **Principal Access Boundary.** Enforcement-grade for engine queries, secrets, keys, storage, BigQuery and Pub/Sub, not Cloud Run invocation (P60) (Ch. 8).
- **Privileged Access Manager.** Time-boxed, justified, logged elevation: at most 7 days, no self-approval (Ch. 8).
- **Security Command Center Premium.** Organisation-wide findings, AI Protection included; funding P11, open (Ch. 11).
- **Semantic Governance.** Preview gateway policy judged by an LLM; may add a refusal, never an approval or evidence (Ch. 9).
- **Sensitive Data Protection.** Folder discovery and the de-identified copy `content_deid` (P108) (Ch. 12).

Regulatory terms

- **The Act.** Regulation (EU) 2024/1689; the Digital Omnibus on AI, Regulation (EU) 2026/1744, defers Annex III obligations to 2027-12-02 (Ch. 20).
- **Provider / deployer.** The provider puts a system into service under its own name; the deployer uses it. The organisation is both for Wall-E and Mo; the legal entity is P23, open (Ch. 20).
- **Annex III.** The high-risk use list; point 4(b) covers task allocation and monitoring at work (Ch. 20).
- **Art. 6(3) derogation.** An Annex III system is not high-risk if a narrow condition holds and no profiling occurs; Wall-E's register class is `annex_iii_adjacent` (Ch. 20).
- **General-purpose AI.** The model provider's regime; the platform never trains or substantially modifies its third-party models (Ch. 20).
- **Serious incident.** Art. 3(49) event with Art. 73 deadlines of 15, 10 and 2 days, run voluntarily while no row is high-risk (P101) (Ch. 11).
- **TISAX label / assessment level.** Earned by a site, never a platform; target Confidential (Assumption) at AL2 (Ch. 21).
- **ISA2027.** The questionnaire for assessments ordered from 2027; ISA 6.0.3 until then (Ch. 21).
- **Maturity level.** ISA 0–5 score; most controls target 3, "established" (Ch. 21).

Abbreviations

CAA Context-Aware Access (Ch. 8) · CMEK customer-managed encryption keys (Ch. 13) · DPIA data protection impact assessment (Ch. 22) · DPO data protection officer (Ch. 22) · DWD domain-wide delegation, never used (Ch. 8) · HSM hardware security module (Ch. 13) · ISMS information security management system (Ch. 21) · MDR managed detection and response (Ch. 11) · MPA multi-party approval (Ch. 8) · PSC Private Service Connect (Ch. 10) · RACI responsible, accountable, consulted, informed (Ch. 23) · SCC Security Command Center (Ch. 11) · SHA Secure Hash Algorithm, SHA-256 throughout (Ch. 13) · SIEM security information and event management (Ch. 11) · SLSA Supply-chain Levels for Software Artifacts, Build Level 3 (Ch. 13) · SOC security operations centre (Ch. 23) · VPC-SC VPC Service Controls, perimeter model (a) (Ch. 10) · WIF Workload Identity Federation (Ch. 7).

Key decisions and what to read next

This appendix decides nothing; the states it quotes (P33 decided; P34, P79, P93 proposed; P5, P7, P10, P11, P14, P23, P25, P29 open) are the register's (Ch. 25).

- Families and states: [../01-hld.md#02-the-six-containment-primitives-and-how-each-is-graded](#), [../12-open-decisions.md#1-how-this-register-works](#)

- Collisions: ../02-landing-zone-and-tiers.md#11-letters-not-numbers-and-how-the-briefs-t0tx-map, ../mo/01-hld.md#the-three-tiers-and-the-seam-between-them, ../04-identity-and-privileged-access.md#3-the-folder-deny-policy-deny-agents-platform-with-verified-permission-names
- Vocabulary: ../05-registry-and-autonomy-contract.md#1-vocabulary-four-things-that-are-not-each-other, ../wall-e/13-agent-interconnection.md#1-seven-things-with-confusable-names
- Products and law: ../01-hld.md#19-sources, ../10-eu-ai-act.md#2-roles--which-legal-entity-is-provider-and-which-is-deployer, ../11-tisax.md#2-the-target--label-level-scope-catalogue-p133

B. Document map

What this appendix gives you

By the end you can find, for any chapter, the design pages that define its facts, which page is authoritative for what, where build procedures and decision records live, and which pages are dated history. Terms are in Appendix A, Glossary.

Precedence

The brief explains intent and defines no fact. **Where the brief and a design page disagree, the design page is authoritative and the brief is corrected.** Each element has one canonical home; other pages summarise and link. Where two design pages disagree, the register records it in [12-open-decisions.md §7](#); rows 10–14 stay open until the propagation stage of [01-hld.md §18](#) (P143) runs.

The platform set

The platform folder holds thirteen pages, 00 to 12 ([README](#)).

- **00, objective review.** Quotes the objective verbatim, derives R1–R16 and names the reversals it forces; current positions live on 01–12.
- **01, the HLD.** The parent: thesis, primitives and grading, roles, tier gate, charter, standing constraints, trust-boundary template, non-goals and what the agent sets must change (§18). Decisions P1–P34.
- **02–11, the detailed pages.** Each owns one part of the HLD and its decisions, P35–P141 in page order; the table below maps them to chapters.
- **12, the register of record.** P1–P143 in one sequence, grouped by the gate each blocks; new rows append at P144. An id on any page means the row here.

Two shared pages sit outside the folder. [project-topology.md](#) is the single authority for where each project and resource lives and for every cross-project grant; its rows feed the factory, and Wall-E decisions 42–52 live there. [gemini-enterprise.md](#) has been a pointer page since 2026-09-13, keeping only the tenant facts step GE-0 records; the tenant app's baseline is page 03.

The agent sets

Each set designs one of the first three tenants; fleet-wide content moved to the platform pages.

Wall-E

The Wall-E [README](#) separates standalone documents from numbered pages.

- **PREREQUISITES.md:** a pointer page since 2026-09-16; what must be true before the first command is now [setup/01](#), [03](#) and [04](#).
- **SETUP.md:** superseded on 2026-09-15 and a pointer page since 2026-09-16, never executed; the Wall-E build is now [setup/30](#) to [39](#).
- **ARCHITECTURE.md:** the service architecture for a pilot decision, and home of the kill-switch table.
- **setup/:** the `walle` automation; its [README](#) says why the script is not used.

The numbered pages 01–14 include the autonomy ladder (05, owner of the ladder's rules), guardrails (06), the team contract (08) and decisions 1–52. Page 07 is only a pointer, kept for inbound links. Pages 11–13 were promoted into platform pages 04, 05 and 06; their agent-specific sections, such as the engine query lock in [12 §7](#), remain canonical.

Eve

The [Eve README](#) lists nine pages, from the HLD to the onboarding runbook (07, a pointer page since 2026-09-16), contract changes CC-1..CC-37 (08) and open decisions (09). Its [reading order](#) starts with 01 and 05; security review continues with 02, 06 and 03, a builder with 08, 03, 04 and 07. The E-1..E-20 versus E-1..E-21 citation gap is in Chapter 25.

Mo

The [Mo README](#) lists eight pages, from what Mo is to the build runbook (07, a pointer page since 2026-09-16) and open decisions M-1..M-11 with the changes Mo forces on the other sets (08). Its [reading order](#) starts with 01 and 03; security review continues with 02, 06 and 04, and a builder reads 08 first, since three of its changes block Mo.

Build procedures

One entry point: [setup/README.md](#) (42 files, order platform → Mo and Eve → Wall-E, 6–7 months to Stage 0). Beside it:

- the proof of value, [pov/README.md](#) (Tiers C, R and W; no Super Admin to any agent; hands over to setup/ with nothing torn down)
- the three-day build, [3-day/README.md](#) (two people, six person-days; a demonstration, not compliance evidence; hands over to pov/)
- the tenant-app baseline in [03 §16](#), executed through [setup/19](#)

[SETUP.md](#), [PREREQUISITES.md](#), [eve/07](#) and [mo/07](#) are pointer pages since 2026-09-16, superseded by the review of 2026-09-15 ([13](#)); none was ever executed. Which runbook creates each resource is [project-topology.md §7](#); the agent files run after the platform exists.

Decision records

A decision's reasoning lives on the page its register row names; the answer is a dated file in the append-only [wiki/decisions](#), where a later record supersedes and never rewrites ([12 §1](#)). On 2026-09-14 it holds two:

- [P33, Wall-E holds Super Admin](#). "Accepted (deviation signatures pending)" in the record's index; decided, signatures pending, in the register.
- [P34, Eve's reporting path may reason](#). Proposed.

Pages kept as dated records

Three pages hold positions partly overturned since; cite them for their date, never for current design ([Wall-E README](#); [00 Status](#)).

- [wall-e/10](#): the weaknesses known in the design of 2026-09-08, the fixes now carried and what was knowingly accepted; its narrow-custom-role findings describe a role that no longer exists.
- [wall-e/14](#): the alternatives weighed for the design of 2026-09-11 and why it stood; the objective of 2026-09-13 closed the service-account option and voided verdict reason 4.
- [00-objective-review.md](#): complete as of 2026-09-13, with some stale positions, `eve-advisor` among them; no design page depends on it for a current position.

The pointer page [wall-e/07](#) belongs with these.

Chapter to canonical pages

Brief chapter	Canonical pages	Register rows
0 About this document	README , 12 §1	—
1 Executive summary	01-hld , README	cites only
2 The objective	00 §1 , 01-hld §0.6	P15, P28
3 Problem and risks	00 §2–§3 , 01-hld "What this reverses" , topology §1	P33
4 Principles	01-hld Status , §0–§1 , §16	P1–P34
5 Architecture overview	01-hld §3 , §15 , topology §2–§3	P45, P46, P60
6 Gemini Enterprise environment	03 , gemini-enterprise	P6, P48–P59
7 Landing zone and tiers	02 , topology	P35–P47, P142, P3, P4
8 Identity and K7	04	P60–P70, P5, P7, P8, P24
9 Registry and autonomy contract	05 , wall-e/05 §1 , §6	P71–P80
10 Gateways, Model Armor, perimeter	06 , wall-e/11	P81–P91, P3
11 Monitoring and incident response	07	P92–P103, P10, P11, P21
12 Data, logging, sovereignty	08	P104–P114, P12, P13
13 Supply chain, keys, recovery	09 §1–§3	P115–P120, P22, P142
14 Scale and AGI readiness	09 §4–§5 , 01-hld §11	P121–P124, P25–P27
15 Wall-E	wall-e 01 , 02 , 03 , 05 , 06 , ARCHITECTURE , setup/30–39	P33, P16, P29; Wall-E 1–52
16 Eve	eve 01 , 02 , 03 , 05 , 06	P34, P14, P15, P19, P123; E-1..E-21
17 Mo	mo 01 , 03 , 04 , 05 , 06	P30; M-1..M-11
18 The three together	wall-e/08 , wall-e/04 , eve/08 , mo/08	P143
19 Threat model	wall-e/06 , 01-hld §13 , §15 , eve/06 , mo/06	P4, P7, P8, P60, P140
20 EU AI Act	10 , mo/04 §1.8	P125–P132, P19, P23, P28, P32
21 TISAX	11	P133–P141, P32
22 Personal data and employees	10 , 08 , 07	P13, P18, P19, P126, P129
23 Operating model	01-hld §0.3 , 11 §7 , PREREQUISITES §2	P137
24 Roadmap and cost	01-hld §0.4–§0.5 , setup/README , pov/README , 3-day/README , eve/05 , mo/05	P31, P143; spikes P3, P4, P57, P61
25 Decisions awaiting the owner	12 , decisions , agent registers	all open and proposed
A Glossary	01-hld §0.2 , 05 §1 , wall-e/13 §1	—

Reading paths through the wiki

These paths run through the design pages; paths through the brief are in Chapter 0, About this document.

- **Executive sponsor.** The [platform README](#); [01-hld Status](#) and "What this reverses and what it costs"; [§0.4](#); [12 §4](#).
- **Security architect.** The nine-step [reviewer order](#), the Eve and Mo security paths above, [wall-e/06](#).
- **Builder.** The ten-step [builder order](#), then [setup/README](#) (its §3 order, files 01 to 42), with [pov/README](#) or [3-day/README](#) if a proof of value or a demonstration comes first, and [topology §7](#).

- **Data protection officer and works council.** 10 §3–§4; 08 §5, retention; 11 §3, TISAX module scope; [eve/03](#), what Eve records.
- **TISAX or AI Act assessor.** 11 §2, §5, §6 and §13; 10 §4; the [decision records](#).

Key decisions and where to go next

This appendix decides nothing. The rows it points to most are P33 (decided, deviation signatures pending), P34 (proposed) and P143 (proposed, the propagation stage). Every open row is in Chapter 25, Decisions awaiting the owner; read next the [platform README](#) and the [register's §1](#).